국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

보안 과제( ), 일반 과제(o) / 공개(o), 비공개( ), 발간등록번호( )
정보보호핵심원천기술개발사업 최종보고서

과제번호 2017-0-00513

Security Analytics 기반의 이기종 보안솔루션 위협 분석 및 대응 기술 개발 최종보고서

2020.02.14.

주관기관 / (주)윈스
참여기관 / (주)이글루시큐리티, (주)소만사,
(주)지란지교 시큐리티, (주)세인트 시큐리티,
(주)한류AI센터, 국민대학교 산학협력단,
고려대학교 세종산학협력단, 한국전자통신연구원

과학기술정보통신부
정보통신기획평가원

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

제 출 문

과학기술정보통신부 장관 귀하

"Security Analytics 기반의 이기종 보안솔루션 위협 분석 및 대응 기술 개발"
(총 수행기간 : 2017.04.01 ~ 2019.12.31.) 과제의 최종보고서 10부를 제출합니다.

2020. 2. 14.

주 관 기 관 명 : (주)윈스 (대표자) 김 대 연 (인)

공동연구기관명 : ㈜이글루시큐리티 (대표자) 이 득 춘 (인)

공동연구기관명 : ㈜소만사 (대표자) 김 대 환 (인)

공동연구기관명 : 국민대학교 산학협력단 (대표자) 차 주 헌 (인)

공동연구기관명 : ㈜한류AI센터 (대표자) 김 대 곤 (인)

공동연구기관명 : ㈜지란지교시큐리티 (대표자) 윤 두 식 (인)

공동연구기관명 : ㈜세인트시큐리티 (대표자) 김 기 홍 (인)

공동연구기관명 : ㈜시큐아이 (대표자) 최 환 진 (인)

공동연구기관명 : 고려대학교 세종산학협력단 (대표자) 백 승 필 (인)

공동연구기관명 : 한국전자통신연구원 (대표자) 김 명 섭 (인)

총괄책임자 : 조 학 수

공동연구기관책임자: 박 종 성 / 공동연구기관책임자: 김 태 완
공동연구기관책임자: 윤 명 근 / 공동연구기관책임자: 이 용 권
공동연구기관책임자: 천 명 재 / 공동연구기관책임자: 김 기 홍
공동연구기관책임자: 장 상 욱 / 공동연구기관책임자: 김 명 섭
공동연구기관책임자: 김 종 현

1. 동 보고서상의 기재 내용이 사실임을 확약하며, 만약, 사실이 아닐 경우 과학기술기본법 제 11조의2 및 정보통신·방송 연구개발사업 관리 규정 제 11조에 따라 참여제한·환수 등의 어떠한 불이익도 감수하겠습니다.
2. 정보통신·방송연구개발 관리규정 제36조에 따른 보고서 공개·활용에 동의합니다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

보고서 요약서

과제번호	2017-0-00513	총 수행기간	2017.04.01 ~ 2019.12.31	단계구분	-
세부사업명	정보보호핵심원천기술개발사업				
연구과제명	총괄과제명	-			
	과제명	Security Analytics 기반의 이기종 보안솔루션 위협 분석 및 대응 기술 개발			
총괄책임자	조학수	총 연구기간 참여 연구원 수	총: 202명 내부: 202명 외부: 0명	총 연구비	정부:3,742,000천원 민간:1,195,084천원 계: 4,937,084천원
주관기관명 및 소속 부서명	(주)윈스 연구개발본부			공동연구기관명	(주)이글루시큐리티, ㈜소만사, ㈜한류AI센터, ㈜지란지교시큐리티, ㈜세인트시큐리티, ㈜시큐아이, 국민대학교 산학협력단, 고려대학교 세종산학협력단, 한국전자통신연구원
국제공동연구	상대국명: -			상대국 연구기관명: -	
위탁연구	연구기관명: 순천향대학교 산학협력단, (주)비상소프트, 세종대학교 산학협력단, 고려대학교 산학협력단			연구책임자: 염흥열, 이대운, 강지원, 이희조	

※ 국내·외의 기술개발 현황은 연구개발계획서에 기재한 내용으로 갈음

연구개발성과의 보안등급 및 사유	일반

9대 성과 등록·기탁번호

구분	논문	특허	보고서 원문	연구시설·장비	기술요약 정보	소프트웨어	화합물	생명자원		신품종	
								생명정보	생물자원	정보	실물
등록·기탁번호	-	-	-	-	-	-	-	-	-	-	-

'연구성과 관리·유통 전담기관 지정 고시' 참조

국가과학기술종합정보시스템에 등록한 연구시설·장비 현황

구입기관	연구시설·장비명	규격 (모델명)	수량	구입연월일	구입가격 (천원)	구입처 (전화)	비고 (설치장소)	NTIS 등록번호
-	-	-	-	-	-	-	-	-

국가과학기술종합정보시스템에 등록한 연구시설·장비 현황은 해당과제 연구개발 시작부터 최종 연구 종료 시점까지 현금으로 구입한 1개(건)당 3천만원(부가세 포함) 이상의 연구시설·장비 및 3천만원 미만이라도 공동 활용이 가능한 연구시설·장비로 국가과학기술종합정보시스템에 등록한 시설·장비를 기재 - 제출시 삭제

요약(연구개발성과를 중심으로 개조식으로 작성하되, 500자 이내로 작성합니다)	보고서 면수 163

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

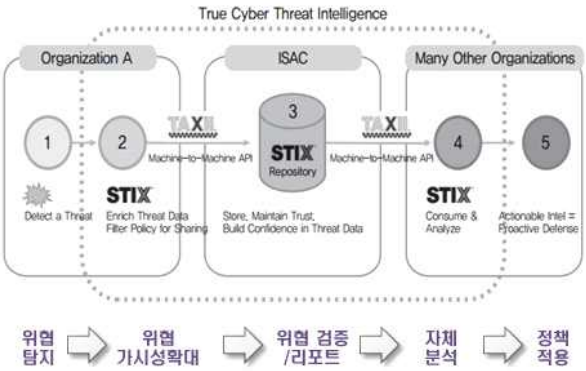
요약문

연구의 목적 및 내용

○ 연구개발 목적

✓ 은밀화·고도화되는 사이버위협을 개별적으로 탐지·분석하기 어렵고, 또한 파편화된 정보로 정확하게 대응하는데 근본적인 한계에 봉착

✓ 글로벌 보안업체들은 공격·방어 중심의 기술에서 피해 최소화를 위한 예방·대응 관점으로 보안기술 변화 중 (CTA[1]) 기반의 신속한 위협대응 체계 구축)



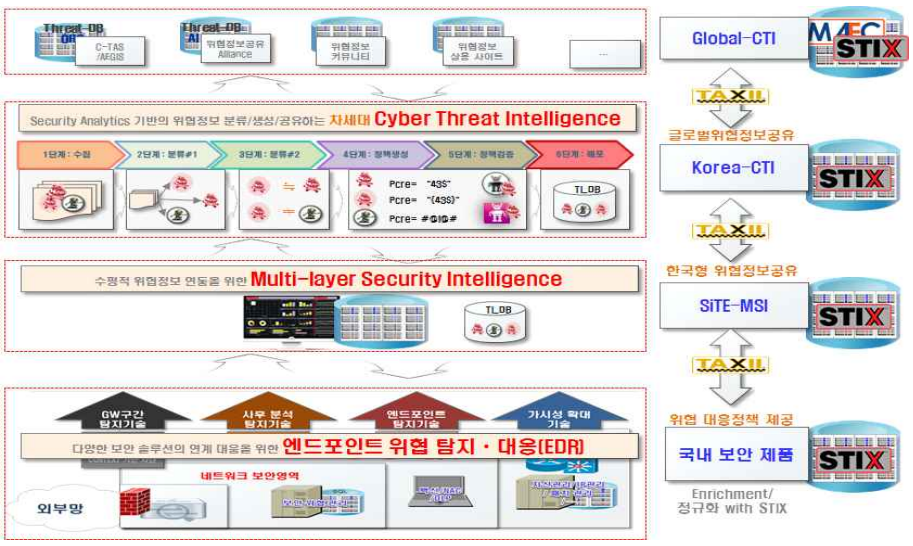
[그림 1] 해외 CTA 업체들의 연동 체계

✓ 차세대 사이버위협 대응을 목적으로 악성행위학습과 Endpoint에서의 효과적인 탐지 및 대응을 위하여 Security Analytics 기반의 K-CTA(한국형 사이버 위협정보 공유 연합)용 위협인텔리전스 공유 기술 개발

○ 최종목표

✓ 이기종 보안솔루션들의 효과적인 사이버위협 탐지·대응을 위한 Security Analytics 기반의 사이버위협정보를 분석·공유하는 KOSIGN (Korea Open Security Intelligence Global Network) 서비스 기술 개발

✓ 사이버위협 분석·공유 서비스 개념

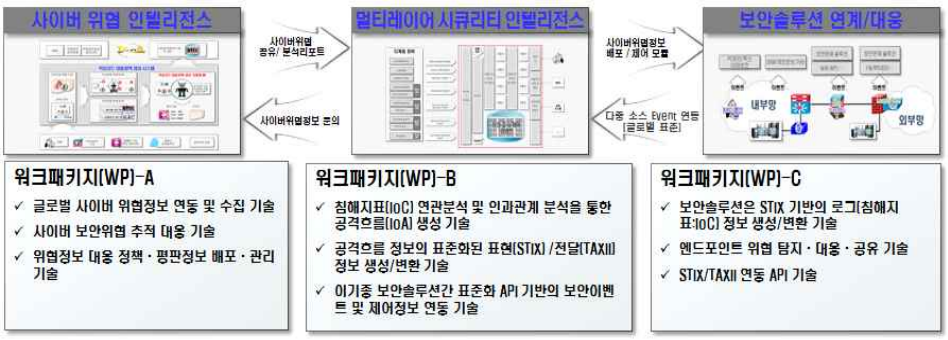


[그림 2] 위협정보 공유 서비스 개념도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구의 목적 및 내용

- 최종 목표시스템의 워크패키지(WP)별 세부 목표



[그림 3] 사이버위협 분석 · 공유 서비스 플랫폼 개념도

- WP-A : 사이버 위협 인텔리전스(CTI) 기술 개발
- WP-B : 멀티레이어 시큐리티 인텔리전스(MSI) 기술 개발
- WP-C : 보안솔루션 연계 대응(EDR) 기술 개발
- STIX/TAXII 기반 사이버 위협 분석 정보 연동 프레임워크 표준 개발

○ 워크패키지별 주요 기능(또는 규격)

✓ (WP-A) 글로벌 사이버 위협정보를 수집/분석하여, 공격을 추정하고 대응 방안을 제공하는 사이버 위협 인텔리전스(CTI) 기술

- 글로벌 위협정보 수집 및 정적/동적 분석 시스템 개발
- 악성코드 동작 분석 지표 추출 기술
  + 빅데이터 딥러닝을 통한 악성코드 종류별 모델 개발 및 그룹핑 기술
  + 그룹핑 정보를 활용한 위협정보 킬-체인 생성 기술
- 사이버 위협정보 대응을 위한 위협대응 정보 배포 시스템 개발

✓ (WP-B) 이기종 장비에서 전송되는 STIX 형식의 다양한 이벤트를 빅데이터 기반으로 수집/저장하고, 수집된 정보를 침해지표 기준으로 Security Analytics 기술을 활용하여 인과관계를 분석하고, 향후 예상되는 위협까지 대응할 수 있는 멀티레이어 시큐리티 인텔리전스(MSI) 기술

- 이기종 보안 장비/Agent의 실시간 이벤트 수집 시스템 개발
- 침해지표(IoC) 기반 연관/인과관계 분석을 통한 공격흐름(IoA) 생성기술
  + 네트워크 악성 트래픽 그룹핑을 통한 사이버 공격 탐지 기술
- 공격흐름 정보를 표준화된 표현(STIX)/전달(TAXII) 정보 생성/변환 기술
- 이기종 보안솔루션간 표준화 API 기반으로 이벤트/제어정보 연동 기술

✓ (WP-C) 이기종 보안장비들의 보안이벤트를 STIX/TAXII 기반으로 정보 연계하고, 추론된 위협에 효과적으로 대응할 수 있는 단말보안제품과의 연계대응(EDR) 기술

- 위협정보 연동을 위한 구성요소 간의 상호 인증 기술
- 위협정보 표준 포맷(STIX)/교환(TAXII) 모듈 개발(API 활용)
- 단말의 위협 대응을 위한 EDR 시스템 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구의 목적 및 내용

○ 워크패키지별 주요 성능치

✓ WP-A(CTI)관련 주요 성능치

- 악성코드 동작분석 판단 지표 : 200건 이상
- 악성코드 유사도분석 성능 : 0.05초 이하

✓ WP-B(MSI)관련 주요 성능치

- MSI 플랫폼의 이벤트 수집성능 (호스트 1대 기준) - 150,000 ESP 이상
- 이벤트 분류정확도 : 악성 트래픽 탐지율(Recall) 98% / 탐지 정확도(Precision) 98%

✓ WP-C(EDR) 관련 주요 성능치

- 로그 검색 소요시간 : 2초 (100만 로그 중, 특정 로그 조회)
- 기계학습 기반 비정상행위 탐지율 : 95%

○ End Product

✓ 사이버 위협 인텔리전스(CTI) 플랫폼

- 악성코드 자동수집 및 연동시스템(서버 탑재형 SW)
- 악성코드 분류 및 그룹별 킬-체인 생성 시스템(서버 탑재형 SW)
- 악성코드 공유서비스 포탈시스템(서버 탑재형 SW)

✓ 시큐리티 인텔리전스(MSI) 플랫폼

- STIX/TAXII 기반의 대용량 이벤트수집 시스템(서버 탑재형 SW)
- Security Analytics 기반의 통합관제시스템(서버 탑재형 SW)

✓ 보안솔루션 연계대응(EDR) 기술 개발

- STIX/TAXII 기반 이벤트 연동API 모듈(서버 탑재형 SW)
- 호스트 행위 수집 및 차단 시스템(서버 탑재형 SW)

연구개발 성과

○ 1차년도 수행내용 및 성과

✓ 연구개발 목표 및 수행결과 요약

세부 과제명	세부 연구 목표	연구개발 수행 내용	연구 결과
WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	글로벌 위협정보 수집	- 자체 클롤러 개발 - KISA의 C-TAS 연동 - 상용 API활용 수집	- 700만건 이상의 악성파일 수집
	악성코드 동작 지표 추출	- 악성코드 동적/정적 분석으로 악성동작 지표 관련 기술 연구	- 210개 이상의 유효한 악성코드 동작지표 추출
	딥러닝 기반 분류 모델 설계	- 추출된 동작지표를 통한 딥뉴얼 기반의 그룹핑 및 UI	- 악성그룹핑 논문 등제 - 분석/그룹핑/CTI 프로토타입 개발
WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	관제 플랫폼 프로토타입 개발	- MSI 플랫폼 설계 - 플랫폼 프로토타입 구현	- MSI 플랫폼 설계완료 - 플랫폼 프로토타입 개발
	Seed 기반 트래픽 그룹핑	- Seed정보를 이용한 트래픽 그룹핑 알고리즘 및 악성탐지	- 알고리즘 논문 등제 - 악성탐지 프로토타입 개발 완료
	위협정보 연동 규격 개발 및 프로토타입 API 개발	- 위협정보 연동 규격 개발 - 연동용 프로토타입 API 개발	- 위협정보 연동 규격 개발 완료 - 연동용 프로토타입 API 개발 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구개발 성과

WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)	네트워크 보안장비의 STIX 연동 규격 설계	- 연동 규격 설계	- IPS/DLP/스펨 업체 제품의 프로토타입 연동 완료
	단말 보안장비의 STIX 연동 규격 설계	- 연동 규격 설계	- PC보안(닉스) 프로토타입 수행 완료
	EDR 규격 설계	- EDR 설계	- EDR 설계 완료
STIX/TAXII 표준화	표준 규격 기안	- 표준화 기고 및 채택	- 국제 표준화 기고서 제출/채택 2건 - 국내 표준화 기고서 제출/채택 1건

✓ 1차년도 정량적 연구성과

구분	특허				논문			표준화						기술이전	상용화(백만원)	기술료(백만원)	성과홍보	시제품	S/W등록	기술문서
	국제		국내		SCI(E)	비SCI		국제			국내									
	출원	등록	출원	등록		국제	국내	기고서제출	기고서채택	표준안채택	기고서제출	기고서채택	표준안채택							
1차년도(목표)	1	0	8	0	1	0	2	2	2	0	1	0	0	0	0	0	0	0	1	11
1차년도(실적)	1	0	11	0	1	0	9	2	2	0	1	1	0	0	49	0	2	0	4	11

○ 2차년도 수행내용 및 성과

✓ 연구개발 목표 및 수행결과 요약

세부 연구명	세부 연구 목표	연구개발 수행 내용	연구 결과
WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	글로벌 위협정보 수집	- 크롤러를 활용한 수집 - KISA C-TAS 연동 고도화 - 상용 API활용 수집	- 640만건 이상의 악성파일 수집 - CTI 수집 시스템 구축
	악성코드 동작 지표 추출	- 악성코드 동적/정적분석으로 행위동작 지표 관련 기술 연구	- 1024개 이상의 동작지표(OP-code) 추출 - 전처리 모듈 개발 완료
	딥러닝 기반 분류 모델 설계	- 추출된 동작지표를 통한 딥뉴얼 기반의 그룹핑 - 킬체인 정보 생성	- 악성 그룹핑 관련 논문 - 딥러닝 기반 악성 그룹핑 분석 시스템
	CTI 포탈 개발	- CTI 서비스 포탈 개발 - 위협정보 리포트 생성 및 STIX/TAXII 배포	- CTI 포탈 시스템 및 위협정보 배포시스템 - CTI 기능 매뉴얼
WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	관제 플랫폼 개발	- 이기종 트래픽 수집엔진 - IOC 기반 IOA 분석기능 - 통합 관제 서비스 UI 개발	- 170K EPS이상의 이기종 이벤트 수집 시스템 - Spider TM 개발(통합보안 관제 솔루션)
	Seed 기반 트래픽 그룹핑	- Seed정보를 이용한 트래픽 그룹핑 알고리즘 및 악성탐지	- 알고리즘 논문 등제(IF 1.34) - 시퀀스패턴을 활용한 악성탐지 시스템
	위협정보 연동 (STIX/TAXII 2.0) API 개발	- 위협정보 연동 규격 (STIX/TAXII 2.0) 개발 - STIX/TAXII 연동용 서버/Agent용 API 개발	- STIX 2.0 API 개발 및 관련 기술자료 - TAXII 2.0 API 개발 및 관련 기술자료
WP-C : EDR (위협대응을 위한 보안솔루션	네트워크 보안장비의 STIX 연동	- STIX/TAXII 2.0 API를 활용한 제품 탑재	- IPS(윈스)/FW(시큐아이)/스펨필터(지란)의 시제품 개발 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구개발 성과

연동 체계 구축)	단말 보안장비의 STIX 연동	- STIX/TAXII 2.0 API를 활용한 제품 탑재	- PC보안(닉스)/DLP(소만사)/백신(세인트)의 시제품 개발 완료
	EDR 시제품 개발	- DLP기반 EDR 제품 개발 - PC보안 Agent 기반 EDR 제품 개발	- 소만사/닉스의 EDR 시제품 개발 완료
STIX/TAXII 표준화	표준 규격 기안	- 표준화 기고 및 채택	- 국제표준 기고/채택 2건 - 국내표준 기고/채택 3건 - 관련 특허 1건

✓ 2차년도 정량적 연구성과

구분	특허				논문			표준화						기술이전	상용화(백만원)	기술료(백만원)	성과홍보	시제품	S/W등록	기술문서
	국제		국내		SCI(E)	비SCI		국제			국내									
	출원	등록	출원	등록		국제	국내	기고서제출	기고서채택	표준안채택	기고서제출	기고서채택	표준안채택							
2차년도(목표)	2	0	8	3	2	1	2	2	2	0	1	1	1	2	0	40	1	6	7	12
2차년도(실적)	2	0	9	4	3	4	12	5	5	0	2	2	3	2	50	40	2	6	7	13

○ 3차년도 수행내용 및 성과

✓ 연구개발 목표 및 수행결과 요약

세부 연구명	세부 연구 목표	연구개발 수행 내용	연구 결과
WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	악성파일 수집	- 기계학습을 위한 악성파일 수집	- 약 7백만개 수집
	실증사업을 위한 CTI 플랫폼 구축	- 실증시험을 위한 군 내부에 CTI 플랫폼 구축	- 수요자(사이버 사령부)의 CTI 기능 시험 완료 - 제품 상용화 진행
	언패킹 해독기술 개발	- 언패킹 분석 기술 확보	- 리얼머신 기반의 동적분석 머신 개발 - 언패킹 기반의 딥러닝 - 학습 모델
WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	실증사업을 위한 관제 플랫폼 구축	- 실증시험을 위한 군 내부에 MSI 플랫폼 구축	- 수요자(사이버 사령부)의 MSI 기능 시험 완료 - 사업화
WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)	실증사업을 위한 보안장비의 STIX 연동	- 실증시험을 위한 군 내부에 네트워크/EDR 보안장비 구축	- 수요자(사이버 사령부)의 연동관련 기능 시험 완료

✓ 3차년도 정량적 연구성과

구분	특허				논문			표준화						기술이전	상용화(백만원)	기술료(백만원)	성과홍보	시제품	S/W등록	기술문서
	국제		국내		SCI(E)	비SCI		국제			국내									
	출원	등록	출원	등록		국제	국내	기고서제출	기고서채택	표준안채택	기고서제출	기고서채택	표준안채택							
3차년도(목표)	1	0	2	6	0	0	0	0	0	0	0	0	0	2	160	40	1	1	0	4
3차년도(실적)	1	0	4	5	1	0	1	0	0	1	0	0	0	3	216	50	1	1	1	5

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구개발 성과

○ 연차별 기술적 성과달성

No	평가 항목 (주요성능 Spec)	단위	전체 항목 차지하는 비중 (%)	세계최고 수준 보유국/보유기업 성능수준	연구개발 전 국내수준 성능수준	1차년도 (2017년) 목표	1차년도 (2017년) 실적	2차년도 (2018년) 목표	2차년도 (2018년) 실적 1)	3차년도 (2019년) 목표	3차년도 (2019년) 실적	평가 방법
1	악성코드 동작분석 판단 지표	건	10%	207 (미국/MAEC)	200	200	205	250	1024	-	-	자체 평가 (논문)
2	악성코드 유사도 분석 성능	초	10%	0.1 (미국/Symantec)	0.089	0.1	0.1	0.02	0.001	-	-	자체 평가 (논문)
	악성코드 유사도 분석 정확도	%	10%		90%	-	-	95%	97.14 %	-	-	
3	이기종 이벤트 수집성능	천EPS	15%	150,000 (미국 Splunk)	100	100	100	170	212	-	-	공인시험 (2차년)
4	이벤트 분류 기준 악성트래픽 탐지율 (Recall)	%	5%	100% (미국/Symantec)	80	90%	86%	98%	99.3%	-	-	자체 평가 (논문)
5	이벤트 분류 기준 악성트래픽 탐지정확도율 (Precision)	%	10%	100% (미국/Symantec)	97	90%	90%	98%	99.5%	-	-	자체 평가 (논문)
6	위협정보 생성을 위한 로그 조회 성능	소요 시간	10%	5초 (미국, Symantec)	-	4초 이내	4초 이내	2초 이내	1.76초	-	-	공인시험 (2차년)
7	단말행위 정보의 기계학습 기반 비정상행위 탐지율	%	15%	90% (미국, EMC)	-	-	-	95%	96.3	-	-	공인시험 (2차년)
8	K-CTI 연동 보안업체 수	개수	15%	- (미국/MS)	-	2	1	5	6	-	-	공인시험 (2차년)
9	KOSIGN 종합연동시험	-	-	-	-	-	-	-	-	양호	양호 2)	수요기관평가

1) 공인시험기관(KSEL)과 진행한 공인시험 결과값 임

2) 국방부의 사이버사령부 실증 시험 결과

[표 1] 정량적 목표 항목

○ 개발결과물의 기술적 우위

✓ 악성파일 분석기술 비교

- 상용서비스 : 정적/동적 분석을 통한 DNA 수준의 악성코드 유사성을 분석하고, 분석된 결과로 악성행위를 예측
- 개발 결과물 : 정적/동적 분석을 통한 DNA 수준의 유사성을 분석하고, 공통행위를 기반으로 행위랭크를 추출하여 향후 발생될 수 있는 주요 행위까지 예상할 수 있는 악성분석 기술로써 기술적인 우수성을 가짐

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 위협정보 공유 분야

- 동적/정적 분석된 위협정보를 표준화된 STIX2.0으로 저장(일부 항목은 사용자 정의를 통해 Snort/YARA 정책까지 저장할 수 있는 구조를 가짐)
- TAXII 2.0 표준을 준수하는 HTTP RESTful API를 지원하는 Java, Python, C++ TAXII 클라이언트 라이브러리로(API 및 소스)까지 공개
- 표준 STIX/TAXII 2.0 API 및 개발 메뉴얼 공개. 보안제품에 신속하게 적용할 수 있음
- 국내 주요 보안벤더(네트워크벤더 : 윈스/시큐아이/지란지교, EDR벤더 : 소만사/한류AI센터, 백신벤더 : 세인트시큐리티)의 협의된 컬렉션별 ID로 검증 완료

연구개발 성과 활용계획 (기대효과)

○ 성과활용 계획

✓ 악성코드 분석/공유(WP-A : CTI) 기술 분야

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
KOSIGN CTI 기술 상용화 추진계획	O	O			
KOSIGN CTI 기술 사업화 활동		O	O		
KOSIGN CTI 후속연구			O	O	O

[표 2] 연도별 CTI분야 성과활용 계획

✓ 관제솔루션(WP-B : MSI) 기술 분야

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
차세대 SIEM으로서의 MSI 솔루션 상용화 추진계획	O	O	O		
STIX/TAXII Library 후속연구를 통한 Secured STIX/TAXII 제품 개발		O	O		
Secured STIX/TAXII 상용화 추진			O	O	O

[표 3] 연도별 MSI 분야의 성과활용 계획

✓ 단말보안 (WP-C : EDR) 기술 분야

- 소만사 성과활용(사업화) 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
외산 경쟁사 EDR 제품 분석	O	O			
차별화 기능 기획 및 개발	O	O	O		
정보보안 컨퍼런스를 통한 EDR제품 홍보		O	O	O	O

[표 4] 연도별 EDR 분야 성과활용 계획

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

연구개발 성과 활용계획 (기대효과)

▪ 시큐아이 사업화 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
MF2 후속모델인 NGF에 적용 및 Migration 진행	O	O	O		

[표 5] 연도별 시큐아이 성과활용 계획

▪ 지란지교 시큐리티

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
STIX/TAXII 연동기능 탑재한 통합 메일보안 어플라이언스	O	O (일본)	O (일본)		
SaaS 기반의 메일보안 제품화		O	O	O (동남아)	O (동남아)

[표 6] 연도별 지란지교시큐리티 성과활용 계획

○ 정성적 기대 성과목표

✓ 위협정보공유(WP-A : CTI) 기술 분야

▪ KOSIGN-CTI 기술 제품화

▪ KT 관제솔루션 연동의 단위기술 활용

▪ 악성파일 분석 기술 후속연구

✓ 관제솔루션(WP-B : MSI) 기술 분야

▪ STIX/TAXII 후속 연구

▪ Secured STIX/TAXII 상용화 추진

✓ 단말보안 (WP-C : EDR) 기술 분야

▪ EDR 제품과 소만사 기존 제품과의 연동을 통한 차별화 기능 기회

▪ STIX/TAXII 모듈 탑재한 시큐아이 제품의 연동기능 고도화

▪ 메일보안 어플라이언스 및 클라우드 제품 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

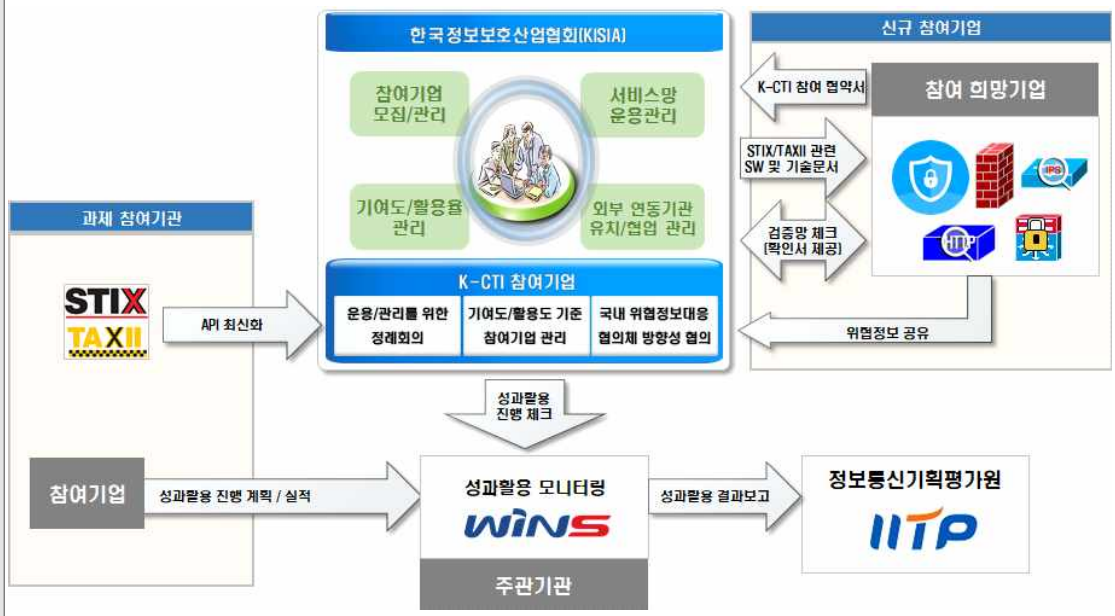
○ 정량적 기대 성과목표

구분		종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
CTI 분야	판매 수량	CTI 플랫폼 1식	CTI 플랫폼 2식	CTI 플랫폼 6식, 경량 CTI 10식	CTI 플랫폼 10식, 경량 CTI 50식	CTI 플랫폼 10식, 경량 CTI 100식
	매출액	100백만원	200백만원	500백만원	1,500백만원	2,500백만원
	고용	2명	4명	10명	30명	50명
MSI 분야	판매 수량	MSI 2대	MSI 4대	MSI10대, 모듈 5대	MSI15대, 모듈 5대	MSI15대, 모듈 5대
	매출액	100백만원	200백만원	500백만원	700백만원	700백만원
	고용	2명	4명	10명	30명	50명
EDR 분야	판매 수량	10대	20대	50대	70대	100대
	매출액	300백만원	600백만원	1,500백만원	2,100백만원	3,000백만원
	고용	6명	12명	30명	42명	60명
보안 장비 분야	판매 수량	10대	20대	50대	70대	100대
	매출액	100백만원	200백만원	500백만원	700백만원	1.000백만원
	고용	2명	4명	10명	14명	20명
합계	**매출액**	**600백만원**	**1,200백만원**	**3,000백만원**	**5,000백만원**	**7,200백만원**
	고용	**12명**	**24명**	**60명**	**100명**	**144명**

[표 7] 연도별 성과활용 (기대)성과목표 (요약표)

○ 성과활용 관리 및 추진체계

✓ 성과활용 관리방안



[그림 4] 성과활용 관리방안

✓ 위협정보공유 협의체 활성화를 통한 개발결과물의 지속적인 활용 및 발전

국문핵심어 (5개 이내)	사이버 위협 인텔리전스	시큐리티 어날리스틱	엔드포인트 탐지/대응	악성트래픽 그룹핑	스틱스/택시
영문핵심어 (5개 이내)	Cyber Threat intelligence,	Security Analytics	Endpoint Detect and Response	malicious-traffic grouping	STIX/TAXII

1) CTA (Cyber Threat Alliance) : 미국내의 사이버 위협정보 공유 협의체 (시만텍, 포티넷, 팔로알토, 인텔 등)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

〈 목 차 〉

1. 연구개발과제의 개요 ····· 1

1-1. 연구개발 목적 ····· 1

1-2. 연구개발의 필요성 ····· 4

1-3. 연구개발 범위 ····· 8

2. 연구수행내용 및 성과 ····· 10

2-1. 1차년도(2017년) 수행내용 및 성과 ····· 10

2-2. 2차년도(2018년) 수행내용 및 성과 ····· 33

2-3. 3차년도(2019년) 수행내용 및 성과 ····· 100

3. 목표 달성도 및 관련 분야 기여도 ····· 117

3-1. 최종 개발 목표 ····· 117

3-2. 목표 달성여부 ····· 120

4. 연구개발성과의 활용 계획 등 ····· 127

4-1. 향후 5년간 성과활용・확산 활용방안 및 계획(활동계획) ····· 127

4-2. 주요 성과활용 (기대)성과목표 ····· 131

4-3. 성과활용 · 관리 추진체계 ····· 136

붙임 1. 사업화대상기술별 기술명세서 ····· 138

붙임 2. 자체 보안관리 진단표 ····· 139

붙임 3. 국방부의 사이버사령부 실증 시험 결과 ····· 140

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

〈 그림 목차 〉

[그림 1] 해외 CTA 업체들의 연동 체계 ····1
[그림 2] K-CTA 서비스 플랫폼 개념도 ····2
[그림 3] 목표시스템 개발범위 ····2
[그림 4] Symantec Internet Security Threat report 2015 ····4
[그림 5] 사이버위협정보 공유 가치 ····4
[그림 6] 악성코드 분류 모델 구축 ····6
[그림 7] Seed Based Traffic Grouping Method ····7
[그림 8] 사이버위협 분석·공유 서비스에 대한 워크패키지 ····8
[그림 9] 위협정보 수집/분석 시스템 개념도 ····11
[그림 10] 차년도 수집 채널 및 악성코드 개수 ····11
[그림 11] 악성코드 바이너리 파일의 특징 추출을 위한 전처리 과정 ····11
[그림 12] 악성코드에서 피처 해싱 리스트를 만드는 과정 ····12
[그림 13] 악성코드 데이터의 진단명을 분석하는 구조 ····12
[그림 14] 딥러닝 기반 악성코드 분류 모델의 전체 구성도 ····12
[그림 15] 합성곱 신경망 모델을 이용한 악성코드 탐지 모델 구조 ····13
[그림 16] 쿠쿠샌드박스에서 제공하는 분석 결과 예시 ····13
[그림 17] 정적/동적 분석화면 ····14
[그림 18] STIX포맷 시각화 화면 ····14
[그림 19] 위협정보 분석결과 화면 ····14
[그림 20] 분석 데이터 제공 화면 ····15
[그림 21] 이기종 보안장비의 이벤트 수집 구조 ····16
[그림 22] CTI와 STIX/TAXII 연동을 통한 위협정보 공유 ····16
[그림 23] CTI 연동 모듈 ····16
[그림 24] MSI와 보안장비의 제어정보 연동 이력 ····16
[그림 25] 위협정보/제어정보 연동 ····16
[그림 26] Sequential Grouping Model ····17
[그림 27] FCI 기반의 트래픽 그룹핑 방법 개념도 ····17
[그림 28] 유사도 값 (Similarity Index) ····17
[그림 29] 유사도 값 (Similarity Index) ····17
[그림 30] GuideLine 적용 개념도 ····18
[그림 31] GuideLine Converging ····18
[그림 32] SGM based Detection System ····18
[그림 33] Multiple-Seed 기반의 탐지 방법 개념 ····18
[그림 34] 분석정보 연동체계 및 Inbox Service 모식도 ····19
[그림 35] STIX/TAXII 오픈소스를 활요한 API 개발화면 ····19
[그림 36] STIX라이브러리 SW저작권등록 ····19
[그림 37] TAXII라이브러리 SW저작권 등록 ····19
[그림 38]네트워크 보안장비의 STIX 연동 규격 설계 ····20
[그림 39] STIX/TAXII 연동 프로토타입 구현 ····21
[그림 40] 단말 보안장비의 STIX 연동 규격 설계 ····21
[그림 41] MSI 플랫폼 연동 이력 조회 ····22
[그림 42] IPS 시스템의 연동 정보 내역 ····22

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[그림 43] EDR 시스템 설계 ……22
[그림 44] EDR 시스템 연동 ……23
[그림 45] 종합 연동 시험 설계 ……23
[그림 46] CTI 플랫폼에서의 악성코드 분석 결과 ……24
[그림 47] CTI와 STIX/TAXII 연동을 통해서 위협정보 공유 ……24
[그림 48] 유해 URL기반 STIX 변환 ……24
[그림 49] 유해 URL기반 TAXII 연동 ……24
[그림 50] ITU-T SG17 표준기고서 ……25
[그림 51] STIX 유스케이스 프로세스 개념(출처: MITRE) ……26
[그림 52] TTA PG503 국내 표준 기고서 ……26
[그림 53] 국내외 표준화 대응 방안 ……26
[그림 54] CTI 시스템 목표 개념도 ……35
[그림 55] 일별 악성코드 개수의 분포 그래프 ……36
[그림 56] 바이러스토탈과 AWS를 이용한 악성코드 라벨 자동 분석 흐름도 ……37
[그림 57] IDA Pro를 이용하여 악성코드를 분석하였을 때 함수 일부 ……38
[그림 58] 쿠쿠샌드박스에서 제공하는 분석 결과 예시 ……38
[그림 59] opcode 시퀀스에 n-gram 기술을 적용한 예시 ……40
[그림 60] IDA Pro 분석 결과에 따른 예시 및 특징 추출 방법(n-gram VS v-gram) 40
[그림 61] 빈도수 기반 피처 해싱 기법을 통해 특징 벡터를 만드는 과정 ……41
[그림 62] 최댓값 기반 피처 해싱 기법을 통해 특징 벡터를 만드는 과정 ……41
[그림 63] 합성곱신경망모델을 통해 악성코드를 이진분류하는 모델 네트워크구조 43
[그림 64] 혼동 행렬 ……44
[그림 65] 엘라스틱 서치 기반 유사 악성코드 검색 엔진 모델 (인덱싱 과정) ……44
[그림 66] 한 비교할 파일의 기본블록(Bops)의 예 ……45
[그림 67] 데이터 인덱싱 과정 예시에 따른 역인덱스 테이블 ……45
[그림 68] 제 단어 점수를 구하는데 사용되는 식 ……45
[그림 69] Doc2의 점수를 구하는 예 ……45
[그림 70] 모든 문서의 점수 결과 ……45
[그림 71] 실험 환경 시스템 구성도 ……46
[그림 72] 총 4개의 엘라스틱 인스턴스 사용 구성 ……46
[그림 73] 엘라스틱서치 결과 ……46
[그림 74] 1008개의 비교할 파일의 결과가 모두 .json 파일로 추출 ……47
[그림 75] 추출된 json파일의 내용 ……47
[그림 76] 쿠쿠샌드박스분석리포트에서 킬-체인 정보를 추출하여 얻어낸 결과파일예시 49
[그림 77] 웹 인터페이스 구조도 ……49
[그림 78] 분석 요청/검색 UI ……50
[그림 79] 분석결과 UI-1: 유사도 분석에 따른 악성 여부 판단 ……50
[그림 80] 분석결과 UI-2: 분석된 결과에 대한 STIX 정보로 표현 ……51
[그림 81] 분석결과 UI-3: 행위지표 요약정보 제공 ……51
[그림 82] 분석결과 UI-4: 행위지표 상세정보 제공 (1/2) ……51
[그림 83] 분석결과 UI-4: 행위지표 상세정보 제공 (2/2) ……52
[그림 84] 분석결과 UI-6: 정책정보 편집 및 공유 ……52
[그림 85] 위협정보 연동 배포 흐름 ……52
[그림 86] CTI 서비스망 구축(고려대학교) ……53

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[그림 87] 시그니처 생성 특허 ……53
[그림 88] 탐지규칙 검증용 패킷 생성 특허 ……54
[그림 89] 악성코드 분류 특허 ……54
[그림 90] 멀티패턴 정책 탐지 특허 ……55
[그림 91] 악성파일 유사성 특허 ……55
[그림 92] 합성곱신경망 모델를 이용한 악성코드 탐지기 ……56
[그림 93] 최적화된 비트맵 자료구조 ……57
[그림 94] MSI 개발 목표 개념도 ……57
[그림 95] 이기종 보안장비의 이벤트 수집 구조 ……58
[그림 96] 보안이벤트 수집/분석 성능 고도화를 위한 빅데이터 기술 ……58
[그림 97] 이기종 이벤트 수집 모듈 성능 검증 ……58
[그림 98] 이기종 보안장비의 이벤트 수집 성능 고도화 ……58
[그림 99] MSI 시스템 구조 ……59
[그림 100] SEED 기반 이벤트 추적 ……59
[그림 101] SEED 기반 이벤트 그룹핑 ……60
[그림 102] Seed 정보를 활용한 이벤트 그룹핑 ……60
[그림 103] 통합관제 UI ……60
[그림 104] 다양한 분석을 통한 보안관제 고도화 ……60
[그림 105] 사용자 정의 대시보드 ……61
[그림 106] FCI 모델의 시스템 구조 ……61
[그림 107] 가이드라인 생성 및 최적화 ……61
[그림 108] 시드기반 연속적인 그룹핑 ……62
[그림 109] SGM 기반 탐지 시스템 및 멀티시드기반 탐지 방법 ……62
[그림 110] 6 가지 Connectivity Feature의 FCI 계산 ……63
[그림 111] 멀티플 가이드라인 적용 예시 ……63
[그림 112] MSI 시스템의 이벤트/정책 연동 ……64
[그림 113] STIX API개발 내역 ……65
[그림 114] TAXII API 개발 내역 ……65
[그림 115] TAXII2.0 RESTful API 및 서버 클라이언트 연동 구조 ……66
[그림 116] TAXII 콜렉션 목록 ……66
[그림 117] TAXII 서비스의 정책배포(하향) 흐름 ……67
[그림 118] TAXII 서비스의 피드백/보안 이벤트(상향) 흐름 ……67
[그림 119] 플로우 연관성 모델을 이용한 트래픽 분류 특허 ……68
[그림 120] 딥러닝을 이용한 시드기반 악성 트래픽 탐지 ……68
[그림 121] STIX 변환장비 특허 개념도 ……68
[그림 122] 위협미수 자동보정 장치 관련 특허 ……69
[그림 123] 위협지수 관리체계 관련 특허 개념 ……69
[그림 124] 새로운 행위기반 시그니처 추출방법을 통한 Traffic Identification ··70
[그림 125] APRE 알고리즘 예시(AutoReEngine) 구조 ……71
[그림 126] WP-C 개발 목표 ……71
[그림 127] (주)소만사 EDR 시스템 구성도 ……72
[그림 128] EDR 서버 클래스 설계도 ……72
[그림 129] 딥러닝 학습데이터 ……73
[그림 130] 딥러닝 기반의 악성행위 탐지 로그 ……73

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[그림 131] 한류AI센터의 EDR 시스템 개념도 ····73
[그림 132] Agent 모듈 개념도 ····74
[그림 133] Agent 정책 관리 서버 모듈 ····74
[그림 134] 한류AI센터 EDR의 정책설정 ····75
[그림 135] NICS 서버의 STIX/TAXII 연동 ····75
[그림 136] 위협정보 처리 흐름도 ····76
[그림 137] SniperONE 위협정보 본문 ····76
[그림 138] SniperONE 위협정보 분석 및 정책 적용 ····76
[그림 139] SniperONE 대응정보를 이용한 트래픽 탐지 ····76
[그림 140] Sniper ONE MSI 시스템 대응 결과 전송 ····77
[그림 141] MF2의 위협정보 연동 및 BL 등록 ····77
[그림 142] MF2의 이벤트 연동 ····78
[그림 143] MF2의 MSI 연동 ····78
[그림 144] SpamSniper 연동 시험 ····78
[그림 145] SpamSniper 위협정보 연동 ····78
[그림 146] SpamSniper 필터로 차단된 이벤트 확인 ····79
[그림 147] 참여기관 소만사 EDR연동 ····79
[그림 148] 위협정보 처리 흐름도 ····80
[그림 149] 위협정보 수신 로그 ····80
[그림 150] 위협정보 본문 ····80
[그림 151] 위협정보 분석 및 업데이트 파일 생성 로그 ····80
[그림 152] 대응정보 업데이트 파일 배포 로그 ····80
[그림 153] 대응정보를 이용한 악성코드 실행 차단 ····81
[그림 154] MSI 시스템으로 대응 결과 전송 ····81
[그림 155] Log_Shipper 이벤트 연동 ····82
[그림 156] 선별적 이벤트 수집 ····82
[그림 157] 연동 순서 및 흐름 ····83
[그림 158] 정책 연동 및 차단 결과 ····83
[그림 159] 한류AI센터진 EDR시스템의 MIS 연동 결과 ····83
[그림 160] 백신서버의 STIX/TAXII를 통해 악성코드 정보 수신 ····84
[그림 161] 백신서버의 대응정책 다운로드 ····84
[그림 162] 악성코드 실행시 탐지 및 실행방지 화면 ····84
[그림 163] 악성파일 격리 화면 ····84
[그림 164] 백신서버의 MIS 이벤트 연동 ····85
[그림 165] STIX 변환장비 특허 개념도 ····86
[그림 166] 시스템 블록도 ····86
[그림 167] 힙 메모리에서의 개인정보 탐지 ····86
[그림 168] 파일 저장 API를 이용한 개인정보 탐지 ····87
[그림 169] 인터넷을 통한 개인정보 탐지 ····87
[그림 170] 폴링응답시간 최소화 ····87
[그림 171] 폴링간격 제어 방법 ····88
[그림 172] 표준화 수행 전략 ····88
[그림 173] ITU-T SG17 표준기고서 2건 제안 ····88
[그림 174] STIX 기능 및 유즈케이스 ····90

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

[그림 175] TTA PG503 구조화된 위협 정보 표현 규격(STIX)에 대한 ……90
[그림 176] ISEC2018 참가 부스 사진 ……99
[그림 177] eGISEC 성과 홍보 사진 ……99
[그림 178] UPX 패킹 프로그램을 통한 패킹/언패킹 예시 ……105
[그림 179] 언패킹 적용 전(왼쪽)/후(오른쪽)의 데이터 개수 비교 ……105
[그림 180] 언패킹 적용 전(왼쪽)/후(오른쪽)의 데이터 개수 비교 ……106
[그림 181] 입력 데이터의 언패킹 적용에 따른 딥러닝 모델의 탐지 정확도 비교 106
[그림 182] 관리자 User Interface : 대시보드 ……109
[그림 183] 관리자 User Interface : 프로세스 분석 ……110
[그림 184] 랜섬웨어 타입별 악성 행위 패턴 ……110
[그림 185] 악성행위 탐지 룰셋 예시 : DLL 인젝션 ……110
[그림 186] GandCrab 랜섬웨어 탐지 로그 ……111
[그림 187] GandCrab 랜섬웨어 대응 정보 배포 로그 ……111
[그림 188] 금융보안공모전 수상(참여기관: 국민대학교 산학협력단) ……115
[그림 189] 2019년 성과관리위원회 발표사진 ……115
[그림 190] 최종연구개발 목표 ……117
[그림 191] 워크패키지별 개발 범위 ……117
[그림 192] 워크패키지별 연차별 개발 목표 및 결과물 ……118
[그림 193] 1차년도 기술 개발내용 및 범위 ……118
[그림 194] 2차년도 기술 개발내용 및 범위 ……119
[그림 195] 국방부 실증 사업 구축 범위(3차년도 사업) ……119
[그림 196] 리버싱랩스의 악성코드 분석 flow ……121
[그림 197] 과제결과물의 악성파일분석 Flow ……122
[그림 198] 클라우드 서버 기반 분석 서비스 ……124
[그림 199] 개발결과물의 STIX/TAXII 2.0 기반의 공유 기술 ……125
[그림 200] 악성코드의 분석 및 공유기술 Flow ……131
[그림 201] Sniper CTI 제품화 ……131
[그림 202] KT 관제솔루션(GSP)와 연계된 CTI 기술 활용 ……132
[그림 203] CTI 결과물의 기능 고도화 ……132
[그림 204] DLP제품과 EDR제품의 연동 기능 ……133
[그림 205] EDR제품 개발 로드맵 ……134
[그림 206] 성과활용 관리방안 ……136
[그림 207] 표준화 성과관리 ……137

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

〈 표 목차 〉

[표 1] 참여기관별 사이버킬체인 방어 범위 ·····3
[표 2] 모델 검증 결과 ·····13
[표 3] 1차년도 기술개발 평가 항목 및 결과 ·····15
[표 4] 멀웨어 전처리 및 검증 시간 ·····15
[표 5] 텐서플로우 학습 환경 플랫폼 ·····42
[표 6] 딥러닝 모델의 구조 및 하이퍼파라미터 설정 값 ·····43
[표 7] 딥러닝 분류 모델 검증 결과 ·····43
[표 8] 정확도 및 성능 측정 결과 ·····48
[표 9] Log_Shipper 이벤트 아이디 종류 ·····81
[표 10] 딥러닝 학습 모델의 하이퍼파라미터 정보 ·····105
[표 11] 연차별 정량적 목표(계획/실적) ·····119
[표 12] 정량적 목표 항목 ·····119
[표 13] 연도별 CTI분야 성과활용 계획 ·····126
[표 14] 연도별 MSI 분야의 성과활용 계획 ·····127
[표 15] 연도별 EDR 분야 성과활용 계획 ·····127
[표 16] 연도별 시큐아이 성과활용 계획 ·····128
[표 17] 연도별 지란지교시큐리티 성과활용 계획 ·····128
[표 18] 연도별 표준화 분야 성과활용 계획 ·····129
[표 19] 연도별 성과활용 (기대)성과목표(요약표) ·····134

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

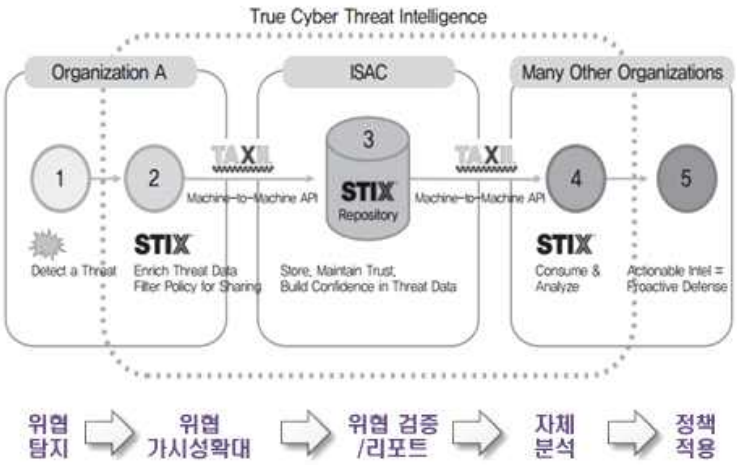
1. 연구개발과제의 개요

1-1. 연구개발 목적

가. 연구개발 목적

○ 은밀화·고도화되는 사이버위협을 개별적으로 탐지·분석하기 어렵고, 또한 파편화된 정보로 정확하게 대응하는데 근본적인 한계에 봉착했다.

✓ 글로벌 보안업체들은 공격·방어 중심의 기술에서 피해 최소화를 위한 예방·대응 관점으로 보안기술 변화 중 (CTA[1] 기반의 신속한 위협대응 체계 구축)



[그림 1] 해외 CTA 업체들의 연동 체계

✓ 차세대 사이버위협 대응을 목적으로 악성행위학습과 Endpoint에서의 효과적인 탐지 및 대응을 위하여 Security Analytics 기반의 K-CTA(한국형 사이버 위협 정보 공유 연합)용 위협인텔리전스 공유 기술 개발 필요

○ K-CTA용 위협 인텔리전스 공유 서비스 플랫폼 구축을 통해 급속도로 증가되는 사이버 위협을 신속하게 분석 · 공유함으로써 국가적인 사이버 위협 빠르게 대응할 수 있는 체계 구축이 가능해 진다.

✓ 사이버위협인텔리전스는 글로벌 CTI[2]와 연동하여 최신 글로벌 위협정보를 수집하며, 또한 자체적으로 위협정보를 수집함. 수집된 위협정보의 자동분석을 통해 사이버 위협 영향도 및 대응방안을 제공하는 통합보안 관제솔루션 체계 구축

✓ 보안관제 플랫폼에서 제공되는 대량의 이벤트를 가공/분석하여 비정상 행위를 자체적으로 분석하고, 대응방안을 보안 솔루션에 제공함. 또한, 사이버위협 인텔리전스(CTI) 플랫폼에서 제공하는 위협정보를 기반으로 비정상 행위를 추론하여, 제로데이 공격의 시간을 줄임으로써 내부망의 보안을 강화함

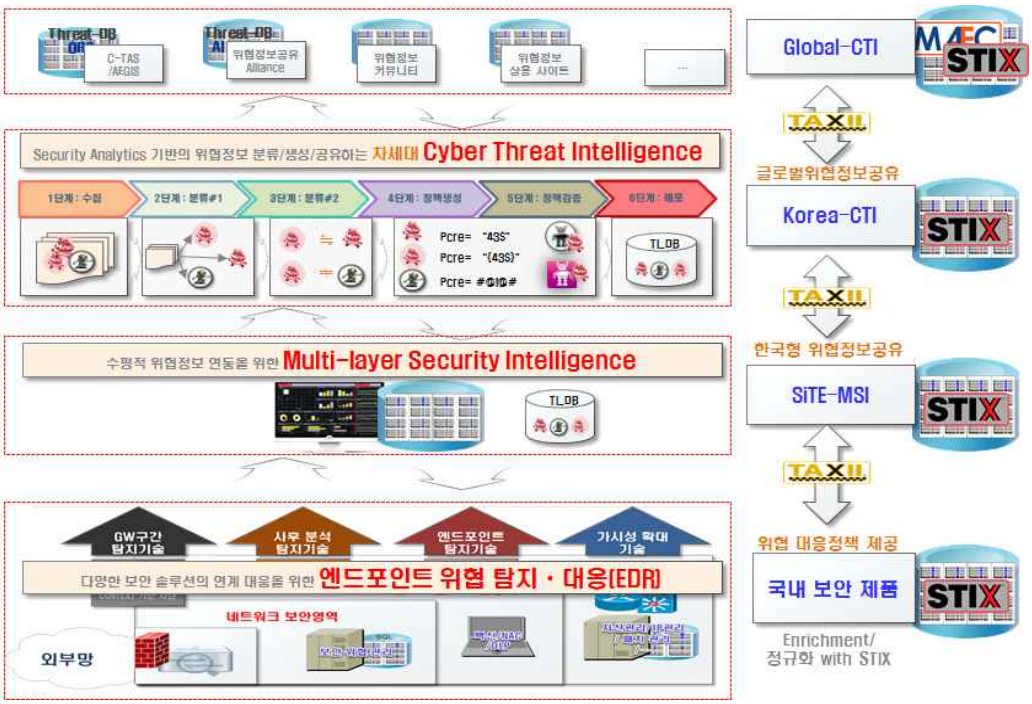
✓ 멀티레이어 보안 솔루션은 기존의 Syslog 및 기타 이벤트 생성 방법을 STIX[3] 또는 유사 STIX 기반으로 보안이벤트를 생성하여 중앙의 통합보안 관제플렛폼으로 전달하고, 제공된 사이버위협 대응 정보를 활용해 사이버 위협 사전대응 체계 구축

1) CTA (Cyber Threat Alliance) : 미국내의 사이버 위협정보 공유 협의체 (시만텍, 포티넷, 팔로알토, 인텔 등)

2) CTI (Cyber Threat Intelligence) : 사이버위협을 분석하고 분석된 정보를 기반으로 방어/대응하는 기술

3) STIX(Structured Threat Information eXpression) : 사이버 보안위협의 표현관련 표준

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

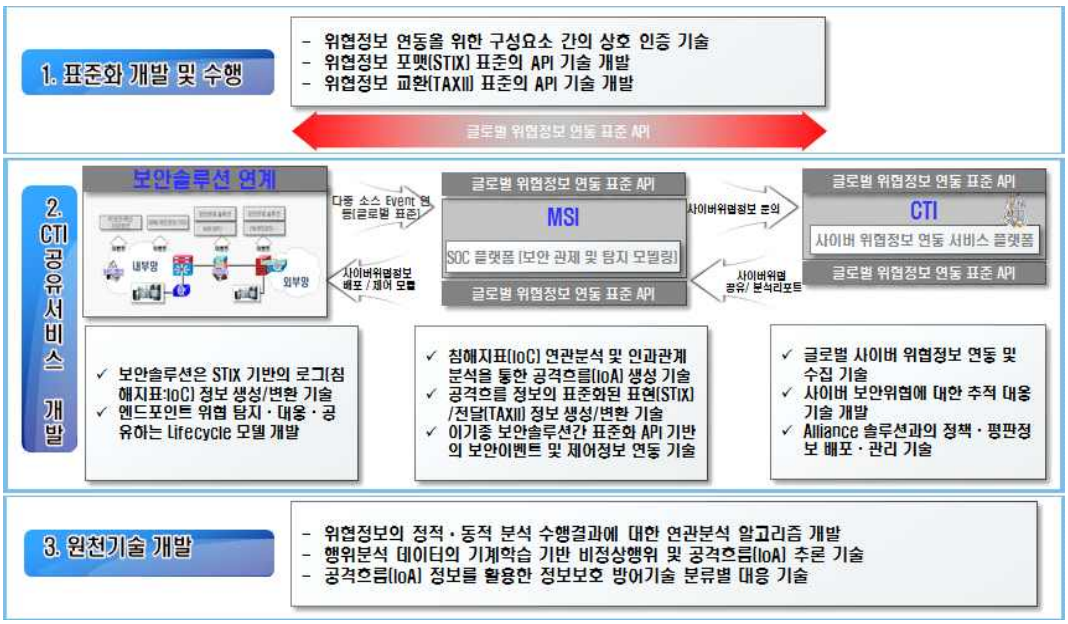


[그림 2] K-CTA 서비스 플랫폼 개념도

✓ 이벤트정보 생성 및 제어정보 교환은 STIX 기반의 규격으로 표현하고, TAXII[4] 기반의 방식으로 전송될 수 있도록 개발. 또한 다수 국내 중소 보안솔루션들이 위협정보공유 서비스 플랫폼과 연동할 수 있도록 관련 API 제공하여 서비스 활성화를 유도하고자 함

나. 연구개발 목표

○ 본 과제의 최종 목표는 “Security Analytics 기반의 이기종 보안솔루션 위협 분석 및 대응 기술 개발 “하는 것으로 개발된 플랫폼을 활용하여 사이버위협을 신속하게 분석 · 공유하는 K-CTA 사이버공격 대응체계를 구축하고자 하며, 과제의 개발 범위는 다음과 같이 정의된다.



[그림 3] 목표시스템 개발범위

4) TAXII(Trusted Automated Exchange of Indicator Information) : 사이버위협 정보 교환관련 표준

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 표준화 개발 및 수행 : 사이버 위협정보를 정형화된 방식으로 표현하고 공유하는 한국형 표준화를 진행하며, 표준화된 방식에 맞는 기술 개발을 함. 또한 사이버위협 기술의 표준에 맞게 개발된 표준 API[5] 기술을 공유함으로써 향후 중소 보안업체가 K-CTA 서비스를 신속하게 받을 수 있도록 소프트웨어 공유

✓ CTI 공유서비스 플랫폼 : 글로벌 사이버 위협정보를 수집/분석/배포하고, 서비스 망에서 보안솔루션과 연계를 통해 보안이벤트를 수집하고, 배포된 사이버 위협정보 기반으로 위협을 분석하여 사이버 위협을 사전에 대응할 수 있는 서비스 개발

✓ 원천기술 확보 : 사이버 위협에 대한 행위데이터를 기계학습 방식으로 공격흐름(IOA)을 추론하고, 공격흐름에 따른 대응 기술을 제공하기 위한 원천기술 개발

○ 멀티레이어 보안 장비를 통한 킬체인 단계별 탐지/대응 시스템 개발

✓ 최근 오랜 기간동안 단계적인 준비 과정을 거쳐 공격을 준비하고 감행하는 이른바 지능형지속가능위협(APT) 사례가 증가함에 따라, 공격 징후를 사전에 탐지해 선제 대응하는 '사이버 킬 체인(Cyber Kill Chain)' 을 기반으로 한 방어 전략이 각광받고 있음

✓ 국내 대표적인 보안업체들을 참여한 본 과제에서는 참여기관의 다양한 계층 보안장비(멀티레이어 보안)들의 이벤트를 활용하여 지능형 지속 위협공격에 대해 사이버킬체인의 모든 단계별 탐지/방어 가능한 한국형 사이버킬체인 위협인텔리전스 사이버위협 대응 시스템 개발이 가능할 것으로 예상

구분	정찰	무기화	침투	탈취	설치	C&C	행동
킬체인 단계							
	조사, 식별	자동화 도구	침투툴 전달	침투/취약점	백도어 설치	권한획득	유출
Firewall (시큐아이)	V		V				
IPS (윈스)	V			V			
Anti-Sapm (지란)	V		V	V			
DLP (소만사)			V	V			V
PC보안 (닉스)		V			V	V	V
Anti-virus (세인트)			V	V	V	V	
SIEM (이글루)	V		V	V			V

[표 1] 참여기관별 사이버킬체인 방어 범위

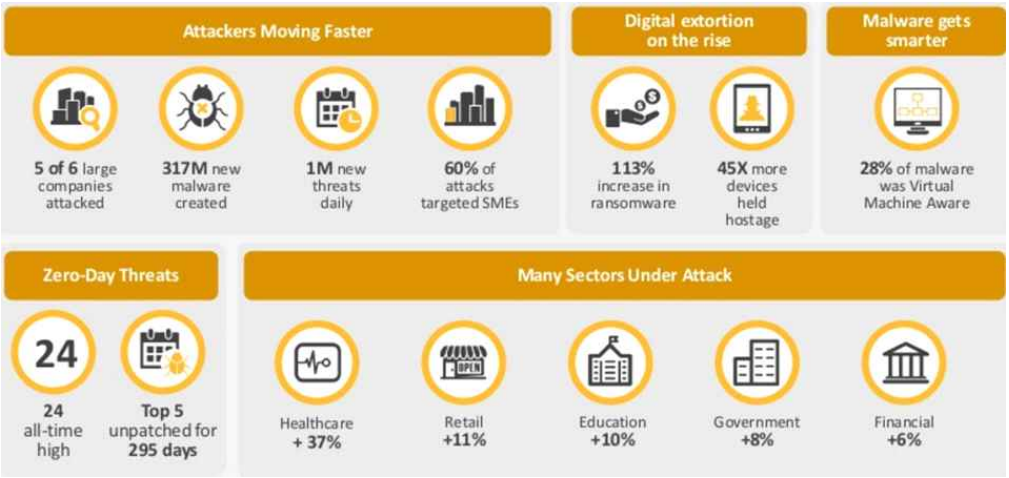
5) API((Application Programming Interface) : 응용 프로그램 프로그래밍 인터페이스

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

1-2. 연구개발의 필요성

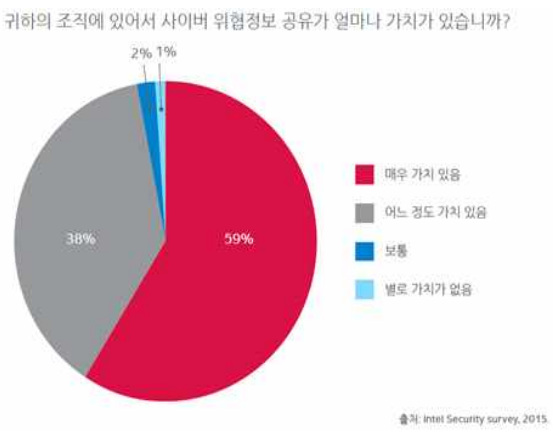
가. 보안 위협/대응 트랜드 변화

- ✓ ICBM[6] 미래환경의 생활방식에 맞게 새롭게 추가되는 서비스는 지속적으로 증가될 것으로 예상되며, 그 서비스를 타깃으로 하거나, 또는 그 서비스를 활용한 새로운 유형의 사이버 위협은 증가될 것으로 예상.
- ✓ Symantec 2015년 보안리포트에서는 이러한 새로운 유형의 사이버위협(Zero-Day) 공격에 대해 기존 보안장비는 인지할 수 없음으로 최대한 빠르게 탐지/대응하기 위해서는 위협정보 공유/대응할 수 있는 위협대응 체계 구축 필요성 강조



[그림 4] Symantec Internet Security Threat report 2015

- ✓ RSA Conference 2016의 주요 핵심 테마는 TI(Threat Intelligence)이며, 키노트 주제로는 TI, Data Analytics, Cloud 등이 공통적인 내용이었는데, 대다수의 글로벌 벤더들이 APT와 같은 보안 위협에 대응하기 위해서 GTI(Global Threat Intelligence)가 중요하며, 이를 위해서는 벤더간 위협정보 공유가 필요하다는 것에 공감대를 형성하고 있고, 이에 따라 TIP((Threat Intelligence Platform)와의 연동을 고려해 CPE, STIX, TAXII, CybOX를 준비해야 한다고 강조됨
- ✓ 2016년 맥아피 랩에서 전 세계 주요 조직의 보안 전문가 500명을 대상으로 설문 조사 결과, 사이버 위협정보 공유에 대한 인지도가 매우 높고, 사이버 위협정보 공유하는 사람들 중 97%가 그 가치를 인정하였음



[그림 5] 사이버위협정보 공유 가치

- ✓ 이글루시큐리티의 "2017년 5대 보안 기술 및 방법" 중 하나가 사이버 얼라이언스(Cyber Alliance)임. 어나니머스, 룰즈섹 등 조직화된 해커집단이 증가하며 사이버 범죄가 하나의 산업처럼 자리잡게 됨에 따라 이에 맞서는 기업과 기관, 국가들도 긴밀한 민/관 협업 및 국가간 협력을 위한 국제법 강화 등을 골자로 하는 '사이버보안 얼라이언스'를 결성하며 범국가적 대응체계를 마련하는데 집중할 것으로 예상함

6) ICBM : 미래 생활에 핵심이 되는 기술(IoT/Cloud/Big-Data/Mobile)에 대한 요약

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 한국인터넷진흥원의 2017년 정보보호 10대 이슈 중 하나는 ‘사이버위협정보 공유와 협력 확대’이며, 글로벌 사이버위협정보 공유 본격화와 국내 사이버위협정보공유 및 인텔리전스 협력 네트워크 확대를 예상함.

○ 기술적 측면

✓ 사이버 위협이 고도화됨에 따라 사용자는 복잡한 방어체계를 구축하여 대응하고 있으나, 다양한 계층의 보안감사 방식과 그 장비들에서 발생되는 대량의 상이한 보안 이벤트를 이해하고 분석/대응하기 위해서는 많은 시간이 소요되어 신속한 사이버 위협대응 어려움

✓ 보안솔루션 제품간 다양한 형식의 보안이벤트 및 각각의 상이한 연동 프로토콜을 가지고 있어, 이기종 제품간의 이벤트 정보 연동/공유가 어렵고, 그에 따라 자동화된 위협대응이 어려움

✓ 글로벌 대형 보안업체들의 협업(CTA)를 통한 자사 제품 경쟁력 강화에 대응하기 위해 신속한 한국형 사이버위협정보 공유 플랫폼 구축 및 서비스 제공으로 국내 보안업체의 글로벌 제품과의 경쟁이 가능한 체계 구축 필요

✓ 글로벌 벤더는 사이버 위협분석공유 제품 출시(TRL 7 ~ 9)하고 있으나, 국내기술 개발 수준은 연구단계(상대 기술수준 70% 이하)로 2년 정도 앞선 것으로 판단됨

○ 정부지원 측면

✓ 중소기업 위주의 국내 보안 산업계의 투자여력 한계로 인하여 위협정보를 공유할 수 있는 사이버위협 인텔리전스 플랫폼 구축 어려움

✓ 국내 보안업체간 위협정보 공유체계(K-CTA)를 구축하고, 다양한 보안업체들의 보안 이벤트 간의 연계를 위해 표준화된 위협정보 공유기술(STIX/TAXII)로 정형화 및 통합하여 공격 분석시간 감소와 분석 효율성 개선으로 신속한 공격대응 및 영향도를 최소화할 수 있을 것으로 예상

✓ 많은 투자비용이 소요되는 K-CTA 기술을 국가지원 사업으로 개발하고, 관련 서비스 플랫폼을 중소 보안업체가 공유함으로써 글로벌 제품 경쟁력을 확보할 수 있을 것으로 예상됨

○ 경제/사회적 측면

✓ 글로벌 보안제품과 치열한 경쟁 환경에서 국내 중소 보안제품의 K-CTA서비스 연동으로 국내 시장 지배력 강화 및 수입대체·수출확대 예상

✓ 보안이벤트 방식의 규격화/통일화에 따른 중소 보안업체들의 이벤트 통합 모듈 개발에 대한 중복개발 최소화 가능

✓ 국가적 사이버위협에 대해 체계적인 서비스 플랫폼 제공하며, 또한 중소 보안 장비들과의 신속한 대응 방안 연동을 통해 국가적인 위협대응 체계 구축 가능

나. 기술적 차별화

○ 글로벌 사이버 위협정보를 활용하여 침해지표(IOC)와 그를 활용한 공격지표(IOA)를 추출하여 공격흐름을 추론하는 보안위협 추적/대응 관련 원천기술 개발 필요

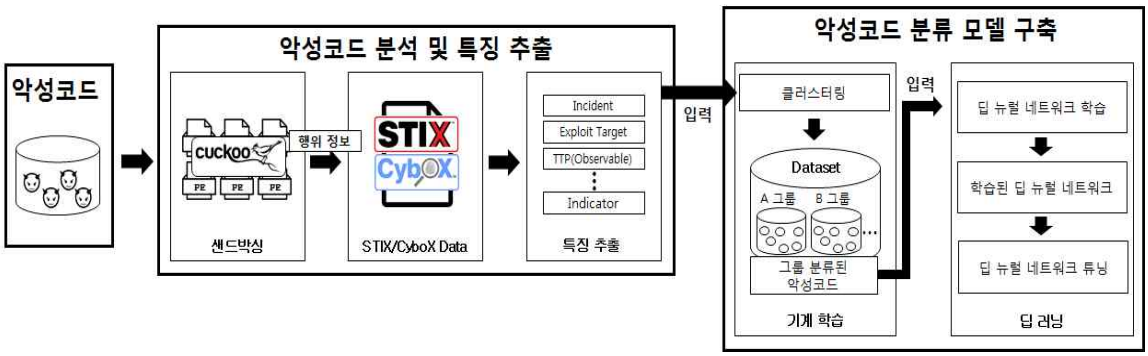
✓ 위협정보의 정적·동적 분석 수행결과에 대한 연관분석 알고리즘 개발

✓ 행위분석 데이터의 기계학습 기반 비정상행위 및 공격흐름(IoA) 추론 기술

✓ 공격흐름(IoA) 정보를 활용한 정보보호 방어기술 분류별 대응 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 위협정보 연관분석 알고리즘 개발



[그림 6] 악성코드 분류 모델 구축

✓ 정적/동적 분석 결과는 STIX/CyboX 표준 형식으로 위협정보 개념으로 표준화 및 구조화하여 위협에 대한 일관된 분석과 자동화된 해석이 가능하도록 악성코드의 특징 추출 과정을 자동화할 예정

✓ STIX/CybOX 표준으로부터 행위 정보를 가공하여 악성코드 특징 정보(침해지표:IOC)를 얻고 머신러닝 기법(클러스터링)으로 악성코드 그룹정보를 분류. 즉, 딥 뉴럴 네트워크에 악성코드 특징정보와 악성코드 그룹정보를 벡터 형태로 입력시켜 주면 악성코드가 어떤 그룹에 속할지에 대한 확률값-벡터 결과를 얻을 수 있고, 이 값을 이용해서 악성코드 분류모델을 구축할 예정임

○ 기계학습 기반 비정상행위 및 공격흐름(IoA) 추론 기술

✓ 급증하고 있는 신종/변종 악성코드에 대응하기 위해서는 악성코드 분류 모델의 정확도와 성능이 고도화를 위해 다른 분야에서 적용되어 검증이 된 딥러닝 기술을 적용하여 고도화 예정

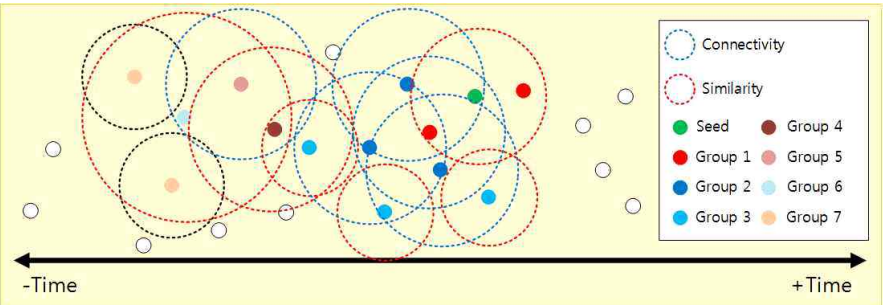
✓ 분류된 악성코드 그룹의 공통된 행위들로부터 사이버 킬-체인을 정의할 수 있으며, 신종/변종 악성코드의 미래 행위들을 그들이 속한 그룹으로부터 추출한 공통 행위를 분석함으로써 공격흐름(IoA)를 추론할 수 있음

○ 공격흐름(IoA) 정보를 활용한 정보보호 방어기술 분류별 대응 기술

✓ 특정 클래스 내에서 주류를 이루는 트래픽 형태를 모델링하고, 이를 기반으로 사이버 공격에 대한 트래픽 탐지 연구하여 악성 행위 트래픽 모델 정립

✓ 사이버위협정보를 킬체인 기반의 공격정보 Seed값들을 제공하고, 이러한 악성에 대한 정보를 기반으로 악성트래픽이라 의심되는 트래픽의 최초 정보 값을 받아, 이를 이용하여 연관성이 높은 트래픽 그룹들을 순차적으로 찾고 이를 분석하며, 이를 위해 특정 두 플로우 간 연결성을 수치화할 수 있는 Flow Correlation Index (FCI)를 정의할 예정임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 7] Seed Based Traffic Grouping Method

✓ 내부망에서 발생되는 보안 이벤트 및 트래픽 정보를 기반으로 의심스러운 악성행위를 판단하고, 그 공격에 대한 향후 발생될 것으로 예상되는 공격형태별 보안정책을 보안장비/단말보안제품에 제공함으로써 사전 대응방안 마련 가능

다. 적용분야

○ 사이버 위협정보 공유 서비스 플랫폼은 3가지의 구성 요소로 구성되며, 다음과 같은 역할을 수행한다.

✓ 위협정보공유 : 사이버위협 정보 수집 및 자동 분석, 대응방안 배포

✓ 관제 솔루션 : 사이버 위협정보를 기준으로 새로운 위협에 탐지/차단 정책 제공

✓ 내부 보안 솔루션 : 단말/네트워크 등의 보안 제품의 이벤트 및 제어정보 연동

○ 사이버위협정보(CTI) 공유 서비스 플랫폼 적용 분야

✓ 독립적인 CERT[7] 조직을 보유한 기업의 사이버위협정보 수집 및 자동분석 솔루션으로 활용

✓ 사이버 위협 대응을 위한 중앙정책 일괄배포 솔루션으로 기능 확장 가능

○ 멀티레이어 보안인텔리전스(MSI) 플랫폼적용 분야

✓ 다량의 이벤트를 수집하여 가공/저장하는 빅데이터 수집 솔루션으로 활용

✓ 이기종 보안 장비의 통합보안 SIEM[8] 솔루션으로 활용

○ 단말/네트워크 적용 분야

✓ 이기종 보안 장비에서 전송되는 이벤트를 표준화된 표현/연동하기 위한 표준 API를 제공하여, 기존 중소 보안 장비들의 이벤트 통합 방식으로 활용

✓ 또한, 표준 API를 통해 보안장비들의 제어정보 연동하는 방식으로 활용

7) CERT(computer emergency response team) : 보안 위협에 대한 침해사고대응팀

8) SIEM(Security information and event management) :다양한 보안이벤트를 활용한 통합보안관리 솔루션

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

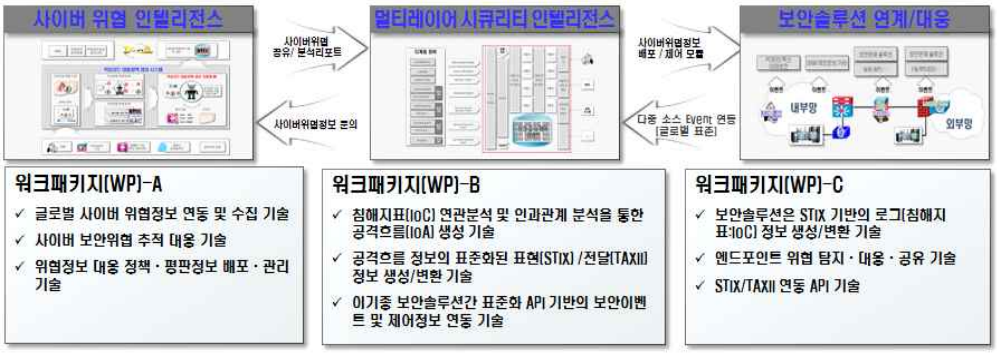
1-3. 연구개발 범위

가. 최종개발 목표

○ 이기종 보안솔루션들의 효과적인 사이버위협 탐지 · 대응을 위한 Security Analytics 기반의 사이버위협정보를 분석 · 공유하는 KOSIGN (Korea Open Security Intelligence Global Network) 서비스 기술 개발

✓ 최종 목표시스템의 워크패키지(WP)별 세부 목표

- WP-A : 사이버 위협 인텔리전스(CTI) 기술 개발
- WP-B : 멀티레이어 시큐리티 인텔리전스(MSI) 기술 개발
- WP-C : 보안솔루션 연계 대응(EDR) 기술 개발
- STIX/TAXII 기반 사이버 위협 분석 정보 연동 프레임워크 표준 개발



[그림 8] 사이버위협 분석 · 공유 서비스에 대한 워크패키지

○ 워크패키지별 주요 기능(또는 규격)

✓ (WP-A) 글로벌 사이버 위협정보를 수집/분석하여, 공격을 추정하고 대응 방안을 제공하는 사이버 위협 인텔리전스(CTI) 기술

- 글로벌 위협정보 수집 및 정적/동적 분석 시스템 개발
- 악성코드 동작 분석 지표 추출 기술
  + 빅데이터 딥러닝을 통한 악성코드 종류별 모델 개발 및 그룹핑 기술
  + 그룹핑 정보를 활용한 위협정보 킬-체인 생성 기술
- 사이버 위협정보 대응을 위한 위협대응 정보 배포 시스템 개발

✓ (WP-B) 이기종 장비에서 전송되는 STIX 형식의 다양한 이벤트를 빅데이터 기반으로 수집/저장하고, 수집된 정보를 침해지표 기준으로 Security Analytics 기술을 활용하여 인과관계를 분석하고, 향후 예상되는 위협까지 대응할 수 있는 멀티레이어 시큐리티 인텔리전스(MSI) 기술

- 이기종 보안 장비/Agent의 실시간 이벤트 수집 시스템 개발
- 침해지표(IoC) 기반 연관/인과관계 분석을 통한 공격흐름(IoA) 생성기술
  + 네트워크 악성 트래픽 그룹핑을 통한 사이버 공격 탐지 기술
- 공격흐름 정보를 표준화된 표현(STIX)/전달(TAXII) 정보 생성/변환 기술
- 이기종 보안솔루션간 표준화 API 기반으로 이벤트/제어정보 연동 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ (WP-C) 이기종 보안장비들의 보안이벤트를 STIX/TAXII 기반으로 정보 연계하고, 추론된 위협에 효과적으로 대응할 수 있는 단말보안제품과의 연계대응(EDR) 기술

- 위협정보 연동을 위한 구성요소 간의 상호 인증 기술
- 위협정보 표준 포맷(STIX)/교환(TAXII) 모듈 개발(API 활용)
- 단말의 위협 대응을 위한 EDR 시스템 개발

○ 워크패키지별 주요 성능치

✓ WP-A(CTI)관련 주요 성능치

- 악성코드 동작분석 판단 지표 : 200건 이상
- 악성코드 유사도분석 성능 : 0.05초 이하

✓ WP-B(MSI)관련 주요 성능치

- MSI 플랫폼의 이벤트 수집성능 (호스트 1대 기준) - 150,000 ESP 이상
- 이벤트 분류정확도 : 악성 트래픽 탐지율(Recall) 98% / 탐지 정확도(Precision) 98%

✓ WP-C(EDR) 관련 주요 성능치

- 로그 검색 소요시간 : 2초 (100만 로그 중, 특정 로그 조회)
- 기계학습 기반 비정상행위 탐지율 : 95%

○ End Product

✓ 사이버 위협 인텔리전스(CTI) 플랫폼

- 악성코드 자동수집 및 연동시스템(서버 탑재형 SW)
- 악성코드 분류 및 그룹별 킬-체인 생성 시스템(서버 탑재형 SW)
- 악성코드 공유서비스 포탈시스템(서버 탑재형 SW)

✓ 시큐리티 인텔리전스(MSI) 플랫폼

- STIX/TAXII 기반의 대용량 이벤트수집 시스템(서버 탑재형 SW)
- Security Analytics 기반의 통합관제시스템(서버 탑재형 SW)

✓ 보안솔루션 연계대응(EDR) 기술 개발

- STIX/TAXII 기반 이벤트 연동API 모듈(서버 탑재형 SW)
- 호스트 행위 수집 및 차단 시스템(서버 탑재형 SW)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2. 연구수행내용 및 성과

2-1. 1차년도(2017년) 수행내용 및 성과

가. 1차년도 연구개발 목표 및 결과

구분 (연도)	세부 과제명	세부 연구 목표	연구개발 수행 내용	연구 결과
1차 연도 (2017) - 프로토타입 개발	WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	글로벌 위협정보 수집	- 자체 클롤러 개발 - KISA의 C-TAS 연동 - 상용 API활용 수집	- 700만건 이상의 악성파일 수집
		악성코드 동작 지표 추출	- 악성코드 동적/정적 분석으로 악성동작 지표 관련 기술 연구	- 210개 이상의 유효한 악성코드 동작지표 추출
		딥러닝 기반 분류 모델 설계	- 추출된 동작지표를 통한 딥뉴얼 기반의 그룹핑 및 UI	- 악성그룹핑 논문 등제 - 분석/그룹핑/CTI 프로토타입 개발
	WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	관제 플랫폼 프로토타입 개발	- MSI 플랫폼 설계 - 플랫폼 프로토타입 구현	- MSI 플랫폼 설계완료 - 플랫폼 프로토타입 개발
		Seed 기반 트래픽 그룹핑	- Seed정보를 이용한 트래픽 그룹핑 알고리즘 및 악성탐지	- 알고리즘 논문 등제 - 악성탐지 프로토타입 개발 완료
		위협정보 연동 규격 개발 및 프로토타입 API 개발	- 위협정보 연동 규격 개발 - 연동용 프로토타입 API 개발	- 위협정보 연동 규격 개발 완료 - 연동용 프로토타입 API 개발 완료
	WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)	네트워크 보안장비의 STIX 연동 규격 설계	- 연동 규격 설계	- IPS/DLP/스펨 업체 제품의 프로토타입 연동 완료
		단말 보안장비의 STIX 연동 규격 설계	- 연동 규격 설계	- PC보안(닉스) 프로토타입 수행 완료
		EDR 규격 설계	- EDR 설계	- EDR 설계 완료
	STIX/TAXII 표준화	표준 규격 기안	- 표준화 기고 및 채택	- 국제 표준화 기고서 제출/채택 2건 - 국내 표준화 기고서 제출/채택 1건

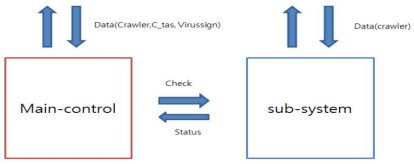
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 워크패키지별 상세 연구수행 내역

(1) WP-A : CTI (위협정보 분석/공유 서비스 기술 개발) : ㈜윈스 + 국민대학교

(가) 연구개발 성과

○ 위협정보 수집시스템을 통한 위협정보 DB 구축 및 악성 분석시스템 개발



No.	수집유형	정의
1	악성파일	공격을 위해 사용되는 대상 파일
2	유포지	악성코드 유포지 IP/Domain/URL 정보
3	C&C	공격을 위해 사용되는 host IP 정보

[그림 9] 위협정보 수집/분석 시스템 개념도

✓ 다양한 외부 채널을 통한 위협정보 수집 기능 개발

- 악성 유포지/경유지 IP, 악성파일 등 수집
- 주기적 악성파일 자동수집을 통한 대용량 악성코드 저장소 구축
- Global CTI를 통한 위협정보 수집

✓ 수집된 데이터 기반으로 위협정보 분석을 위한 기반데이터 생성

✓ 유포지 또는 C&C 주소를 활용하여 다양한 정책 생성 기능 설계/개발

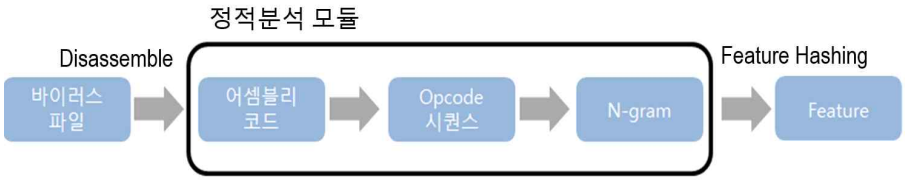
✓ 700백만개 이상의 위협정보 수집

No.	분류	수집채널	수집유형	정의	총 수집량
1	무료채널	malshare	악성파일	신규 출현 악성코드 공유정보 및 샘플 수집	75,868개
2		minotaur	악성파일		12,366개
3		vxvault	악성파일		2,308개
4		malc0de	악성파일		1,566개
5		C-TAS	악성파일		10,903개
6			악성URL	악성코드 유포지 IP/Domain/URL 정보	2,832개
7	유료채널	VirusSign	악성파일	신규 출현 악성코드 공유정보 및 샘플 수집	7,003,113개
8	합계			전체 위협 정보 수집 합계	7,108,956개

[그림 10] 차년도 수집 채널 및 악성코드 개수

○ 악성코드 동작지표 추출

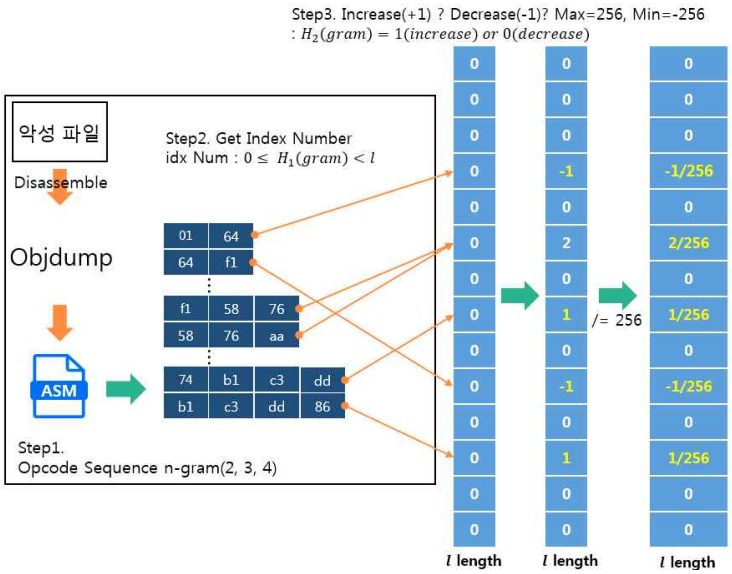
○ 진단명이 확정된 악성코드를 딥러닝을 통해 분류하는 모델을 학습시키는 방법으로 악성코드 바이너리 파일 자체를 이용한 학습 방법과 정적분석 기술을 통해 악성코드의 특징들을 추출, 가공하여 학습시키는 방법으로 진행



[그림 11] 악성코드 바이너리 파일의 특징 추출을 위한 전처리 과정

- 악성코드 바이너리 업샘플링(up-sampling)/다운샘플링(down-sampling) 기술을 통해 분류모델 학습을 위한 악성파일을 고정 크기로 변환
- 디스어셈블 이후 Opcode 추출 및 n-gram 기법으로 악성코드 고유 특징 추출
- 추출한 n-gram은 고정 크기로 변환하여 피처 해싱(Feature Hashing) 수행함으로써 악성코드 피처 추출

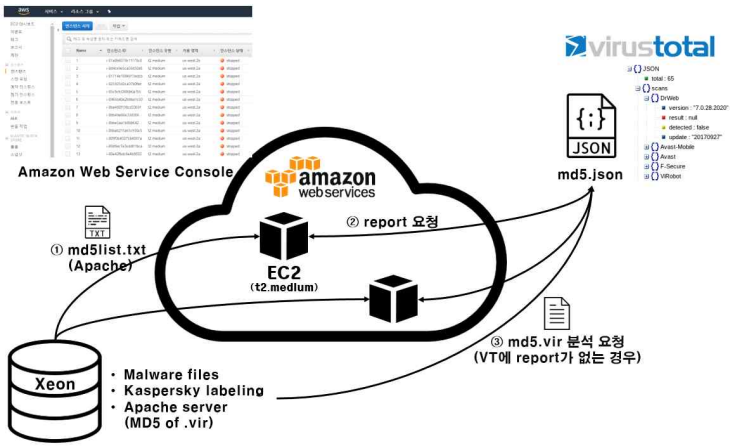
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 12] 악성코드에서 피처 해싱 리스트를 만드는 과정

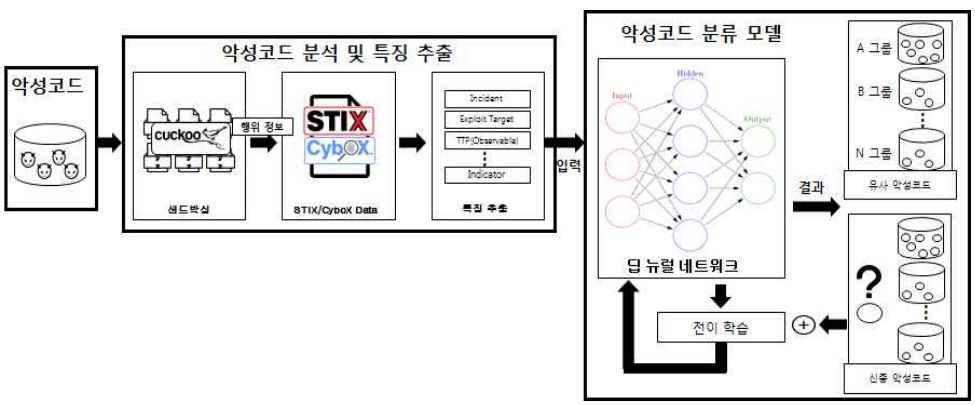
✓ 악성코드 동작분석 판단지표는 디스어셈블을 통한 Opcode 추출 및 n-gram 기법으로 정의될 수 있으며, 추출될 수 있는 Opcode의 최대 개수는 256개로(16^2), Opcode를 이용하여 2, 3, 4-gram을 추출하여 각각 독립적인 판단지표로 65,536(256^2), 16,777,216(256^3), 4,294,967,296(256^4)개의 경우를 가지며, 본 과제에서는 2/3/4-gram 모두를 채택하였으므로 판단지표는 총 개수는 43억개 정도임.

✓ 악성코드 데이터 셋의 그룹을 파악하기 위해 바이러스토탈(Virustotal) 서비스를 이용한 뒤 안티 바이러스 업체인 카스퍼스키(Kaspersky)의 진단명을 이용하였음.



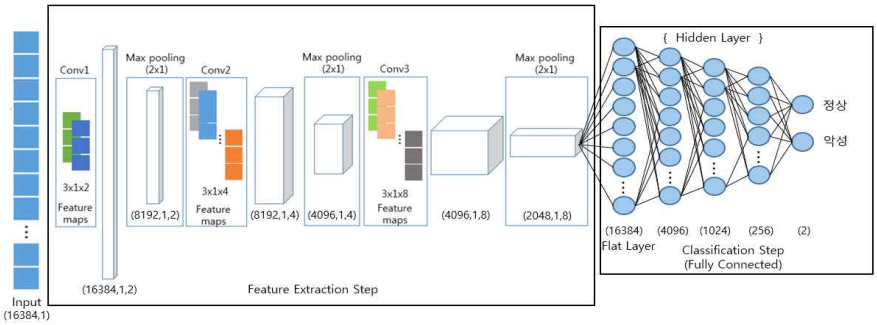
[그림 13] 악성코드 데이터의 진단명을 분석하는 구조

○ 딥러닝 기반 분류 모델 설계



[그림 14] 딥러닝 기반 악성코드 분류 모델의 전체 구성도

✓ 바이너리코드/어셈블리코드의 입력정보를 활용한 구글 텐서플로우(Tensorflow) 기반의 다양한 학습모델(CNN[9]/ANN[10]) 개발 수행



[그림 15] 합성곱 신경망 모델을 이용한 악성코드 탐지 모델 구조

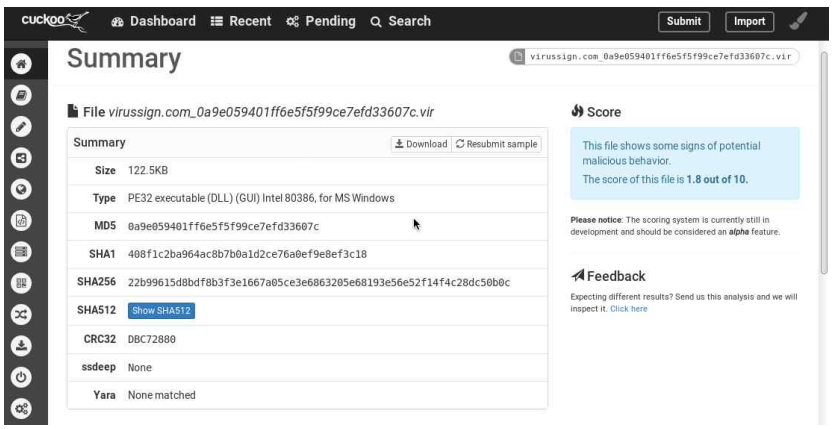
✓ 17년 7~8월에 수집된 악성코드로 모델을 학습하여 9월에 수집된 악성코드로 검증

모델 구분	입력형태	딥러닝 모델	정확도(%)	데이터 셋(개)
Binary Classification	Binary file	CNN	96.4%	학습(정상/악성)35,078/1,517,011 검증(정상/악성) 8,769/1,955,392
	Featuring hashing	ANN	99.7%	학습(정상/악성) :30,593/1,477,101 검증(정상/악성) : 7,647/1,841,211
		CNN	98.0%	
Multi-class Classification (그룹 : 29개)	Binary file	CNN	83.4%	학습:1,517,011검증:1,955,392
	Featuring hashing	ANN	88.4%	학습: 1,477,101 검증: 1,841,211
		CNN	83.7%	

[표 2] 모델 검증 결과

○ 그룹핑 정보를 활용한 위협정보 킬-체인 생성 모델 설계

✓ 샌드박스를 이용하여 악성코드 분석 보고서를 생성하고, IoA(Indicator of Attack) 정보를 추출하는 원천 자료로서 활용



[그림 16] 쿠쿠샌드박스에서 제공하는 분석 결과 예시

9) CNN (Convolutional Neural Network) :합성곱 신경망 기반의 딥러닝 기계학습 알고리즘

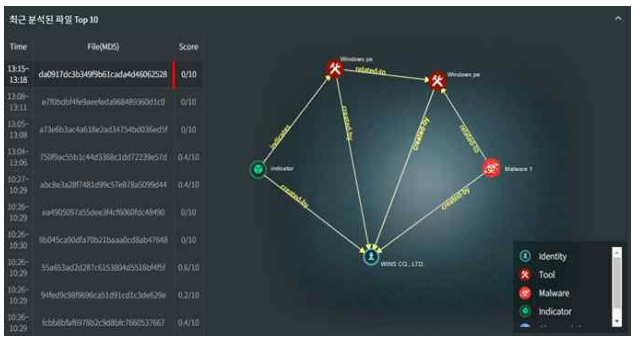
10) ANN (Artificial Neural Network) : 인공신경망 기반의 통계학적 기계학습 알고리즘

✓ 샌드박스의 Call_API_list 기준으로 유효한 값 210개 이상의 행위지표를 기반으로 리포트 제공하며, 아래의 분석정보를 얻을 수 있음

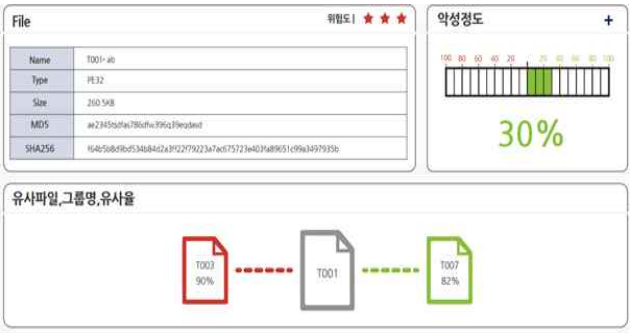
- Static Analysis : 악성코드의 파일 구조에 따른 각 섹션이나 import되는 dll과 각종 함수들, 포함하고 있는 스트링과 virustotal의 분석 결과를 얻을 수 있음.
- Behavioral Analysis : 동적 분석한 결과로 실제 악성코드를 실행하고 받아볼 수 있는 로그 기록들이 있음. 네트워크, 파일시스템, 레지스트리, 프로세스, 서비스, 동기화 등 다양한 정보를 얻을 수 있음.
- Network Analysis : 네트워크를 통해 분석한 정보를 바탕으로 Hosts, Domains, HTTP, ICMP, IRC 등의 정보를 구분하고 각 정보를 보여줌.
- Dropped Files : 악성코드를 실행한 후 추가적으로 생성하고 삭제하는 파일들을 모두 수집해 별도로 저장함.
- Volatility를 이용하여 석결과 : 메모리 분석 기능 활성화로 인해 추가적인 분석 결과를 얻을 수 있음. 프로세스 정보, 서비스, 인젝션된 코드 정보, API 후킹 의심 정보 등을 얻을 수 있음.

○ CTI 프로토타입 개발

✓ 자동화된 정적/동적 분석하고, STIX 포맷으로 시각화 제공

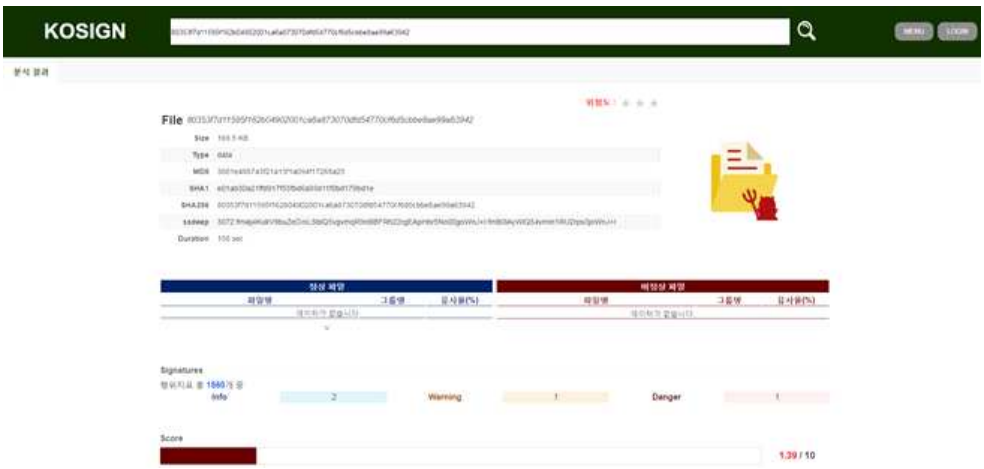


[그림 17] 정적/동적 분석화면



[그림 18] STIX포맷 시각화 화면

✓ 위협정보의 자동화된 분석 및 분석된 위협정보 실시간 확인으로 알려지지 않은 위협정보에 대한 분석결과 제공



[그림 19] 위협정보 분석결과 화면

✓ 추가적인 분석을 위한 기반 데이터 제공



[그림 20] 분석 데이터 제공 화면

(나) 연구개발 평가

○ 기술개발 평가 항목 및 결과

구분	평가 항목	평가 결과
악성코드 동작분석 판단 지표	200개 이상	유효한 동작지표 210 개 추출
악성코드 유사도 분석 성능	0.1초 이내	0.02 초이내

[표 3] 1차년도 기술개발 평가 항목 및 결과

○ 기술개발 평가 방법 (관련 기술 논문 및 특허 출원)

✓ 기술개발 평가 항목 관련 연구개발 성과

- 논문 : Regular Expression Filtering on Multiple q-grams(IEICE 등제)
- 특허 출원 : CNN 학습 기반의 멀웨어 분석 장치, 이를 수행하는 CNN 학습 기반의 멀웨어 분석 방법 및 이를 저장하는 기록매체

✓ 악성코드 동작분석 판단 지표관련 평가 방법 (증빙자료 - CTI 시험 결과서 참조)

- 샌드박스의 Call_API_list 기준으로 유효한 값 210개 이상의 행위지표 기반으로 킬체인 리포트 제공
- 또한 악성코드 및 그룹 분석을 위한 동작분석 판단지표의 기본이 되는 opcode는 최대 개수는 256개(16의 제곱) 사용

✓ 악성코드 유사도 분석 성능관련 평가 방법 (증빙자료 - CTI 시험 결과서 참조)

- 악성코드 유사도 분석 성능 판단에 사용하는 판단 지표에 따라 달라짐. 바이너리 지표를 사용하는 경우 파일 전체를 증가시켜 다운샘플링을 하여 전처리 시간 오래 걸리는 모습을 보여줌. 정적 지표를 사용하는 경우에 1차년도 목표치인 0.1(s)를 만족하였으며 표는 판단지표에 따른 속도를 보여줌.
- 평균 멀웨어 크기 : 300K

입력 형태	전처리 시간(s)	검증시간(s)
Binary file	-fixed size : 0.24	-CNN : 0.019
Feature hashing	-Disassemble + gram+hashing : 0.068	-ANN : 0.011 -CNN : 0.018

[표 4] 멀웨어 전처리 및 검증 시간

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

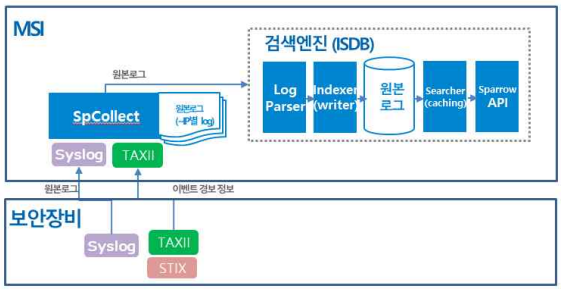
(2) WP-B : MSI (Securtiy Analytics 기반의 보안관제 솔루션) : 이글루시큐리티 + 고려대학교

(가) 연구개발 성과

○ 멀티레이어 시큐리티 인텔리전스 플랫폼 프로토타입 구현

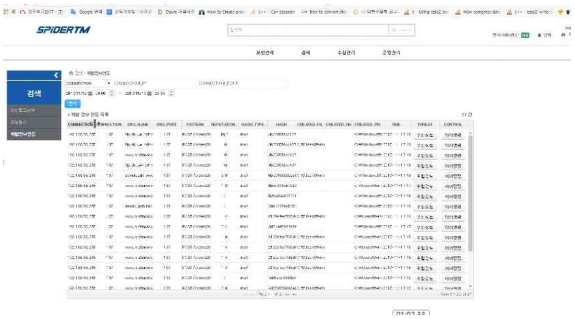
✓ 멀티레이어 시큐리티 인텔리전스 시스템 구조

- 이기종 보안 이벤트를 표준화된 표현(STIX)/전달(TAXII) 프로토콜을 이용한 데이터 수집
- 수집된 정보에 대한 파싱, 부가정보 추가, 변환하여 저장.
- 데이터 효과적 관리 위한 압축 저장 , 인덱싱, 캐싱, 검색.

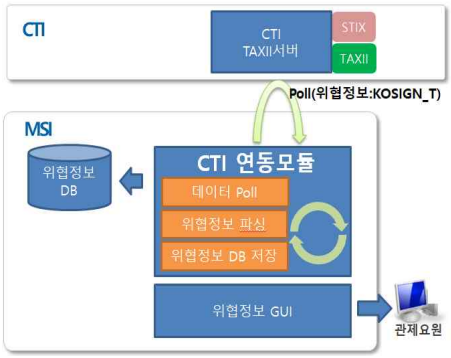


[그림 21] 이기종 보안장비의 이벤트 수집 구조

✓ CTI에서 위협정보를 연동하는 모듈



[그림 22] CTI와 STIX/TAXII 연동을 통한 위협정보 공유



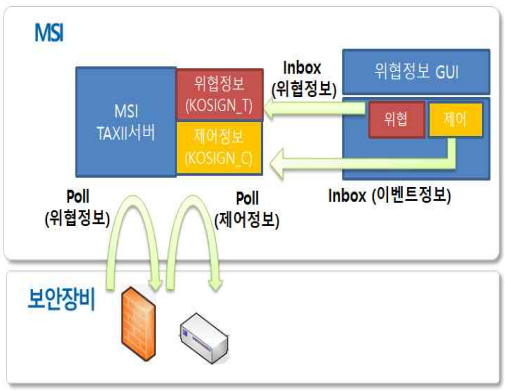
[그림 23] CTI 연동 모듈

- CTI에서 배포한 위협정보를 MSI에서 주기적으로 데이터를 동기화 하여 저장.
- 연동 포맷은 표준화된 표현(STIX)/전달(TAXII)를 이용하여 연동.

✓ 이기종 보안솔루션간 표준화 API 기반으로 위협정보/제어정보 연동



[그림 24] MSI와 보안장비의 제어정보 연동 이력



[그림 25] 위협정보/제어정보 연동

- CTI에서 연동된 위협정보/제어정보를 이기종 보안솔루션과 정보 공유 및 제어.
- 연동 포맷은 표준화된 표현(STIX)/전달(TAXII)를 이용하여 연동.

✓ MSI 플랫폼 설계 및 프로토타입 구현

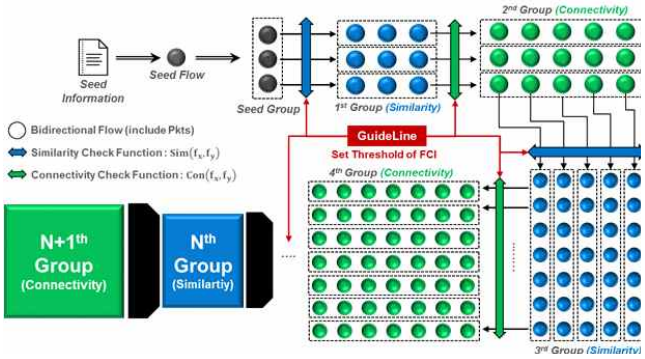
- MSI 플랫폼 기술 설계서 및 요구사항서 작성.
- MSI 플랫폼 프로토타입 구현 및 시험 평가 결과서 작성.

○ Seed정보를 이용한 FCI기반의 트래픽 그룹핑

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 트래픽 그룹핑을 위한 FCI 체계 개념

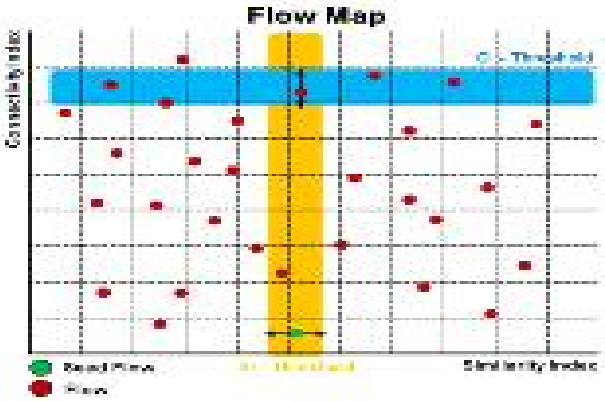
- 유사성(Similarity) 기반의 그룹핑과 연결성(Connectivity) 기반의 그룹핑 수행하며, 1차적으로 유사성(Similarity)으로 그룹핑하고, 그 정보를 바탕으로 연결성(Connectivity) 기반 그룹핑을 순환적으로 사용하여 그룹핑 함
- Sequential Grouping Model을 설계해서 MSI 플랫폼으로부터 입력으로 받는 Seed 정보와 유사한 플로우를 연속적으로 탐지



[그림 26] Sequential Grouping Model

✓ FCI 기반의 트래픽 그룹핑 방법

- 입력받은 시드로부터 Seed Flow와 Seed Group을 생성하고 Seed Group에서부터 연속적으로 유사성과 연결성 그룹을 교차하며 탐색



[그림 27] FCI 기반의 트래픽 그룹핑 방법 개념도

- 유사도 기반의 그룹핑을 위해서 각 플로우에서 5가지 Feature들을 정의하고 플로우간의 연관성을 Euclidean 유사도를 통해서 측정하고, 연결성 기반의 그룹핑을 위해서는 각 플로우를 구성하는 패킷의 5-Tuple(프로토콜, Src-Dst IP, Src-Dst Port) 정보를 활용해서 연결성 값을 설정한 후 플로우간의 연결성을 Euclidean 유사도를 통해 측정.

Similarity Index	
Features	Explanation
PIT_mean PIT5_mean	# PIT = Packet Inter-arrival Times of the Flow # PIT 5 = PIT of first 5-Packets (except TCP 3-way handshake)
PSD_mean PSD5_mean	# PSD = Packet Size Distribution of the Flow # PSD 5 = PSD of first 5-Packets (except TCP 3-way handshake,Non-Data Packets)
PSS5	# PSS 5 = Packet Size Seq. of first 5-Packets (Consider Packet Direction Forward & Backward)

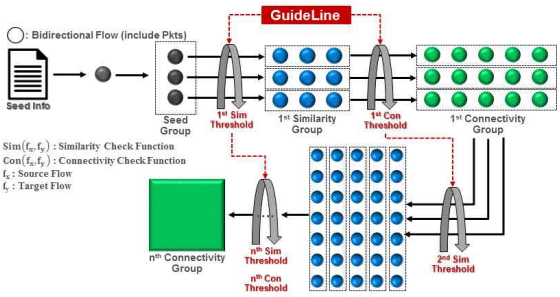
[그림 28] 유사도 값 (Similarity Index)

Connectivity Index			
Features	Explanation	Function	Weight
ST	Start Time	$a_{ST}(f_x,f_y)$	w_{1_ST}
SIP	Source IP Address	$a_{IP}(f_x,f_y)$	w_{2_IP}
DIP	Destination IP Address		
SPT	Source Port Number	$a_{PT}(f_x,f_y)$	w_{3_PT}
DPT	Destination Port Number		
PROT	L4 Protocol	$a_{PROT}(f_x,f_y)$	w_{4_PROT}

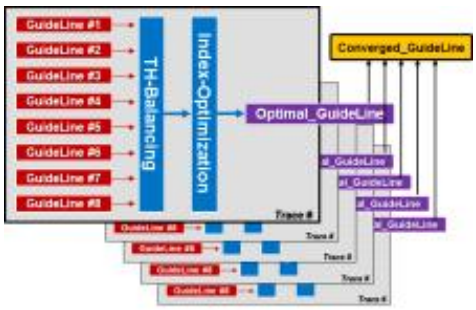
[그림 29] 유사도 값 (Similarity Index)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 정교한 탐지를 위한 기준 값(Threshold) 정의 및 GuideLine 생성 방법 연구



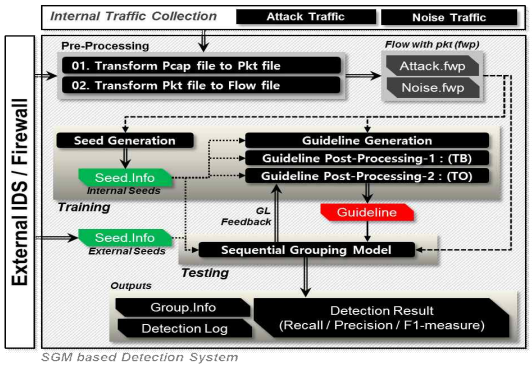
[그림 30] GuideLine 적용 개념도



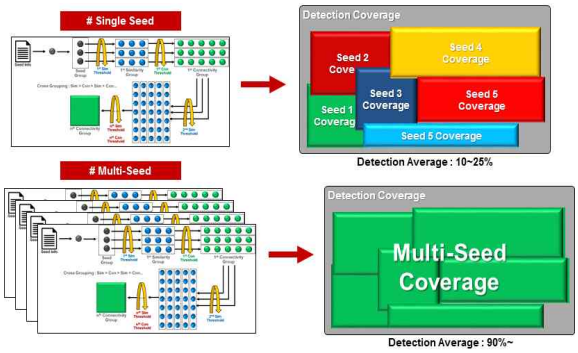
[그림 31] GuideLine Converging

- 보다 정교한 연관 트래픽 그룹핑 작업을 위해서는 유사성 값과 연결성 값에 대한 정교한 기준 값 그리고 각 Feature들에 대한 가중치에 대한 정보 생성 필요.
- 유사성과 연결성 값 모두 정교한 그룹화 작업을 위해서는 만족해야 하는 기준이 필요. 이러한 기준 값(Threshold)는 다양한 트래픽 학습을 통해 생성
- 이러한 가중치와 기준 값들에 대한 정보를 'GuideLine' 이라는 내용으로 정의해 탐지를 수행하는 데에 있어 그 정확도와 범위를 보정 수행

✓ Seed 정보 기반 Sequential Grouping Model을 적용한 FCI 탐지 시스템 프로토타입 개발



[그림 32] SGM based Detection System



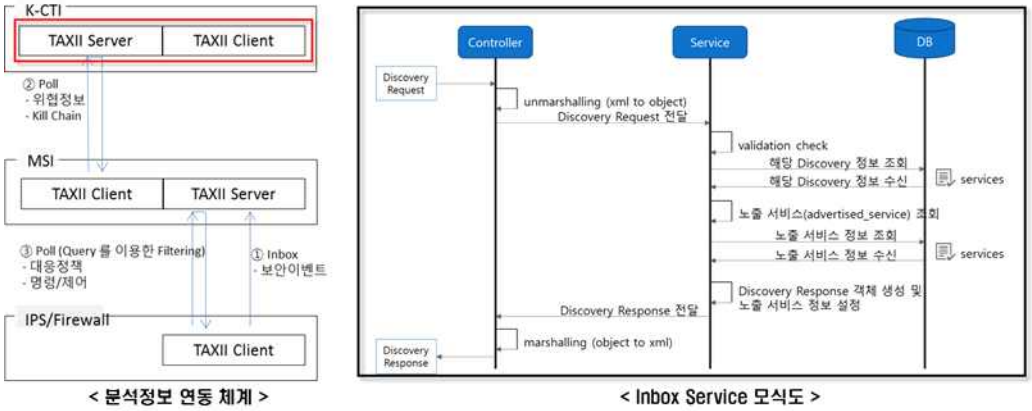
[그림 33] Multiple-Seed 기반의 탐지 방법 개념

- Seed Generation 모듈은 수집한 악성 트래픽에서 각 Flow를 시드 정보로 추출.
- GuideLine Extractor에서는 Threshold Balancing과정을 통해 입력에서 받은 각 Seed에서 GuideLine을 추출
- GuideLine Optimizer에서는 생성된 GuideLine을 통합해 입력으로 받은 공격 트래픽에 최적화된 탐지 GuideLine을 생성하고 이러한 Optimal GuideLine을 융합해 Converged GuideLine을 생성
- Sequential Grouping 모듈은 기존의 FCI-Calculator를 튜닝한 트래픽 그룹핑 모듈로서, Multiple-Seed 기반의 탐지 방법 적용을 통해 기존에는 탐지하지 못했던 Flow들 또한 다양하게 탐지하여, 매우 높은 정확도의 탐지 시스템 구현

○ 보안솔루션 위협정보 공유 및 글로벌 위협정보 연동 표준 개발

✓ STIX/TAXII 표준 기반 보안 위협 정보 공유 데이터 모델링 및 프로토콜 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 34] 분석정보 연동체계 및 Inbox Service 모식도

✓ STIX/TAXII 오픈소스를 활용한 API 개발



[그림 35] STIX/TAXII 오픈소스를 활용한 API 개발화면

- CTI와는 Polling(Taxii-Client) 방식으로 위협정보(차단 IP) 연동 프로토타입 구현
- CTI와 연동한 위협정보(IP)를 보안솔루션으로 전달(Taxii-Server 모듈)

✓ STIX/TAXII 연동 API관련 SW 등록



[그림 36] STIX라이브러리 SW저작권등록



[그림 37] TAXII라이브러리 SW저작권 등록

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(나) 연구개발 기술 평가

○ 기술개발 평가 항목 및 결과

시험 항목	시험 내용	목표치	측정치
이기종 이벤트 수집 성능	로그성 데이터를 적재하는 수집 엔진의 성능이 100,000 EPS(Event per Second) 이상인지 확인	100,000 EPS	169,206 EPS
Seed기반 악성 트래픽 탐지	이벤트 분류 기준 악성트래픽 탐지율 (Recall)	90%	93% (악성 트래픽별 평균)
	이벤트 분류 기준 악성트래픽 탐지정확도율 (Precision)	90%	100% (악성트래픽별 평균)

○ 기술개발 평가 방법

✓ 기술개발 평가 항목 관련 연구개발 성과

- 논문 : Effective Behavior Signature Extraction Method using Sequence Pattern Algorithm for Traffic Identification (학술지 - IJNM, John Wiley and Sons)
- 특허 출원 : 네트워크 플로우의 연관성 모델을 이용한 트래픽 분류

✓ 이벤트 수집 성능 관련 평가 방법 (증빙자료 - MSI 시험서 참고)

✓ Seed기반 악성 트래픽 탐지 관련 평가 방법 (증빙자료 - MSI 시험서 참고)

(3) WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)

: 소만사 + 한류AI센터 + 지란지교시큐리티 + 시큐아이 + 세인트시큐리티

(가) 연구개발 성과

○ 네트워크 보안장비의 STIX 연동 규격 설계



[그림 38]네트워크 보안장비의 STIX 연동 규격 설계

✓ STIX 변환 모듈 : 실망에서 수집된 이벤트를 STIX 형태로 변경

✓ TAXII 연동 모듈 : 변환된 STIX 형태의 이벤트를 TAXII 기반으로 MSI 시스템으로 전달함으로써 비정상행위에 대한 종합적인 분석 제공

○ 네트워크 보안업체(소만사/윈스/지란)의 STIX/TAXII 연동 프로토타입 구현

✓ 네트워크 보안장비의 보안이벤트 및 기타 위협정보 중 연동이 필요로 하는 내용에 대해 STIX 규격의 XML을 작성함

✓ 윈스/소만사/지란/시큐아이 장비의 STIX/TAXII 기반의 프로토타입 연동 구현

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

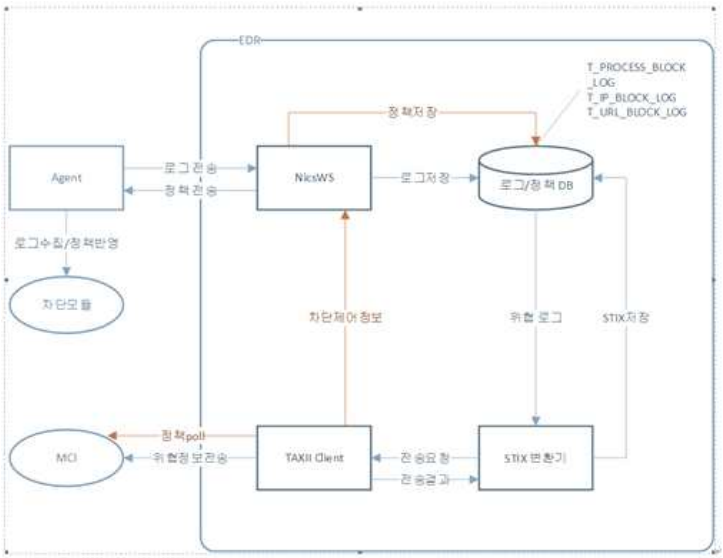
```
[C2IP]

[16:38:15.130] DEBUG [LogUtils.printXMLRequest] - [Request ------------------------------------------
[16:38:15.146] DEBUG [LogUtils.printXMLRequest] - <taxii_11:Inbox_Message result_id="123" message_id="urn:uuid:953b760e-e805-4e91-89b8-
d0e9304f90a0" xmlns:xmldsig="http://www.w3.org/2000/09/xmldsig#" xmlns:taxii_11="http://taxii.mitre.org/messages/taxii_xml_binding-1.1">
    <taxii_11:Destination_Collection_Name>collection-A</taxii_11:Destination_Collection_Name>
    <taxii_11:Message>Hello!</taxii_11:Message>
    <taxii_11:Source_Subscription collection_name="collection-A">
        <taxii_11:Subscription_ID>SubIdJiran</taxii_11:Subscription_ID>
        <taxii_11:Exclusive_Begin_Timestamp>2017-09-07T07:38:13.602Z</taxii_11:Exclusive_Begin_Timestamp>
        <taxii_11:Inclusive_End_Timestamp>2017-09-07T07:38:13.602Z</taxii_11:Inclusive_End_Timestamp>
    </taxii_11:Source_Subscription>
    <taxii_11:Record_Count partial_count="true">22</taxii_11:Record_Count>
    <taxii_11:Content_Block>
        <taxii_11:Content_Binding binding_id="urn:stix.mitre.org:xml:1.1">
            <taxii_11:Subtype subtype_id="subtype1"/>
        </taxii_11:Content_Binding>
        <taxii_11:Content>
            <stix:STIX_Package xmlns="http://xml/metadataSharing.xsd" xmlns:stixCommon="http://stix.mitre.org/common-1"
xmlns:indicator="http://stix.mitre.org/Indicator-2" xmlns:ttp="http://stix.mitre.org/TTP-1"
xmlns:stixVocabs="http://stix.mitre.org/default_vocabularies-1" xmlns:AddressObj="http://cybox.mitre.org/objects#AddressObject-2"
xmlns:stix="http://stix.mitre.org/stix-1" xmlns:cybox="http://cybox.mitre.org/cybox-2">
                <stix:Indicators xmlns="">
                    <stix:Indicator id="JRN:indicator-5941fbcf-bc45-49ce-b3a2-e3d96c26624e" negate="false" timestamp="2017-09-
07T07:38:10.265Z" version="1.0.0" xsi:type="indicator:IndicatorType" xmlns:JRN="jiransecurity.com"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
                        <indicator:Title>IP Address for known C2 Channel</indicator:Title>
                        <indicator:Type xsi:type="stixVocabs:IndicatorTypeVocab-1.1">IP Watchlist</indicator:Type>
                        <indicator:Description>SMTP 공격시도로 의심되는 IP 정보</indicator:Description>
                        <indicator:Observable id="JRN:observable-0669dc92-8a5e-40da-9051-0a30bb96dd45">
                            <cybox:Title>Observable for IP Address Indicator</cybox:Title>
                            <cybox:Description>IP 정보 인디케이터의 관찰체</cybox:Description>
                            <cybox:Object id="JRN:Object-ac8fe8c2-dd9d-4c08-825f-7ca430fc14f2">
                                <cybox:Properties category="ipv4-addr" xsi:type="AddressObj:AddressObjectType">
                                    <AddressObj:Address_Value condition="Equals">10.0.0.1</AddressObj:Address_Value>
                                </cybox:Properties>
                            </cybox:Object>
                        </indicator:Observable>
                        <indicator:Indicated_TTP>
                            <stixCommon:TTP idref="JRN:ttp-77cab4a6-4ac5-4fd6-a39d-965ab1cfd091" version="1.0.0" xsi:type="ttp:TTPType"/
                        </indicator:Indicated_TTP>
                    </stix:Indicator>
                </stix:Indicators>
```

[그림 39] STIX/TAXII 연동 프로토타입 구현

○ 단말 보안장비(소만사/한류AI센터)의 STIX 연동 규격 설계

✓ STIX 변환을 위한 시스템 자원을 많이 사용됨으로 단말보안 관리시스템에서 STIX 변환 및 TAXII 연동을 수행



[그림 40] 단말 보안장비의 STIX 연동 규격 설계

- 로그수집기: 단말(에이전트)에서 발생된 위협정보(차단로그)를 DB에 저장
- 에이전트: 단말에서 정책에 의해 차단된 프로세스, IP,URL 을 수집
- STIX 변환기: 수집된 위협정보로그를 STIX(XML) 포맷으로 변환
- TAXII Client: 변환된 STIX 정보를 MCI로 전송 후 결과를 저장

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ URL기반의 STIX 변환 및 TAXII 연동



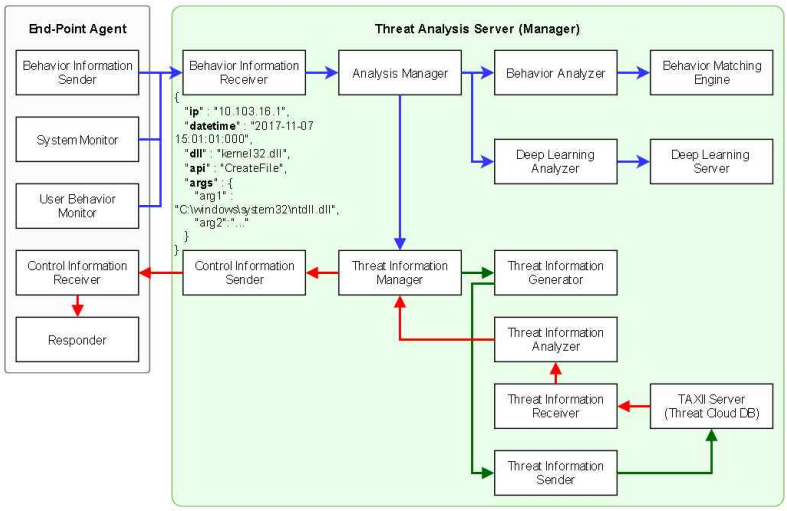
[그림 41] MSI 플랫폼 연동 이력 조회



[그림 42] IPS 시스템의 연동 정보 내역

○ 단말의 위협대응을 위한 EDR 시스템

✓ EDR 시스템 설계

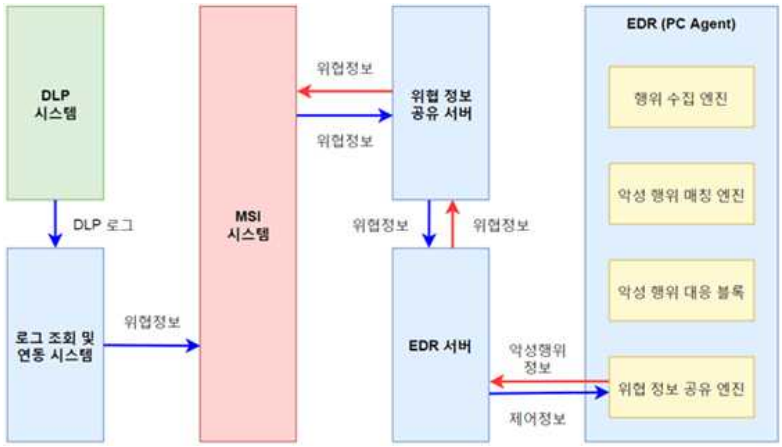


[그림 43] EDR 시스템 설계

- End-Point에서의 행위 수집을 위한 Agent와 악성 행위 탐지 및 위협 정보 연동을 위한 서버의 2-Tier 구조
- API 실행의 순차 정보를 이용한 방법과 API 실행 정보를 딥러닝 기반으로 분석하는 방법의 두 방법으로 악성 행위를 탐지
- 탐지된 악성 행위 정보를 기반으로 위협 정보를 생성하여 공유
- 이기종 보안 장비로부터 공유된 위협 정보를 분석하여 End-Point에서 대응하기 위한 제어 정보를 생성하여 End-Point Agent로 공유
- End-Point Agent는 공유된 제어 정보를 기반으로 대응 (프로세스 종료/실행 방지, 네트워크 접속 차단 등)

✓ 단말의 위협대응을 위한 EDR 시스템 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

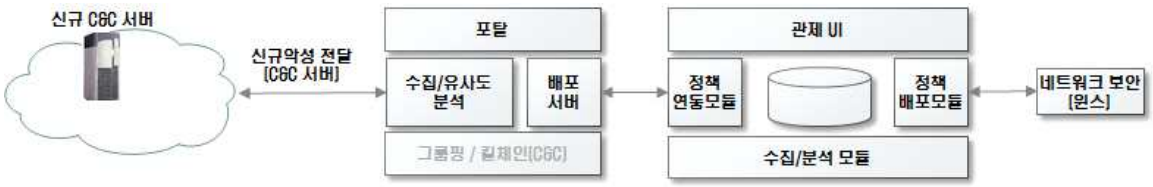


[그림 44] EDR 시스템 연동

- DLP 시스템으로부터 DLP 로그를 조회 & 분석하여 STIX(Structured Threat Information Expression) 형식의 위협 정보로 변환하여 TAXII(Trusted Automated eXchange of Indicator Information)를 이용하여 MSI 시스템으로 공유
- 위협 정보 공유 서버는 MSI 시스템으로부터 공유된 위협 정보를 EDR 서버로 TAXII(Trusted Automated eXchange of Indicator Information)를 이용하여 전송하며, EDR 서버는 EDR Agent에서 제어 가능한 제어 정보로 변환하여 MQTT(Message Queuing Telemetry Transport)를 이용하여 EDR Agent로 배포
- EDR Agent는 EDR 서버로부터 MQTT(Message Queuing Telemetry Transport)를 이용하여 공유 받은 제어 정보를 분석하여 PC 환경을 제어

○ 종합연동 시험

✓ 시나리오 : 글로벌 CTI에서 위협정보(C2 IP)가 신규로 등록되면, 해당 정보는 CTI => MSI => EDR까지 연동되어 전달되며, 결과적으로 최종 단말단에서는 해당 C2 IP가 차단됨을 확인하는 시험

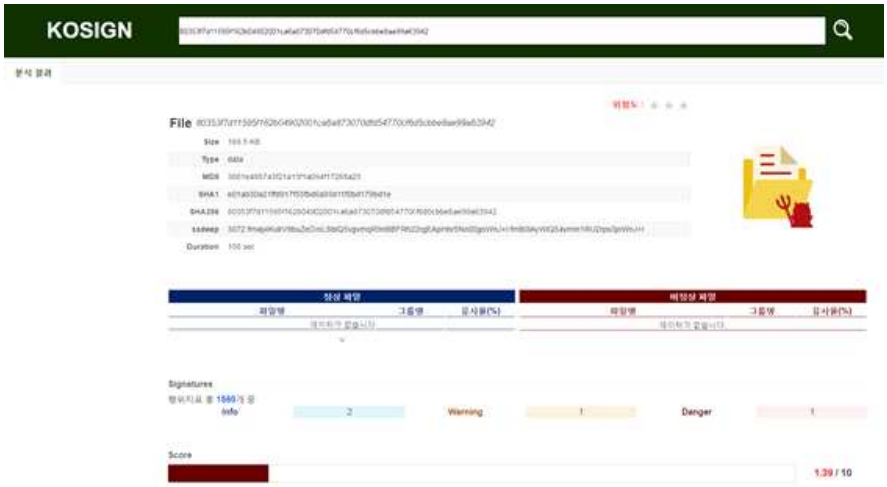


[그림 45] 종합 연동 시험 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

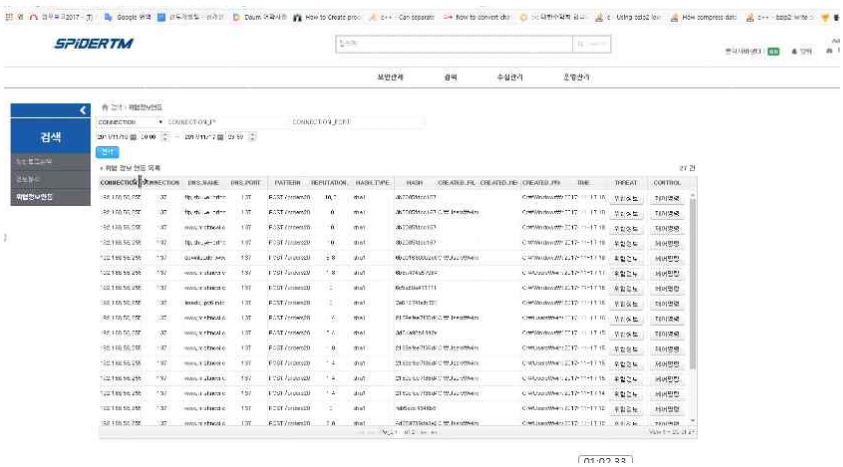
✓ 각 단계별로 제공되는 프로토타입 시스템을 통해 확인

- CTI 플랫폼의 악성파일에 대한 정보 분석



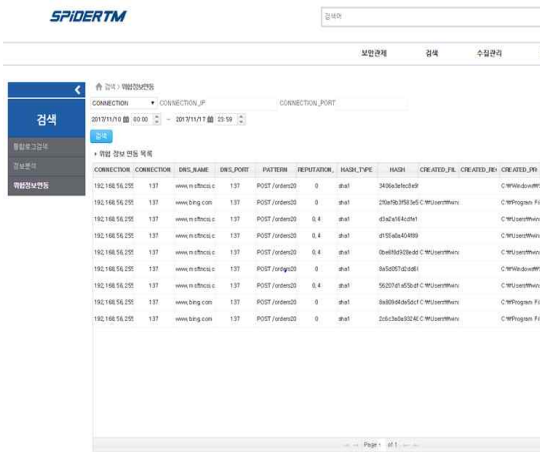
[그림 46] CTI 플랫폼에서의 악성코드 분석 결과

- CTI 플랫폼의 위협정보가 MSI 연동됨을 확인



[그림 47] CTI와 STIX/TAXII 연동을 통해서 위협정보 공유

- MSI(SPIDER-TM) => IPS 에서 연동됨을 확인



[그림 48] 유해 URL기반 STIX 변환



[그림 49] 유해 URL기반 TAXII 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(나) 연구개발 기술 평가

○ 기술개발 평가 항목 및 결과

시험 항목	시험 내용	목표치	결과
단말보안	위협정보 생성을 위한 로그 조회성능 (100만건 이벤트 기준)	4초이내	2~3초
연동 업체	K-CTI 연동 보안업체 수	3제품	윈스/소만사/지란

○ 기술개발 평가 방법

✓ 단말보안의 로그 조회 성능 (증빙자료 - EDR 시험서 참고)

✓ 2개이상의 연동업체수 (증빙자료 - EDR 시험서 참고)

(4) 표준화

(가)연구개발 성과

○ STIX/TAXII 기반 사이버 위협 분석 정보 연동 프레임워크 요구사항 분석

✓ STIX/TAXII 기반 보안 솔루션 위협정보 분석 시스템 관련 특허 1건(출원 심사중)

✓ 이기종 보안이벤트 연동을 위한 STIX/TAXII 표준 API 분석 및 표준 아이템 도출

○ UseCase 표준 개발 (ITU-T, OASIS, TTA)

✓ 사이버 보안 관련 신규 과제 승인) 구조화된 위협 정보 표현 규격(STIX) 유스케이스에 대한 ITU-T SG17 Q.4 신규 권고안 개발 과제 승인

✓ 관련분야 해당 기고서

▪ Proposal for a new work item: Use Cases for Structured Threat Information Expression (STIXTM) (구조화된 위협 정보 표현 규격(STIXTM)에 대한 유스케이스 신규 과제 제안)



INTERNATIONAL TELECOMMUNICATION UNION
TELECOMMUNICATION STANDARDIZATION SECTOR
STUDY PERIOD 2017-2020

TD 0266
STUDY GROUP 17
Original: English

Question(s): 4/17 — Geneva, 22-30 March 2017

TD

Source: Associate Rapporteur Q4/17 (Cybersecurity)

Title: Revised NWI Proposal for X.ucstix, "Use Cases for Structured Threat Information Expression (STIX™)"

Purpose: Proposal

Contact: Jong-Hyun Kim, ETRI, Korea (Republic of) — Tel: +82-42-860-3843, Fax: +82-42-860-1471, E-mail: jhk@etri.re.kr

Abstract

In this Q4/17 meeting, the contributions C76 was discussed carefully on the initiating a new work item for Use Cases for Structured Threat Information Expression (STIX™). The group reviewed the background, necessity and content of NWI proposal in-depth, and agreement was reached to consider establishment of this new work item as X.ucstix.

The attachments contain the revised NWI proposal and draft new Recommendation for X.ucstix, "Use Cases for Structured Threat Information Expression (STIX™)"

Attachments:

A.1 justification for proposed draft new Recommendation

A.2 Draft new Recommendation ITU-T X.ucstix



Annex A.1

A.1 justification for proposed draft new Recommendation

Question:	4/17	**Proposed new ITU-T Recommendation**	Geneva, 22 – 30 March 2017
Relevance and title:	ITU-T X.ucstix "Use Cases for Structured Threat Information Expression (STIX™)"		
Base text:	COM17-C 0070 Annex A.1	**Timing:**	2018-09
Editor(s):	Jong-Hyun Kim, ETRI, Korea (Republic of), jhk@etri.re.kr Takeshi Takahashi, NICT, Japan, takeshi_takahashi@nict.go.jp	**Approval process:**	TAP

Scope (defines the intent or object of the Recommendation and the aspects covered, thereby indicating the limits of its applicability)

This Recommendation aims to provide various use cases for Structured Threat Information Expression (STIX™) which is a structured language for describing cyber threat information. It is targeted to support a range of core use cases involved in cyber threat management, including analysing cyber threats, managing response activities, sharing cyber threat information and etc. These use cases are typically simple in nature and do not convey the full expressivity or flexibility of the STIX language. The use cases include some implementations, representations of STIX content, and fully validated STIX content documents. The STIX suite of specifications is the responsibility of OASIS. See <https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti>

Summary (provides a brief overview of the purpose and contents of the Recommendation, thus permitting readers to judge its usefulness for their work):

For real-time response to cyber threats, not only individual security systems, but also global cooperative security management systems should be provided since there are global problems which cannot be solved by any single entity as well as single domain. Therefore, global cyber threat intelligence is an important component of an organization's security program and can be obtained manually and from external sources. One of solutions for cyber threat intelligence and information sharing is Structured Threat Information Expression (STIX™) which is a structured language for describing cyber threat information. STIX provides structured representations of cyber threat information that is expressive, flexible, extensible, automatable, and readable. The STIX suite of specifications is the responsibility of OASIS. See <https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti>

The purpose of this draft Recommendation is to provide various use cases for how the STIX language may be used to support the cyber threat intelligence and information sharing context. This draft Recommendations also describes concepts and functionality of Structured Threat Information Expression (STIX™). It is targeted to support a range of core use cases involved in cyber threat management, including analysing cyber threats, managing response activities, sharing cyber threat information and etc. Given this kind of information, a security decision can be made on how to best defend against the threat. It is intended to support both more effective analysis and the command exchange of cyber threat information.

Relation to ITU-T Recommendations or to other standards (approved or under development):

ITU-T X.1500, ITU-T X.1500 Amendment 10

Liaisons with other study groups or with other standards bodies:

OASIS, ETSI

Supporting members that are committing to contributing actively to the work item:

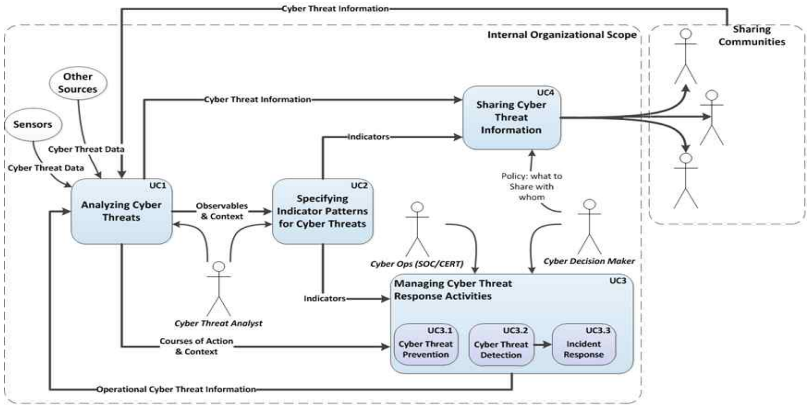
Korea (Republic of), ETRI, KISA, USA, NICT

[그림 50] ITU-T SG17 표준기고서 : Proposal for a new work item: Use Cases for STIX

✓ 주요 내용

▪ 3월 ITU-T SG17 회의에서 우리나라는 사이버 위협 정보 공유와 사이버 위협 분석을 신속히 처리할 수 있는 사이버 위협 정보 표현 규격(STIX)에 대한 유스케이스를 제시하는 신규 권고안(X.ucstix)을 제출하여 채택됨

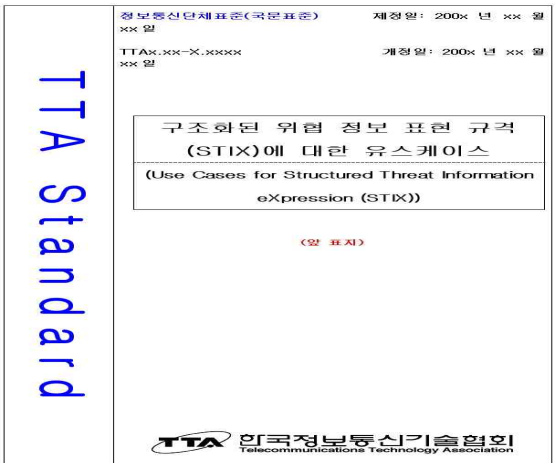
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 51] STIX 유스케이스 프로세스 개념(출처: MITRE)

○ TTA PG503 신규 과제 채택 : 구조화된 위협 정보 표현 규격(STIX)에 대한 유스케이스 표준 과제 채택

✓ 관련분야 해당 기고서 (과제번호: 2017-666) : 구조화된 위협 정보 표현 규격(STIX)에 대한 유스케이스


TTA Standard

정보통신단체표준(국문표준) 제정일: 200× 년 ×× 월 ×× 일

TTAx.xx-x.xxxx 개정일: 200× 년 ×× 월 ×× 일

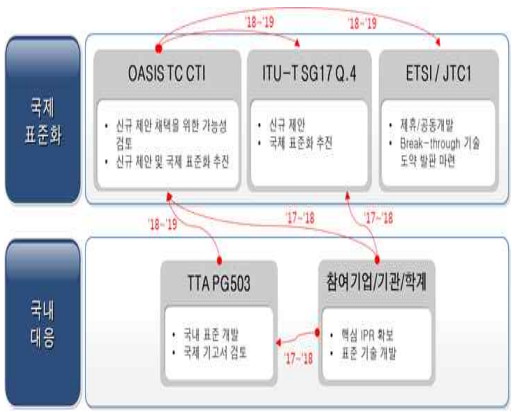
구조화된 위협 정보 표현 규격 (STIX)에 대한 유스케이스

(Use Cases for Structured Threat Information eXpression (STIX))

(앞 표지)

TTA 한국정보통신기술협회 Telecommunications Technology Association

[그림 52] TTA PG503 국내 표준 기고서



[그림 53] 국내외 표준화 대응 방안

✓ 주요 내용

- 본 표준은 사이버 위협 정보 교환을 위한 구조화된 위협 정보 표준 규격(STIX)에 대한 개념, 주요 특성, 및 주요 기능 등을 설명하고,
- 사이버 위협 분석, 침해 대응 활동, 사이버 위협 정보 교환 등의 전반적인 사이버 위협 관리 체계를 용이하게 수립할 수 있는 다양한 유스케이스를 제시한다.

(나) 연구개발 기술 평가

○ 기술개발 평가 항목 및 결과

구분	평가 항목	평가 결과
국제 표준화	기고서 제출 2건, 채택 2건	기고서 제출 2건, 채택 2건
국내 표준화	기고서 제출 1건	기고서 제출 1건, 채택 1건

○ 기술개발 평가 방법

✓ 국제(ITU-T) 표준화실적(기고서 제출/채택)

- Proposal for the 1st revised text for X.ucstix, Use Cases for Structured Threat Information Expression (STIX) : 관련 번호 C-121

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- The revised text for ITU-T X.ucstix, Use Cases for Structured Threat Information Expression (STIX) : 관련번호 TD681

✓ 국내 표준화 실적(기고서 제출/채택)

- 구조화된 위협정보 표현 규격 (STIX)에 대한 유스케이스 (관련 번호 : 2017-666)

다. 1차년도(2017년) 정량적 연구성과

(1) 목표대비 연구성과

구분			목표	실적	비고
특허 출원	국내		8	11	
	국외		1	1	
	계		9	12	
특허 등록	국내		-	-	
	국외		-	-	
	계		-	-	
국외 논문 게재	SCI		1	1	
	비SCI		-	-	
	계		1	1	
국내 논문 게재	SCI		-	-	
	비SCI		2	2	
	계		2	2	
국내 및 국제 학술회의 발표	SCI		-	-	
	비SCI		0	7	
	계		0	7	
국제 표준화	기고서 제출		2	2	
	기고서 채택		2	2	
	표준안 채택		-	-	
국내 표준화	기고서 제출		1	1	
	기고서 채택		0	1	
	표준안 채택		-	-	
기술 이전	계약 건수		-	-	
	계약액		-	-	
	징수액		-	-	
등록·기탁 대상 성과물	보고서 원문		-	-	
	연구시설·장비		-	-	
	기술요약정보		-	-	
	소프트웨어		1	4	
	화학물		-	-	
인력 양성	학사		-	-	
	석사		-	-	
	박사		-	-	
기타	시제품		-	-	
	상용화		0	49백만원	
	성과 홍보		0	2	
	기술문서		11	11	
			개발 전	개발 후	
	일자리 창출	연구인력	-명	-명	
		생산인력	-명	-명	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 지식재산권(특허, 실용신안, 의장, 디자인, 상표, 규격, 신품종, 프로그램)

번호	지식재산권 등 명칭 (건별 각각 기재)	국명	출원			등록			기여율
			출원인	출원일	출원번호	등록인	등록일	등록번호	
1	네트워크 플로우의 연관성 모델을 이용한 트래픽 분류	한국	고려대학교 세종산학협력단 (김명섭, 구영훈, 심규석, 이성호)	2017.08.30	10-2017-0110011	고려대학교 세종산학협력단	2018.10.31	10-1915908	100%
2	CNN 학습 기반의 멀웨어 분석 장치, 이를 수행하는 CNN 학습 기반의 멀웨어 분석 방법 및 이를 저장하는 기록매체	한국	국민대학교 산학협력단	2017.11.01	10-2017-0144951	국민대학교산학협력단	2019.10.11	10-2033354	100%
3	STIX 변환 장치 및 방법	한국	이글루시큐리티	2017.10.19	10-2017-0135939	이글루시큐리티	2018.12.10	10-1929522	100%
4	위험지수 자동 보정 장치 및 방법	한국	이글루시큐리티	2017.11.15	10-2017-0152254	이글루시큐리티	2018.12.10	10-1929528	100%
5	계층간 네트워크 장치 추적 관리 시스템	한국	(주)윈스 (한욱연)	2017.07.06	10-2017-0086055	-	-	-	100%
6	프로파일링 기반의 통계 학습을 활용한 이상 징후 탐지 장치 및 방법	한국	(주)윈스 (한욱연)	2017.10.31	10-2017-0143077	-	-	-	100%
7	구성 요소 기반 악성 파일 유사성 분석 장치 및 방법	한국	(주)윈스 (최병환)	2017.10.31	10-2017-0143082	윈스	2018.10.05	10-1907443	100%
8	악성행위정보에 근거한 악성코드 자동 분류방법 및 장치	한국	소만사 (김상욱, 김태완, 최일훈)	2017.11.20	10-2017-0154438	-	-		100%
9	데이터 저장 장치 및 방법	한국	시큐아이(윤남식)	2017.12.21	10-2017-0176995	-	-	-	100%
10	텍스트 마이닝 기반 보안 이벤트 자동 검증 시스템 및 방법	한국	한류AI센터 (박동훈, 김종연, 조승연, 김병훈)	2017.12.13	10-2017-0171485	-	-	-	100%
11	보안 장비, 보안 위협 분석 장치 및 방법	한국	한국전자통신연구원 (김종현, 김영수, 김익균)	2017.12.01	10-2017-0164302	-	-	-	100%
12	METHOD AND APPARATUS FOR AUTOMATICALLY CLASSIFYING MALIGNANT CODE ON BASIS OF MALIGNANT BEHAVIOR	미국	소만사 (김상욱, 김태완, 최일훈)	2017.11.28	15/823,929				100%

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	INFORMATION								

(3) 국내 및 국외 논문 게재

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCI 여부 (SCI/비SCI)	게재일	등록번호 (ISSN)
1	SCADA 시스템의 주기성과 발생순서 정보를 반영한 Structured ACL 모델에 관한 연구	KNOM Review	정우석 (고려대학교)	20	한국	KNOM	비SCI	2017-08-31	2287-1543
2	SCADA 네트워크 다양성을 반영한 플로우 화이트 리스트 생성	한국통신학회논문지	정우석 (고려대학교)	42	한국	한국통신학회	비SCI	2017-07-31	1226-4717
3	Regular Expression Filtering on Multiple q-grams	IEICE Transactions on Information and Systems	Seon-Ho Shin, HyunBong Kim, MyungKeun Yoon (국민대학교)	1	일본	IEICE	SCIE	2018.1.1	1745-1361 (IF: 0.576)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(4) 국내 및 국제학술회의 발표

번호	회의명칭	논문명	발표자	발표 일시	장소	국명
1	Asia-Pacific Network Operations and Management Symposium (APNOMS) 2017	SigManager: Automatic Payload Signature Management System for the Classification of Dynamically Changing Internet Applications	심규석 (고려대학교)	2017-09-27	Seoul,Korea	한국
2		A Traffic Grouping Method using the Correlation Model of Network Flow	구영훈 (고려대학교)	2017-09-27	Seoul,Korea	한국
3		Sky-Scope : Skype Application Traffic Identification System	이성호 (고려대학교)	2017-09-27	Seoul,Korea	한국
4		Structured Whitelist Generation in SCADA Network using PrefixSpan Algorithm	정우석 (고려대학교)	2017-09-27	Seoul,Korea	한국
5		Classification of Application Traffic Using Tensorflow Machine Learning	박지태 (고려대학교)	2017-09-27	Seoul,Korea	한국
6		Survey on Network Protocol Reverse Engineering Approaches, Methods and Tools	김명섭 (고려대학교)	2017-09-27	Seoul,Korea	한국
7	2017년도 한국통신학회 추계종합학술발표회	플로우의 연관성 모델과 시드 기반의 연속적인 그룹핑을 이용한 악성 트래픽 탐지	박지태 (고려대학교)	2017-11-11	대구 경북대학교	한국

(5) 표준화

번호	수행 기관명	표준화 주제	표준화 기구	표준화 단계	관련 번호	제출(채택)일	국가
1	한국전자통신연구원	Proposal for the 1st revised text for X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 제출/채택	C-121	2017.08.31	스위스
2	한국전자통신연구원	The revised text for ITU-T X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 제출/채택	TD681	2017.09.05	스위스
3	한국전자통신연구원	구조화된 위협 정보 표현 규격 (STIX)에 대한 유스케이스	TTA	기고서 제출/채택	2017-666	2017.09.06	한국

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(6) 사업화 현황

(단위: 명, 년)

번호	사업화 방식	사업화 형태	지역	사업화명	내용	업체명	매출액		매출 발생 연도	기술 수명
							국내	국외		
1	자가실시	기존 제품 개선	국내	제어시스템 네트워크 트래픽 3D 시각화 시스템 구축	자사 기존 솔루션인 LIGER-1의 정보 수집 구간에 STIX/TAXII 기술 적용	국가보안기술연구소	17,820,000원	-	2017	3년
2	자가실시	기존 제품 개선	국내	제어시스템 로그수집 및 지능형보안관제 시스템 구축	자사 기존 솔루션인 SPiDER-TM의 정보 수집 구간에 STIX/TAXII 기술 적용	국가보안기술연구소	32,000,000원	-	2017	3년.

(7) 저작권(소프트웨어, 서적 등)

번호	저작권명	창작일	저작자명	등록일	등록번호	저작권자명	기여율
1	STIX 라이브러리	2017.07.07	주식회사 이글루시큐리티	2017.11.15	C-2017-028643	주식회사 이글루시큐리티	100%
2	TAXII 라이브러리	2017.07.07	주식회사 이글루시큐리티	2017.11.15	C-2017-028642	주식회사 이글루시큐리티	100%
3	시스템 기반 악성코드 탐지, 차단 프로그램	2017.11.22	주식회사 세인트시큐리티	2017.11.27	C-2017-030116	주식회사 세인트시큐리티	100%
4	KOSIGN-CTI V0.1 (코사인 악성코드 분석 시스템 V0.1)	2017.12.11	주식회사 윈스	2017.12.13	C-2017-033540	주식회사 윈스	100%

(8) 기술문서

번호	기술문서 제목
1	KOSIGN시스템 개발요구사항 정의서
2	KOSIGN시스템 CTI 기능상세설계서
3	KOSIGN시스템 MSI 기능상세설계서
4	KOSIGN시스템 보안장비 연동 기능상세설계서
5	KOSIGN시스템 EDR시스템 기능상세설계서
6	STIX_API활용문서
7	TAXII 서버 가이드
8	CTI - 성능기능시험 결과서
9	MSI_성능기능시험 결과서
10	EDR_성능기능시험 결과서
11	종합연동시험 결과서

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(9) 기타성과

(가) 홍보

○ 사이버보안 정보공유체계 R&D 기술검토회의

- 일시 : 2017. 9. 26.(화) 10:00~16:00
- 장소 : 더케이 서울호텔(서울 양재), 그랜드볼룸/오크(OAK)
- 발표 내용 : STIX/TAXII 기반 이기종 장비 연동 기술 및 과제 진행 소개

○ 국방 SW/IT융합 컨퍼런스

- 일시 : 2017. 11. 13(월) 09:30~18:00
- 장소 : 서울 COEX 그랜드볼룸
- 발표 내용 : Security analytics 기반 이기종 장비연동 과제 진행 사항 보고
- 주체 : 과학기술정보통신부, 국방부, 방위사업청

(나) 외부 수상

○ 수상1

논문명	학술지명	주저자명	국명	발행기관	SCI 여부 (SCI/비SCI)	수상일
4차 산업혁명을 대비한 딥러닝 기술의 금융보안 적용 연구	금융정보보호공모전	정지만,홍성현,김영재,명준우,정성민,이진우,김준호,윤명근 (국민대학교)	한국	금융감독원	비SCI, 최우수논문상	2017.10.19.

○ 수상2

논문명	학술지명	주저자명	국명	발행기관	SCI 여부 (SCI/비SCI)	수상일
Regular expression filtering on multiple q-gram	사이버보안 논문공모전	정지만, 정성민, 김영재 (국민대학교)	한국	한국정보보호학회	비SCI, 최우수논문상	2017.11.16.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2-2. 2차년도(2018년) 수행내용 및 성과

가. 2차년도 연구개발 목표 및 결과

구분(연도)	세부 연구명	세부 연구 목표	연구개발 수행 내용	연구 결과
2차 연도 (2018)	WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	글로벌 위협정보 수집	- 크롤러를 활용한 수집 - KISA C-TAS 연동 고도화 - 상용 API활용 수집	- 640만건 이상의 악성파일 수집 - CTI 수집 시스템 구축
		악성코드 동작 지표 추출	- 악성코드 동적/정적분석으로 행위동작 지표 관련 기술 연구	- 1024개 이상의 동작지표(OP-code) 추출 - 전처리 모듈 개발 완료
		딥러닝 기반 분류 모델 설계	- 추출된 동작지표를 통한 딥뉴얼 기반의 그룹핑 - 킬체인 정보 생성	- 악성 그룹핑 관련 논문 - 딥러닝 기반 악성 그룹핑 분석 시스템
		CTI 포탈 개발	- CTI 서비스 포탈 개발 - 위협정보 리포트 생성 및 STIX/TAXII 배포	- CTI 포탈 시스템 및 위협정보 배포시스템 - CTI 기능 매뉴얼
	WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	관제 플랫폼 개발	- 이기종 트래픽 수집엔진 - IOC 기반 IOA 분석기능 - 통합 관제 서비스 UI 개발	- 170K EPS이상의 이기종 이벤트 수집 시스템 - Spider TM 개발(통합보안 관제 솔루션)
		Seed 기반 트래픽 그룹핑	- Seed정보를 이용한 트래픽 그룹핑 알고리즘 및 악성탐지	- 알고리즘 논문 등제(IF 1.34) - 시퀀스패턴을 활용한 악성탐지 시스템
		위협정보 연동 (STIX/TAXII 2.0) API 개발	- 위협정보 연동 규격 (STIX/TAXII 2.0) 개발 - STIX/TAXII 연동용 서버/Agent용 API 개발	- STIX 2.0 API 개발 및 관련 기술자료 - TAXII 2.0 API 개발 및 관련 기술자료
	WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)	네트워크 보안장비의 STIX 연동	- STIX/TAXII 2.0 API를 활용한 제품 탑재	- IPS(윈스)/FW(시큐아이)/스펨필터(지란)의 시제품 개발 완료
		단말 보안장비의 STIX 연동	- STIX/TAXII 2.0 API를 활용한 제품 탑재	- PC보안(닉스)/DLP(소만사)/백신(세인트)의 시제품 개발 완료
		EDR 시제품 개발	- DLP기반 EDR 제품 개발 - PC보안 Agent 기반 EDR 제품 개발	- 소만사/닉스의 EDR 시제품 개발 완료
	STIX/TAXII 표준화	표준 규격 기안	- 표준화 기고 및 채택	- 국제 표준화 기고서/ 채택 2건 - 국내 표준화 기고서/채택 2건 - 관련 특허 1건

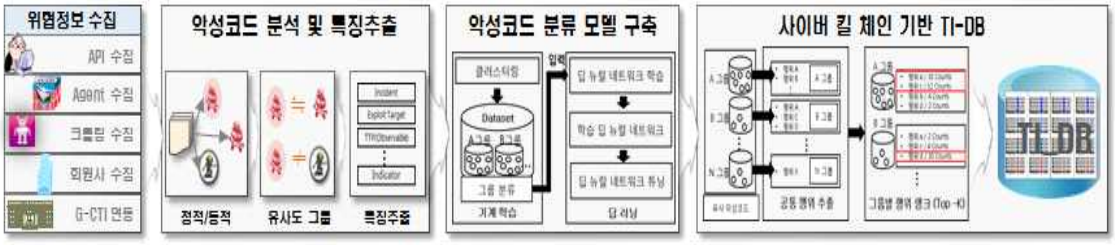
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 워크패키지별 상세 연구수행 내역

(1) WP-A : CTI (위협정보 분석/공유 서비스 기술 개발) : ㈜윈스 + 국민대학교

(가) 연구개발 목표

○ 글로벌 사이버 위협정보를 수집/분석하여, 공격을 추론하고 그에 대한 대응방안을 제공하는 사이버위협인텔리전스(CTI) 기술 개발



[그림 54] CTI 시스템 목표 개념도

○ 연구개발 범위

✓ 글로벌 위협정보 수집 및 정적/동적분석 시스템 개발

✓ 악성코드 동작분석지표 추출 기술

+ 빅데이터 딥러닝을 통한 악성코드 종류별 모델 개발 및 그룹핑 기술

+그룹핑 정보를 활용한 위협정보 킬-체인 생성 기술

✓ 킬체인 기반의 사이버위협 대응을 위한 위협대응정보 배포 시스템 개발

(나) 위협정보수집

○ 수집모듈 개발

✓ 웹 크롤러 모듈을 통한

▪ 악성파일 수집 결과

```
root@wins-SU7-2212G:/kosign/raw/2018/11# tree
.
└── 03
    └── blacklist
        └── file
            ├── malc0de
            │   ├── 2435823107733fc8569b95f45021789217504f902f746e2a392ab5a09cdfa54d
            │   ├── 7c2b0b9576b755b5b931d283bd9d415fc30fa78c612856f3a79371fc17c66668
            │   ├── a013e5b6e43bc4750717d163538acbdbba5723d3a558824a8858242284be2881
            │   └── f1331f18074d758acde1087ccad97857la7451bbdbe82e6f52e0273c0b51a9c7
            └── vxvault
```

▪ 악성파일 수집 개수: 26257 (2018.11.20. 기준)

```
ing_info where downloadtime between '20180101000000' and '20181115235959';
```

✓ C-TAS 수집

▪ 악성파일 수집 결과

```
2018-04-11-171830-16339708_malcode.dex          2018-08-07-150035-0016377417_B_악성코드-PC.zip
2018-04-11-201839-0016339709_B_악성코드-PC.zip  2018-08-07-150035-0016377418_B_악성코드-PC.zip
2018-04-11-201839-0016339710_B_악성코드-PC.zip  2018-08-07-150035-0016377419_B_악성코드-PC.zip
2018-04-11-201839-0016339711_B_악성코드-PC.zip  2018-08-07-150035-0016377420_B_악성코드-PC.zip
2018-04-11-201839-0016339712_B_악성코드-PC.zip  2018-08-07-150035-0016377421_B_악성코드-PC.zip
2018-04-11-201839-0016339713_B_악성코드-PC.zip  2018-08-07-150035-0016377422_B_악성코드-PC.zip
2018-04-11-201839-0016339714_B_악성코드-PC.zip  2018-08-07-150035-0016377423_B_악성코드-PC.zip
```

▪ 악성파일 수집 개수:1766 (2018.11.20. 기준)

```
sqlite> select count(*) from malware_info where downloadtime between '2018-01-01' and '2018-11-15';
1766
```

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ Virussign 수집

▪ . 악성파일 수집 결과



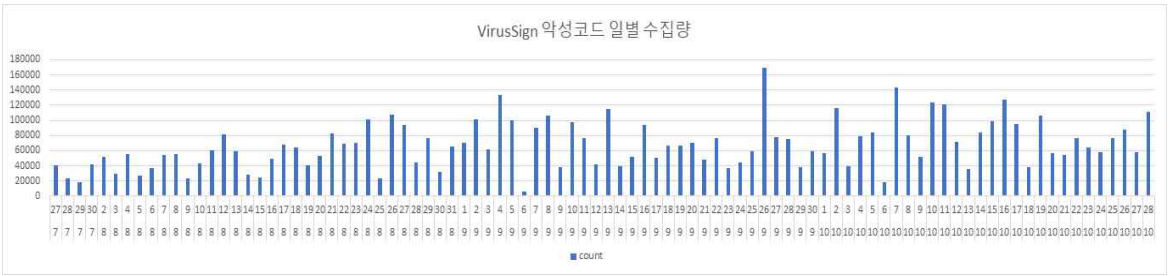
▪ 악성파일 수집 개수: 6426419 (2018.11.20. 현재)



○ 악성 및 정상 파일수집

✓ 정상파일은 윈도우즈 운영체제 파일과 신뢰성 높은 어플리케이션 프로그램 파일을 자체적으로 수집하였음.

✓ 악성코드는 바이러스사인(VirusSign)을 통해 약 650만개 수집하였음. 7월 27일~8월에 발생한 악성코드의 총 개수는 1,524,598개, 9월에 발생한 악성코드의 총 개수는 1,970,149개, 그리고 10월에 발생한 악성코드의 총 개수는 2,273,444개임. 악성코드의 수집량은 시간이 지날수록 점점 많이 수집되고 있는 양상을 확인하였음.



[그림 55] 일별 악성코드 개수의 분포 그래프
(x축 : 2017.07.27. ~ 2017.10.29., y축: 악성코드 개수[단위:2만])

○ 데이터 분석 연구

✓ 효과적인 데이터 분석을 하기 위해서는 악성코드와 정상파일에 대한 라벨(label) 정보가 필수적임. 또한, 이러한 라벨 정보를 이용하여 기계 학습 기반의 지도 학습을 진행하였으며, 분석시스템의 정확도 검증 시험 진행

✓ 악성코드 데이터 분석 연구 방법

▪ 바이러스토탈(Virustotal) 서비스를 이용하여 가지고 있는 악성코드, 정상파일 데이터셋에 대한 분석 리포트를 수집하였음.

▪ 바이러스토탈 분석 리포트에는 약 60여개의 안티 바이러스 업체들의 악성 분석 정보 등이 포함되어 있으며, 본 과제에서는 현 안티 바이러스 업체 중 가장 뛰어나다고 알려진 카스퍼스키(Kaspersky)의 진단명을 활용하였음.

▪ 카스퍼스키 진단명에 따라, 악성이라고 분류한 데이터셋은 악성코드로 최종 분류하였고, 정상이라고 분류한 데이터셋은 정상파일로 최종 분류하였음,

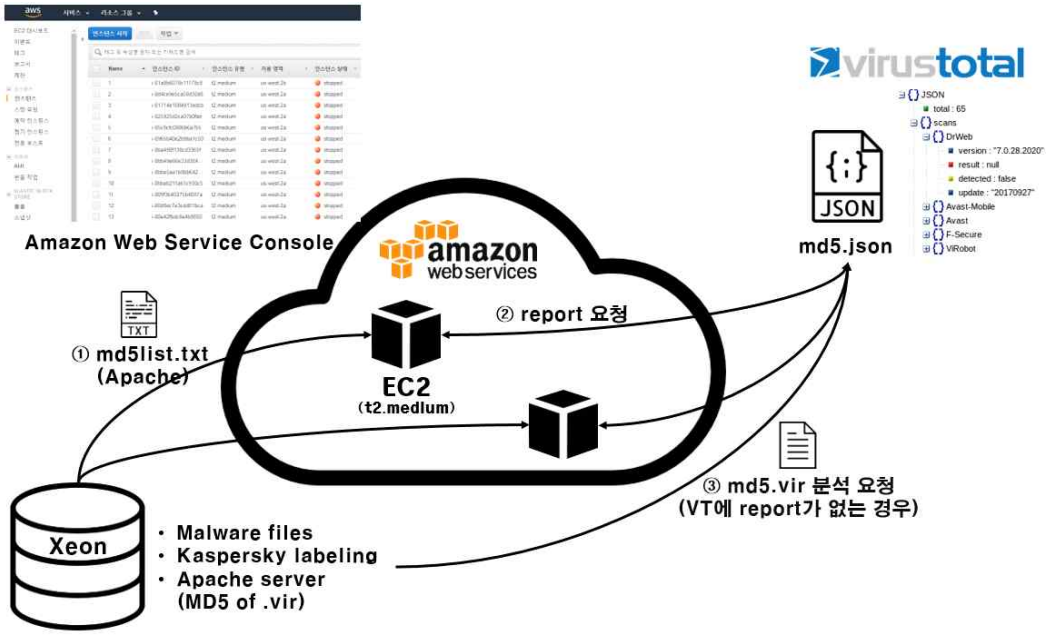
▪ 위 작업을 자동화하기 위해서는 바이러스토탈의 API를 활용하여 데이터 분석 모듈이 자동으로 의심 파일에 대한 라벨을 얻어올 수 있도록 구현하였음.

▪ 바이러스토탈 공공(Public) API는 1분에 4개의 분석 정보밖에 받아올 수 없기 때문에, AWS(Amazon Web Service)의 EC2 인스턴스를 다량 활용하여 효율적으로 대량 악성코드에 대한 라벨을 받아오는 환경을 구축하였음.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 안티 바이러스 업체들의 분석 정보 업데이트 주기를 고려하여, 매달 바이러스토탈 리포트를 갱신하였음.

✓ 데이터 분석을 위한 악성코드 라벨링 Flow



[그림 56] 바이러스토탈과 AWS를 이용한 악성코드 라벨 자동 분석 흐름도

① 서버에서 악성 코드들의 md5를 추출하여 Apache 서버에 업로드 한 전체 파일 정보를 각 인스턴스에서 접근하여 읽음.
② 각 인스턴스에서 읽은 전체 파일 정보에 있는 악성코드의 md5를 바이러스토탈에 넘겨 리포트를 요청함.
③ ②의 과정에서 바이러스토탈에 해당 md5에 대한 분석 기록이 없는 경우 서버에 있는 해당 되는 악성 코드 파일을 서버에서 바이러스토탈에 전송하여 분석을 요청하여 리포트를 받아옴.
④ 요청한 리포트는 인스턴스가 꺼질 때 FTP 프로토콜을 활용하여 지정한 서버에 일괄적으로 보내짐.

(나) 정적/동적분석 기술

○ 정적분석

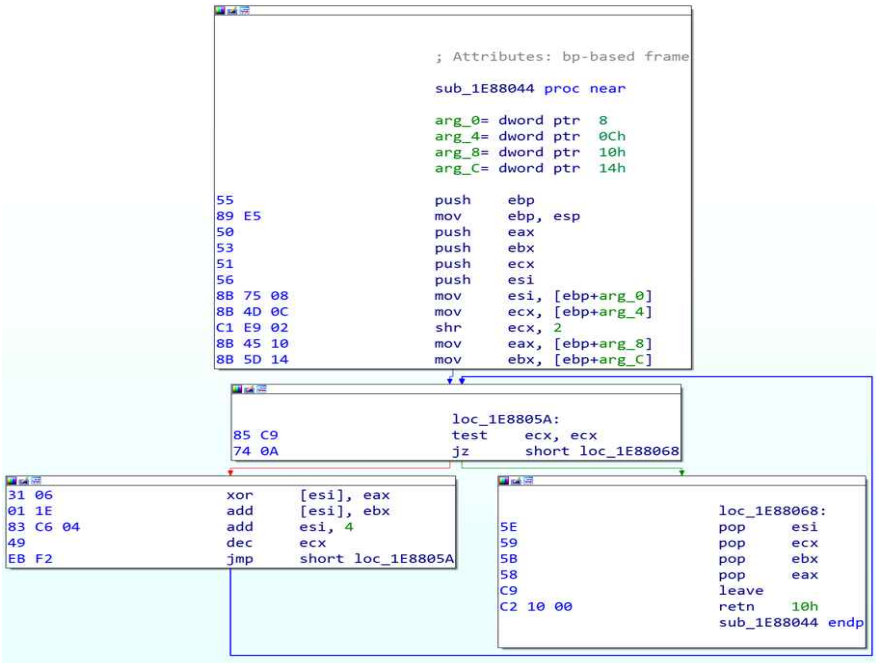
✓ 악성코드를 분석하는 방법 중 정적분석은 파일을 실행하지 않고 얻을 수 있는 모든 분석 방법을 의미함.

✓ 정적분석 정보는 파일의 크기, 엔트로피, 헤더 정보, 실행 명령어 정보 등 다양하나, 본 과제는 악성코드의 디스어셈블(disassemble)을 통한 opcode 시퀀스를 정적 정보로 활용하였음.

✓ 파일의 opcode를 추출하기 위해 IDA Pro를 사용하였고, IDAPython을 통한 분석 자동화 스크립트를 구현하여 IDA가 디스어셈블한 파일인 IDB 파일을 저장하고, 이후 동작 지표 추출을 위해 활용함. 또한, opcode는 1바이트를 사용해서 표현함

✓ IDA Pro를 통해 분석 가능한 실행 파일은 함수 단위로 구성되고, 각 함수는 기본 블록(basic block) 단위로 구성됨.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 57] IDA Pro를 이용하여 악성코드를 분석하였을 때 함수 일부

○ 동적분석

✓ 악성코드를 분석하는 방법 중 동적분석은 파일을 실행하여 얻을 수 있는 모든 분석 방법을 의미함.

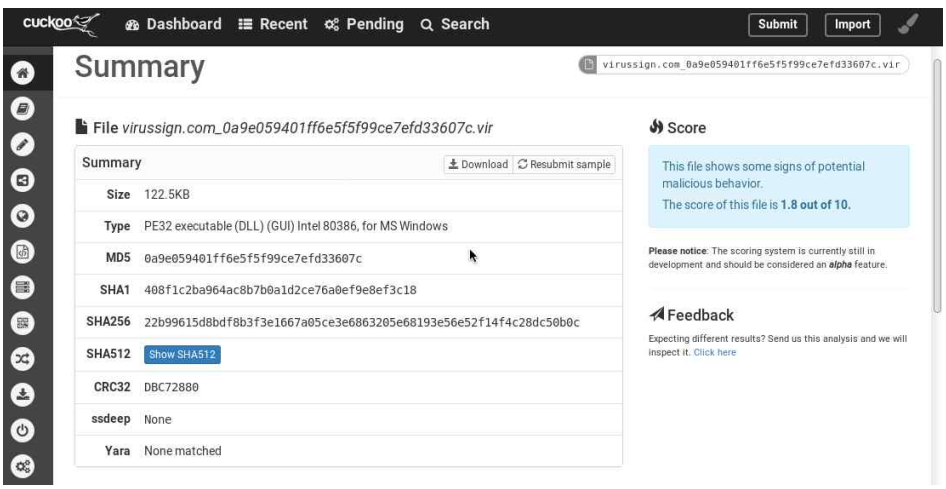
✓ 동적분석 정보는 API 시퀀스, 통신한 네트워크 IP 주소등 다양함.

✓ 동적분석 정보를 얻기 위해 오픈소스 샌드박스 프레임워크인 쿠쿠샌드박스(cuckoo sandbox)를 활용하였음.

✓ 샌드박스는 주 환경에서 신뢰할 수 없는 프로그램을 실행하고자 할 때 제한된 실행 환경을 생성하고 의심 프로그램을 실행하는 기술임. 쿠쿠 샌드박스는 동적분석 기반의 악성코드 분석 유틸리티로, 파이썬을 기반으로 개발된 오픈소스 소프트웨어임. 분리된 가상 환경을 만들어 의심 프로그램을 실행하고, 실행을 통한 동적분석 정보를 하나의 리포트로 종합하여 제공함.

✓ 쿠크샌드박스의 분석결과 정보

▪ info: 쿠쿠샌드박스의 실행 환경 정보 및 Host/Guest 머신의 운영체제 등 정보를 얻을 수 있음.



[그림 58] 쿠쿠샌드박스에서 제공하는 분석 결과 예시

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- signatures: 호출 API나 위험도에 따라 해당 파일에 대한 시그니처 정보를 저장하고 있음. 예를 들어, 특정 파일의 API와 레지스트리 수정 정보를 분석한 등의 정보 뿐만 아니라, 패킹 유무와 암호화 등의 중요한 판단 지표 등을 많이 남김.
- target: 분석 파일에 대한 간단한 정보를 저장함. 예를 들어 파일의 해시값, crc 정보, 배포 시 파일 이름, ssdeep 정보, 파일 크기 등임.
- buffer: 분석 파일에 대해 실행 당시 사용했던 버퍼 정보가 주로 있음. 또는 yara 규칙에 의한 안티 VM 기능이나 윈도우즈 API 사용 등이 명시되어 있음.
- network: 분석 파일이 통신한 네트워크 정보를 포괄적으로 가짐. 예를 들어 udp, tcp, icmp, smtp, dns 등임.
- static: 쿠쿠샌드박스는 분석 파일에 대한 기본적인 정적정보를 제공함. 예를 들어 분석파일의 pdb 경로, PE 헤더 정보, IAT, PEiD 시그니처 정보, imphash 등
- dropped: 실행 파일이 실행 도중 생성하는 파일에 대한 정보를 제공함.
- behavior: 분석 파일의 행위 기반 정보를 제공함. 분석 파일이 생성한 프로세스에 따라 API 호출 시퀀스, 레지스트리 수정 정보 등을 제공함.
- debug: 쿠쿠샌드박스의 별도 디버깅 정보를 제공함.
- screenshots: 쿠쿠샌드박스의 분석 결과를 스크린샷으로 제공함.
- strings: 제공 파일에 대한 스트링 정보를 자체 분석하여 제공함.

✓ 대용량의 파일을 자동으로 분석하기 위해, 하나의 쿠쿠 Host에 대해 40대 이상의 Guest를 할당하였고, 한 파일당 2분씩 분석하여 하루에 평균 3~4만개를 분석하는 동적분석 자동화 모듈을 개발하였음.

✓ 쿠쿠샌드박스의 분석 결과는 다양한 정보를 제공함. 분석 정보는 이후 사이버 킬-체인 정보를 위해 이후 추가 특징 추출을 진행함.

(다) 동작지표추출 기술

○ 악성코드 동작 분석 지표는 악성코드를 잘 나타내는 특징으로써, 본 과제에서는 디스어셈블을 통한 정적 지표인 opcode 시퀀스를 활용하였음. (디스어셈블 도구는 IDA Pro 7.0 버전을 사용함.)

○ opcode 기반의 특징 추출

✓ 추출한 opcode 들은 의미를 가지기 위해서는 시퀀스 단위로 쪼개어 추가적인 특징 추출하는 방식으로 연구개발 됨.

✓ IDA Pro를 통해 분석 가능한 실행파일은 함수와 기본 블록으로 구성됨. 기본 블록은 opcode 1byte를 여러 개 가지는 1차원 리스트로 표현 가능하고, 함수는 기본 블록을 여러 개 가지는 2차원 리스트로 표현 가능하므로, 하나의 디스어셈블된 실행 파일은 3차원 리스트로 표현함

○ n-gram 기법 기반의 opcode 특징 추출

✓ 기법은 입력 문자열에 대해 고정된 길이로 특징을 추출하여 워드를 생성하고, 집합으로 표현하는 기술임.

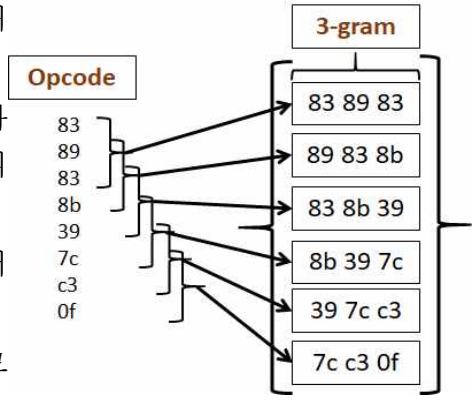
✓ 하지만, n-gram 기법 사용 시 opcode 시퀀스의 구조를 반영하지 못하고 기본 블록, 함수 간 의미없는 단어인 불용어를 생성하게 되므로 불필요한 단어를 많이 생성함으로써 불필요하게 저장 공간을 많이 사용하는 단점이 존재함.

○ v-gram 기법 기반의 opcode 특징 추출

✓ 본 과제에서는 n-gram 기법의 한계를 극복하기 위해, v-gram 기법을 제안함.

✓ v-gram 기법은 opcode 시퀀스의 구조적 특징을 효과적으로 반영하기 위해서, 하나의 기본 블록을 하나의 워드로 나타냄.

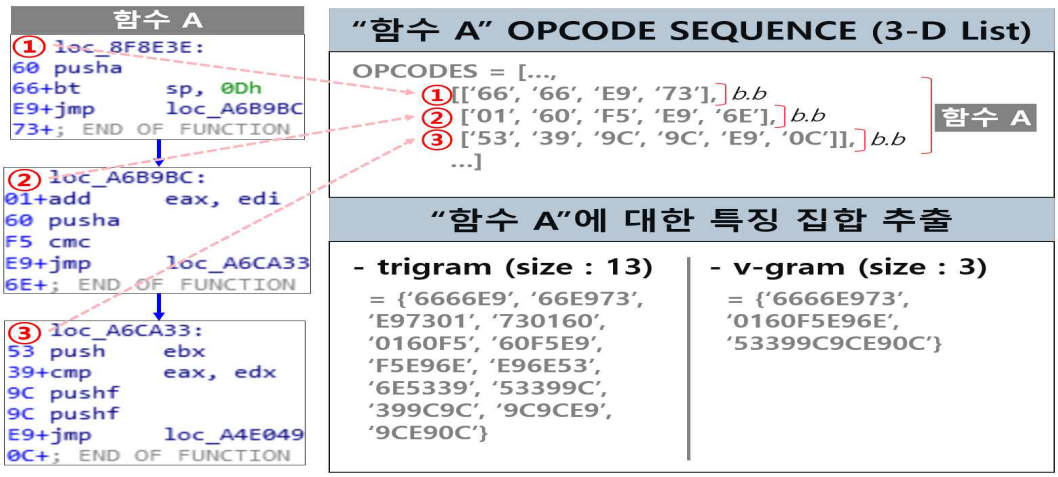
- 하나의 기본 블록에 속한 opcode를 순서대로 이어서 하나의 시퀀스 생성함.
- 하나의 시퀀스는 기본 블록의 길이에 따라 다르므로 가변적임.
- 이 시퀀스는 암호학적 해시 알고리즘을 통해 하나의 시그니처로 변환됨.



[그림 59] opcode 시퀀스에 n-gram 기술을 적용한 예시

✓ v-gram 기법의 장점은 의미를 가지도록 하는 특징을 효율적으로 추출함과 동시에, n-gram 기법의 한계인 불용어 생성을 극복하였음. 또한, 특징의 개수가 적기 때문에 이후 특징 벡터를 만드는 전처리 과정의 속도를 대폭 감소하였음.

✓ 우측 하단 그림은 함수 A에 대해 trigram(3-gram)과 v-gram을 적용했을 때 실제로 추출되는 특징 정보의 개수 비교를 나타냄.



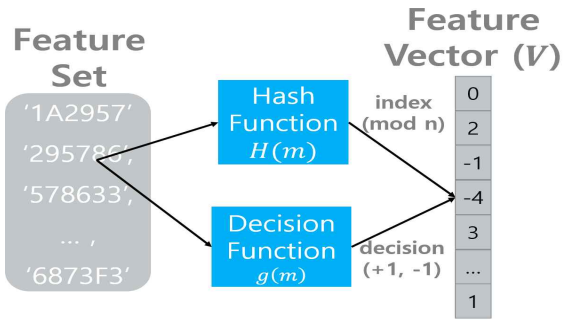
[그림 60] IDA Pro 분석 결과에 따른 예시 및 특징 추출 방법(n-gram VS v-gram)

○ 특징 정보에 따른 동작 지표 벡터 생성

✓ 본 과제에서는 v-gram 기법으로 추출한 특징들을 활용하여 피처 해싱(feature hashing) 기반의 동작 지표 벡터를 생성하였음.

✓ 피처 해싱 기술은 고차원의 입력 데이터를 해싱 기법을 적용하여 저차원으로 사상하는 알고리즘임. 이 알고리즘은 기계학습 분야에서 많이 활용되는 차원 축소 알고리즘이고, 특징을 고정 크기 벡터로 효과적으로 나타낼 수 있음

- 고정 크기의 벡터 크기를 정의하고, 벡터의 모든 원소 값을 0으로 초기화함.
- 입력 특징들에 대해 두 종류의 해시 함수를 적용함. 하나는 벡터의 인덱스를 지정하고, 다른 하나는 해당 인덱스에 값을 1 증가 또는 감소할지 결정함.
- 모든 입력 특징들에 대해 값을 적용하고 나면 모든 값을 -1 이상 1 이하로 사상하는 데이터 정규화(scaling) 작업을 진행하였음. 이와 같은 방법을 빈도수 기반 피처 해싱 벡터라고 정의하였음.

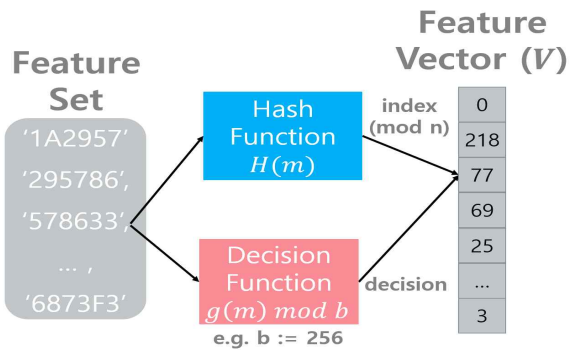


[그림 61] 빈도수 기반 피처 해싱 기법을 통해 특징 벡터를 만드는 과정

✓ 본 과제에서는 피처 해싱 기법을 통해 특징 벡터를 만들었을 때, 더욱 효과적으로 값을 저장하도록 하는 최댓값 기반 특징 벡터 알고리즘을 제안함.

✓ 최댓값 기반 피처 해싱 알고리즘: 빈도수 기반 피처 해싱 기법은 결정 함수(decision function)를 통해 값을 1 증가 또는 감소함으로써 입력 특징에 대한 빈도를 나타내었음. 최대값 기반 피처 해싱 알고리즘은 이전 알고리즘과 결정 함수가 차이를 가짐.

- 인덱스를 구하는 것 까지는 빈도수 기반 알고리즘과 동일함.
- 입력 특징에 대해 암호학적 해시 함수를 적용하고, 임의의 자연수 B로 나누었을 때 나머지 값을 해당 배열의 인덱스에 저장함.
- 만약 값이 이미 존재할 경우, 최댓값을 덮어 쓰기함.



[그림 62] 최댓값 기반 피처 해싱 기법을 통해 특징 벡터를 만드는 과정

✓ 최댓값 기반 피처 해싱 알고리즘의 장점은, 입력 특징에 대한 시그니처 값을 대표하는 값을 특징 벡터에 제공함. 또한, 최댓값을 덮어씀으로써, 딥러닝 중 합성곱 신경망(Convolutional Neural Network)의 최대 풀링(max pooling) 과 같은 대푯값 추출을 기대할 수 있음.

✓ 만들어진 특징 벡터는 악성코드의 특징 정보를 요약한 동작 지표 벡터로써, 이후에 그룹핑 기술에 활용하기 위한 좋은 데이터로 판단됨.

(라) 딥러닝 모델링

○ 본 과제는 600만개 이상의 빅데이터 악성코드에 대해, 구글 텐서플로우(Tensorflow) 기반의 딥러닝 학습 모델 개발 고도화 및 최적화를 수행하여 2차년도 연구 목표를 충실히 달성하였음.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	운영체제	Tensorflow	기타 설치 SW	HW
전처리, 딥러닝 학습 및 테스트	Windows 10 (64 bit)	1.7.0	-python 3.6.4 -anaconda3 4.2.0	-CPU:Intel i7-6850k -MEM:DDR4 128GB -GPU:TITAN Xp 2개

[표 5] 텐서플로우 학습 환경 플랫폼

○ 합성곱 신경망

✓ 심층 신경망(Artificial Neural Network)과는 달리, 주어진 입력에 대해 특징을 자동으로 추출하는 단계와 추출된 특징을 입력으로 분류를 수행하는 단계로 나누어짐. 특징 자동 추출 단계에서는 합성곱 연산과 풀링 연산을 기본적으로 수행하며, 이를 기본 블록이라고 명명함. 합성곱 신경망의 장점은 지역적 특징을 다양하고 깊이 있는 관점을 통해 양질의 특징을 자동으로 추출함.

✓ 합성곱 연산을 하기 위해서는 층마다 커널(=필터)의 수를 정해주어야 함. 커널은 전체 데이터에서 특징을 추출할 때 수용하고자 하는 지역을 정해주는 역할을 함. 합성곱 연산은 차원에 관계없이 수행 가능하며, 본 과제에서는 1차원 데이터에 대해 합성곱 연산을 수행하였음.

✓ 합성곱 연산을 하기 위해서는 커널을 데이터의 처음부터 끝까지 움직이며 적용하게 되는데, 이 때 움직이는 보폭(stride)를 지정할 수 있음. 또한, 합성곱 연산 시, 입력 데이터의 크기가 작아지지 않게 하는 덧대기(padding) 기술을 적용할 수 있음.

✓ 풀링 연산은 입력 데이터에 대해 대푯값을 추출함으로써, 입력 크기를 효과적으로 줄일 수 있는 연산임. 학습에 영향을 받지 않고도 입력 차원을 줄일 수 있기 때문에 합성곱 신경망의 핵심 기술로 자리매김 하였음. 대푯값 추출 방법에 따라 최대 풀링(max pooling), 최소 풀링(min pooling), 평균 풀링(average pooling), 전역 평균 풀링(global average pooling) 등으로 사용할 수 있음.

○ 활성함수

✓ 선형함수 모델을 비선형함수로 변환하기 위해 사용하는 함수로 시그모이드(sigmoid)나 렐루(ReLU) 함수가 많이 사용

✓ 본 과제에서는 앞서 소개한 활성 함수의 단점을 보완하는 리키렐루(Leaky ReLU)를 사용하였음.

○ 배치 정규화(Batch Normalization)

✓ 딥러닝을 통한 학습을 진행할 때 은닉층을 통과할 때마다 생성된 출력 데이터들 분포가 맞지 않아, 학습을 방해하는 요소로 작용하고 있음(Covariate Shift).

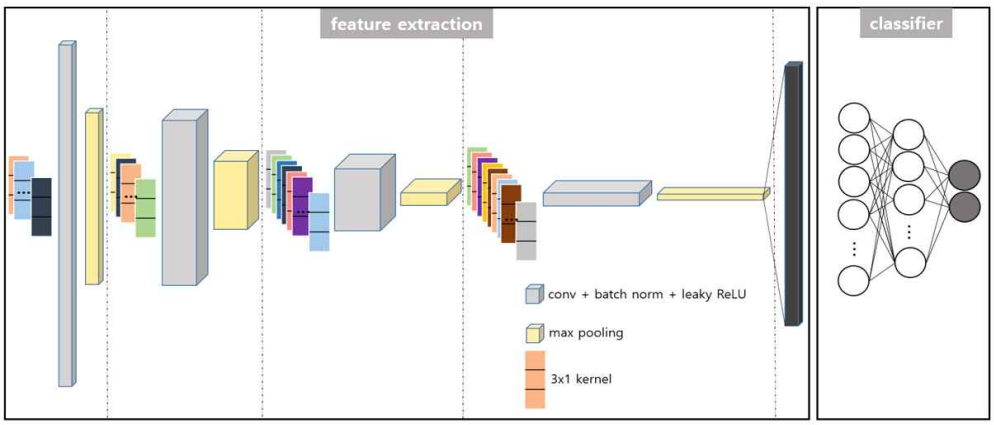
✓ 이 현상을 최소화하기 위해 합성곱 신경망의 매 층마다 배치 정규화를 적용하였음.

✓ 배치 정규화의 장점은 학습률을 높힐 뿐만 아니라, 초기화에 대한 의존성 감소, 그리고 어느 정도 규제의 역할을 수행함.

○ 아래의 그림은 특징 벡터를 입력으로 하고 악성코드 이진 분류를 수행하는 합성곱 신경망 딥러닝 모델을 나타냄.

✓ 본 과제에서 구현한 합성곱 신경망 모델은 4층으로 구성됨. 회색 직육면체는 주어진 필터에 대해 합성곱 연산, 배치 정규화, 그리고 리키렐루 활성함수를 적용한 특징 맵(feature map)을 의미함. 노란색 직육면체는 특징 맵에 대해 최대 풀링을 적용한 결과를 의미함. 각 커널의 크기는 3으로 고정하였음.

✓ 합성곱 신경망 모델의 분류기는 심층 신경망을 사용하였음. 심층 신경망의 은닉층은 2층으로 구성됨. 딥러닝 학습 모델은 실험을 통해 최적화되었음.



[그림 63] 합성곱 신경망 모델을 통해 악성코드를 이진 분류하는 모델의 네트워크 구조

✓ 아래의 표는 딥러닝 모델에 대한 구조와 설정한 하이퍼파라미터를 설명함.

하이퍼파라미터		하이퍼파라미터	
합성곱 연산(1x3 커널) 수	16, 32, 64, 128	활성 함수	Leaky ReLU
풀링 연산	최대 풀링(1x2)	에폭	10
분류기 은닉층 노드 수	128, 16	학습률	0.0001
목적 함수	크로스 엔트로피	배치 크기	256
옵티마이저	Adam	드랍 아웃	적용안함

[표 6] 딥러닝 모델의 구조 및 하이퍼파라미터 설정 값

○ 딥러닝 모델 검증

✓ 딥러닝 기반 악성코드 분류모델이 악성 혹은 정상으로 이진 분류하는 모델에 대한 정확도 및 실험 결과를 나타냄. 실험 결과는 최적화된 모델을 통해 가장 높게 측정된 결과를 반영하였음.

✓ 실험 시 사용한 악성코드는 바이러스사인에서 수집한 데이터 중 8,9월은 학습 데이터로 활용하였고, 10월은 검증 데이터로 활용하였음. 이는 실제 서비스 환경과 유사하며, 기존에 수집된 악성코드를 통해 학습한 딥러닝 모델이 이후에 수집한 악성코드도 잘 판별할 수 있다는 것을 증명함.

✓ 실험 시 사용한 정상파일은 자체 수집한 약 4만개 파일에 대해 무작위로 80% 추출하여 학습 데이터로 사용하였고, 나머지 20%는 검증 데이터로 사용하였음.

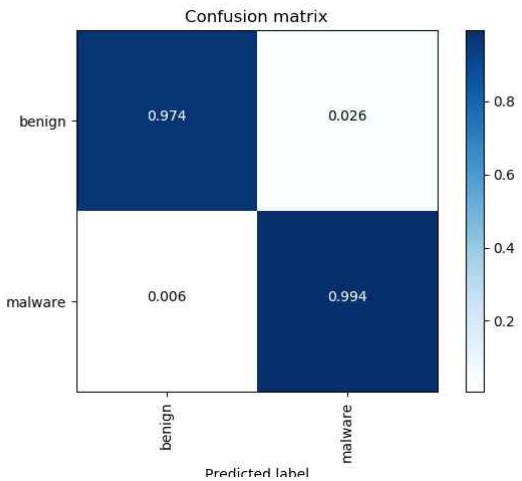
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

모델 구분	입력 형태	딥러닝 모델	정확도 (%)	데이터 셋(개)	검증 성능
Binary 분류	Feature Vector	CNN	99.364	학습(정상/악성) 30,682 / 3,761,243 검증(정상/악성) 7,670 / 2,011,186	전체 검증 파일: 2,018,856개 전체 검증 시간: 107.3564초 한 파일 당 검증 시간: 0.000053초

[표 7] 딥러닝 분류 모델 검증 결과

✓ 검증 성능은 딥러닝 모델을 통해 하나의 파일을 악성 혹은 정상으로 분류하는 시간을 나타내며, 한 파일당 검증 시간은 약 0.00005초로 매우 빠른 성능을 보였음.

✓ 딥러닝 모델의 혼동 행렬(confusion matrix)를 나타냄. 색이 진할수록 정확하게 예측을 한 그룹이고, 대각행렬의 지역이 짙을수록 모델의 성능이 높다고 측정함. 전체 정확도는 99.364%이며 악성을 악성으로 판별한 경우는 99.4%, 정상을 정상으로 판별한 경우는 97.4%임. 따라서 악성코드에 대한 이진 분류 정확도는 매우 높고, 주어진 모델이 잘 학습되었다고 판단할 수 있음.



[그림 64] 혼동 행렬

(마) 악성그룹분류

○ 엘라스틱서치 검색엔진

✓ 1차년도 결과를 통해 딥러닝 기반의 악성코드 그룹 분류는 높은 정확도를 얻지 못할 뿐만 아니라, 신종 악성코드 탐지에 한계를 드러냄을 확인하였음.

✓ 본 과제에서는 악성코드의 동작 지표를 추출한 후 유사한 악성코드를 검색하는 방향으로 연구를 진행하였음.

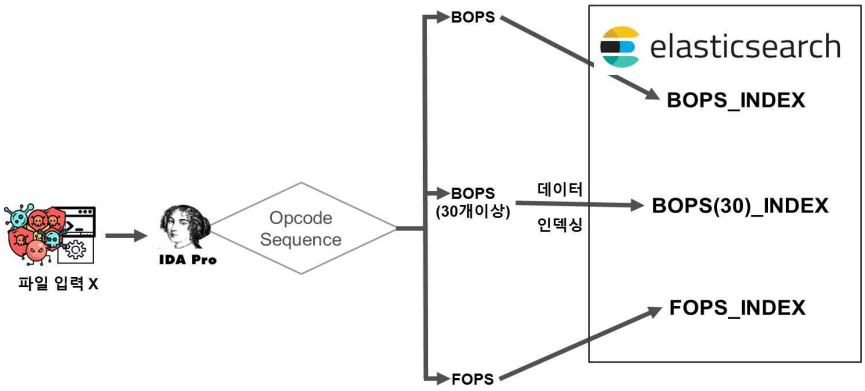
✓ 수백만개의 악성파일에서 빠르게 유사한 파일을 찾기 위해 엘라스틱서치 검색엔진을 이용함.

✓ 바이러스사인에서 제공한 2017년 8월~9월 악성파일 약 300만개를 엘라스틱서치에 인덱싱 후 바이러스사인에서 제공하는 2018년 10월 악성파일 중 1,008개를 임의 추출하여 정확도 및 성능(초)을 평가함.

○ 데이터 인덱싱

✓ 300만개의 악성파일을 IDA Pro로 정적분석하여 opcode 시퀀스를 추출함. 기본블록 대푯값(Bops), 기본블록 대푯값 중 opcode가 30개 이상인 것들(Bops30), 함수 대푯값(Fops)를 인덱싱할 특징정보로 활용.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

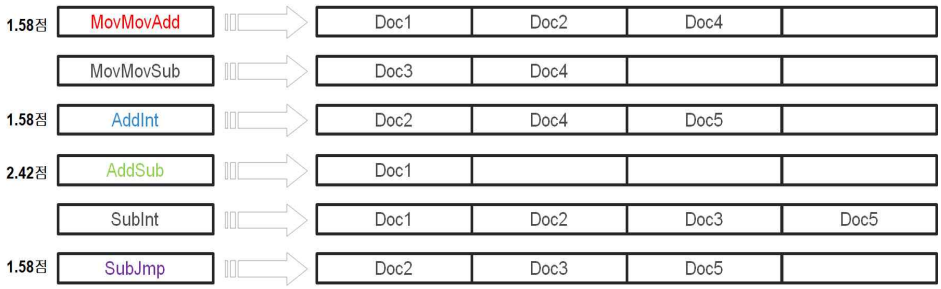


[그림 65] 엘라스틱 서치 기반 유사 악성코드 검색 엔진 모델
(인덱싱 과정)

✓ 데이터 인덱싱 과정(예)

Documents
Doc1 : { MovMovAdd, AddSub, SubInt }
Doc2 : { MovMovAdd, AddInt, SubInt, SubJmp }
Doc3 : { MovMovSub, SubInt, SubJmp }
Doc4 : { MovMovAdd, MovMovSub, AddInt }
Doc5 : { AddInt, SubInt, SubJmp }

[그림 66] 한 비교할 파일의 기본블록(Bops)의 예



[그림 67] 데이터 인덱싱 과정 예시에 따른 역인덱스 테이블

- 역 인덱스 테이블을 만들어서 높은 점수를 갖는 문서들만 빠르게 검색함
- 유사도 공식은 TF-IDF을 사용함. TF (Term Frequency)란 단어가 얼마나 문서내에 존재하는지를 나타냄.
- 엘라스틱서치에서는 SET 모델이기 때문에 TF = 1임. IDF (Inverse Document Frequency)란 해당 단어가 전체 문서 수에서 얼마나 등장했는지를 나타내는 지표임.
- 해당 단어가 전체 문서 수에서 적게 등장 할수록 유니크한 단어이기 때문에 해당 단어는 높은 점수를 받음.

✓ 예시 - 분석할 악성파일의 기본블럭 : { MovMovAdd, AddSub, SubJmp, AddAdd, SubSub, AddInt }

-IDF = log(1 + (docCount – docFreq + 0.5) / (docFreq + 0.5))
-docCount=16 (전체 등장 문서 수, 중복 카운트)
-docFreq := 해당 워드가 등장하는 문서 갯수

[그림 68] 제 단어 점수를 구하는데 사용되는 식

- 위와 같은 기본 블록을 갖는 opcode가 들어왔을 때, 유사도(점수)가 가장 높은 문서인 Doc2의 문서의 점수를 구하는 방법은 아래와 같음.

Doc2 score = MovMovAdd score + SubJmp score + AddInt score
=(1 * log(1 + (16 - 3 + 0.5) / (3 + 0.5))) + (1 * log(1 + (16 - 3 + 0.5) / (3 + 0.5))) + (1 * log(1 + (16 - 3 + 0.5) / (3 + 0.5)))= 4.74

[그림 69] Doc2의 점수를 구하는 예

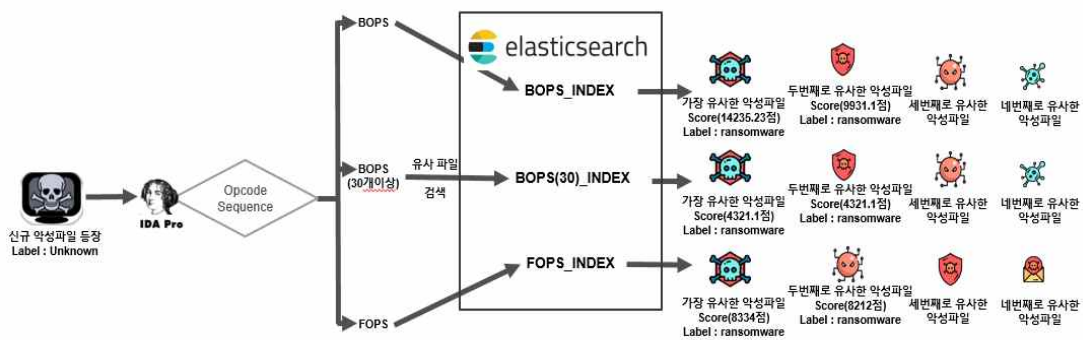
- 다른 문서들의 유사도 점수를 구해보면 Doc2 가장 높음.
- 문서의 유사도(점수)를 위와 같은 방법으로 구하여 최대 유사 악성파일 찾아냄.

Doc2 score = 4.74
Doc1 score = 4.00
Doc5 score = 3.16
Doc4 score = 3.16
Doc3 score = 1.58

[그림 70] 모든 문서의 점수 결과

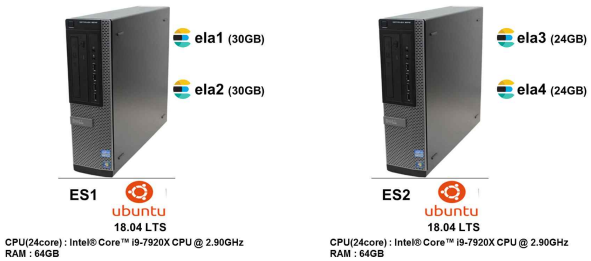
○ 유사 파일 검색 과정

✓ 실환경 구성



[그림 71] 실험 환경 시스템 구성도

- 총 4개의 엘라스틱서치 인스턴스 사용, 하나의 클러스터 구성 (to-be: 2개 서버에 4개 노드로 클러스터 운영).
- 엘라스틱서치는 데이터를 샤드(Shard)라는 곳에 분산 저장하여 각 샤드에서 높은 점수를 갖는 문서들을 뽑아내어 그것을 추합 해 가장 높은 점수를 갖는 문서들을 높은 순서로 보여줌.
- 즉 인덱싱 되어 있는 데이터 양이 많을 때, 인스턴스 여러개 띄워 샤드를 분산 저장하면, 컴퓨팅 파워가 보장되는 만큼 보다 빠른 성능을 보일 수 있음.
- 실험 환경에서는 각 서버 하나당 Raid 구성이 완료된 HDD 14TB를 사용함.



[그림 72] 총 4개의 엘라스틱 인스턴스 사용 구성

✓ 인덱싱 후 엘라스틱서치에 저장된 결과

- 샤드들이 각 노드들에 골고루 분산 저장되어 있음.
- 이 때 샤드의 개수는 인덱스를 만들 때 맵핑을 하면서 설정 할 수 있음.
- 변경이 불가능하기 때문에 해당 인덱스에 들어갈 데이터의 용량을 잘 고려하여 설정해야 함.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

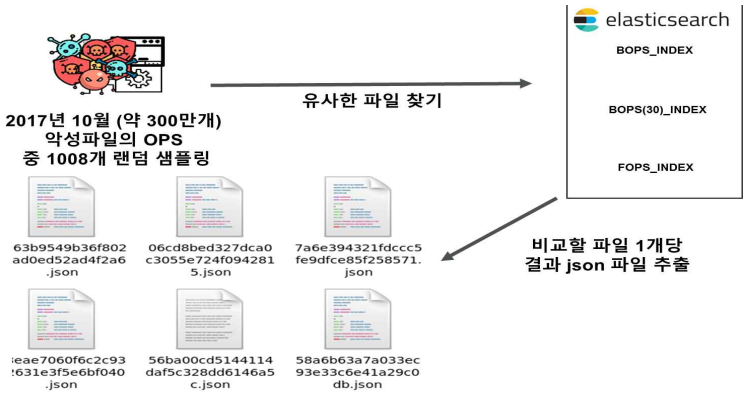


[그림 73] 엘라스틱서치 결과

○ 유사도 파일 검색 정확도 측정 알고리즘

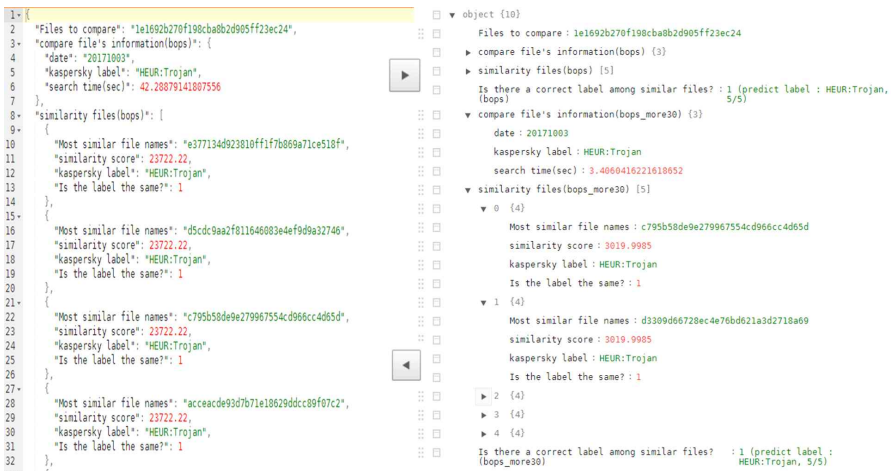
✓ 최고점을 얻은 유사한 파일(동점 파일 등장 시 최대 100개)에서 투표를 진행하여 과반수를 얻은 라벨을 정답 라벨로 간주함. 비교하는 파일의 라벨과 투표 결과로 뽑힌 라벨이 일치할 경우 예측이 성공했음.

✓ 유사 파일 검색 결과



[그림 74] 1008개의 비교할 파일의 결과가 모두 .json 파일로 추출

✓ 검색하려는 악성파일 하나당 1개의 결과 json 파일이 생성됨.



[그림 75] 추출된 json파일의 내용

- 비교할 파일의 md5는 1e1692b270f198cba8b2d905ff23ec24이며 비교할 파일의 라벨은 HEUR:Trojan임.
- 오른쪽 부분은 왼쪽 부분을 json 형식의 파일을 보기 쉽게 변형한 것으로 가장 유사하게 나온 파일(동점 파일 존재 시 최대 100개 까지)을 확인 할 수 있음.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 정확도, 시간 측정 방법

✓ 가장 유사한 파일의 최고점수, 동점파일 존재 시 최대 100개까지 추출하여 추출된 라벨 중 제일 많은 라벨을 이용함. 만약 비교할 파일의 라벨이 존재하지 않거나 None일 경우 결과 대상에서 제외함.

✓ 가장 높게 나온 유사한 파일들 중에서 카스퍼스키 라벨을 가지고 있는 것들만 투표에 참여함.

✓ 라벨은 카스퍼스키 라벨에서 1.2.3.4가 있을 때 1의 부분만 사용함.

✓ 피쳐를 추출하는 시간을 제외하고 쿼리를 엘라스틱서치에 날려서 그 결과를 받을 때 까지의 시간을 측정함. (예)Trojan-Downloader.Win32.Agent.gznn 에서Trojan-Downloader만 사용)

○ 정확도, 시간 측정 결과

구분	BOPS	BOPS(30개 이상)	FOPS
비교한 파일 수	854개	659개	820개
라벨이 맞은 개수	685개	583개	685개
정확도	0.802	0.884	0.835
총 걸린 시간	2084초	132초	2078초
파일 한 개당 찾는 데 걸린 시간	2.4초	0.2초	2.5초

[표 8] 정확도 및 성능 측정 결과

✓ 약 300만개의 대용량의 데이터를 미리 엘라스틱에 넣었지만, BOPS(30개 이상)의 경우, 파일 하나를 검색하는 데에 평균 0.2초 밖에 걸리지 않는 것을 확인 할 수 있음.

✓ 지금보다 더 많은 데이터를 넣는다 하더라도, 분산검색을 하는 엘라스틱서치 검색엔진의 특성상 엘라스틱 인스턴스를 더 추가 하면, 빠른 속도로 가장 유사한 파일을 탐색해 줄 수 있음.

✓ 위의 결과를 보면, BOPS(30개이상)을 피처로 사용하였을 때 정확도, 성능 측면 모두 가장 좋은 것을 알 수 있음. 이는 너무 짧은 길이의 BOPS는 유의미한 정보를 나타낸 다고 보기 어렵기 때문이라고 생각됨.

✓ 즉, 해당 BOPS의 특징 정보를 잘 반영하는 일정 이상 길이를 가지고 있는 BOPS(30개 이상)를 사용하면 저장공간을 줄일 수 있을 뿐만 아니라 검색속도를 향상시키고, 정확도까지 증가시킬 수 있음을 확인함.

(마) 킬체인 생성 기술

○ 사이버 킬-체인 정보는 쿠쿠샌드박스의 동적분석 정보를 일부 선별 및 추출하여 생성하였음. 사이버 킬-체인 분류 7단계(“Reconnaissance”, “Weaponization”, “Delivery”, “Exploitation”, “Installation”, “C2”, “Action”)의 정의에 따라 추출 정보를 판단하였음.

✓ Reconnaissance : 악용 가능한 취약점을 확인 및 불법적인 접근 시도, 주변 시스템 스캐닝 도구를 탐지. => 쿠쿠샌드박스 리포트에서는 적합한 정보가 없음)

✓ Weaponization : 은닉화, 코드 난독화, 패킹, 안티-디버깅, 안티-가상화, 시한폭탄 로직, 안티-포렌식 등의 여부를 확인. => 쿠쿠샌드박스 리포트에서는 Signature 정보와 Static 분석 정보인 PDB 정보를 추출하였음)

✓ Delivery : 저장매체, 네트워크, 다운로드, 그리고 사회공학적 기법에 의한 신종 전파 방법 등으로 전달. => 쿠쿠샌드박스 리포트에서는 적합한 정보가 없음.

✓ Exploitation : Exploit 코드가 심어져있거나 악성코드 대량 삽입 여부에 대한 확인 정보 => 쿠쿠샌드박스 리포트에서는 해당 정보에 적합한 정보가 없음.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- ✓ Installation : 서비스 등록 여부, 부팅 시 자동 실행 여부 등에 대한 정보나 실행 중 파일을 생성하는 행위 정보 포함. => 쿠쿠샌드박스 리포트에서는 Dropped 정보를 사용하였음.
- ✓ C2 : C&C(Command&Control)와 네트워크로 통신을 하는 등의 정보와 백도어 기반 통신 여부에 대한 정보를 포함. => 쿠쿠샌드박스 리포트에서는 Network의 IP 주소 정보와 TCP,UDP 연결 정보, 그리고 도메인 정보를 추출하였음.
- ✓ Action : 정보 유출 정보, 스팸 전송 정보, 파일 암호 처리 여부 등의 정보를 포함. 행위 기반 정보를 나타내기 때문에, 쿠쿠샌드박스 리포트에서는 Behavior 정보 중 파일 열기/닫기, 읽기/쓰기 에 해당하는 정보를 추출하였음. 또한, 파일 뿐 만 아니라 레지스트리를 열기/닫기, 읽기/쓰기 하는 정보도 활용하였음.

○ 쿠쿠샌드박스 분석 리포트에 의한 동적 정보를 판단하여 사이버 킬-체인 정보를 JSON 형태로 저장하였음.



```
{
    "Weaponization": {
        "Signatures": {
            "antivm_queries_computername": "Queries for the computername",
            "antivm_memory_available": "Checks amount of memory in system,
            "p2p_cnc": "Communication to multiple IPs on high port numbers
            "allocates_rwx": "Allocates read-write-execute memory (usually
            "antivm_disk_size": "Queries the disk size which could be used
            "creates_shortcut": "Creates a shortcut to an executable file",
            "exe_appdata": "Drops an executable to the user AppData folder"
            "antivm_network_adapters": "Checks adapter addresses which can
            "persistence_autorun": "Installs itself for autorun at Windows
            "disables_proxy": "Disables proxy possibly for traffic intercep
            "modifies_proxy_wpad": "Sets or modifies WPAD proxy autoconfigu
        },
        "PDB": ""
    },
    "Installation": {
        "Dropped": [
            [
                "e3b0c44298fc1c14_nscDFD6.tmp"
            ],
            [
                "5d9172bec2d83c9e_internettarget.url"
```

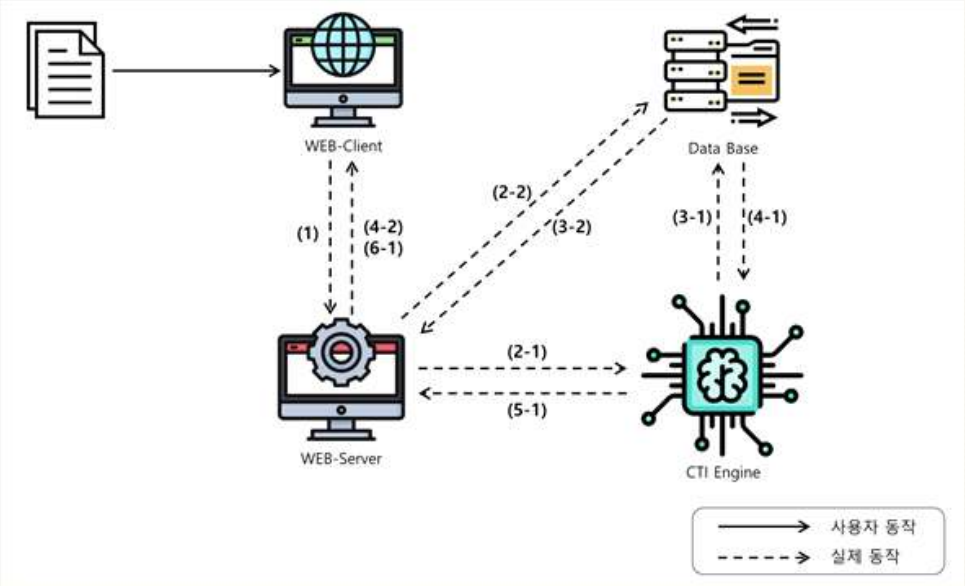

[그림 76] 쿠쿠샌드박스 분석 리포트에서 킬-체인 정보를 추출하여 얻어낸 결과 파일 예시

- ✓ 임의의 악성코드에 대해 쿠쿠샌드박스 분석 리포트를 생성하고, 생성한 리포트를 기반으로 정의한 사이버 킬-체인 정보에 맞게 추출한 예시임
- ✓ 본 예시에서는 “Weaponization”에 해당하는 Signature 정보를 다량 추출하였고, “Installation” 정보를 통해 악성코드가 생성하는 파일의 이름을 확인하였음. 또한 “C2” 정보를 통해 네트워크 통신 정보를 확인하였음.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(바) CTI 포탈

○ 웹 인터페이스



[그림 77] 웹 인터페이스 구조도

○ 사용자 주요 기능 정의

✓ 웹 클라이언트가 웹 서버에 파일을 분석 또는 검색을 요청한다.

- 웹 서버는 CTI engine을 호출하여 파일 분석을 한다.
- 기 분석된 파일의 분석 데이터를 DB에서 조회 요청한다.

✓ CTI Engine이 분석한 결과를 DB에 저장한다. 기 분석된 파일의 분석 데이터를 DB에서 응답 받는다.

✓ DB 수행 결과를 CTI Engine 이 응답받는다. DB에서 가져온 데이터를 웹 서버가 웹 클라이언트에게 넘겨준다.

✓ CTI Engine의 분석 상태를 웹 서버가 응답 받는다.

✓ CTI Engine으로부터 받은 응답을 웹 클라이언트에게 넘겨준다.

○ 웹 페이지 개발

✓ 분석 요청/검색 UI

- 파일의 해쉬값을 입력하여 분석결과를 검색하는 기능 제공
- 우측 상단에는 추가 메뉴 제공



[그림 78] 분석 요청/검색 UI

○ 분석 리포트 포함 내용

✓ 분석결과 UI-1: 유사도 분석에 따른 악성 여부 판단

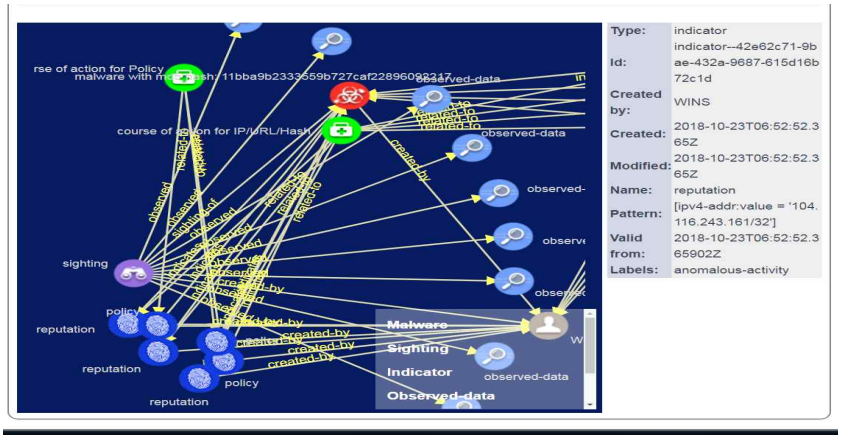
- 1:1 비교 분석화면 조회기능 제공
- 1:1:1 비교 분석화면 조회기능 제공

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 79] 분석결과 UI-1: 유사도 분석에 따른 악성 여부 판단

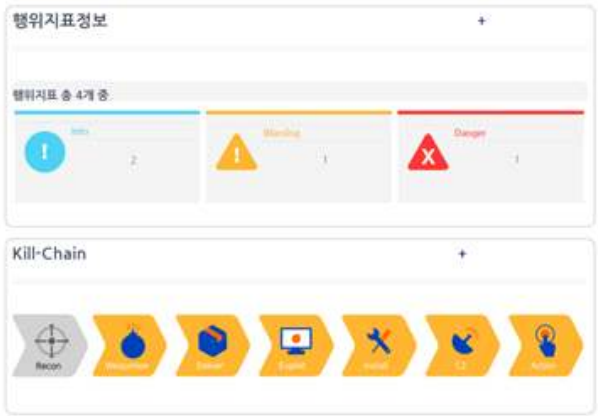
✓ 분석결과 UI-2: 분석된 결과에 대한 STIX 정보 표현



[그림 80] 분석결과 UI-2: 분석된 결과에 대한 STIX 정보로 표현

✓ 분석결과 UI-3: 행위지표 요약정보 제공

- 추출된 행위지표 정보 제공
- 행위지표 기반의 Cyber Kill-Chain 정보 제공



[그림 81] 분석결과 UI-3: 행위지표 요약정보 제공

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 분석결과 UI-4: 행위지표 상세정보 제공 (1/2)

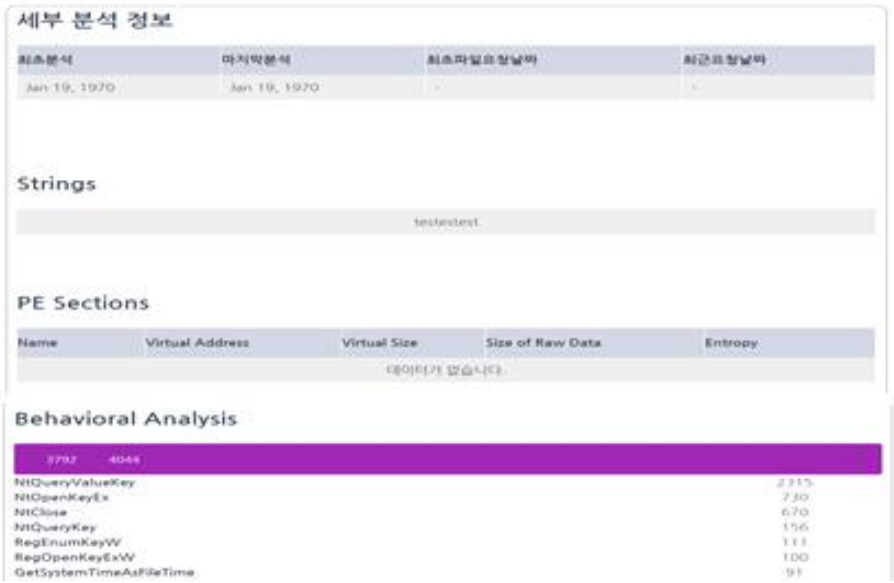
- 네트워크, Dropped 파일정보 등 상세정보 제공



[그림 82] 분석결과 UI-4: 행위지표 상세정보 제공 (1/2)

✓ 분석결과 UI-5: 행위지표 상세정보 제공 (2/2)

- 세부 분석정보, String, PE Section 에 대한 추가 정보 제공



[그림 83] 분석결과 UI-4: 행위지표 상세정보 제공 (2/2)

✓ 분석결과 UI-6: 정책정보 편집 및 공유

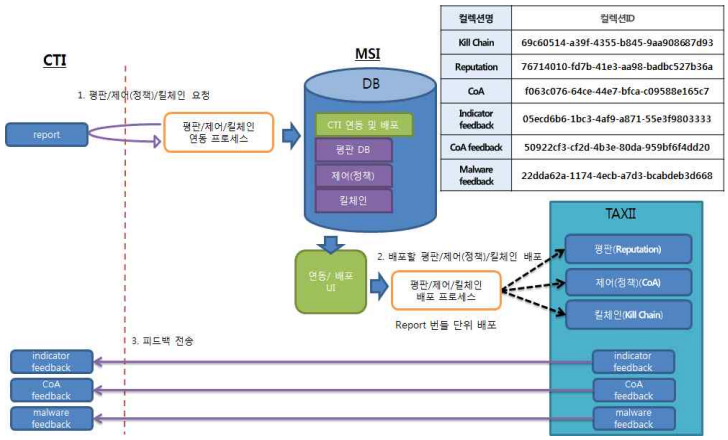
- Snort/Yara 정책정보 제공



[그림 84] 분석결과 UI-6: 정책정보 편집 및 공유

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

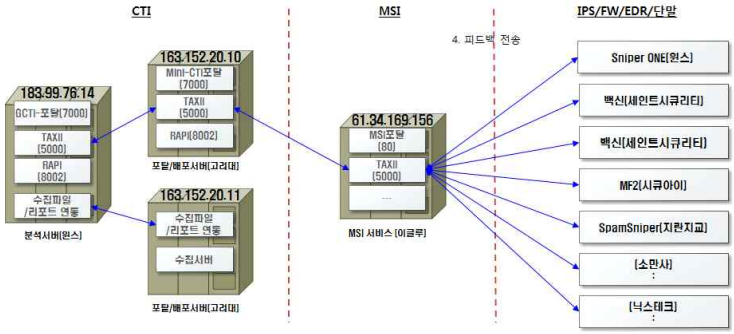
○ CTI => MSI 정책킬체인 연동/배포



컬렉션명	컬렉션ID
Kill Chain	69c60514-a39f-4355-b845-9aa908687d93
Reputation	76714010-fd7b-41e3-aa98-badbc527b36a
CoA	f063c076-64ce-44e7-bfca-c09588e165c7
Indicator feedback	05ecd6b6-1bc3-4af9-a871-55e3f9803333
CoA feedback	50922cf3-cf2d-4b3e-80da-959bf6f4dd20
Malware feedback	22dda62a-1174-4ecb-a7d3-bcabdeb3d668

[그림 85] 위협정보 연동 배포 흐름

○ CTI 서비스 플랫폼 구축
: 고려대 안암 캠퍼스 - IoT 큐브 센터



[그림 86] CTI 서비스망 구축(고려대학교)

(바) 개발 기술의 우수성

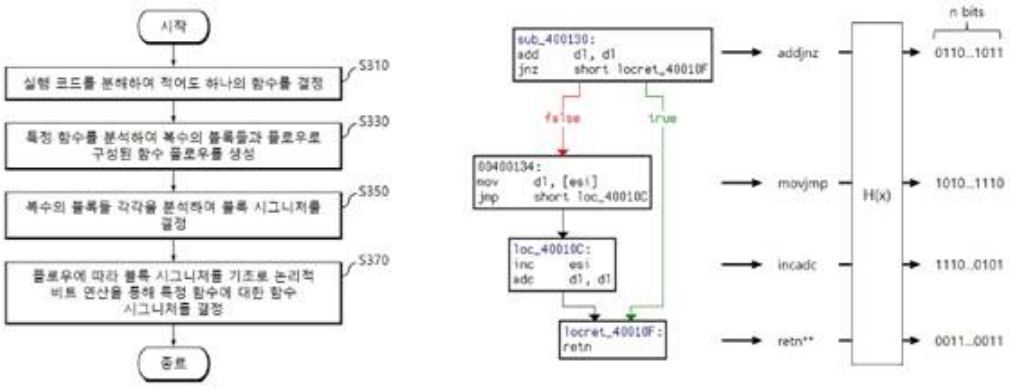
○ 특허

✓ CTI 개발 분야 특허 출원/등록 리스트

순번	특허명	출원인	출원국	출원일	출원번호	등록번호	기여율
1	실행 코드 상의 함수 시그니처 생성 장치 및 방법	국민대	한국	18.07.24	10-2018-0086038	-	100
2	탐지 규칙 검증을 위한 패킷 생성 방법 및 장치	윈스	한국	18.07.24	10-2018-0086038	-	100
3	악성코드 머신러닝 분류 모델 검증 방법과 그 장치	윈스	한국	18.09.06	10-2018-0106470	-	100
4	멀티 패턴 정책 탐지 시스템 및 방법	윈스	미국	18.09.21	16/138,254	-	100
5	구성 요소 기반 악성 파일 유사성 분석 장치 및 방법	윈스	한국	17.10.31	10-2017-0143082	10-1907443	100

✓ 출원 :실행 코드 상의 함수 시그니처 생성 장치 및 방법(10-2018-0090947)

- 내용: 정적분석 결과로 도출되는 Opcode 시퀀스를 기본 블록(basic block) 단위로 그룹화하고, 함수내에 있는 기본 블록들을 XOR 연산을 하여 유일한 함수 대푯값(시그니처)를 생성하는 내용을 특허로 출원함.

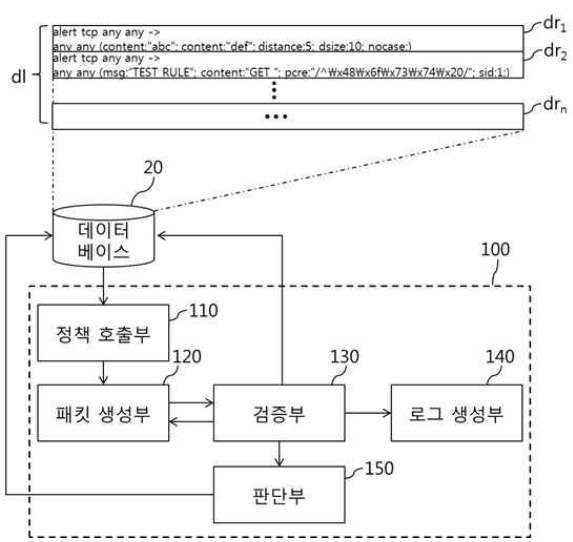


[그림 87] 시그니처 생성 특허

- 특허 장점: 기존 기술에 비하여 기본 블록간 순서가 차이가 발생하여도 동일한 대푯값을 생성하는 장점을 갖기 때문에 동일한 함수지만 기본 블록의 순서만 다른 경우도 같은 함수로 인식 시킬 수 있게 됨. 정적분석 결과를 폭넓게 활용하는데 사용될 것으로 기대되며, 악성코드 분석 업무는 물론 함수의 대푯값을 필요로하는 모든 분야에 적용이 가능함.
- 과제 적용 : 정적분석 엔진의 대푯값 기반으로 분석함으로써 악성분석시스템의 자원 사용의 효율성 및 탐지 정확도를 높임

✓ 출원: 탐지 규칙 검증을 위한 패킷 생성 방법 및 장치 (10-2018-0086038)

- 내용: 본 발명은 네트워크 침입탐지 시스템에서 탐지규칙의 유효성을 효율적으로 검증할 수 있고, 탐지규칙의 신뢰도를 높일 수 있는 탐지규칙 검증을 위한 패킷 생성 방법 제공
- 장점: 네트워크 침입 탐지 시스템에서 페이로드를 구성하는 탐지 규칙의 옵션 정보를 역분석하는 모듈을 제공함으로써 탐지 규칙의 유효성을 효율적으로 검증할 수 있다. 또한, 패킷 생성 방법 및 장치는 탐지 규칙에 대응하는 범위 내에서 헤더 데이터와 페어로드를 무작위로 생성할 수 있고, 이는 동일한 탐지 규칙에 대해 여러 경우의 수를 적용한 한계 테스트에도 적용 가능하다. 또한, 패킷 생성 방법 및 장치는 잘 알려진 포트를 이용하여 서비스 템플릿을 적용함으로써 실제 네트워크 침입 탐지 상황과 유사한 환경에서 탐지 규칙의 검증이 가능하다.



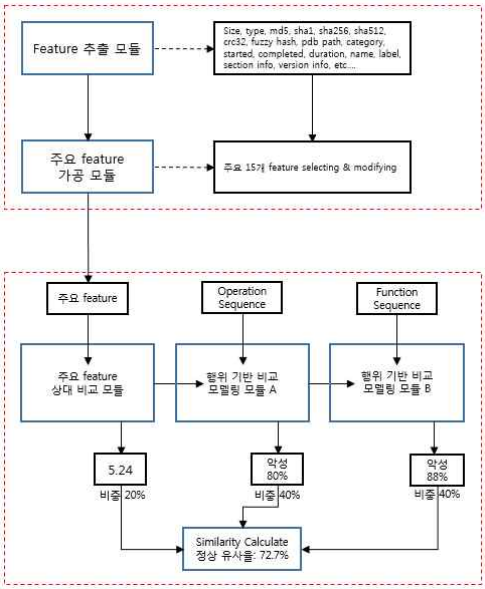
[그림 88] 탐지규칙 검증용 패킷 생성 특허

- 과제 적용: CTI 분석된 위협정보 검증 자동화를 통한 배포의 신뢰성을 높임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

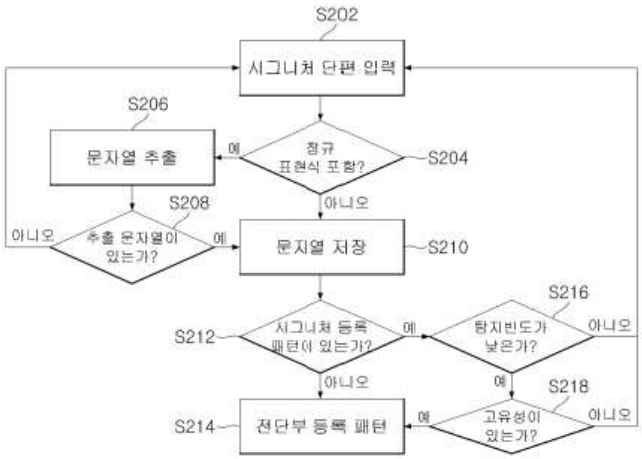
✓ 출원: 악성코드 머신러닝 분류 모델 검증 방법과 그 장치(10-2018-0106470)

- 내용: 파일 간 멀티레이터 순환 검증을 통해 머신러닝 모델에 대한 검증을 하고 예측 결과에 대한 신뢰성을 확보하기 위한 방안 제공
- 장점: 신종 또는 변종 악성코드 분석을 위해 머신러닝이 활용되고 있는 추세이다. 이에 따라 머신러닝에 의해 판별된 예측 정보에 대한 신뢰성 확보 문제가 대두되고 있다. 본 발명에서는 머신 러닝 모델에 대한 검증 및 결과 신뢰성 확보를 위한 방법을 제시한다.
- 과제 적용: 딥러닝 결과에 대한 신뢰성 확보에 활용함



[그림 89] 악성코드 분류 특허

✓ 출원(미국): 멀티 패턴 정책 탐지 시스템 및 방법



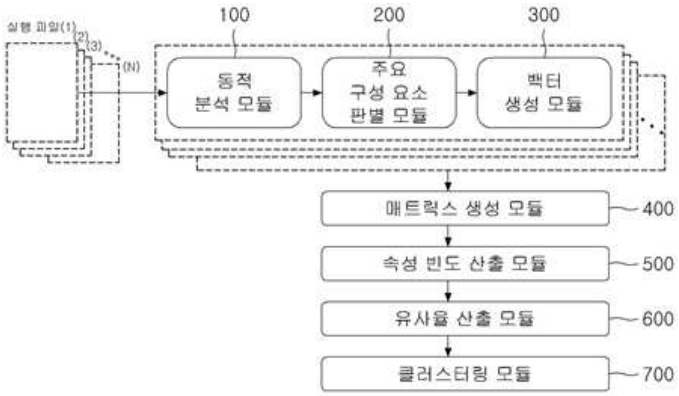
[그림 90] 멀티패턴 정책 탐지 특허

- 내용: 문자열 또는 정규화된 포맷에 의한 매칭 여부를 판단하기 위한 다수의 정책을 운용하는 환경에서 다수의 정책을 일시에 탐색 가능한 형태의 자료 구조로 표현하고 이를 최적화하여 탐색 성능을 향상시킨 멀티 패턴 정책 탐지 방안 제공
- 장점: 본 발명은 다수의 시그니처를 사용하여 탐색하는 환경에서 기존의 멀티 패턴 매칭보다 적은 매칭 시도로 매칭 결과를 얻을 수 있도록 한다. 또한, 고성능 네트워크 장비에서 대용량 네트워크 트렁크에 대한 시그니처 탐색 시 전단부 노드 최적화를 통해 line-speed의 탐색 성능을 보장할 수 있다.
- 과제 적용: 악성파일 분석 시에 발생하는 트래픽를 활용한 악성행위 탐지를 위한 검증체계에서 시그니처 탐지율/정확율을 높임

✓ 등록: 구성요소 기반 악성 파일 유사성 분석 장치 및 방법
(등록 번호 : 10-1907443, (K-PEG 에서 진행한 특허 평가 : B+)

- 내용: 본 발명은 악성파일 유사성 분석 장치 및 방법에 관한 것으로, 특히 악성 실행 파일에서 발생하는 주요 구성 요소의 속성 빈도와 속성역 빈도를 이용하여 유사성을 판단할 수 있도록 한 구성 요소 기반 악성파일 유사성 분석 장치 및 방법에 관한 것이다.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 91] 악성파일 유사성 특허

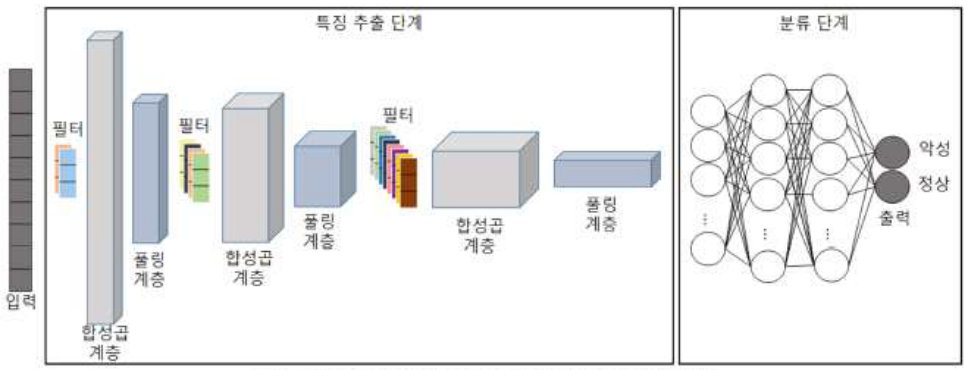
- 내용: 본 발명은 악성파일 유사성 분석 장치 및 방법에 관한 것으로, 특히 악성 실행 파일에서 발생하는 주요 구성 요소의 속성 빈도와 속성역 빈도를 이용하여 유사성을 판단할 수 있도록 한 구성 요소 기반 악성파일 유사성 분석 장치 및 방법에 관한 것이다.

- 장점: 신종 악성코드에 대해서 기존 악성 코드와의 유사성을 판단하여 악성 여부를 판단할 수 있다. 또한 “주요 구성 요소 판별 모듈”을 구성함으로써 다차원 매트릭스 구성시 차원을 축소하는 효과가 있으며, 메모리 사용량을 감소시키는 효과가 있다. 또한, “속성 빈도 산출 모듈”에서 “분석한 실행 파일 리스트와 누적 정보“와 ” 주요 구성 요소 발생 빈도 누적 정보“를 학습하고, 이를 기반하여 학습된 데이터를 사용하여 유사성 분류가 가능하다.
- 과제 적용: 유사도 기반의 악성파일 분류 기능에 활용함

○ 논문

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCI 여부	게재일	IF
1	심층학습과 악성코드 분석 연구	정보과학회지	정성민	36(2)	한국	한국정보과학회	비SCI	2018.2.	-
2	Finding Widespread Events with Simple Bitmaps	IEICE trans. on information and systems	Myung Keun Yoon	12	일본	IEICE	SCIE	2018.12.	0.41

✓ 심층학습과 악성코드 분석 연구

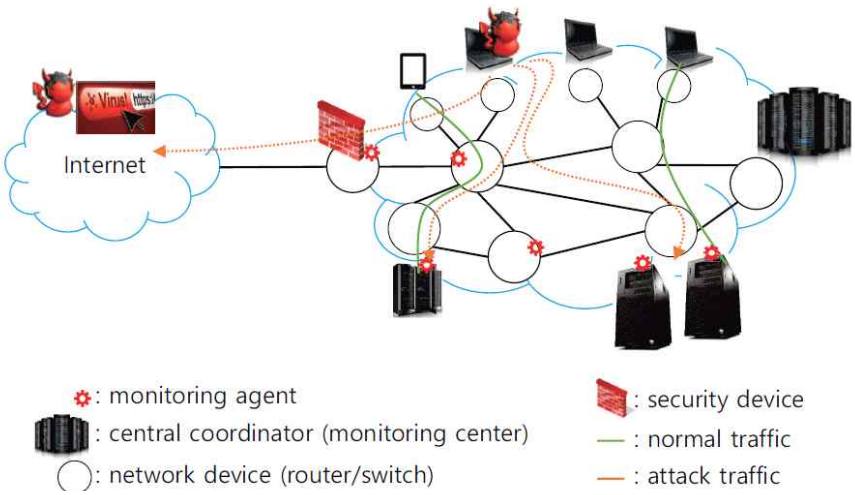


[그림 92] 합성곱신경망 모델를 이용한 악성코드 탐지기

- 심층학습(딥러닝)에 대한 관심이 높아지면서 악성코드 분석 연구에 적용시키는 방법에 대한 연구가 활발해지고 있음.
- 본 논문은 정보과학회지에 실린 초청 논문으로서 본 과제를 진행하면서 습득한 지식을 다른 연구자들에게 쉽게 전달시키는 목적으로 작성되었음.

✓ Finding Widespread Events with Simple Bitmaps

- 1차원 벡터 중 비트맵 자료구조를 사용 공간 측면에서 최적화시키는 연구로서 최적화된 1차원 벡터가 보안 장비 다수의 에이전트와 중앙의 모니터 간의 전송 트래픽 양을 최소로 줄이는 연구임.



[그림 93] 최적화된 비트맵 자료구조

- 본 연구과제에서는 정적분석 결과와 동적분석 결과를 1차원 벡터로 변환시키고 딥러닝의 학습 입력 데이터로 활용함.

(2) WP-B : MSI (Securtiy Analytics 기반의 보안관제 솔루션) : 이글루시큐리티 + 고려대학교

(가) 연구개발목표

○ 연구목표 : 이기종 장비에서 전송되는 대량의 이벤트를 STIX 형식의 빅데이터로 수집/저장하고, 사이버킬체인 기반의 침해지표 기준으로 Security Analytics 기술을 활용하여 인과관계를 분석하고, 향후 예상되는 위협에 대응하는 멀티레이어 시큐리티 인텔리전스(MSI) 기술

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 94] MSI 개발 목표 개념도

○ 연구개발 범위

✓ 이기종 보안 장비/Agent의 실시간 이벤트 수집 시스템 개발

✓ 침해지표(IoC) 기반 연관/인과관계 분석을 통한 공격흐름(IoA) 생성기술
+ 네트워크 악성트래픽 그룹핑을 통한 사이버 공격 탐지 기술
+ 통합보안관제 모니터링 기술

✓ 공격흐름 정보를 표준화된 표현(STIX)/전달(TAXII) 정보 생성/변환 기술

✓ 이기종 보안솔루션간 표준화 API 기반으로 이벤트/제어정보 연동 기술

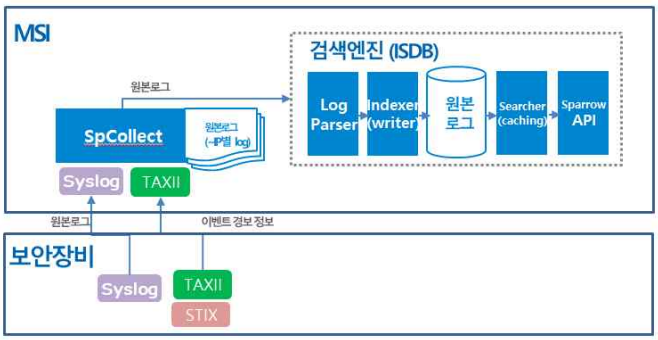
(나) 이벤트수집 시스템

○ 이기종 보안 이벤트 수집 구조

✓ 이기종 보안 장비/Agent의 실시간 이벤트 수집 시스템 개발 : 지속적으로 대량의 데이터를 수집해야 하는 네트워크 보안 장비들에 대해서는 syslog 기반으로, 다른 보안 장비들에 대해서는 STIX/TAXII 기반으로 보안 이벤트를 실시간 수집하는 기능을 개발

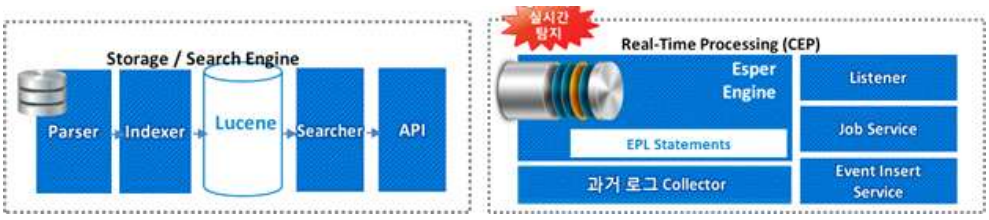
✓ 이벤트 수집

- 수집된 정보에 대한 파싱, 부가정보 추가, 변환하여 저장.
- 데이터 효과적 관리 위한 압축 저장 , 인덱싱, 캐싱, 검색.



[그림 95] 이기종 보안장비의 이벤트 수집 구조

✓ 빅데이터 기술



[그림 96] 보안이벤트 수집/분석 성능 고도화를 위한 빅데이터 기술

- Lucene 기반 고속 검색 엔진 (분산검색/클러스터링)
- PCRE 기반 비정형 이기종 데이터 고속 수집 (Agent / Agentless 방식)
- 람다 아키텍처 (스트리밍 분석 + 배치 분석) 기반의 CEP 기반 In-Memory Correlation 분석

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 수집 성능

✓ 성능 검증 방안 (자체 테스트 이벤트 및 툴 개발을 통한 검증 진행)



[그림 97] 이기종 이벤트 수집 모듈 성능 검증

✓ 이기종 보안장비의 이벤트 수집 성능 고도화(170K 이상의 EPS 저장 속도)

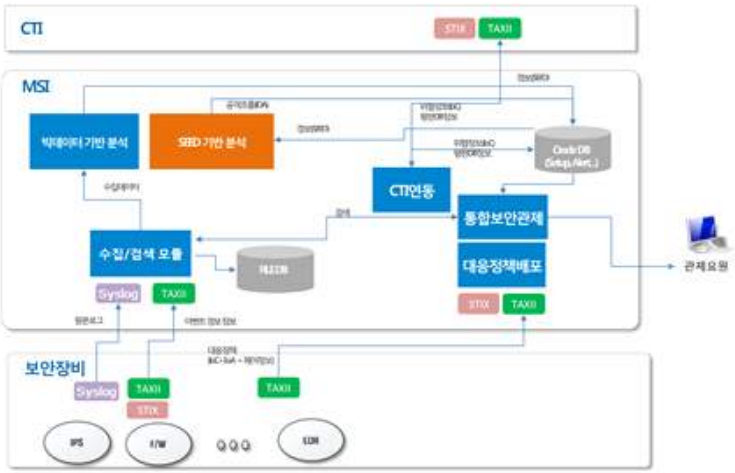


회차	EPS
1회	205,970 EPS
2회	216,215 EPS
3회	214,244 EPS
평균	**212,413 EPS**

[그림 98] 이기종 보안장비의 이벤트 수집 성능 고도화

(다) 통합보안관제

○ 멀티레이어 시큐리티 시스템 구조



[그림 99] MSI 시스템 구조

✓ 이기종 장비에서 전송되는 대량 이벤트를 STIX 형식의 빅데이터로 수집/저장

✓ CTI에서 전송된 사이버킬체인 기반의 침해지표(IOC) 값을 Seed 값으로 하여서, 이벤트에 대한 FCI 탐지 시스템을 통한 과거이력 기준의 감염여부 검사

✓ 감염세션의 상황정보를 인과관계를 분석하고, 그에 대한 대응정책 배포

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ IOC(공격지표) 기반으로 IOA(공격흐름)를 인지 기능 개발

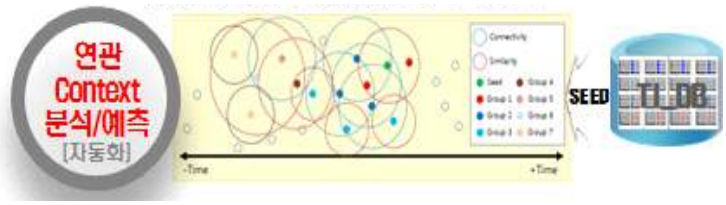
✓ Security Analytics 기술로 침해지표(IoC) 연관분석 및 인과관계 분석하여 공격흐름(IoA)을 판단하는 기술

✓ 대량의 데이터 볼륨과 데이터 스트림 분석을 통해 실시간 상황 인지

✓ 침해지표(IoC)값을 Seed로 하여 그룹핑하여 악성 트래픽/플루우 탐지

✓ 침해지표(IoC) 항목 고도화 및 그에 따른 공격흐름(IoA) 추출 고도화

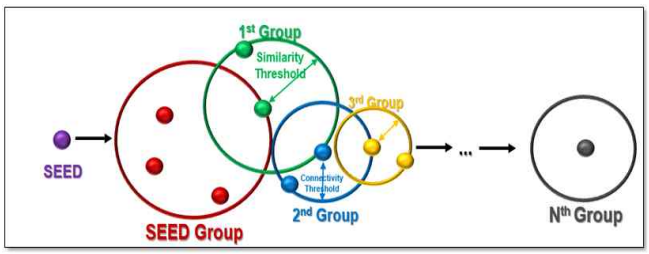
- CTI에서 전달 받은 킬체인 데이터를 분석하여 추출한 Seed 데이터를 통해 대량의 트래픽 데이터를 그룹핑하여 악성 트래픽/플로우를 탐지
- 자체적으로 학습된 악성 트래픽/플로우 모델링 기준으로 이벤트에 대한 악성 그룹핑의 유사성을 검사



[그림 100] SEED 기반 이벤트 추적

- FCI 분석 시스템을 통해 그룹핑된 행위 정보와 모델의 행위정보를 매핑하여, 향후 공격 흐름(IoA) 정보를 효과적으로 추출

✓ MSI 시스템은 CTI시스템에서 전달된 위협정보를 판단할 수 있는 정보(IP/도메인/파일정보 등)를 SEED값으로 변경하여 관련 비정상 행위 그룹을 탐지



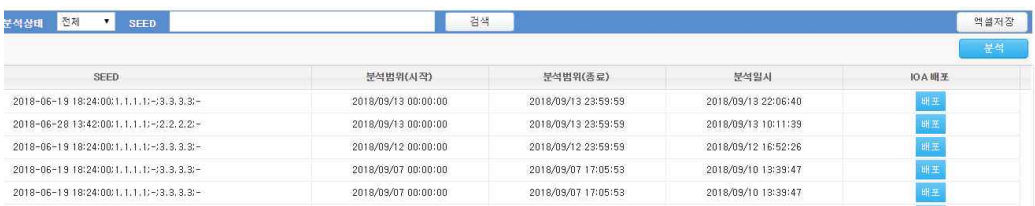
[그림 101] SEED 기반 이벤트 그룹핑

○ MSI 시스템에서의 Seed 기반 IOA(공격흐름) 정보 제공

✓ 분석을 요청한 세션에 대한 분석 수행

✓ CTI 연동을 통한 자동 분석 가능(but, 시스템 성능의 안정성을 위해 수동 요청)

✓ 분석된 정보는 IOA를 정책으로 변환되어 배포됨



[그림 102] Seed 정보를 활용한 이벤트 그룹핑

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 통합보안관제 모니터링 기술

✓ 통합 보안관제 기본 UI



[그림 103] 통합관제 UI

✓ 실시간 모니터링부터 다양한 분석을 통한 보안관제 고도화.



[그림 104] 다양한 분석을 통한 보안관제 고도화

✓ 사용자 정의 대시보드 기능을 통한 다양한 관점의 관제 대시보드로 모니터링.



[그림 105] 사용자 정의 대시보드

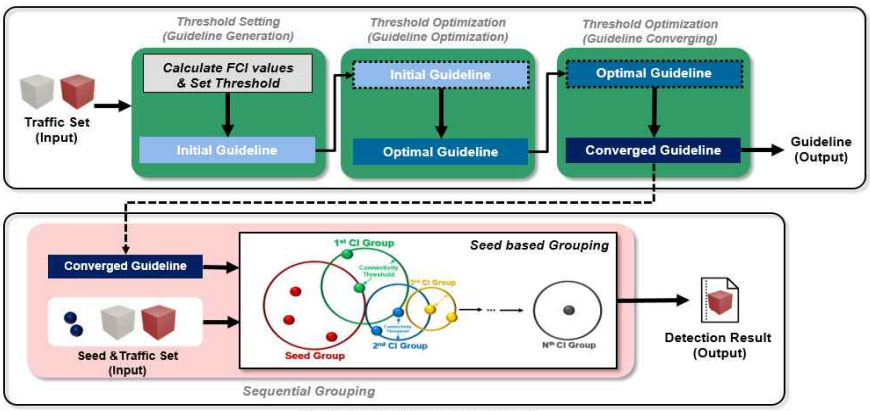
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(라) 악성그룹핑

○ Seed정보를 이용한 트래픽 그룹핑 및 FCI 모델 개발

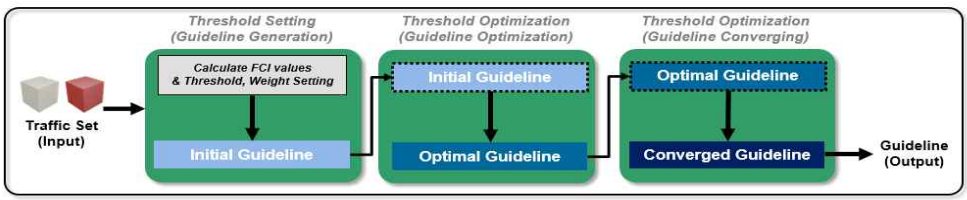
✓ Sequential Grouping Model을 설계해서 MSI 플랫폼으로부터 입력으로 받는 Seed 정보와 유사한 플로우를 연속적으로 탐지

✓ 1차 년도와 달리 유사성 특성 배제하고, 연결성 특성만을 이용하여 연속적 그룹핑 진행



[그림 106] FCI 모델의 시스템 구조

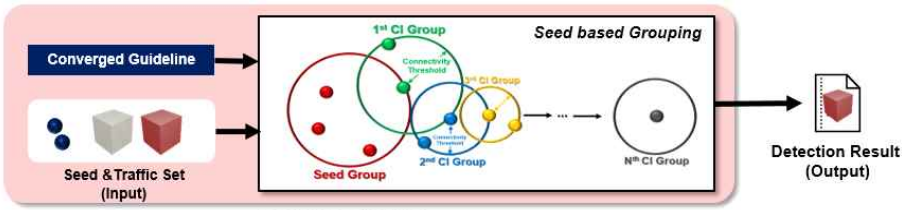
✓ 정교한 탐지를 위한 기준 값(Threshold) 정의 및 Guideline 생성 방법 연구



[그림 107] 가이드라인 생성 및 최적화

- 보다 정교한 연관 트래픽 그룹핑 작업을 위해서는 연결성 값에 대한 정교한 기준 값 그리고 각 Feature들에 대한 가중치에 대한 정보 생성 필요.
- 유사성과 연결성 값 모두 정교한 그룹화 작업을 위해서는 만족해야 하는 기준이 필요. 이러한 기준 값(Threshold)은 다양한 트래픽 학습을 통해 생성
- 이러한 가중치와 기준 값들에 대한 정보를 'GuideLine' 이라는 내용으로 정의해 탐지를 수행하는 데에 있어 그 정확도와 범위를 보정 수행

✓ FCI 기반의 트래픽 그룹핑 방법



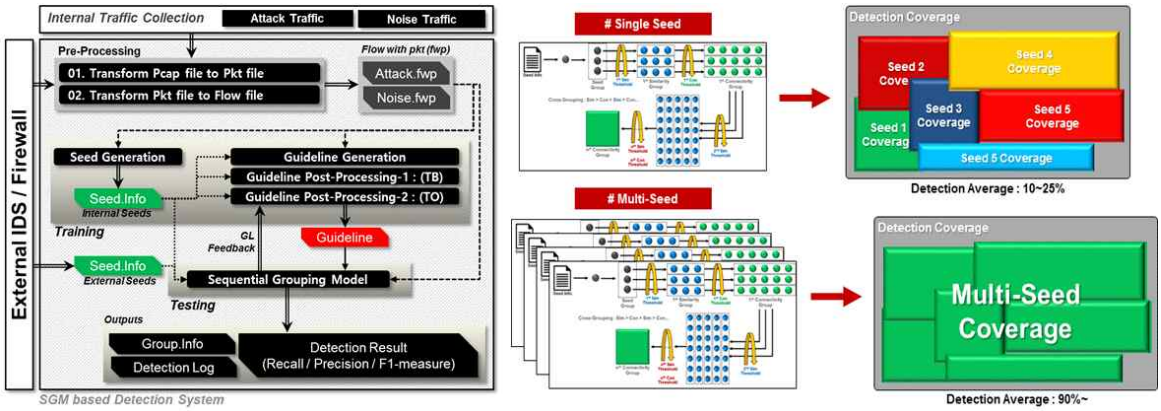
[그림 108] 시드기반 연속적인 그룹핑

- 입력받은 시드로부터 Seed Flow와 Seed Group을 생성하고 Seed Group에서부터 연속적으로 유사성과 연결성 그룹을 교차하며 탐색 (1차 년도와 동일)
- 연결성 기반의 그룹핑만을 적용하기 위하여 각 플로우를 구성하는 패킷의 5-Tuple(프로토콜, Src-Dst IP, Src-Dst Port) 정보와 NetFlow V5의 플로우 정보(Packet Count, Byte Count)를 활용한 연결성 Feature 값을 설정한 후 플로우간의 연결성을 Euclidean 유사도를 통해 측정.

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ Seed 정보 기반 Sequential Grouping Model과 Advanced FCI Algorithm을 적용한 FCI 탐지 시스템 개발

✓ Sequential Grouping Model을 적용한 FCI 탐지 시스템 개발



[그림 109] SGM 기반 탐지 시스템 및 멀티시드기반 탐지 방법

- Seed Generation 모듈은 수집한 악성트래픽에서 각 Flow를 시드 정보로 추출.
- GuideLine Extractor에서는 Threshold Balancing과정을 통해 입력에서 받은 각 Seed에서 GuideLine을 추출
- GuideLine Optimizer에서는 생성된 GuideLine을 통합해 입력으로 받은 공격 트래픽에 최적화된 탐지 GuideLine을 생성하고 이러한 Optimal GuideLine을 융합해 Converged GuideLine을 생성
- Sequential Grouping 모듈은 기존의 FCI-Calculator를 튜닝한 트래픽 그룹핑 모듈로서, Multiple-Seed 기반의 탐지 방법 적용을 통해 기존에는 탐지하지 못했던 Flow들 또한 다양하게 탐지하여, 매우 높은 정확도의 탐지 시스템 구현

○ Advanced FCI Algorithm을 적용한 개선된 FCI 탐지 시스템 개발

✓ Grouping Sequence Adjustment

- 기존의 FCI 모델에서는 최대 Grouping Sequence가 5로 설정되어 있었기 때문에 최대 5번 까지 그룹핑 진행
- 여기서 6번째 그룹핑을 할 경우 탐지 가능한 플로우 있음에도 불구하고 그룹핑을 5번만 진행하기 때문에 미탐지 된 플로우로 판단하기 때문에 Recall이 낮아짐
- 따라서 최대 Grouping Sequence를 조정하여 최대 7~10번까지 그룹핑이 진행 될 수 있도록 설정

✓ Weight Combination Elaboration

- Guideline 생성 및 Cascade Grouping 과정의 Weight 계산 할 때, 단위를 세밀하게 조정(기존의 0.1 ==> 0.05)
- 기존의 Weight의 경우 소수 첫째 자리까지 계산 되기 때문에 Threshold와 Weight 값이 세밀하지 않았지만, Weight Combination 정교화를 통하여 세밀하게 값 조정 가능 (Recall, Precision 향상)

✓ New Connectivity Feature

- 유사성 특성을 배제했을 때, 기존의 연결성 특성만을 사용하여 그룹핑을 진행하면 성능적 제한이 존재(Time, IP, Port, Protocol의 Feature만으로 모든 악성 플로우의 특성을 구분 짓기 어려움)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

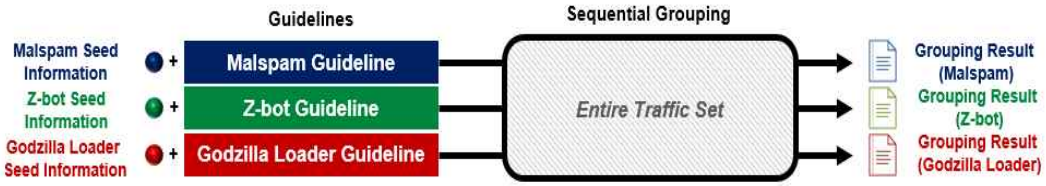
- 따라서 기존의 4 가지 Feature와 추가로 ‘Forward Packet 비율’, ‘Forward Byte 비율’의 특성을 추가하여 총 6 가지의 Feature 사용

Connectivity Features	Explanation	Function	Range
ST	Start Time	$a_{ST}(f_x,f_y)=1-\sqrt{\frac{dist(f_x,f_y)}{maxdist(F)}}$	0~1
SIP	Source IP Address	$a_{IP}(f_x,f_y)=\left(\frac{prefixlenAddr(f_x,f_y)}{32}\right)^2$	0~1
DIP	Destination IP Address		
SPT	Source Port Number	$a_{PT}(f_x,f_y)=\left(\frac{prefixlenPort(f_x,f_y)}{16}\right)^2$	0~1
DPT	Destination Port Number		
PROT	L4 Protocol	$a_{PROT}(f_x,f_y)=\begin{cases}0; f_x.PROT \neq f_y.PROT\\ 1; f_x.PROT = f_y.PROT\end{cases}$	0 or 1
Ratio of Forward Packet (RP)	Forward Packet Ratio	$1-The\ Difference\ of\ Forward\ Packet\ Ratio\ in\ Flow\ (f_x,f_y)$	0~1
Ratio of Forward Byte (RB)	Forward Byte Ratio	$1-The\ Difference\ of\ Forward\ Byte\ Ratio\ in\ Flow\ (f_x,f_y)$	0~1
$Conn(f_x,f_y)=w_{1_ST}\times a_{ST}(f_x,f_y)+w_{2_IP}\times a_{IP}(f_x,f_y)+w_{3_PT}\times a_{PT}(f_x,f_y)+w_{4_PROT}\times a_{PROT}(f_x,f_y)+w_{4_PROT}\times a_{PROT}(f_x,f_y)+w_{4_PROT}\times a_{PROT}(f_x,f_y)$ $(where, 0\le a_i(f_x,f_y)\le 1,\ \sum_{i=1}^{4} w_i=1)$			0~1

[그림 110] 6 가지 Connectivity Feature의 FCI 계산

✓ Applying Multiple Guideline

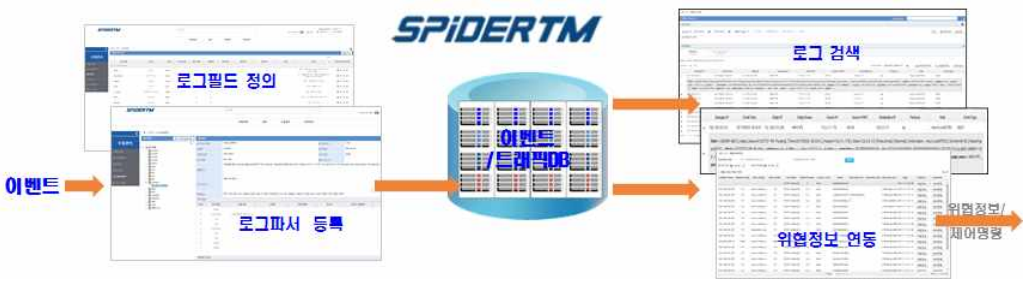
- 기존의 Guideline 적용 과정을 보면, 하나의 Converged Guideline을 모든 타입의 악성 트래픽에 적용 시켜서 그룹핑 진행
- 하지만 각 악성 트래픽의 종류 마다 특성이 조금씩 다르기 때문에, 특성이 다른 악성 트래픽을 차례로 사용하여 테스트 하면 성능적인 면에서 좋지 않은 결과 도출
- 이를 해결하기 위하여, 각 타입 별로 Converged Guideline을 생성 한 다음, 해당 타입의 악성 트래픽만 선책적으로 탐지하고, 결과 도출 (예 : 그림에서 각 Guideline을 트래픽 셋에 적용 할 때, Malspam의 경우 Malspam에 대한 그룹핑 결과만 도출)



[그림 111] 멀티플 가이드라인 적용 예시

(마) 위협정보 연동을 위한 STIX/TAXII 2.0 API 개발

○ 이기종 보안솔루션간 표준화 API 기반 연동 개념



[그림 112] MSI 시스템의 이벤트/정책 연동

✓ 위협정보 연동을 위한 구성요소 간의 상호 인증기술

- STIX-TAXII 표준 기반 공유정보 상호 보안 및 인증 모듈 구현
- STIX-TAXII 표준 기반 공유정보 암호화 모듈 구현

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 위협정보 포맷(STIX) 표준의 API 기술 개발

- STIX 표준 기반 보안위협정보 생성/조회 API 구현 (Incident, TTP, Campaign, CoA 구조체)
- 한국형 STIX표준 적용을 위한 SDK 또는 API 기능 확장

✓ 위협정보 교환(TAXII) 표준의 API 기술 개발

- CTI 및 외부 기업등과 데이터 송수신을 위한 경량화 된 범용 오픈 API 지원 SDK 구현 및 테스트
- 한국형 TAXII표준 적용을 위한 SDK 또는 API 기능 확장

✓ 위협정보연동을 위한 표준화 API 기반 보안이벤트 및 제어정보 연동 기술

- 이기종 보안솔루션간 위협정보 연동 기술
- 이기종 보안솔루션간 보안이벤트/제어정보 연동 위한 TAXII Collection 정의

○ 보안 프로토콜 기반 상호 보안 및 인증 메시지 구현

✓ TAXII2.0 표준에 정의된 HTTP Basic Authentication 기능의 구현에 추가

- 인증서 기반의 2-way 상호 인증 기능을 이용한 HTTPS 지원 기능을 TAXII 서버와 클라이언트에 구현.
- 서버는 특정 Root CA에서 발급한 인증서인지 검증을 수행. Java, Python, C++ TAXII 클라이언트 라이브러리는 인증서 기반의 2way 인증 API 구현
- 클라이언트 접속 요청 시 서버와 클라이언트는 인증서 기반의 상호인증을 수행하고 상호인증이 성공한 경우에 한해 HTTPS 통신을 허용.
- 또한 상호인증의 성공 후 HTTP Basic Authentication 방식의 ID / Password를 인증으로 사용자를 인증

✓ STIX-TAXII 표준 기반 공유정보 암호화 모듈 구현

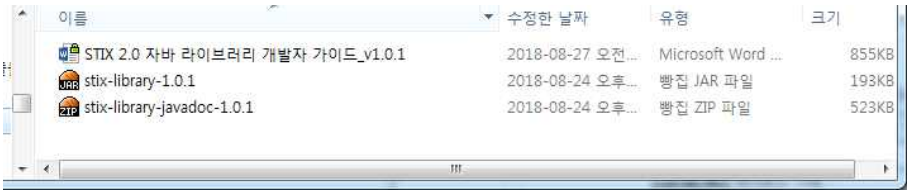
- STIX1.x 와 다르게, STIX2.0 과 표준 수준의 정보 암호화를 정의하지 않음
- TAXII2.0 은 표준은 HTTPS 프로토콜을 기본 통신 프로토콜로 정의
- 인증서 기반의 2-way 상호 인증 기능을 이용한 HTTPS 통신 방식을 구현하여 공유정보의 암호화를 지원

○ 보안솔루션 위협정보 공유 및 글로벌 위협정보 연동표준 개발

✓ 위협정보 포맷(STIX) 표준의 API 기술 개발

- STIX 표준 기반 보안위협정보 생성/조회 API 구현 (Incident, TTP, Campaign, CoA 구조체).
- 12개 SDO 객체(Threat Actor, Intrusion Set, Attack Pattern, Indicator, Identity, Campaign, Tool, Malware, Vulnerabiltiy, Course of Action, Observed Data, Report)와 2개의 SRO 객체(Relationship, Sighting)를 생성/파싱하는 Java, Python, C++ STIX2.0 라이브러리를 제작 및 배포하여 업체에 적용
- 업체는 이를 이용하여 TAXII 로부터 수신받은 STIX 제어정보, 평판정보, 정책정보의 파싱 및 자체 생성한 보안이벤트 및 제어정보 등을 STIX 형식으로 변환 시에 STIX 라이브러리 API를 이용하여 적용
- STIX 2.0 라이브러리기반 API 개발 (:JAVA 기반 라이브러리 API 개발, 파이선은 오픈소스에 등록된 API 활용)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 113] STIX API개발 내역

✓ 한국형 STIX표준 적용을 위한 SDK 또는 API 기능 확장(STIX2.0 표준에서 정의하고 있지 않으나, 과제 진행으로 새롭게 정의 및 SDK 적용/배포한 기능)

- Indicator 표준 정의에 x_kosign_snort_rule, x_kosign_yara_rule 커스텀 속성을 정의하여 Snort 룰과 Yara 룰을 추가로 정의 및 공유할 수 있도록 확장
- Course of Action 표준 정의에 Indicator 로의 관계(related_to)를 새롭게 추가하여, 효과적인 제어 정보 표현에 이용
- Course of Action 표준 정의에 소프트웨어 패치를 위한 새로운 속성을 확장 속성 표준에 준수하여 추가 (url, hash)

✓ 위협정보 교환(TAXII) 표준의 API 기술 개발

- CTI 및 외부 기업등과 데이터 송수신을 위한 경량화 된 범용 오픈 API 지원 SDK 구현 및 테스트
- TAXII 2.0 표준을 준수하는 HTTP RESTful API를 지원하는 Java, Python, C++ TAXII 클라이언트 라이브러리를 제작 및 배포
- 연동 업체는 자체 생성한 보안이벤트의 MSI 전송, MSI TAXII 서버로부터 정책/평판/제어정보를 수신하는 기능의 구현 시에 배포된 TAXII 클라이언트 라이브러리의 API를 적용하여 개발 및 테스트 진행
- TAXII 2.0 라이브러리 API 개발(C++/JAVA 기반 라이브러리 API 개발, 파이선은 오픈소스에 등록된 API 활용)



[그림 114] TAXII API 개발 내역

✓ 한국형 TAXII표준 적용을 위한 SDK 또는 API 기능 확장 (TAXII2.0 표준에서 정의되어 있지 않으나, 과제 진행으로 새롭게 정의 및 적용/배포 기능)

- 인증서 기반의 2-way 상호 인증 기능을 TAXII 서버와 클라이언트에 구현하여, 특정 Root CA에서 발급한 인증서인지 검증하는 기능을 추가.
- Java, Python, C++ TAXII 클라이언트 라이브러리에 API 로 기능을 추가

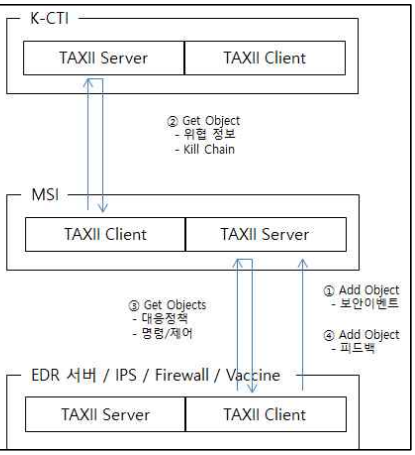
○ 위협정보연동을 위한 표준화 API 기반 보안이벤트 및 제어정보 연동 기술

✓ 이기종 보안솔루션간 위협정보 연동 기술

- 통신 프로토콜 설계 (데이터 전송채널 생성 및 데이터 전송, 통신해제)

- 통신 프로토콜은 TAXII 2.0 표준에 정의된 HTTPS Restful 방식으로 설계
- 표준을 준수한 Python TAXII서버 및 Java, Python, C++ TAXII 클라이언트를 설계하여 구현 및 배포
- 연동 업체는 배포된 SDK의 API를 활용하여 이벤트/제어정보 생성, 변환 및 파싱 처리에 적용. 이벤트/제어정보의 연동 기술로 TAXII2.0 표준을 지원하는 Java, Python, C++ TAXII 클라이언트 라이브러리를 제작 및 배포
- Python 으로 제작된 TAXII 서버를 제작하여 MSI 에 설치/운영하고, 이를 업체와 연동을 위한 TAXII 공유 서버로 활용

API	METHOD	설명
Server Discovery	GET	TAXII 서버의 일반 정보 조회
Get Api Root	GET	API Root 정보 조회
Get Status	GET	이전 요청 상태 정보 조회
Get Collections	GET	API Root 아래 호스팅되는 Collection 목록 조회
Get a Collection	GET	하나의 Collection 정보 조회
Get Objects	GET	Collection 내의 객체 목록 조회
Add Objects	POST	Collection 에 객체 추가
Get an Object	GET	하나의 객체 조회
Get Object Manifests	GET	하나의 Collection 으로부터 객체들에 대한 manifest 조회



[그림 115] TAXII2.0 RESTful API 및 서버 클라이언트 연동 구조

✓ 이기종 보안솔루션간 보안이벤트 및 제어정보 연동 위한 TAXII Collection 정의

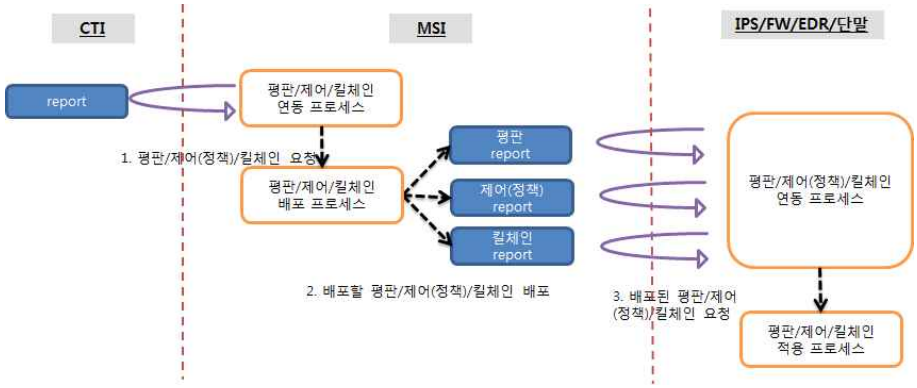
- TAXII_Collction 리스트

컬렉션명	컬렉션ID	사용여부	설명	연동대상
MSI STIX Collection	36ca1220-63a7-11e8-adc0-fa7ae01bbebc	O	일반 테스트 용	모든 기관/업체
Kill Chain	69c60514-a39f-4355-b845-9aa908687d93	O	킬체인 컬렉션 (배포용) : report stix sdo	모든 기관/업체
Reputation	76714010-fd7b-41e3-aa98-badbc527b36a	O	평판 컬렉션 (배포용) : report stix sdo	모든 기관/업체
CoA	f063c076-64ce-44e7-bfca-c09588e165c7	O	제어/정책 컬렉션 (배포용) : report stix sdo	모든 기관/업체
Indicator feedback	05ecd6b6-1bc3-4af9-a871-55e3f9803333	O	EDR/IPS/단말로부터 전송된 평판 피드백 컬렉션	모든 기관/업체
CoA feedback	50922cf3-cf2d-4b3e-80da-959bf6f4dd20	O	EDR/IPS/단말로부터 전송된 제어/정책 피드백 컬렉션	모든 기관/업체
Malware feedback	22dda62a-1174-4ecb-a7d3-bcabdeb3d668	O	EDR/IPS/단말로부터 전송된 Malware 피드백 컬렉션	모든 기관/업체
Nework Security Event	721428bd-6e5c-402f-a667-23386bcfea8c	O	네트워크 보안이벤트 정보 컬렉션 (탐지/차단/악성코드 탐지/메타데이터)	윈스, 시큐아이, 지란지교
EDR Security Event	e5ace2a6-ae4c-4626-b870-d33dda69d36b	O	EDR 보안이벤트 정보 컬렉션 (탐지/차단/악성코드 탐지/메타데이터)	닉스테크, 소만사
Vaccine Security Event	5b17a9d2-5a2e-451a-93d5-1849e82a6a4a	O	단말 보안이벤트 정보 컬렉션 (탐지/차단/악성코드 탐지/메타데이터)	세인트시큐리티

[그림 116] TAXII 콜렉션 목록

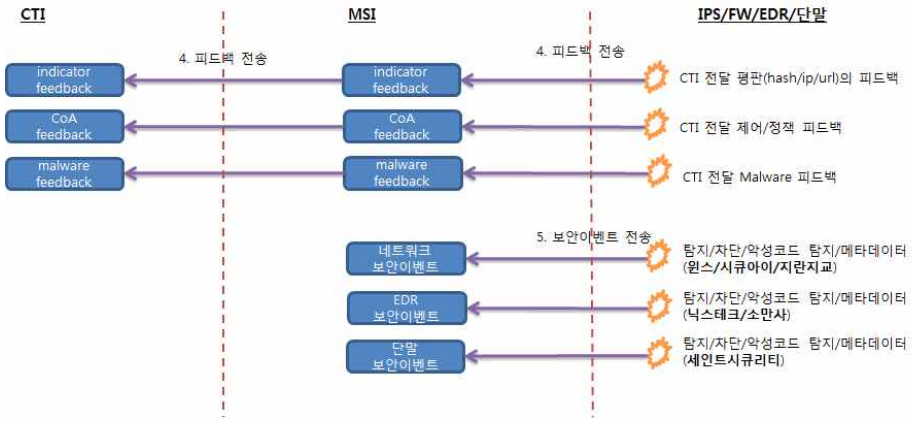
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

▪ 배포 관련 TAXII_Collction 연동



[그림 117] TAXII 서비스의 정책배포(하향) 흐름

▪ 피드백/이벤트 전송 관련 TAXII_Collction 연동



[그림 118] TAXII 서비스의 피드백/보안 이벤트(상향) 흐름

(바) 개발 우수성

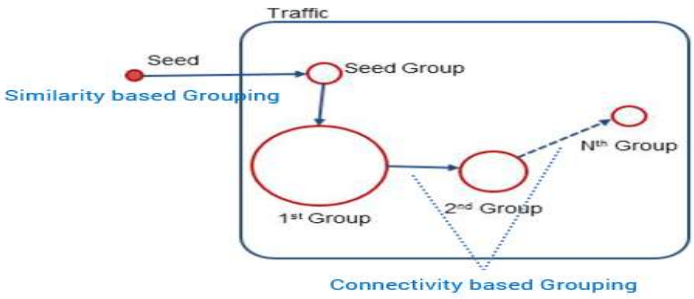
○ 특허

✓ CTI 개발 분야 특허 출원/등록 리스트

No	특허명	출원인	출원국	출원일	출원번호	등록번호	기여율
1	네트워크 플로우의 연관성 모델을 이용한 트래픽 분류	고려대학교 세종산학협력단	한국	17.08.30	10-2017-0110011	10-1915908	100
2	딥 러닝을 이용한 시드기반 악성 트래픽 탐지 방법 및 장치	고려대학교 세종산학협력단	한국	18.07.30	10-2018-0088477	10-2032249	100
3	STIX 변환 장치 및 방법	이글루시큐리티	한국	17.10.19	10-2017-0135939	10-1929522	100
4	위험지수 자동 보정 장치 및 방법	이글루시큐리티	한국	17.11.15	10-2017-0152254	10-1929528	100
5	공격 빈도 및 자산 중요도, 취약 정보에 따른 위험지수 보정 기술	이글루시큐리티	한국	18.11.15	10-2018-0140853	10-2088310	100

✓ 출원/등록 : 네트워크 플로우의 연관성 모델을 이용한 트래픽 분류

- 유사성 및 연결성 특성을 사용한 FCI 값 계산 및 계산 된 FCI 값을 통한 연관 플로우 그룹핑 진행한다.

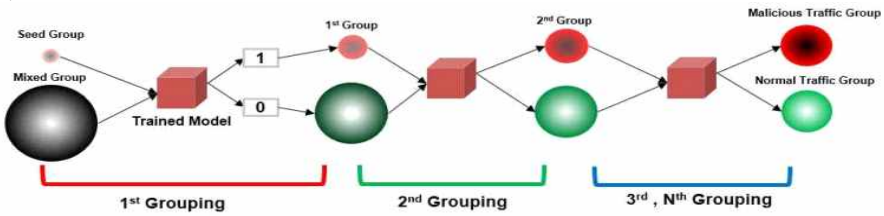


[그림 119] 플로우 연관성 모델을 이용한 트래픽 분류 특허

- 장점 : 기존 유사성과 연결성 모두를 사용하였으나, 네트워크 플로우의 연관성 모델만을 이용한 트래픽 분류 방법 제시
- 과제 활용 :시드 그룹을 기반으로 탐지된 비정상인 플로우를 계산된 수치를 바탕으로 FCI 값을 도출하고, 도출된 FCI 값을 기준으로 연속적 그룹핑 탐지하여, 악성그룹 분류할 수 있도록 해 줌

✓ 출원 : 딥 러닝을 이용한 시드기반 악성 트래픽 탐지 방법 및 장치 (출원)

- 목표 : 유사성 및 연결성 특성을 사용한 FCI 값 계산을 딥러닝 알고리즘에 적용하여 연관된 플로우 그룹핑 진행한다.
- 내용 : 시드 그룹을 기반으로 반복적 학습을 통한 해당 플로우와 연관된 플로우 연속적으로 그룹핑 탐지 진행한다.

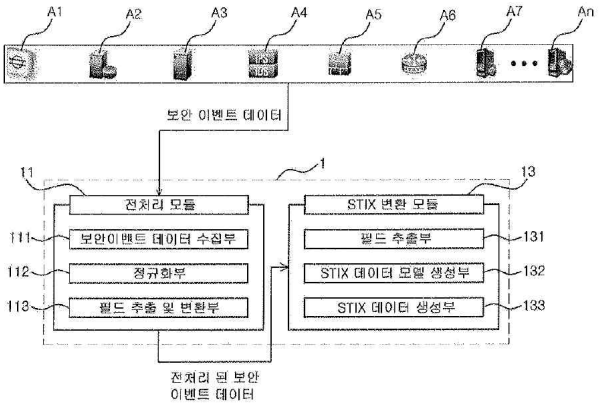


[그림 120] 딥러닝을 이용한 시드기반 악성 트래픽 탐지

- 활용방법 : FCI 시스템에 딥러닝 시드기반 악성 트래픽 탐지 정확도를 높임

✓ 출원/등록(심사) : STIX 변환 장치 및 방법

- STIX형식이 아닌 보안이벤트에 대한 혹과적인 STIX 변환 방법에 대한 특허



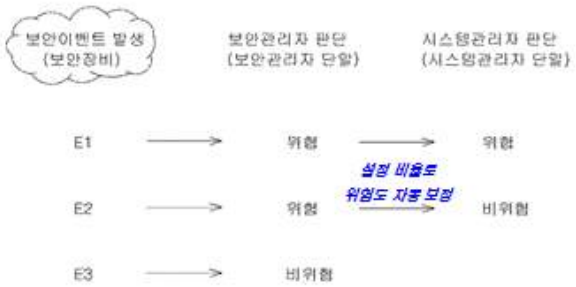
[그림 121] STIX 변환장비 특허 개념도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- 장점 :다양한 보안장비의 효과적으로 STIX형식의 이벤트 생성 방법 제공
- 과제 적용 : 참여기관의 보안장비 및 MSI의 STIX 이벤트 수집부 적용

✓ 출원/등록(심사중): 위험지수 자동 보정 장치 및 방법

- 각종 보안장비에서 발생하는 보안이벤트의 위험지수를 사전에 설정된 비율로 상향 또는 하향 조정함으로써 보안 이벤트에 따른 신속한 대응

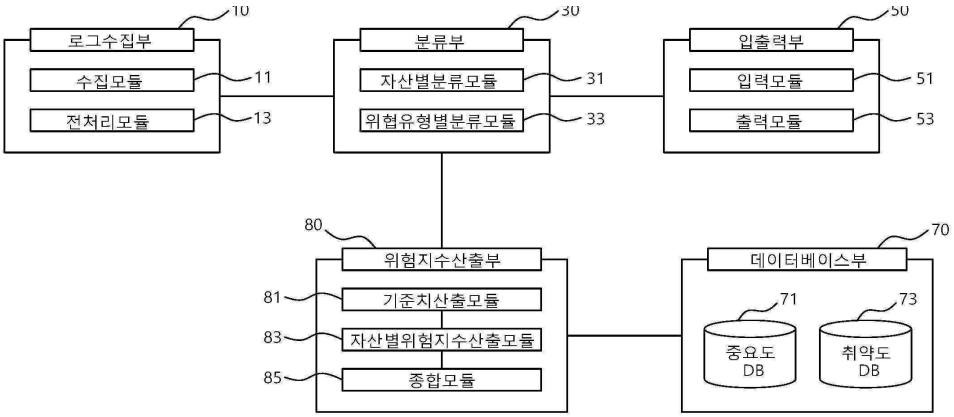


[그림 122] 위협미수 자동보정 장치 관련 특허

- 장점 :개별 보안이벤트 및 상위 위험지수 적적성 판단 및 개별 보안이벤트에 대한 위험지수에 기반하여 도출되는 각종 상위 위험지수의 적정성 및 신뢰도를 향상시켜주는 위험지수 자동 보정 장치 및 방법
- 과제 활용 : 공격흐름 (IoA) 정보 추출에 활용되는 위협 정보 및 로그 등에 대한 평판 DB 구축에 필요한 요소 기술임.

✓ 출원 :공격빈도, 자산중요도 및 취약정도에 따른 위험지수 보정시스템 및 방법

- 자동 보정기술을 적용하여 보안이벤트/자산별 위험지수 값의 정확도까지 개선할 수 있는 방법



[그림 123] 위협지수 관리체계 관련 특허 개념

- 장점 : 위험지수 관리체계의 자동화 및 신뢰성 확보를 통해 보안관리 업무의 효율성을 증대.
- 과제 활용 : MSI에 수집된 이벤트 및 자산에 대한 위험지수의 관리 체계 구현

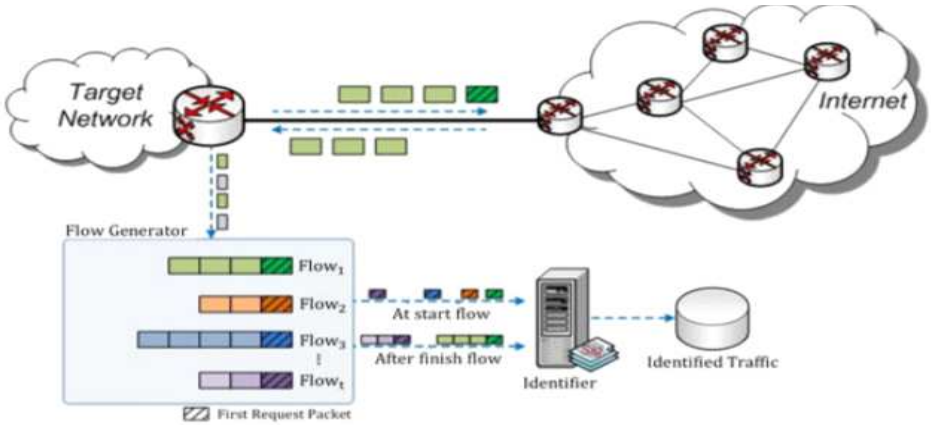
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 주요 논문(SCIE 급)

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCI 여부	게재일	IF
1	Effective Behavior Signature Extraction Method using Sequence Pattern Algorithm for Traffic Identification	International Journal of Network Management	Kyu-Seok Shim	18. No.02	영국	John Wiley & Sons, Ltd	SCIE	2018. 03	1.34
2	A Survey of Automatic Protocol Reverse Engineering Approaches, Methods, and Tools on the Inputs and Outputs View	Security and Communication Networks	Myung-Sup Kim	18, ID.8370341	영국	John Wiley & Sons	SCIE	2018. 02	0.90

✓ 논문 1 : Effective Behavior Signature Extraction Method using Sequence Pattern Algorithm for Traffic Identification

- 내용 : 트래픽 패턴추출에 대한 행위 기반 시그니처 모델은 높은 성능을 가지지만 다량의 트래픽에 대해서는 그렇지 않다는 단점을 가지고 있었다. 따라서 본 논문에서는 새로운 시그니처 추출 방법을 제시하여 다량의 트래픽에 대해서도 높은 성능을 가지는 방안에 대해 소개한다.

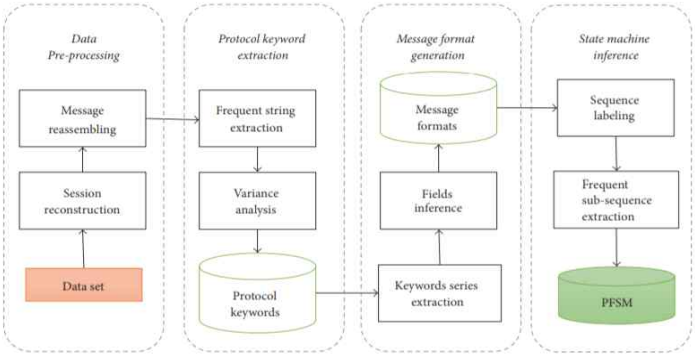


[그림 124] 새로운 행위 기반 시그니처 추출 방법을 통한 Traffic Identification

- 연구 연관성 : FCI 시스템은 기존의 행위 기반 시그니처 추출 알고리즘 보다 더 효율적인 알고리즘을 제시하였고, 제시한 알고리즘을 사용하여 더 정교한 악성 행위 분석을 진행 할 수 있었다.

✓ 논문 2 : A Survey of Automatic Protocol Reverse Engineering Approaches, Methods, and Tools on the Inputs and Outputs View

- 내용 : PRE(Protocol Reverse Engineering)은 처리는 상당히 시간이 많이 소모되며, 정적으로 진행되는 분석이기 때문에 알 수 없는 프로토콜에 대해서는 적용하기 힘들다는 단점이 있다. 따라서 기존의 PRE 보다 더 효율적이고 알지 못하는 프로토콜, 혹은 암호화 되어있거나 동적으로 동작하는 프로토콜 분야에 대해서도 효율적으로 분석 할 수 있는 알고리즘(APRE - Automatic Protocol Reverse Engineering)에 대해 소개한다.



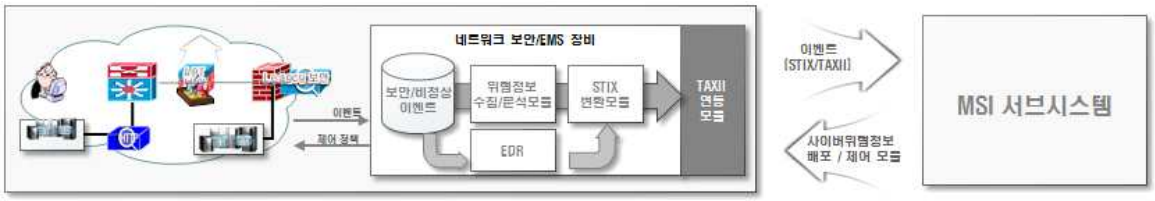
[그림 125] APRE 알고리즘 예시(AutoReEngine) 구조

- 연구 연관성 :본 과제에서는 다양한 악성 행위의 트래픽에 대하여 탐지, 분석 차단하는 통합보안 시스템 구축을 목표로 하고 있다. 특히 최근에는 트래픽이 암호화되어져 있어 트래픽을 정확하고 효율적으로 분석하기 위해서는 기존의 분석 방법보다 개선된 알고리즘이 필요하고, 본 논문에서 소개하는 여러 가지 알고리즘을 사용하여 악성 트래픽 분석을 더 효율적으로 진행 할 수 있었다.

(3) WP-C : EDR - 위협대응을 위한 보안솔루션 연동 체계 구축

(가) 연구 개발 목표

○ 이기종 보안 장비들의 보안이벤트를 STIX/TAXII 기반으로 정보 연계하고, 추론된 위협에 효과적으로 대응할 수 있는 단말보안 탐지/대응(EDR) 기술



[그림 126] WP-C 개발 목표

✓ 위협정보 연동을 위한 구성요소 간의 상호 인증기술
✓ 위협정보 표준 포맷(STIX)/교환(TAXII) 모듈 개발(API 활용)
✓ 단말의 위협대응을 위한 EDR 시스템 개발 목표시스템 구성

○ 개발 범위

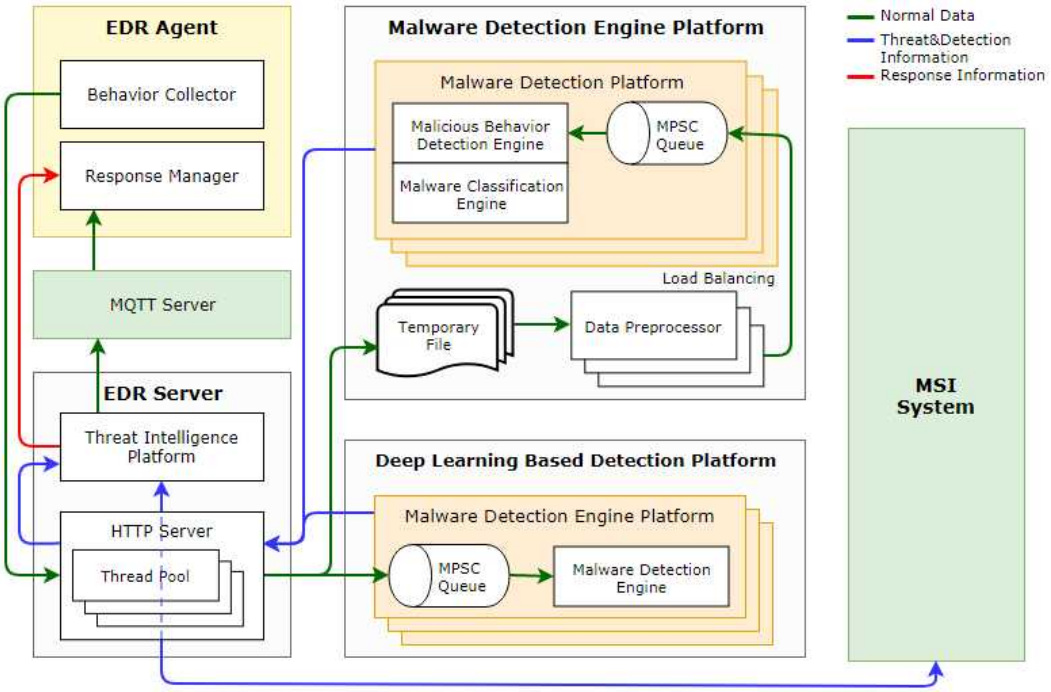
✓ EDR 시스템 개발
✓ 네트워크 보안장비 및 단말 보안장비의 STIX 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(나) (주)소만사 EDR시스템 개발

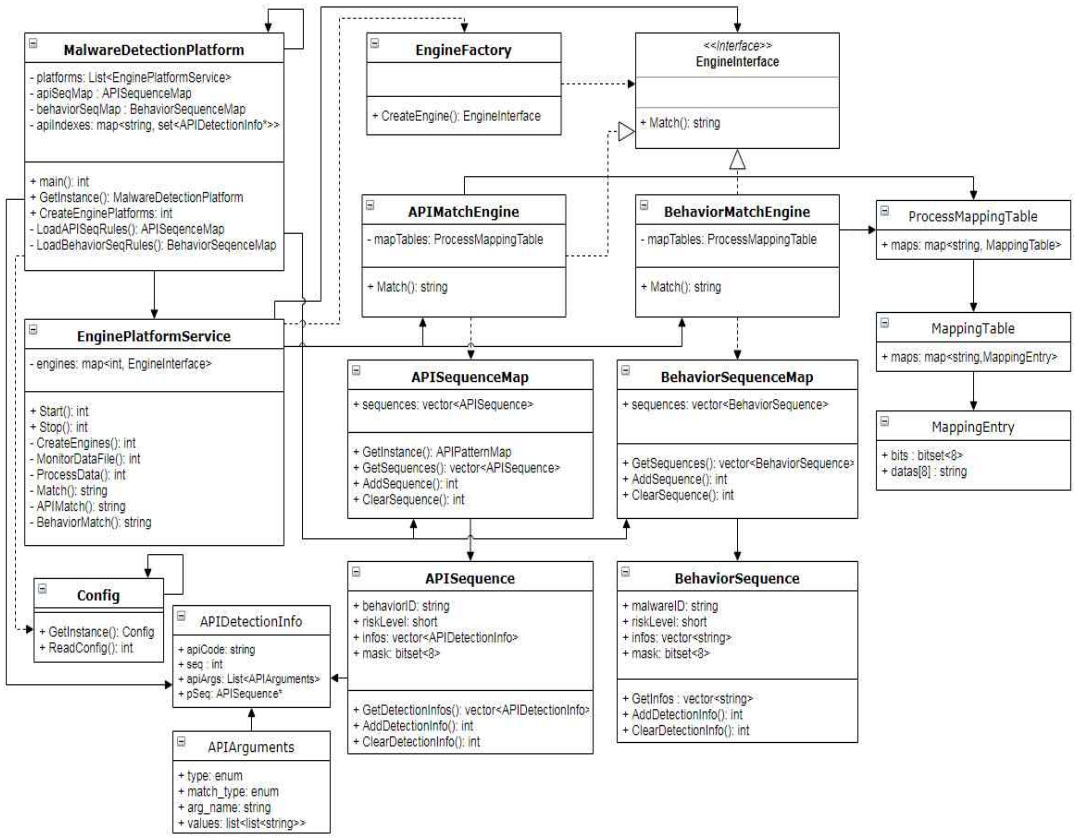
○ 엔드포인트 환경에서의 악성 행위 탐지 및 대응을 위한 EDR 시스템

✓ EDR 시스템 구조



[그림 127] (주)소만사 EDR 시스템 구성도

✓ 모듈별 정보 교환

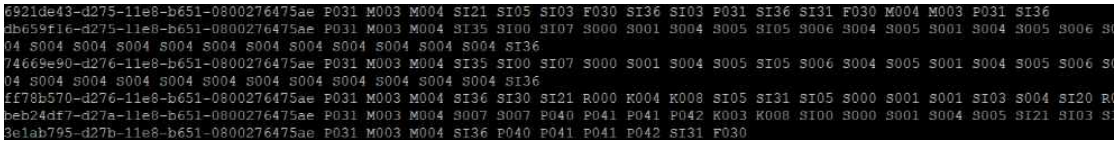


[그림 128] EDR 서버 클래스 설계도

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

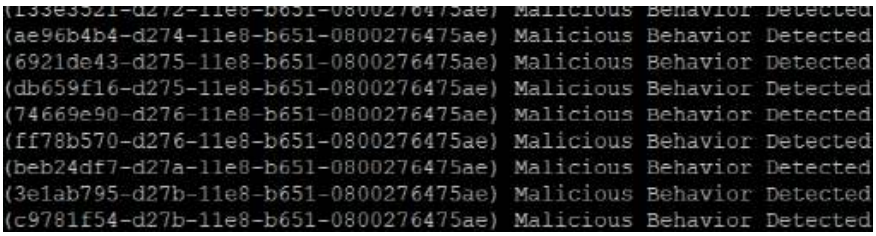
○ 엔드포인트 행위를 대상으로 딥러닝 기반의 악성행위 탐지 개발

✓ 단말의 악성코드의 행위 정보를 수집하여 딥러닝을 위한 학습데이터 생성



[그림 129] 딥러닝 학습데이터

✓ 엔드포인트에서 실행된 행위 중 딥러닝 기반의 악성행위 탐지 확인

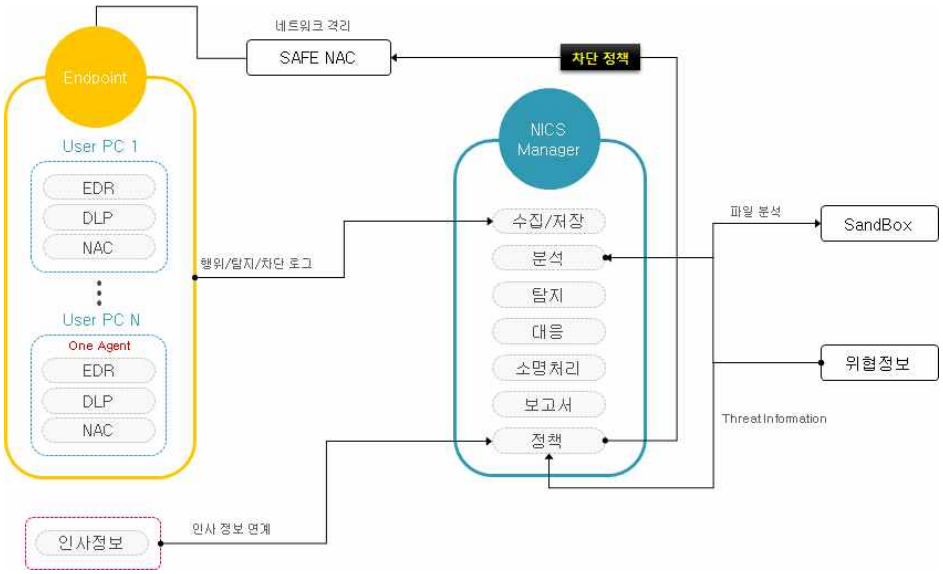


[그림 130] 딥러닝 기반의 악성행위 탐지 로그

✓ 단말 행위 분석 데이터를 기반의 기계학습을 통한 위협 정보 생성 기능 개발

(다) (주) 한류AI센터 EDR시스템 개발

○ 한류AI센터 EDR 시스템



[그림 131] 한류AI센터의 EDR 시스템 개념도

✓ Safe NAC의 Agent 기반으로 EDR 시스템 개발

✓ 기 개발된 NICS 관리서버의 Agent 이벤트 기반으로 비정상 행위 탐지/대응

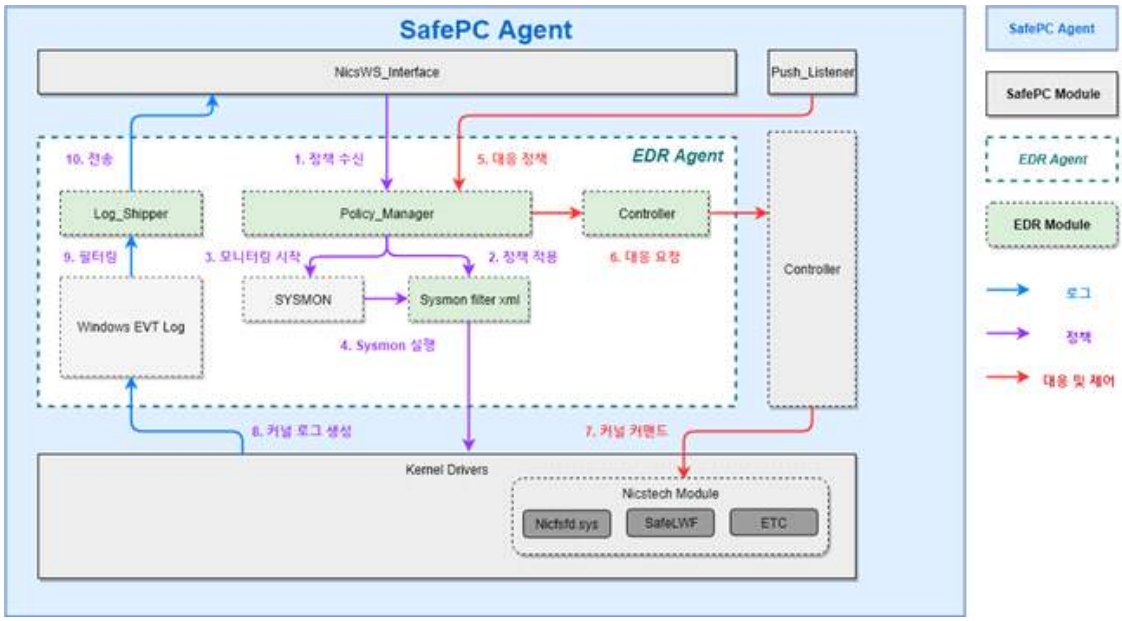
✓ STIX/TAXII 연동을 통해 수집된 위협정보로 학습된 위협에 대응

✓ 자체 SandBox를 통해 연동/수집된 파일에 대한 자체 검증 수행

○ Agent 위협 대응

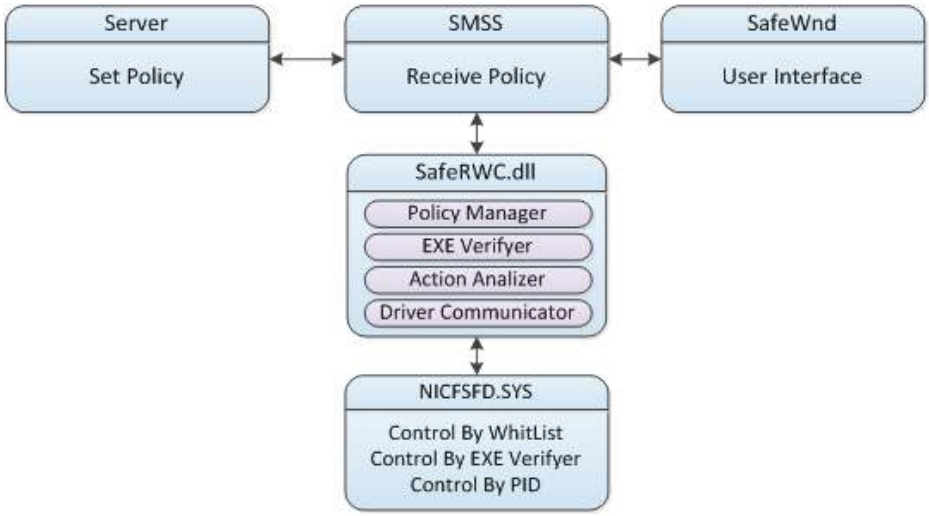
✓ 단말 보안이벤트 수집 agent 및 수집 서버 개발, 정책에 의한 단말 제어(IP/HASH 차단) 모듈 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 132] Agent 모듈 개념도

✓ Agent 정책 관리 서버 개발



[그림 133] Agent 정책 관리 서버 모듈

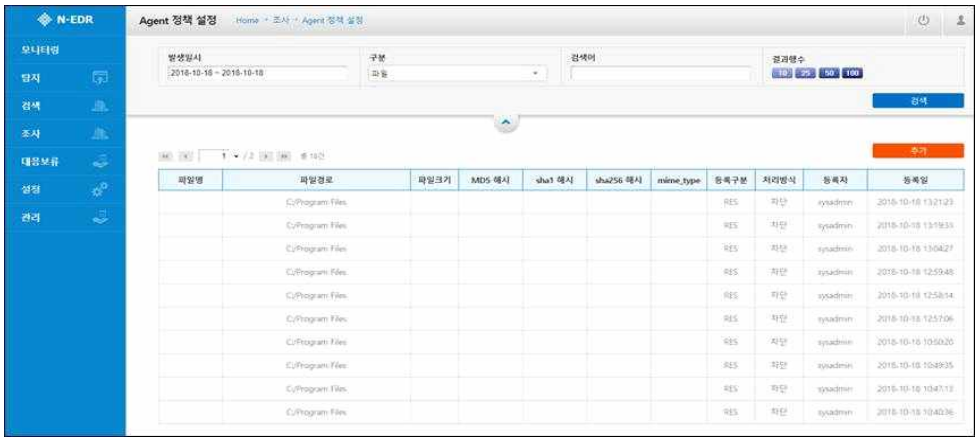
○ EDR 대응 시스템

✓ EDR 에이전트의 대응 및 관리 그리고 평판 기반의 악성행위 차단 서비스 개발

✓ 관리 서버는 에이전트에 대한 설치 및 운영 그리고 해당 로그에 대하여 STIX로 변환 전달하며 STIX의 정보에 따른 대응정책을 수립하여 에이전트에 전송하여 악성행위에 대하여 대응 기능 제공.

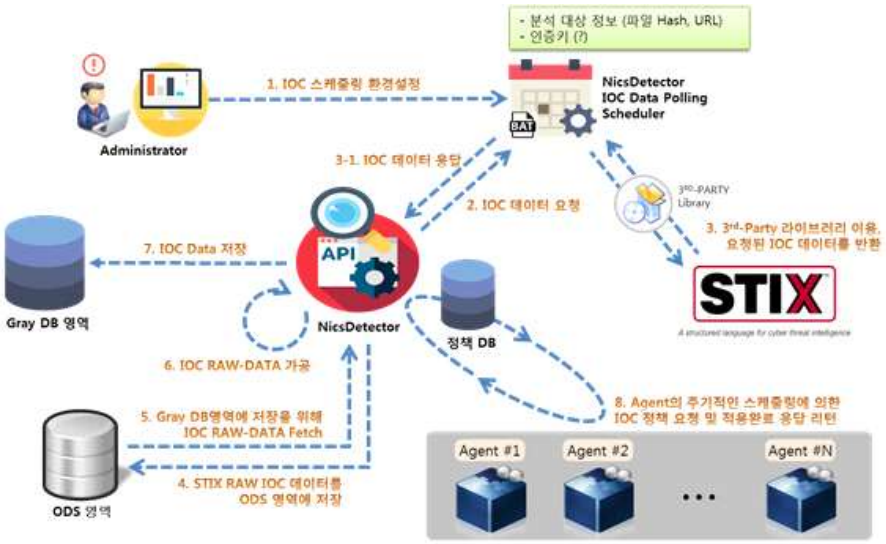
- 단말 관리 및 정책 설정을 위한 관리서버(웹) 개발
- 관리서버(UI)와 MSI 연동서버 분리로 기능성 증대 및 성능향상
- 정책설정 화면 예)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 134] 한류AI센터 EDR의 정책설정

○ STIX/TAXII 2.0 연동



[그림 135] NICS 서버의 STIX/TAXII 연동

✓ STIX/TAXII 연동은 NICS 관리서버에서 수행함(주기적인 Polling 방식)

✓ 수집된 위협정보(파일해시, URL)를 활용하여 Agent 정책관리 서버에 제공하여 Agent에 정책 제공

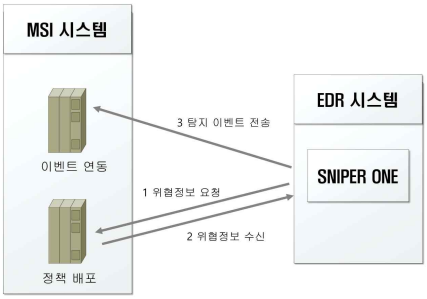
✓ 주요 이벤트는 STIX/TAXII 2.0 기반으로 연동

(라) 네트워크보안 제품군 연동시험

○ 윈스 SniperONE 시제품

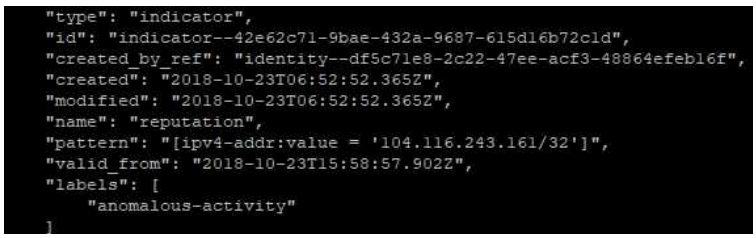
✓ MSI 시스템과의 위협 정보 연동을 위한 정보 흐름 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



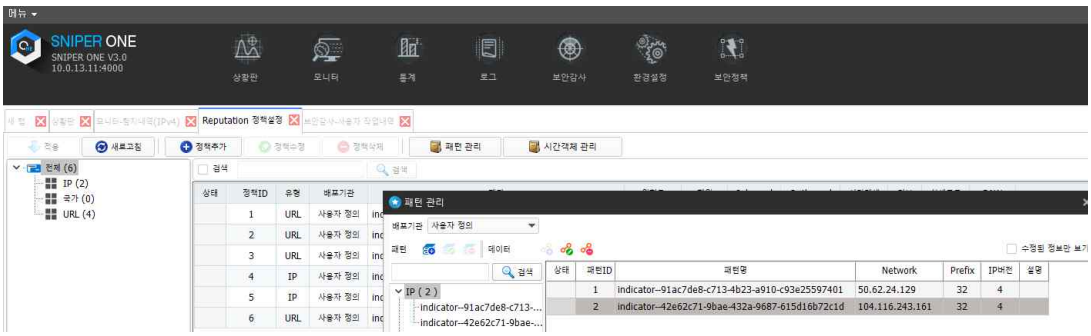
[그림 136] 위협정보 처리 흐름도

✓ MSI 시스템에서 위협정보를 수신함을 확인



[그림 137] SniperONE 위협정보 본문

✓ 수신된 위협정보를 분석하여 탐지 정책을 생성하고 정책이 적용됨을 확인



[그림 138] SniperONE 위협정보 분석 및 정책 적용

✓ 엔드포인트 에이전트에서 수신한 대응 정보를 이용하여 해당 IP의 트래픽이 탐지 되는 것을 확인

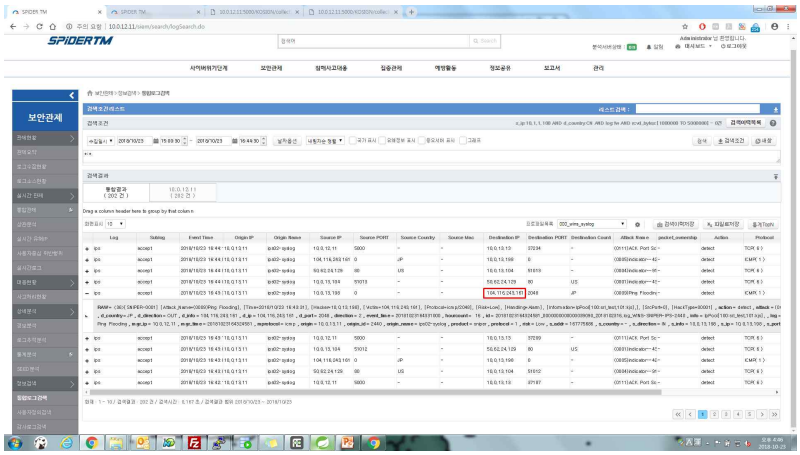


[그림 139] SniperONE 대응정보를 이용한 트래픽 탐지

✓ 엔드포인트의 대응 결과 정보를 MSI 시스템으로 전송 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 윈스 - Sniper ONE에서 탐지됨



[그림 140] Sniper ONE MSI 시스템 대응 결과 전송

○ 시큐아이 MF2 시제품

✓ 연구개발 내용

- TAXII 연동 API를 이용하여 MSI로부터 정책 정보를 가져오는 기능 개발
- STIX기반의 위협 정보에서 IP 정보를 추출하여 방화벽 블랙리스트에 등록하는 기능 개발
- 등록한 IP 정보에 매칭하는 이벤트가 발생 시 해당 이벤트 정보를 syslog를 통해 MSI 서버에 전송하는 기능 개발

✓ 연구개발 기능의 성과

- 위 기능을 MF2 방화벽에 탑재하여 MSI와 연동하면, CTI에서 생성하여 MSI에 전달한 위협 대응 정보가 자동적으로 MF2 방화벽 블랙리스트 정책에 입력되어 위협에 대한 신속한 대응이 가능하다.

✓ 연동 시험

- MSI와의 위협 정보 연동: CTI에서 입력한 위협 정보를 MSI와 연동을 통해 방화벽 블랙리스트에 등록



[그림 141] MF2의 위협정보 연동 및 BL 등록

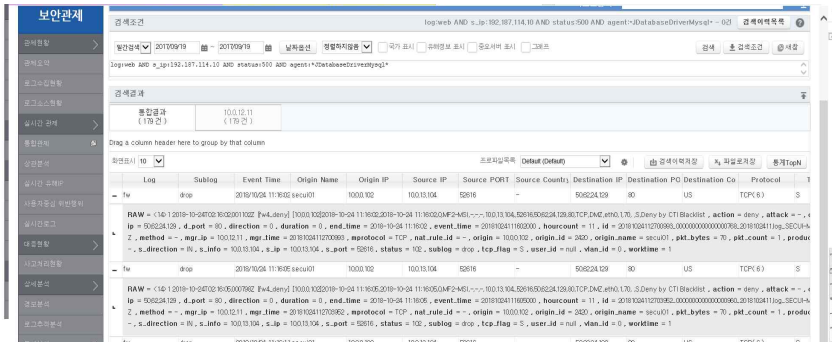
- 위협 정보에 대한 이벤트 연동: 연동을 통해 발생한 이벤트를 syslog로 MSI에 전송
  => 파이어월은 발생되는 모든 세션 이벤트 및 차단이벤트까지 다양한 종류의 이벤트를 STIX/TAXII로 보내기에는 부하가 많아서, 이벤트 정보는 Syslog로 전송하는 것이 타당하다고 판단됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



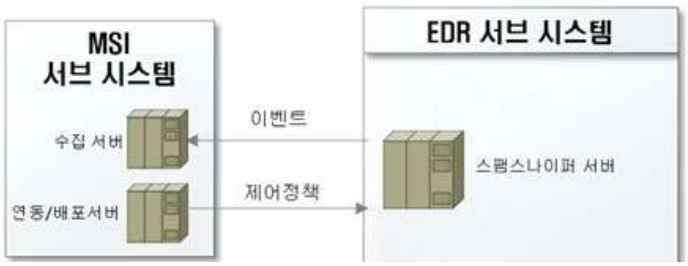
[그림 142] MF2의 이벤트 연동

▪ MSI와 이벤트 연동 결과



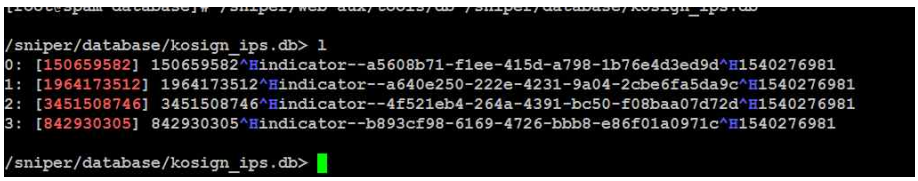
[그림 143] MF2의 MSI 연동

○ 지란지교 SpamSniper 시제품



[그림 144] SpamSniper 연동 시험

✓ 위협대응 정책 연동



[그림 145] SpamSniper 위협정보 연동

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 정책 등록 화면

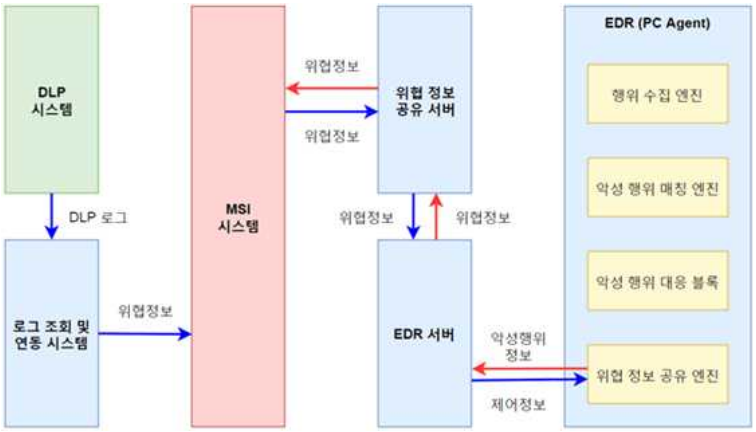


[그림 146] SpamSniper 필터로 차단된 이벤트 확인

(마) 단말보안 제품군 연동시험

○ 소만사 EDR 연동

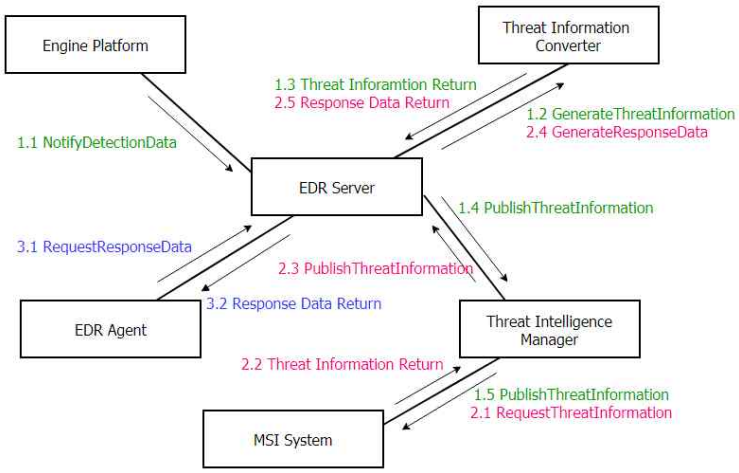
✓ 단말의 위협대응을 위한 STIX/TAXII 기반의 EDR 시스템 연동



[그림 147] 참여기관 소만사 EDR연동

- DLP 시스템으로부터 DLP 로그를 조회 & 분석하여 STIX 2.0 형식의 위협 정보로 변환하여 TAXII 2.0 API를 이용하여 MSI 시스템으로 공유
- 엔드포인트 대응 기능 개발을 위한 MSI 시스템과의 위협 정보 연동을 위한 정보 흐름 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 148] 위협정보 처리 흐름도

✓ MSI 시스템에서 위협정보를 수신 확인



[그림 149] 위협정보 수신 로그



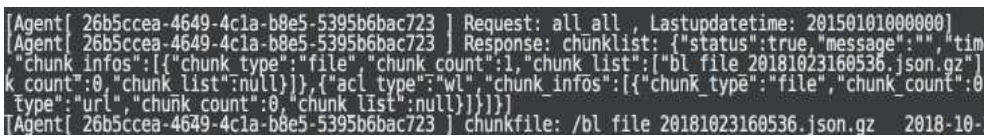
[그림 150] 위협정보 본문

✓ 수신된 위협정보를 분석하여 대응 정보를 생성하고 업데이트 파일을 생성 확인



[그림 151] 위협정보 분석 및 업데이트 파일 생성 로그

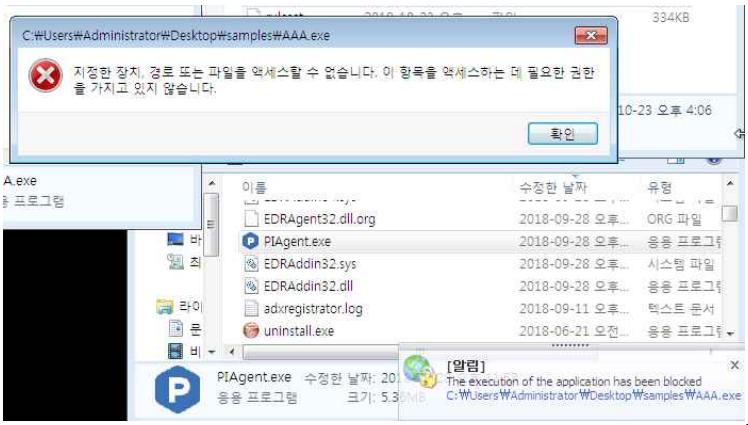
✓ 생성된 대응정보 업데이트 파일을 엔드포인트 에이전트로 배포 확인



[그림 152] 대응정보 업데이트 파일 배포 로그

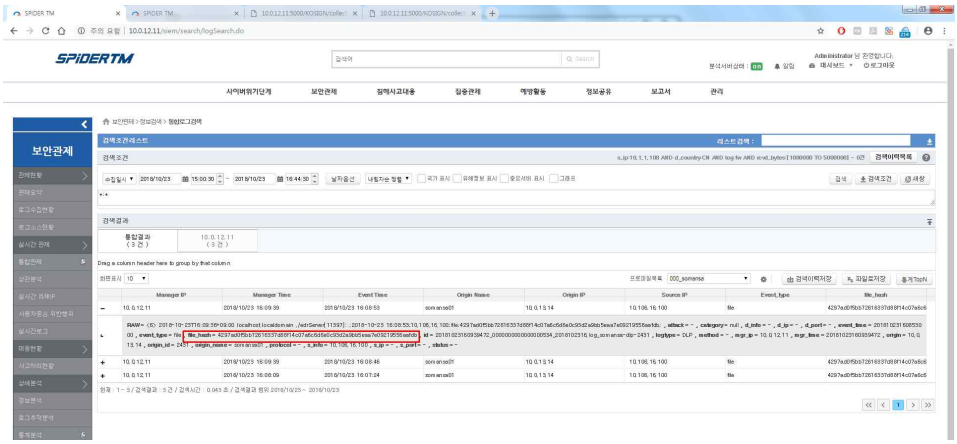
✓ 엔드포인트 에이전트에서 수신한 대응 정보를 이용하여 해당하는 악성코드가 정상적으로 실행 차단되는 것을 확인

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 153] 대응정보를 이용한 악성코드 실행 차단

✓ 엔드포인트의 대응 결과 정보를 MSI 시스템으로 전송 확인(대응 파일 해시(SHA256)로 확인)

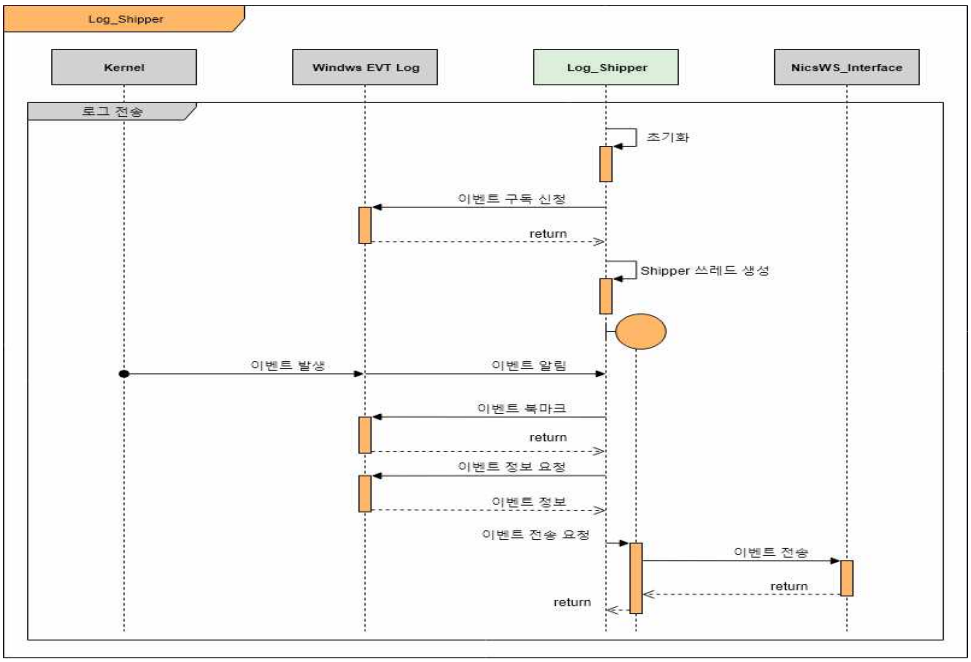


[그림 154] MSI 시스템으로 대응 결과 전송

○ 한류AI센터 (구 바이오닉스진)

✓ STIX/TAXII 2.0 API와 이벤트 생성 설계서를 기준으로 보안이벤트 생성

- Microsoft sysinternal Sysmon 을 통해 수집된 Windows 이벤트 로그를 연동서버(NicsWS) 로 전송
- 연동서버는 전송된 이벤트를 STIX 포맷으로 변환하여 MSI 전송



[그림 155] Log_Shipper 이벤트 연동

- 관련 이벤트 ID

이벤트 ID	의미	비고
1	Process Creation	프로세스 생성
2	A Process change a file create time	파일 접근 시간 변경
3	Network Connection	네트워크 접근 (IP/PORT)
4	Sysmon service state changed	Sysmon service 상태 변경
5	Process terminated	프로세스 종료
7	Image Loaded	DLL 로드
11	File Create	파일 생성 (접근)
12	Registry Event (Object create and delete)	레지스트리 생성/삭제
13	Registry Event (Value set)	레지스트리 값 설정

[표 9] Log_Shipper 이벤트 아이디 종류

- 단말의 비정상 판단을 위한 위협지표 관련된 단말 상태정보까지 선별적으로 수집기능 고도화 (sysmon 필터링 기술을 통해 단말에서 발생하는 이벤트 선별적 수집 가능하도록 에이전트 모듈 고도화)

```
<Sysmon schemaversion="4.00">
  <!--SYSMON META CONFIG-->
  <hashAlgorithms>md5,sha256</hashAlgorithms> <!-- Both MD5 and SHA256 are the industry-standard algorithms for identifying files -->
  <CheckRevocation/> <!-- Check loaded drivers, log if their code-signing certificate has been revoked, in case malware stole one to sign a kernel driver -->

  <!-- <ImageLoad/> --> <!-- Would manually force-on ImageLoad monitoring, even without configuration below. Included only documentation. -->
  <!-- <ProcessAccessConfig/> --> <!-- Would manually force-on ProcessAccess monitoring, even without configuration below. Included only documentation. -->
  <!-- <PipeMonitoringConfig/> --> <!-- Would manually force-on PipeCreated / PipeConnected events, even without configuration below. Included only documentation. -->

  <EventFiltering>

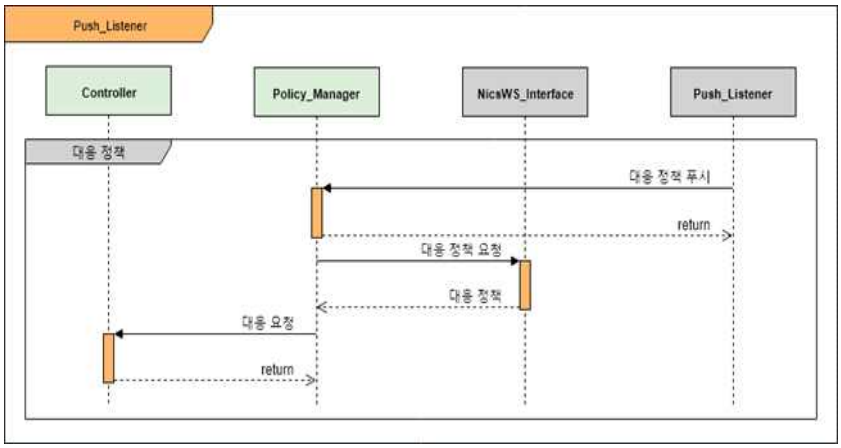

  </EventFiltering>
</Sysmon>
```

[그림 156] 선별적 이벤트 수집

✓ MSI에서 제공하는 위협정보 기준으로 탐지 모듈 기능 고도화

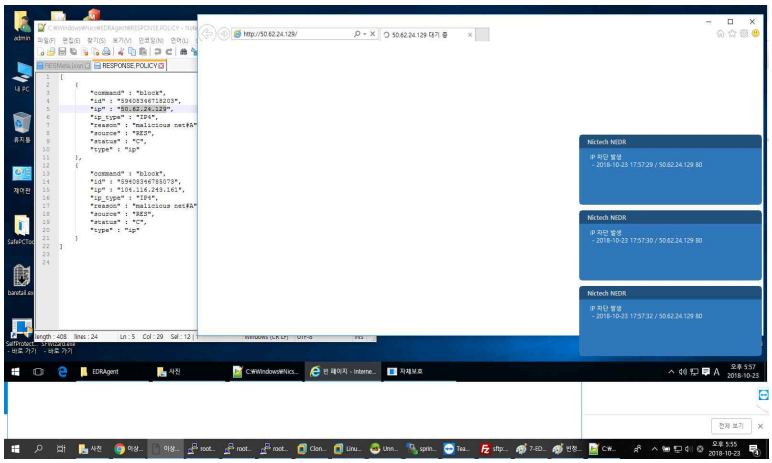
- 연동서버에서 푸쉬로 내려주는 정보를 바탕으로 실시간 대응이 가능하도록 모듈 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



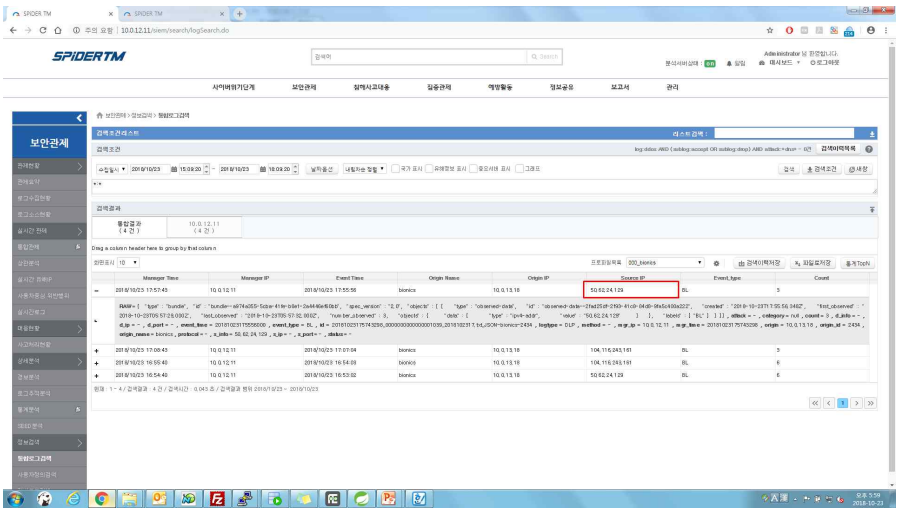
[그림 157] 연동 순서 및 흐름

▪ 서버로부터 실시간 푸쉬 이벤트를 수신하여 수신된 위협정보는 Policy_Manager에 의해 대응정책으로 단말 정책에 반영됨



[그림 158] 정책 연동 및 차단 결과

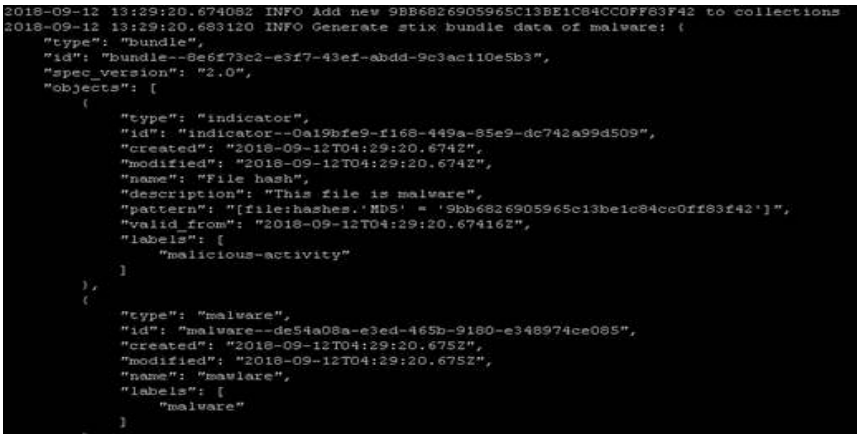
✓ 한류AI센터 - EDR (대응 IP(50.62.24.129)로 확인)



[그림 159] 한류AI센터진 EDR시스템의 MIS 연동 결과

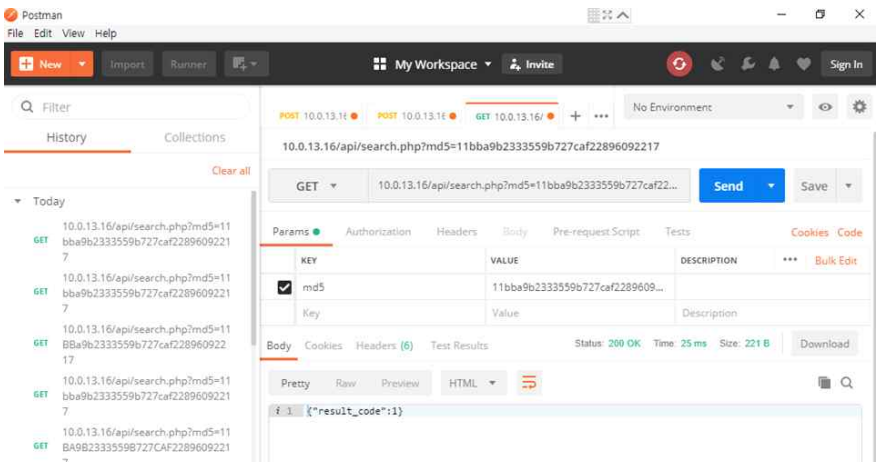
○ 세인트 - 백신 연동

✓ 백신서버는 주기적으로 MSI에 접속하여 악성코드 정보(위협대응 정책)를 체크한후, STIX/TAXII 연동동작 정책을 다운로드 함



[그림 160] 백신서버의 STIX/TAXII를 통해 악성코드 정보 수신

✓ 백신 서버의 정책 업로드 및 Agent 배포



[그림 161] 백신서버의 대응정책 다운로드

✓ 위협정보 대응 기술 개발



[그림 162] 악성코드 실행시 탐지 및 실행방지 화면

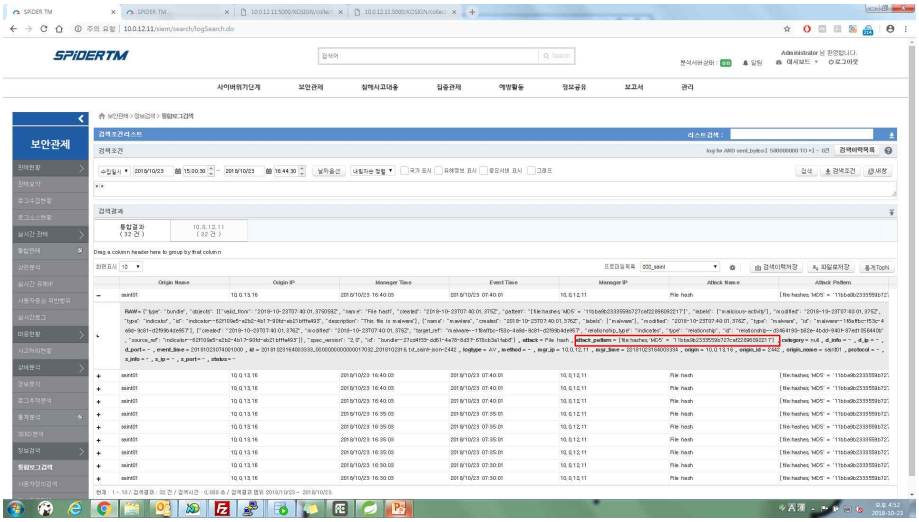
- MSI에서 수신받은 악성코드 정보 기반으로 단말에서 실행되는 파일들의 위협 여부를 검사
- 악성코드로 판단되는 파일이 실행될 경우 탐지하여 실행방지 팝업창으로 알림을 주고 실행을 방지
- 또한, 탐지된 악성코드는 검역소에 격리되어 보관.



[그림 163] 악성파일 격리 화면

✓ 단말에서 탐지된 악성코드는 정보는 STIX/TAXII를 통해 MSI 서버로 전송함 .

: 대응 파일 해시(MD5)로 확인



[그림 164] 백신서버의 MIS 이벤트 연동

(바) 기술개발의 우수성

○ 특허

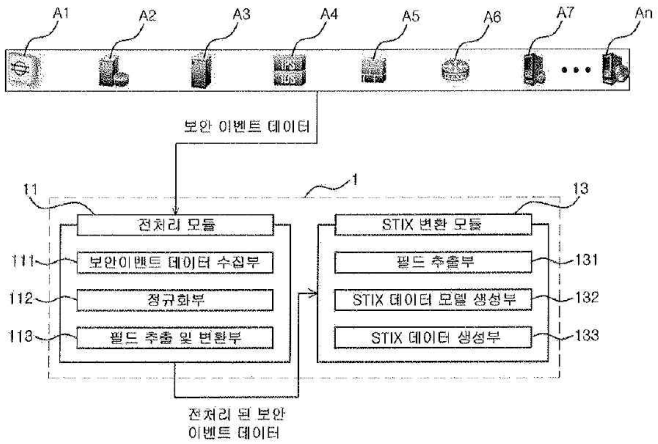
✓ STIX/TAXII 연동분야 특허 출원/등록 리스트

No	특허명	출원인	출원국	출원일	출원번호	등록번호	기여율
1	STIX 변환 장치 및 방법	이글루시큐리티	한국	17.10.19	10-2017-0135939	10-1929522	100
2	엔드포인트 정보유출 추적시스템 및 방법 (SYSTEM AND METHOD FOR TRACKING INFORMATION LEAKAGE AT ENDPOINT)	소만사	한국	18.11.09	10-2018-0134701	-	100
			미국	18.11.28	16/202,618	-	100
3	네트워크 통신 장치 및 방법	시큐아이	한국	18.10.26	10-2018-0129326	-	100
4	자동 개인 아이피 주소 할당 대역에 대한 제어 시스템 및 방법	한류AI센터	한국	18.11.23	10-2018-0146105	10-2103010	100
5	엔드포인트의 비정상 행위를 분석하는 시스	ETRI	한국	18.11.30	10-2018-0153005	-	100

✓ 출원/등록(심사) : STIX 변환 장치 및 방법

▪ STIX형식이 아닌 보안이벤트에 대한 혹과적인 STIX 변환 방법에 대한 특허

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

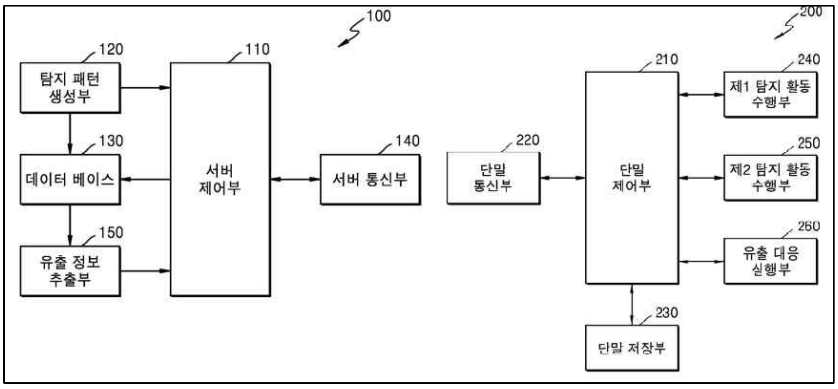


[그림 165] STIX 변환장비 특허 개념도

- 장점 :다양한 보안장비의 효과적으로 STIX형식의 이벤트 생성 방법 제공
- 과제 적용 : 참여기관의 보안장비 및 MSI의 STIX 이벤트 수집부 적용

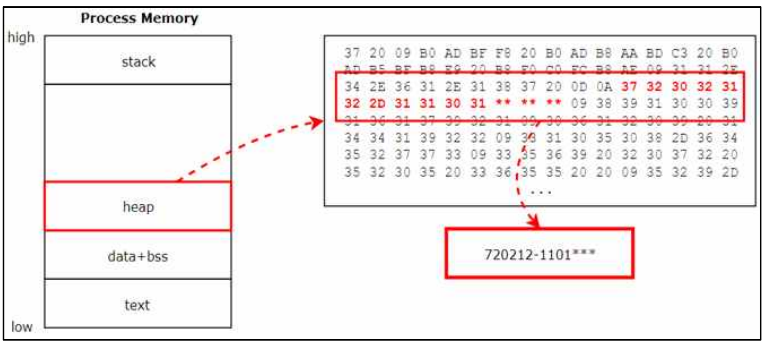
✓ 엔드포인트 정보유출 추적시스템 및 방법(10-2018-0134701, 미국특허 예정)

- 엔드포인트의 행위 및 메모리 감시를 통한 개인정보 등의 정보 유출 탐지 및 시스템 및 방법에 대한 특허로 엔드포인트에서 실행 중인 프로세스의 힙 메모리를 대상으로 주기적으로 검사하여 힙 메모리 내의 개인정보 등의 키워드 패턴 매칭을 통해 정보 유출을 탐지하는 [제1정보유출탐지] 단계와 엔드포인트에서 실행 중인 프로세스의 특정 API의 실행을 모니터링하고 인자 정보를 분석하여 해당 인자가 가르키는 메모리 영역에서 개인정보 등의 키워드 패턴 매칭을 통해 정보 유출을 탐지하는 [제2정보유출탐지] 단계로 이루어지는 것이 주된 특징



[그림 166] 시스템 블록도

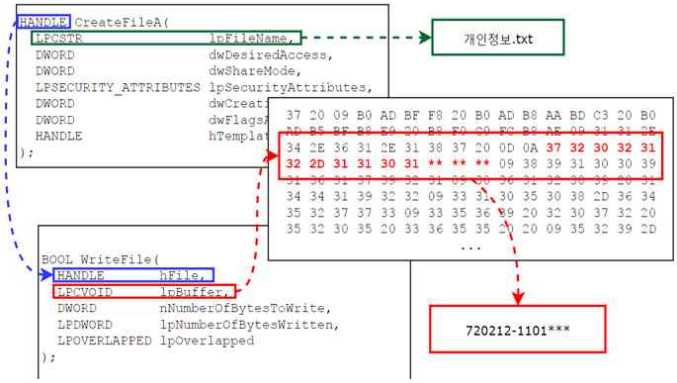
- [제1정보유출탐지] 특정 프로세스 힙 메모리 영역의 개인정보 패턴 탐지



[그림 167] 힙 메모리에서의 개인정보 탐지

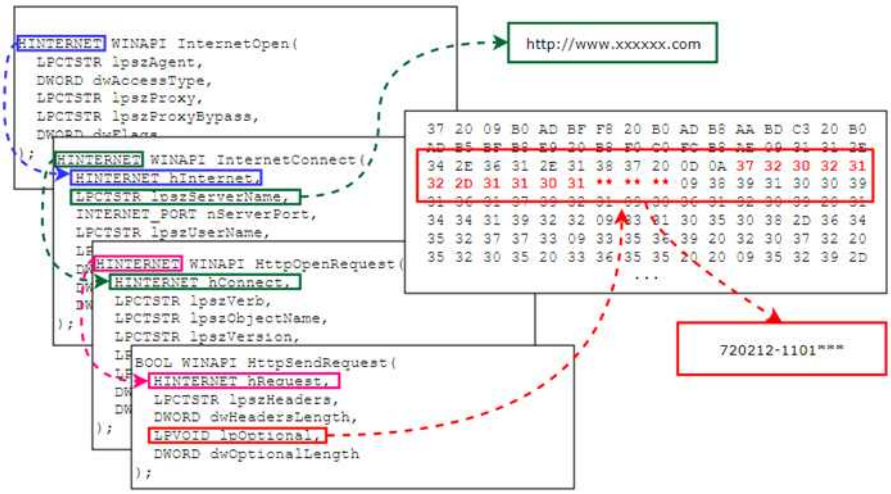
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

- [제2정보유출탐지] 파일 저장 관련 API를 모니터링하고 해당 인자를 분석하여 개인정보를 탐지



[그림 168] 파일 저장 API를 이용한 개인정보 탐지

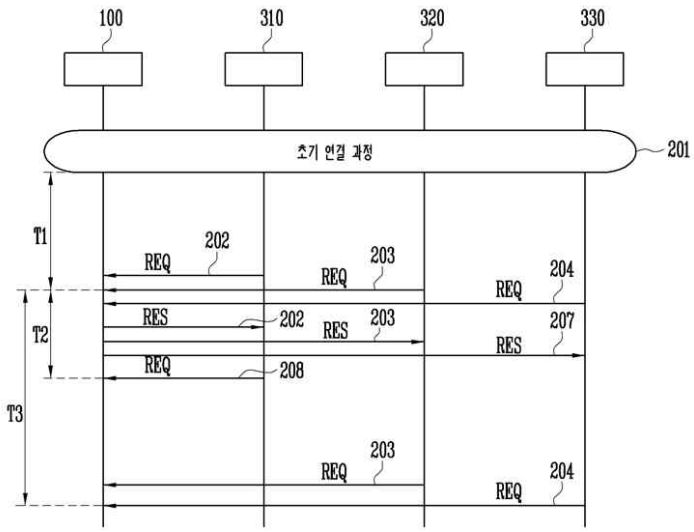
- [제2정보유출탐지] 인터넷 전송 관련 API를 모니터링하고 해당 인자를 분석하여 개인정보를 탐지



[그림 169] 인터넷을 통한 개인정보 탐지

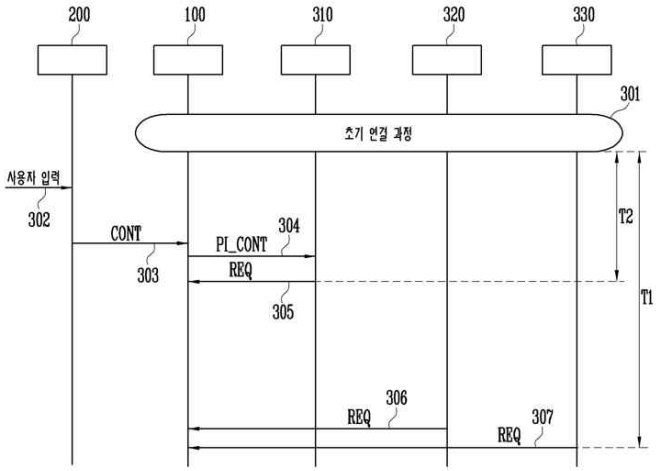
✓ 네트워크 통신 장치 및 방법

- 네트워크 통신 장치의 최초 폴링 응답 시간을 최소화할 수 있도록 하는 방법으로 MSI와 연동 기능에 응용할 수 있는 방법



[그림 170] 폴링응답시간 최소화

✓ 문의 메시지(REQ)에 대한 응답 메시지(RES)에 폴링 제어 명령을 같이 내려 네트워크 통신 장치의 폴링 간격을 제어하는 방법



[그림 171] 폴링간격 제어 방법

- 효과 : 사용자 입력에 대한 제어 메시지가 통신 장치에 전달되면 각 네트워크 통신 장치들은 근시간 내에 데이터 수집이 있을 것으로 예상되므로 폴링 간격을 감소하도록 함

✓ 네트웍 차단 기능 고도화 (특허 출원중) = 한류AI센터 진

- 자동 개인 IP 주소(APIPA) 환경에서는 서브넷 자체에서 네트웍 사용에 대한 접근제어가 안되는 상태이기 때문에 동일 서브넷의 APIPA를 사용하는 PC간 중요 내부 자료의 이동으로 인해 정보 유출이 발생하거나, 웜 등의 악성코드에 감염된 PC로 인해 서브넷 상에 악성코드 감염을 발생할 수 있어 이에 대한 차단방법 개발

(4) 표준화

(가) 연구개발 목표

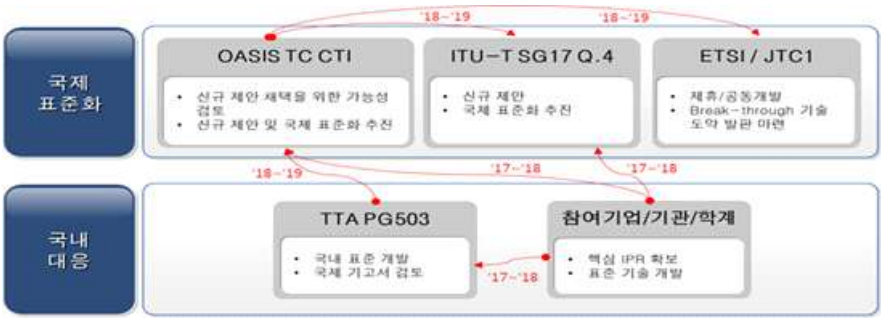
○ 연구목표 :

✓ STIX/TAXII 기반 사이버 위협 분석 정보 연동 프레임워크 표준 개발

○ 표준화 수행 전략

✓ ITU-T SG17 Q4 표준 기고/채택 2건(상반기 표준안 개발 - 국내업체의 개발 이슈 반영)

✓ TTA PG503(사이버보안프로젝트)에 표준 기고/채택 1건과 표준안 제정 1건 (유스케이스 표준 개발)



[그림 172] 표준화 수행 전략

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(나) 연구개발 성과

○ STIX/TAXII 기반 사이버위협 분석정보 연동 프레임워크 개발 (ITU-T, OASIS, TTA)

✓ STIX/TAXII를 이용한 엔드포인트 비정상행위 탐지 및 분석 시스템 관련 특허 1건(출원 심사중)

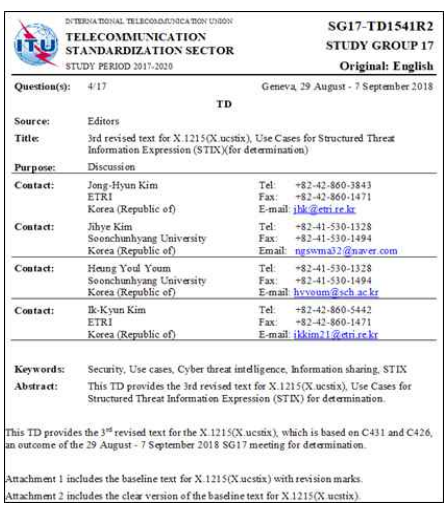
✓ 이기종 보안 이벤트 연동을 위한 STIX/TAXII의 표준 지표 분석 및 Use Case 표준 개발

○ ITU-T 국제표준화

(사이버 위협 정보 교환 표준 권고안 사전채택) 구조화된 위협 정보 표현 규격(STIX)에 대한 유스케이스 권고안(X.1215) 사전채택(determination)

✓ 관련분야 해당 기고서

- Proposal for the 3rd revised text for X.ucstix, Use Cases for Structured Threat Information Expression (STIX) (STIX 유스케이스에 대한 3차 수정 텍스트 제안)
- Proposal for an additional STIX 2.0 use case for X.ucstix, Use Cases for Structured Threat Information Expression (STIX) (STIX 이용 사례 (X.ucstix) 추가 제안)



INTERNATIONAL TELECOMMUNICATION UNION
TELECOMMUNICATION STANDARDIZATION SECTOR
STUDY PERIOD 2017-2020

SG17-TD1541R2
STUDY GROUP 17
Original: English

Question(s): 4/17 Geneva, 29 August - 7 September 2018

TD

Source: Editors

Title: 3rd revised text for X.1215(X.ucstix), Use Cases for Structured Threat Information Expression (STIX)(for determination)

Purpose: Discussion

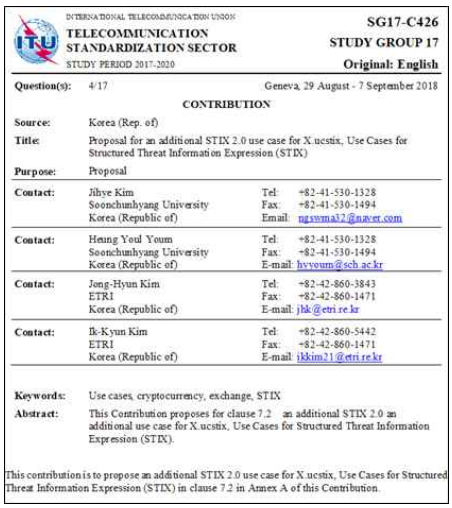
Contact:	Jong-Hyun Kim ETRI Korea (Republic of)	Tel: +82-42-860-3843 Fax: +82-42-860-1471 E-mail: jhk@etri.re.kr
Contact:	Jihye Kim Soonchunhyang University Korea (Republic of)	Tel: +82-41-530-1328 Fax: +82-41-530-1494 Email: ngswma32@naver.com
Contact:	Heung Youl Youm Soonchunhyang University Korea (Republic of)	Tel: +82-41-530-1328 Fax: +82-41-530-1494 E-mail: hyyoum@sch.ac.kr
Contact:	Ik-Kyun Kim ETRI Korea (Republic of)	Tel: +82-42-860-5442 Fax: +82-42-860-1471 E-mail: ikkim21@etri.re.kr

Keywords: Security, Use cases, Cyber threat intelligence, Information sharing, STIX

Abstract: This TD provides the 3rd revised text for X.1215(X.ucstix), Use Cases for Structured Threat Information Expression (STIX) for determination.

This TD provides the 3rd revised text for the X.1215(X.ucstix), which is based on C431 and C426, an outcome of the 29 August - 7 September 2018 SG17 meeting for determination.

Attachment 1 includes the baseline text for X.1215(X.ucstix) with revision marks.
Attachment 2 includes the clear version of the baseline text for X.1215(X.ucstix).



INTERNATIONAL TELECOMMUNICATION UNION
TELECOMMUNICATION STANDARDIZATION SECTOR
STUDY PERIOD 2017-2020

SG17-C426
STUDY GROUP 17
Original: English

Question(s): 4/17 Geneva, 29 August - 7 September 2018

CONTRIBUTION

Source: Korea (Rep. of)

Title: Proposal for an additional STIX 2.0 use case for X.ucstix, Use Cases for Structured Threat Information Expression (STIX)

Purpose: Proposal

Contact:	Jihye Kim Soonchunhyang University Korea (Republic of)	Tel: +82-41-530-1328 Fax: +82-41-530-1494 Email: ngswma32@naver.com
Contact:	Heung Youl Youm Soonchunhyang University Korea (Republic of)	Tel: +82-41-530-1328 Fax: +82-41-530-1494 E-mail: hyyoum@sch.ac.kr
Contact:	Jong-Hyun Kim ETRI Korea (Republic of)	Tel: +82-42-860-3843 Fax: +82-42-860-1471 E-mail: jhk@etri.re.kr
Contact:	Ik-Kyun Kim ETRI Korea (Republic of)	Tel: +82-42-860-5442 Fax: +82-42-860-1471 E-mail: ikkim21@etri.re.kr

Keywords: Use cases, cryptocurrency, exchange, STIX

Abstract: This Contribution proposes for clause 7.2 an additional STIX 2.0 an additional use case for X.ucstix, Use Cases for Structured Threat Information Expression (STIX).

This contribution is to propose an additional STIX 2.0 use case for X.ucstix, Use Cases for Structured Threat Information Expression (STIX) in clause 7.2 in Annex A of this Contribution.

[그림 173] ITU-T SG17 표준기고서 2건 제안

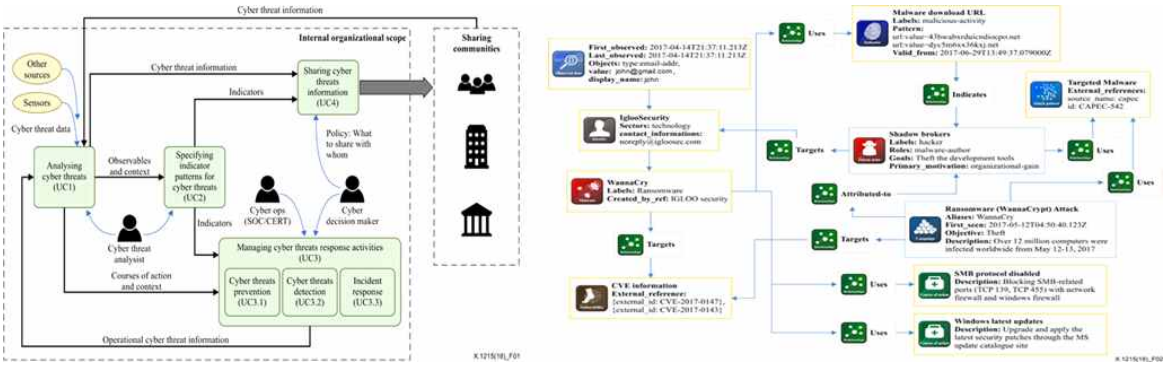
✓ ITU-T 국제표준화 진행 경과

- 2017년 3월 ITU-T SG17 회의에서 우리나라는 사이버 위협 정보 공유와 사이버 위협 분석을 신속히 처리할 수 있는 사이버 위협 정보 표현 규격(STIX)에 대한 유스케이스를 제시하는 신규 권고안(X.ucstix)을 제안하여 채택됨
- 2018년 3월 ITU-T SG17회의에서 구조화된 위협 정보 표현 규격(STIX)에 대한 유스케이스 권고안(X.ucstix) 두번째 수정 텍스트를 제안하여 채택됨
- 2018년 8월 ITU-T SG17회의에서 Determination 절차를 진행하기 위하여 문서 전반에 대한 권고안의 내용을 보완하는 세번째 수정 텍스트 및 빗썸 거래소의 해킹사고를 STIX로 표현하는 유스케이스 사례를 제안하여 채택됨

○ ITU-T 국제표준화 주요 내용

✓ 본 표준은 보안 솔루션의 위협탐지 정보를 신속히 공유하고 최근 랜섬웨어 공격대응 정책을 용이하게 수립할 수 있는 STIX의 기능 및 유스케이스를 제공한다.

- STIX의 개념, 구성요소 및 주요 기능 제시
- 랜섬웨어 대응을 위한 STIX 유스케이스 제시
- 암호화폐거래소 공격 대응을 위한 STIX 2.0 유스케이스 제시



[그림 174] STIX 기능 및 유즈케이스

○ ITU-T 국제표준의 목표

✓ 국내 위협 정보 공유 체계 및 사이버위협 대응 방안에 대한 국제 표준화 추진 (現 STIX 국제표준 부재)

✓ 국내 보안 솔루션의 위협 정보 공유時 STIX 연동을 위한 데이터 교환 포맷의 국제표준 준수

✓ ETRI에서 주도적으로 개발하고 있는 X.1215(X.ucstix) 권고안이 차기 SG17 회의(2019.01)에서 최종 승인(Approval)될 예정임

○ ITU-T 국제표준의 활용

✓ 본 과제에서 개발 중인 보안 솔루션 위협 정보 공유API 보급時 활용

✓ 국가기관, 보안수요자(관제센타), 보안산업체 중심의 사이버 위협정보 공유 및 연동 인프라 구축時 활용

- 과기부 : 사이버 위협정보 공유시스템 구축사업시 국내 보안산업제품 연동에 국제 표준(X.1215) 활용
- 연구기관 : 연구기관 자체 사이버 위협정보 공유센타 구축 및 운영을 위한 국제 표준(X.1215) 활용
- 국가 기관의 위협 정보 공유시 효과적인 대응 정책 수립을 위한 국제 표준(X.1215) 활용

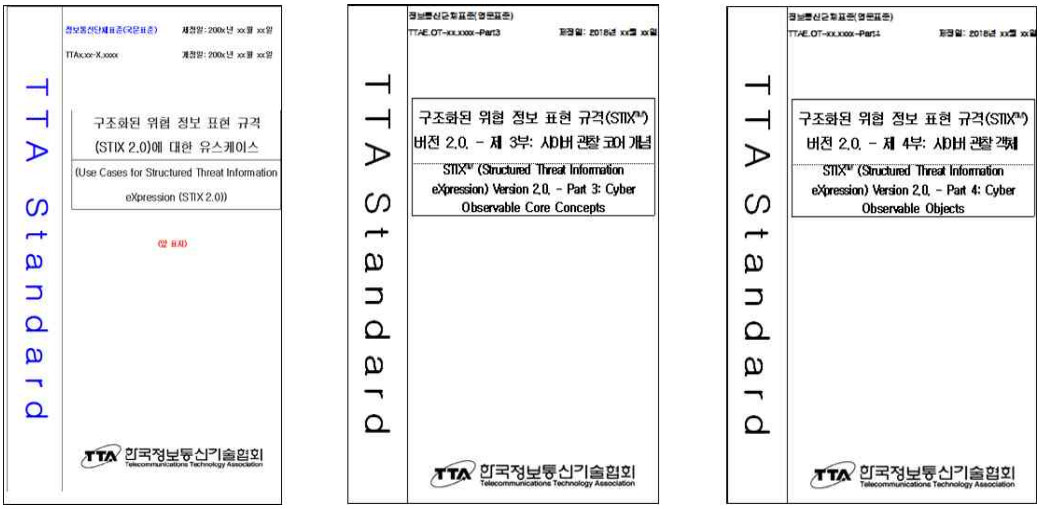
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ TTA 국내표준화

✓ (TTA PG503 신규 과제 채택) 구조화된 위협 정보 표현 규격(STIXTM) 버전 2.0 (제 3, 4부)에 대한 영문표준 과제 채택

✓ 관련분야 해당 기고서

- (과제번호: 2017-666) 구조화된 위협 정보 표현 규격(STIX)에 대한 유스케이스
- (과제번호: 2018-2121) 구조화된 위협 정보 표현 규격(STIX) 버전 2.0 - 제3부 사이버 관측코어 개념
- (과제번호: 2018-2122) 구조화된 위협 정보 표현 규격(STIX) 버전 2.0 - 제4부 사이버 관측 객체



[그림 175] TTA PG503 구조화된 위협 정보 표현 규격(STIX)에 대한 국내 표준 기고서 3건

○ TTA 국내표준화 진행 경과

✓ 2017년 6월 TTA PG503 회의에서 사이버 위협 정보 표현 규격(STIX)에 대한 유스케이스 신규 표준 1건을 제안하여 채택됨

✓ 2018년 5월 TTA PG503 회의에서 구조화된 위협 정보 표현 규격(STIX) 2.0에 대한 신규 영문표준 2건을 제안하여 채택됨

✓ 현재 상기 3건의 표준안에 대한 최종 TTA 의견수렴단계에 있으며, 2018년 12월 중순에 최종 표준안으로 승인될 예정임

✓ 주요 내용

- 본 표준(과제번호: 2017-666)은 사이버 위협 정보 교환을 위한 구조화된 위협 정보 표준 규격(STIX)에 대한 개념, 주요 특성, 및 주요 기능 등을 설명하고, 사이버 위협 분석, 침해 대응 활동, 사이버 위협 정보 교환 등의 전반적인 사이버 위협 관리 체계를 용이하게 수립할 수 있는 다양한 유스케이스를 제시.
- 본 표준(과제번호: 2018-2121)은 이 표준은 멀웨어 특성, 침입 탐지, 사고 대응 및 관리, 디지털 포렌직에 적용하도록 관측 가능 객체와 사이버 도메인의 속성에 대한 구조화 된 표현을 정의.
- 본 표준(과제번호: 2018-2122)은 표준은 STIX(Structured Threat Information Expression) 2.0에서 사용하는 STIX 사이버 관측 객체를 정의하고, STIX 2.0에 포함된 사이버 관측 객체에 대한 기본적인 소비자 및 생산자의 요구사항을 제시함

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

다. 2차년도(2018년) 정량적 연구성과

(1) 목표대비 연구성과

구분			당초계획	실적	비고
특허 출원	국내		8	9	
	국외		2	2	
	계		10	11	
특허 등록	국내		3	4	
	국외		0	0	
	계		3	4	
국외 논문 게재	SCI		2	3	
	비SCI		1	0	
	계		3	3	
국내 논문 게재	SCI		-	-	
	비SCI		2	1	
	계		2	1	
국내 및 국제 학술회의 발표	SCI		-	-	
	비SCI		-	15	
	계		-	15	
국제 표준화	기고서 제출		2	5	
	기고서 채택		2	5	
	표준안 채택		0	0	
국내 표준화	기고서 제출		1	2	
	기고서 채택		1	2	
	표준안 채택		1	3	
기술 이전	계약 건수		2	2	
	계약액		40백만원	40백만원	
	징수액		0	0	
등록·기탁 대상 성과물	보고서 원문		0	0	
	연구시설·장비		0	0	
	기술요약정보		0	0	
	생명자원	생명정보	0	0	
		생물자원	0	0	
		신품종	0	0	
	소프트웨어		7	7	
	화학물		0	0	
인력 양성	학사		0	2	
	석사		0	1	
	박사		0	0	
기타	시제품		6	6	
	상용화		0	50백만원	
	성과 홍보		1	2	
			개발 전	개발 후	
	일자리 창출	연구인력	0명	0명	
		생산인력	0명	0명	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 지식재산권(특허, 실용신안, 의장, 디자인, 상표, 규격, 신품종, 프로그램)

번호	지식재산권 등 명칭 (건별 각각 기재)	국명	출원			등록			특허등급 평가결과	기여율
			출원인	출원일	출원번호	등록인	등록일	등록번호		
1	탐지 규칙 검증을 위한 패킷 생성 방법 및 장치	대한민국	(주)윈스	2018.07.24	10-2018-0086038	윈스	2019.08.09	10-2011603		100
2	악성코드 머신러닝 분류 모델 검증 방법과 그 장치	대한민국	(주)윈스	2018.09.06	10-2018-0106470	윈스	2019.08.07	10-2010468		100
3	네트워크 통신 장치 및 방법	대한민국	(주)시큐아이	2018.10.26	10-2018-0129326	-	-	-		100
4	실행 코드 상의 함수 시그니처 생성 장치 및 방법	대한민국	국민대학교	2018.08.03	10-2018-0090947	국민대학교산학협력단	2020.01.08	10-2066022		100
5	딥 러닝을 이용한 시드기반 악성 트래픽 탐지 방법 및 장치	대한민국	고려대학교	2018.07.30	10-2018-0088477	고려대학교 세종산학협력단	2019.10.08	10-2032249		100
6	공격 빈도, 자산 중요도 및 취약 정도에 따른 위험지수 보정시스템 및 그 방법	대한민국	(주)이글루시큐리티	2018.11.15	10-2018-0140853	이글루시큐리티	2020.03.06	10-2088310		100
7	엔드포인트의 정보 유출 추적 시스템 및 방법	대한민국	(주)소만사	2018.11.05	10-2018-0134701	-	-			100
8	자동 개인 아이피 주소 할당 대역에 대한 제어 시스템 및 방법	대한민국	(주)한류AI센터	2018.11.23	10-2018-0146105	한류에이아이센터	2020.04.14	10-2103010		100
9	엔드포인트의 비정상 행위를 분석하는 시스템	대한민국	한국전자통신연구원	2018.11.30	10-2018-0153005	-	-	-		100
10	구성 요소 기반 악성 파일 유사성 분석 장치 및 방법	대한민국	(주)윈스	2017.10.31	10-2017-0143082	(주)윈스	2018.10.05	10-1907443	B3	100
11	네트워크 플로우의 연관성 모델을 이용한 트래픽 분류	대한민국	고려대학교	2017.08.30	10-2017-0110011	고려대학교	2018.10.31	10-1915908	B1	100
12	STIX 변환 장치 및 방법	대한민국	(주)이글루시큐리티	2017.10.19	10-2017-0135939	(주)이글루시큐리티	2018.12.10	10-1929522	B2	100
13	위험지수 자동 보정 장치 및 방법	대한민국	(주)이글루시큐리티	2017.11.15	10-2017-0152254	(주)이글루시큐리티	2018.12.10	10-1929528	B2	100
14	Multi-pattern policy detection system and method	미국	(주)윈스	2018.09.21	16/138,254	-	-	-		100
15	SYSTEM AND METHOD FOR TRACKING INFORMATION	미국	(주)소만사	2018.11.28	16/202,618	-	-			100

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	LEAKAGE AT ENDPOINT									

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(3) 국내 및 국외 논문 게재

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCI 여부 (SCI/비SCI)	게재일	등록번호
1	Finding Widespread Events with Simple Bitmaps	IEICE trans. on information and systems	MyungKeun Yoon	12	일본	IEICE	SCIE	2018.12	1745-1361 (IF 0.411)
2	Effective Behavior Signature Extraction Method using Sequence Pattern Algorithm for Traffic Identification	International Journal of Network Management	Kyu-Seok Shim	Vol 2018. No.02	England	John Wiley & Sons, Ltd	SCIE	2018.03	1099-1190 (IF 1.340)
3	A Survey of Automatic Protocol Reverse Engineering Approaches, Methods, and Tools on the Inputs and Outputs View	Security and Communication Networks	Myung-Sup Kim	Vol.2018, ID.8370341	England	John Wiley & Sons	SCIE	2018.02	1939-0122 (IF 0.904)
4	심층학습과 악성코드 분석 연구	정보과학회지	정성민	36(2)	한국	한국정보과학회	비SCI	2018.2.	1229-6821

(4) 국내 및 국제학술회의 발표

번호	회의명칭	논문명	발표자	발표 일시	장소	국명
1	2018 International Conference on Information and Communication Technology Convergence (ICTC 2018)	Network Attack Traffic Detection for Calculating Correlation of the Flow	Jee- Tae Park	2018.10.17.~19	Jeju Island Malson Glad Jeju	Korea
2	NOMS 2018-IEEE/IFIP AnNet workshop	"Network Attack Traffic Detection using Seed based Sequential Grouping Model	Jee-Tae Park	2018.04.23	Taipei Taiwan	Taiwan
3	NOMS 2018-IEEE/IFIP DISSECT workshop	Inference of Network Unknown Protocol Structure using CSP(Contiguous Sequence Pattern) Algorithm based on Tree Structure	Kyu-Seok Shim	2018.04.23	Taipei Taiwan	Taiwan

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4	2018 2nd International Conference on Communication and Network Technology (ICCNT 2018)	Automatic Reverse Engineering Method for Extracting Well-trimmed Protocol Specification	Young-Hoon Goo	2018.04.23	Taipei Taiwan	Taiwan
5	2018 한국통신학회 하계종합학술발표회	딥 러닝을 이용한 시드기반 악성 트래픽 연속적 그룹핑	백의준	2018.06.20.~22	신화월드, 제주	한국
6	2018 한국통신학회 하계종합학술발표회	Apriori 알고리즘을 이용한 비공개 프로토콜 구조분석 연구	이민섭	2018.06.20.~22	신화월드, 제주	한국
7	2018 한국통신학회 하계종합학술발표회	자기 조직화 지도(SOM) 기반 실시간 DoS 트래픽 탐지 시스템	신무곤	2018.06.20.~22	신화월드, 제주	한국
8	2018 한국통신학회 하계종합학술발표회	안전한 네트워크 구축을 위한 컨볼루션 신경망 기반 악성트래픽 탐지	지세현	2018.06.20.~22	신화월드, 제주	한국
9	2018 한국통신학회 하계종합학술발표회	프로토콜 리버스 엔지니어링을 위한 객관적 평가 및 검증 방법에 관한 연구	구영훈	2018.06.20.~22	신화월드, 제주	한국
10	2018년 통신망운용관리 학술대회 (KNOM 2018)	통신망 최적화를 위한 기계학습 알고리즘을 적용한 응용 트래픽 분류	지세현	2018.05.10.~11	제주대학교, 제주	한국
11	2018년 통신망운용관리 학술대회 (KNOM 2018)	SOM 알고리즘 기반 DoS 트래픽 탐지	신무곤	2018.05.10.~11	제주대학교, 제주	한국
12	2018년 통신망운용관리 학술대회 (KNOM 2018)	프로토콜 리버스 엔지니어링의 정교한 정적필드 추출 방법 제안	이민섭	2018.05.10.~11	제주대학교, 제주	한국
13	2018년 통신망운용관리 학술대회 (KNOM 2018)	딥 러닝을 이용한 시드 기반 악성 트래픽 탐지	백의준	2018.05.10.~11	제주대학교, 제주	한국
14	2018년 한국통신학회 동계종합학술발표회	효율적인 통신망 관리를 위한 기계학습 알고리즘을 적용한 트래픽 발생량 예측	지세현	2018.01.17.~19	하이원리조트, 강원	한국
15	2018년 한국통신학회 동계종합학술발표회	LSTM 기반 학내 망 트래픽 발생량 예측	백의준	2018.01.17.~19	하이원리조트, 강원	한국

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(5) 표준화

번호	수행 기관명	표준화 주제	표준화 기구	표준화 단계	관련 번호	제출(채택)일	국가
1	한국전자통신연구원	Proposal for the 2nd revised text for X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 채택	C-229	2018.03.23	스위스
2	한국전자통신연구원	The revised text for ITU-T X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 채택	TD1137	2018.03.26	스위스
3	한국전자통신연구원	Proposal for the 3rd revised text for X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 채택	C-431	2018.08.31	스위스
4	한국전자통신연구원	Proposal for an additional STIX 2.0 use case for X.ucstix, Use Cases for Structured Threat Information Expression (STIX)	ITU-T	기고서 채택	C-426	2018.08.31	스위스
5	한국전자통신연구원	3rd revised text for X.1215(X.ucstix), Use Cases for Structured Threat Information Expression (STIX)(for determination)	ITU-T	기고서 채택	TD1541R2	2018.09.05	스위스
6	한국전자통신연구원	구조화된 위협 정보 표현 규격(STIXTM) 버전 2.0 - 제3부: 사이버 관측 코어 개념	TTA	표준안 채택	TTAE.0T-12.0019-Part 3	2018.11.30	한국
7	한국전자통신연구원	구조화된 위협 정보 표현 규격(STIXTM) 버전 2.0 - 제4부: 사이버 관측 객체	TTA	표준안 채택	TTAE.0T-12.0019-Part 4	2018.11.30	한국
8	한국전자통신연구원	구조화된 위협 정보 표현 규격 (STIX 2.0)에 대한 유스케이스	TTA	표준안 채택	TTAK.K0-12.0338	2018.11.30	한국

(6) 기술 거래(이전) 등

번호	기술 이전 유형	기술 실시 계약명	기술 실시 대상 기관	기술 실시 발생일	기술료 (해당 연도 발생액)	누적 징수 현황
1	통상실시권	딥러닝 기반 악성코드 탐지 및 유사도 분석 기술	(주)윈스	2018.11.26	20,000,000	-
2	통상실시권	Seed 기반의 연속적 그룹핑을 통한 악성 트래픽 탐지	(주)이글루시큐리티	2018.11.20	20,000,000	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(7) 사업화 현황

(단위: 명, 년)

번호	사업화 방식	사업화 형태	지역	사업화명	내용	업체명	매출액		매출 발생 연도	기술 수명
							국내	국외		
1	자가실시	기존 제품 개선	국내	국군지휘통신사령부 SPiDER-TM 구축	자사 기존 솔루션인 SPiDER-TM의 정보 수집 구간에 STIX/TAXII 기술 적용	국군지휘통신사령부	50,400	-	2018	-

(8) 저작권(소프트웨어, 서적 등)

번호	저작권명	창작일	저작자명	등록일	등록번호	저작권자명	기여율
1	엔드포인트 기반 악성코드 대응 프로그램	2018.10.12.	(주)세인트시큐리티	2018.10.16.	C-2018-027388	(주)세인트시큐리티	100
2	택시 2.0 라이브러리	2018.08.31.	(주)이글루시큐리티	2018.10.31	C-2018-029733	(주)이글루시큐리티	100
3	엠에프투 스틱디 데몬 (MF2 stixd daemon)	2018.10.01.	(주)시큐아이	2018.11.05.	C-2018-030252	(주)시큐아이	100
4	SpamSniper KOSIGN (스팸스나이퍼 코싸인)	2018.10.01.	(주)지란지교시큐리티	2018.11.06.	C-2018-030553	(주)지란지교시큐리티	100
5	KOSIGN-CTI V0.2 (코사인 악성코드 분석 시스템)	2018.11.07.	(주)윈스	2018.11.13	C-2018-031830	(주)윈스	100
6	엔드포인트 탐지 및 대응 시스템 (EDR V1.0)	2018.11.09.	(주)소만사	2018.11.13	C-2018-032062	(주)소만사	100
7	SafeEDR (세이프이디알)	2018.10.31	(주)한류AI센터	2018.11.19	C-2018-033367	(주)한류AI센터	100

(9) 전문 연구 인력 양성

번호	분류	기준 연도	현황										
			학위별			성별			지역별				
			박사	석사	학사	기타	남	여	수도권	충청권	영남권	호남권	기타
1	신규 입사 연구원	2018	-	1	2	-	2	1	3	-	-	-	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(10) 기타성과

○ 기술문서

번호	기술문서 제목
1	CTI 기능상세설계서
2	MSI 기능상세설계서
3	Agent기반 EDR기능상세설계서
4	기계학습기반 EDR기능상세설계서
5	보안장비 연동 기능상세설계서
6	STIX 2.0 라이브러리 개발자 가이드_v1.0.1
7	TAXII 2.0 라이브러리 개발자 가이드_v1.0.1
8	TAXII Collection 설계 v1.2
9	단위시험(CTI) 결과서 v1.0 (181004)
10	단위시험(MSI) 결과서
11	단위시험(EDR) 결과서
12	종합연동시험
13	표준화 유즈케이스(암호화폐거래소_공격)

○ 시제품

번호	기관명	시제품명
1	(주)세인트 시큐리티	WAX V1.0
2	(주)시큐아이	SECUI MF2 50
3	(주)이글루 시큐리티	SPiDER TM
4	(주)지란지교 시큐리티	SPAM SNIPER KOSIGN
5	(주)윈스	SNIPER ONE
6	(주)한류AI센터	SAFE EDR

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 성과 홍보

✓ 참여기관 (주)지란지교 시큐리티 : 국제사이버시큐리티 컨퍼런스(ISEC 2018)에 참가하여 KOSIGN과제 관련 성과 홍보함(참가일자: 2018.08.30.~31)



[그림 176] ISEC2018 참가 부스 사진

✓ 참여기관 (주)한류AI센터 : eGISEC(전자정부 정보보호 솔루션 페어)에 참가하여 KOSIGN 과제 관련 EDR 연동에 대한 성과 홍보함 (참가일자: 2018.03.15.~17)



[그림 177] eGISEC 성과 홍보 사진

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

2-3. 3차년도(2019년) 수행내용 및 성과

가. 3차년도 연구개발 목표 및 결과

구분(연도)	세부 연구명	세부 연구 목표	연구개발 수행 내용	연구 결과
3차 연도 (2019)	WP-A : CTI (위협정보 분석/공유 서비스 기술 개발)	악성파일 수집	- 기계학습을 위한 악성파일 수집	- 약 7백만개 수집
		실증사업을 위한 CTI 플랫폼 구축	- 실증시험을 위한 군 내부에 CTI 플랫폼 구축	- 수요자(사이버 사령부)의 CTI 기능 시험 완료 - 제품 상용화 진행
		언패킹 해독기술 개발	- 언패킹 분석 기술 확보	- 리얼머신 기반의 동적분석 머신 개발 - 언패킹 기반의 딥러닝 - 학습 모델
	WP-B : MSI (Security Analytics 기반 보안관제 솔루션)	실증사업을 위한 관제 플랫폼 구축	- 실증시험을 위한 군 내부에 MSI 플랫폼 구축	- 수요자(사이버 사령부)의 MSI 기능 시험 완료 - 사업화
	WP-C : EDR (위협대응을 위한 보안솔루션 연동 체계 구축)	실증사업을 위한 보안장비의 STIX 연동	- 실증시험을 위한 군 내부에 네트워크/EDR 보안장비 구축	- 수요자(사이버 사령부)의 연동관련 기능 시험 완료

나. 실증사업

○ 실증 사업를 위한 진행 이력

일자	발표 및 협의 내용	주관/장소	비고
17년 4월	KOSIGN 개발 분야별 (CTI/MSI/EDR) 소개	국방부(지하벙커)	Kick-off 보고(약 50명 참석)
17년 5월	KOSIGN 전체 서비스 소개	계룡대	
17년 6월	KOSIGN 과제 관련 기관 워크샵	곤지암리조트	국방부 관련 담당자 참석
17년 8월	KOSIGN 서비스 소개 및 진행 사항 소개 (2차)	계룡대	국방부 내 KOSIGN 관련 담당자 변경
17년 9월	국방부 담당자와 협의 (2회)	국방부, 사이버사령부	운용협의체 구성 의견 반영 담당자 소개 및 향후 일정 협의
17년 10월	KOSIGN 서비스 소개 및 진행 사항 소개 (3차)	계룡대(육해공)	운용협의체 회의 - KOSIGN 설명 및 구축시 고려사항 수렴
17년 11월	수요기관 요구사항 수렴 및 KOSIGN 서비스 소개 (11월 10일 ~ 20일) - 방식 : 설문, 1:1 interview를 통해 요구사항 수렴 - 대상 : 육군/해군/공군/해병대,사이버사령부/국통사/DIDC		- 취약점/악성코드/네트워크보안 및 서버/DB 담당자와 요구사항 수렴 - 1차 보고서 전달 (12월)
18년 ~4월	실증방안 계획서(안)작성		윈스 및 국방부(이홍석주무관)
18년 5월	수요기관 초정 : 요구사항 조사 결과 보고 및 2차 의견 수렴		과제 워크샵 - 공군참석
18년 6월	KOSIGN 소개 및 실증기관 선정	계룡대(공군 회의실)	공군AFFCCS망 실증 적용성 검토
18년 7월	KOSIGN 소개 및 진행사항 보고	계룡대(육군 회의실)	개발 진행 사항 소개 및 실증기관 선정 요청
18년 10월	KOSIGN 실증기관 선정 (국전원 => 사사)		

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

18년 11월	KOSIGN 실사 및 구축 관련 회의	사이버사령부(507호)	사이버사령부 구축/계획/운용/실증파트 실무자와 업체간 협의 검증망 구축을 위한 실사(2F)
18년 12월	보안대책 관련 실무자 회의		보안대책 계획서 작성 체크사항
19년 2월	실증사업 진행사항 및 일정 체크	국방부,사이버사령부	일정 협의 및 진행 사항 체크
19년 3월	실증사업관련 KICK-OFF회의	국방부 지하벙커	사사팀장님외 공군, 국방부 참석
19년 3월	KOSIGN 실사 및 구축 관련 회의		검증망 구축를 위한 실사(3F)
19년 5월	KOSIGN 워크샵 진행	곤지암리조트	실증사업 개념정의 및 일정협의
19년 5월	보안측정	사이버사령부 3F	안보지원사의 보안측정
19년 ~6월	실증 시험항목 검증 완료	사이버사령부	구축된 검증망 환경에서 시험항목의 적절성 평가
19년 ~8월	실증 시험 진행	사이버사령부	운용자 관점의 실증 시험

○ 실증시험 결과 : 국방부 실증 (19년 7월 8일 ~ 8월 30일)

4284-01-02-19-09

실증시험 결과 종합의견

○ 과제명 : 한국형 사이버위협정보 공유기술(KOSIGN) 연구

○ 실증기간 : '19. 7. 8.(월) ~ 8. 30.(금)

○ 실증장소 : (구)사이버지휘통제센터 3층(실증시험실)

○ 실증위원단 : 상황관리대장 등 6명

구 분	소 속	계 급	성 명	서 명
위원장	작전센터	중령	윤 영 수	윤영수
위 원	작전센터	7급	김 미 선	김미선
위 원	작전센터	8급	김 병 완	김병완
위 원	체계개발단	소령(진)	김 희 록	김희록
위 원	체계개발단	상사	이 은 경	이은경
간 사	기획과	5급	박 창 욱	박창욱

○ 실증결과

실증 항목		실증기관 검토의견	실증 결과
1. 개발체계 설치 및 초기자료 구축		○의견 없음	충 족 : 7 미 달 : 0 소결함 : 0
2. 품질요소(기능) 만족도		○(소결함) 3-1-4, 위협대응정책에 배포정보 요약하여 제공 ○(추가의견) 2-1-2, CTI 행위지표에 분석정보 팝업 표시 ○(추가의견) 3-1-2, 대시보드에 기간설정 기능 추가	충 족 : 15 미 달 : 0 소결함 : 1
3. 통합 연동 운용 가능성		○의견 없음	충 족 : 5 미 달 : 0 소결함 : 0
4.적합성 검토의견	상호운용성	○군내 침해지표 및 정책적용 정보를 효과적으로 보여주지 못하여 추가적인 확인 작업이 필요 ○군 특성을 고려하여 침해지표 및 정책적용을 위한 자동화 및 사용자 인터페이스 개선이 필요	
	적용가능성	○각종 보호체계가 연동표준화를 구현하도록 시기 검토 필요 ○KOSIGN 도입시 사전 ISP를 통해 장비성능/요구기능(작전체계 연동여부 등) 세부 판단 필요	
종합의견		○KOSIGN은 정보보호체계의 영역별 설치·운용으로 인한 비효율적 자원/인력 부담 가중을 줄이기 위한 솔루션으로 반드시 필요함 ○군내에서 운용중인 기존 정보보호체계와 KOSIGN 설치시기의 조정이 필요 ○정/오탐 판단 및 정책배포를 위한 별도의 전문 운영인력 운용, 정보보호 시장의 연동 표준화 기술 성숙도, ISP를 통한 사업 안전성, 사령부 및 각 군 방호센터 등 체계 운영을 위한 인력 확보 방안이 선행되어야 함	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

다. 워크패키지별 상세 연구수행 내역

(1) WP-A : 실증기관 CTI (위협정보 분석/공유 서비스 기술 개발) 시스템 구축

(가) 악성파일 수집

수집시기	전체 파일 개수	전체 데이터 규모	설명
2017	7,019,782	약 2.1TB	무료 + 유료 수집 채널
2018	7,108,497	약 4.0TB	유료 수집 채널
2019	15,879,152	약 5.4TB	유로 수집 채널
합계	30,007,431	약 9.5TB	

(나) 실증사업

○ CTI 플랫폼 실증기관 요청사항 개발

✓ 운용자가 직관적으로 판단할 수 있도록 관련된 수치를 100% 방식으로 표기 요청



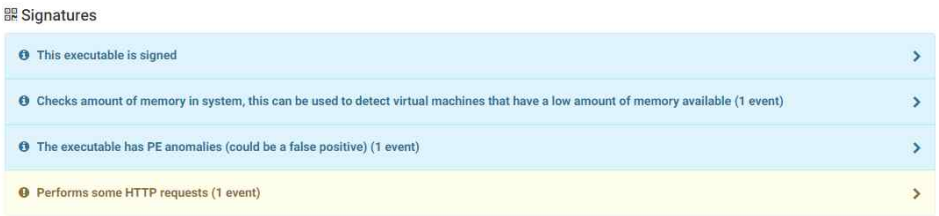
✓ 분석결과를 쉽게 판단하기 위한 지표 제공



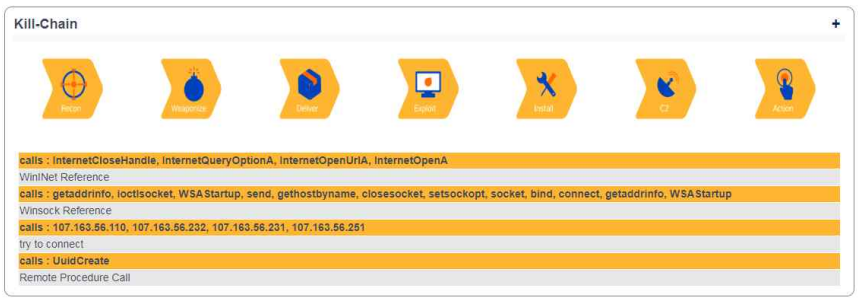
✓ 침해 상태에 대한 요약정보 제공



✓ 중요 행위지표에 분석정보 팝업 제공 (Top-Down 방식 접근 요청)



✓ 악성코드의 분석된 결과는 Kill-chain 기반의 상세 분석정보 제공



✓ Anti-Virus 내장 엔진 분석 결과 제공 (폐쇄망 CTI 환경에서도 제공)

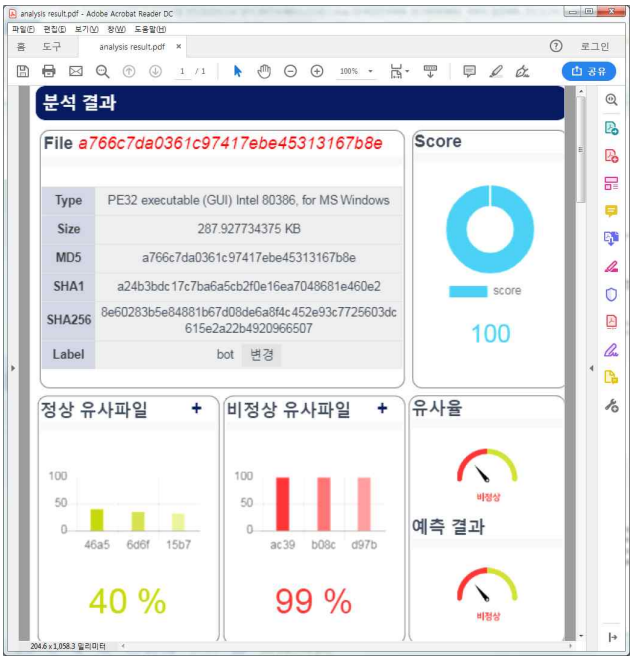


✓ STIX 분석 정보를 팝업방식으로 제공하여 상세한 정보 표기

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



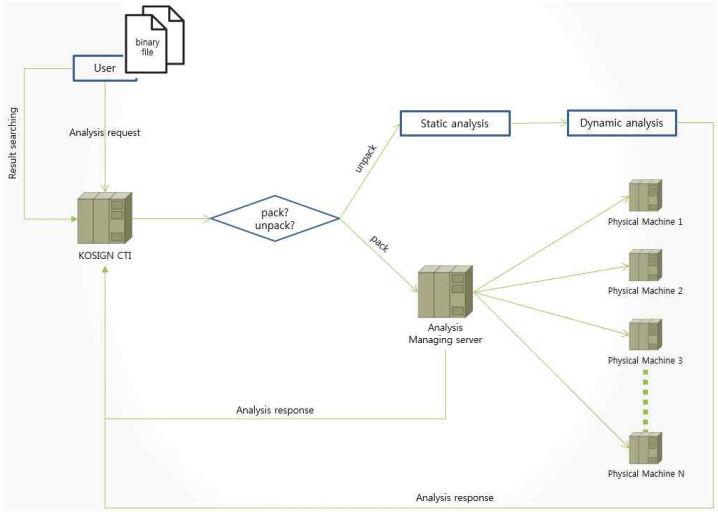
✓ 분석된 결과는 PDF 형식으로 분석 결과 제공



(다) 언패킹 파일 분석

○ 리얼머신 기반의 악성코드 분석 시스템

✓ 리얼머신 구성



✓ 분석 머신 관리 화면



○ 언패킹 기반의 딥러닝 학습 모델

✓ 언패킹 자동화 툴 개발

```
D:₩Downloads₩upx-3.95-win64>upx -o 19184d2113cc0a948293daba6a7d6890_upx.vir 19184d2113cc0a948293daba6a7d6890.vir
                       Ultimate Packer for eXecutables
                          Copyright (C) 1996 - 2018
UPX 3.95w       Markus Oberhumer, Laszlo Molnar & John Reiser   Aug 26th 2018

        File size         Ratio      Format      Name
   --------------------   ------   -----------   -----------
    160664 ->    117656   73.23%    win32/pe     19184d2113cc0a948293daba6a7d6890_upx.vir

Packed 1 file.

D:₩Downloads₩upx-3.95-win64>upx -d 19184d2113cc0a948293daba6a7d6890_upx.vir
                       Ultimate Packer for eXecutables
                          Copyright (C) 1996 - 2018
UPX 3.95w       Markus Oberhumer, Laszlo Molnar & John Reiser   Aug 26th 2018

        File size         Ratio      Format      Name
   --------------------   ------   -----------   -----------
    160664 <-    117656   73.23%    win32/pe     19184d2113cc0a948293daba6a7d6890_upx.vir

Unpacked 1 file.
```

[그림 179] UPX 패킹 프로그램을 통한 패킹/언패킹 예시

✓ 주어진 실행 파일의 패킹 유무를 확인하고, 언패킹이 가능하면 언패킹을 시도하는 악성코드 언패킹 모듈을 개발 (패킹 프로그램인 UPX를 통해 언패킹 시도)

- 언패킹이 가능하면 성공한 실행 파일에 대한 딥러닝 입력 데이터를 생성함.
- 언패킹이 불가능하면 그 파일 자체에 들어있는 프로그램의 패턴을 학습하기 위해 기존 파일을 딥러닝의 입력 데이터로 사용함.

✓ UPX 언패킹 프로그램은 자체 패킹 프로그램에서 기능을 지원하며, 커맨드 라인으로 입

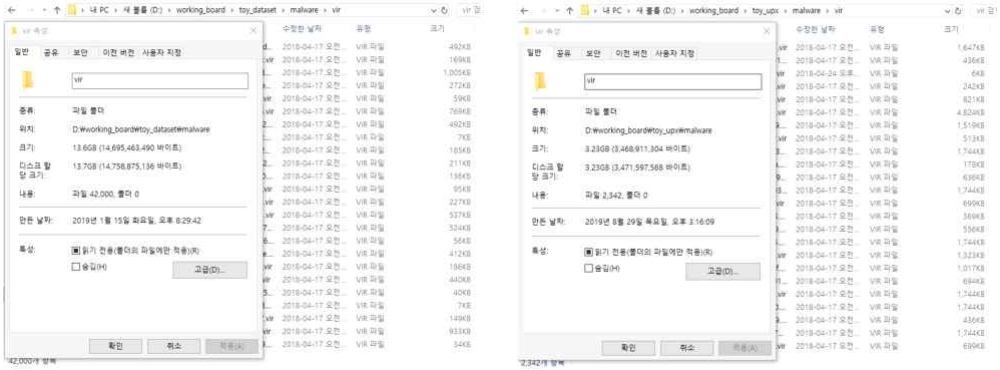
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

력함으로써 언패킹을 자동화하도록 구현.

- 결과적으로 악성코드 언패킹 모듈은 주어진 데이터에 대해 UPX 언패킹 프로그램을 실행
- 성공하면 언패킹에 의해 생성된 파일의 내용기반의 특징 추출하도록 구현
- 실패하면 자체 데이터 특징을 추출하도록 구현

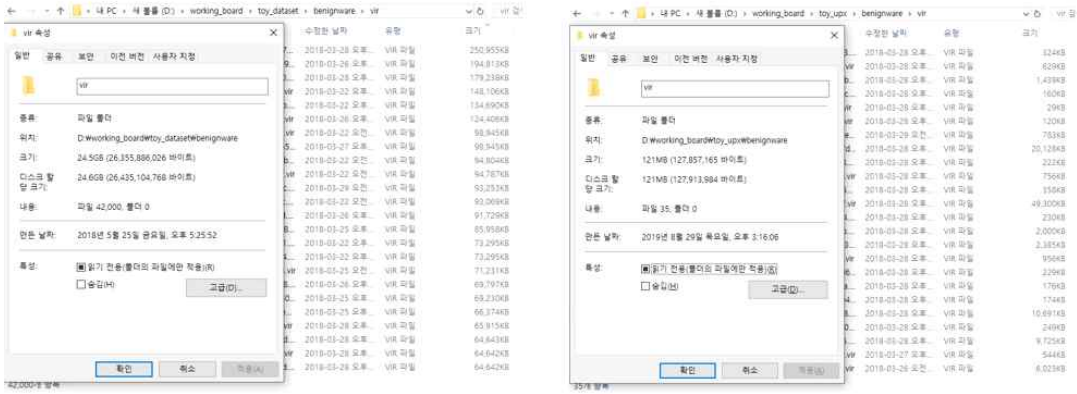
✓ 자체 선별한 악성코드 42,000개, 정상파일 42,000개에 대해 UPX 언패킹 프로그램을 시도하였음. 악성코드는 42,000개 파일 중 2,342개 파일을 UPX 언패킹 성공하였고, 정상파일은 42,000개 파일 중 35개 파일을 UPX 언패킹 성공하였음.

[악성코드: 42,000개 → 2,342개 언패킹 성공]



[그림 180] 언패킹 적용 전(왼쪽)/후(오른쪽)의 데이터 개수 비교

[정상파일: 42,000개 → 35개 언패킹 성공]



[그림 181] 언패킹 적용 전(왼쪽)/후(오른쪽)의 데이터 개수 비교

✓ 2차년도 때 수행했던 전처리 방법론과 딥러닝 학습 모델을 사용하여 검증 수행

- 악성코드 전처리 방법은 실행파일을 디스어셈블하여 기본 블록, 함수 단위의 opcode 시퀀스를 생성
- v-그램 방법을 통해 특징을 생성한 뒤 피처해싱 기법을 사용하여 고정 크기의 특징 벡터를 생성
- 딥러닝 모델은 합성곱 신경망(Convolutional Neural Network, CNN)을 사용하였음.

✓ 개발한 악성코드 언패킹 모듈을 사용한 이후의 딥러닝 기반 악성코드 탐지 모델의 정확도를 검증

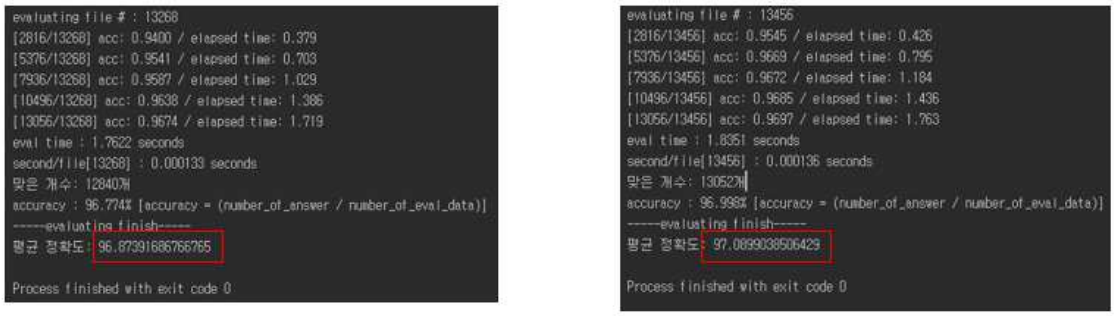
- 딥러닝 모델은 합성곱 신경망외 모델에 대한 하이퍼파라미터는 아래 표와 같음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

하이퍼 파라미터		값
CNN	합성곱 연산 층 별 필터 개수 (conv1D, 1x3 필터)	2,4,8,16
	풀링 방법	최대 풀링
ANN	은닉층	128, 16
입력 데이터 크기		1,024
활성 함수		Leaky ReLU
손실 함수		Cross Entropy
옵티마이저		Adam
학습률(learning rate)		0.0001

[표 10] 딥러닝 학습 모델의 하이퍼파라미터 정보

- 언패킹 적용 전(왼쪽)/후(오른쪽)에 따른 딥러닝 모델의 탐지 정확도 비교



[그림 182] 입력 데이터의 언패킹 적용에 따른 딥러닝 모델의 탐지 정확도 비교

✓ 결론

- 언패킹을 시도하지 않은 학습 모델의 검증 정확도는 96.87%, 언패킹을 한 데이터를 사용한 학습 모델의 검증 정확도는 97.09%로 약간의 성능 향상 확인
- 실험을 통해 딥러닝 모델은 양질의 정보를 주었을 때 더욱 높은 성능을 보인다는 것을 검증함

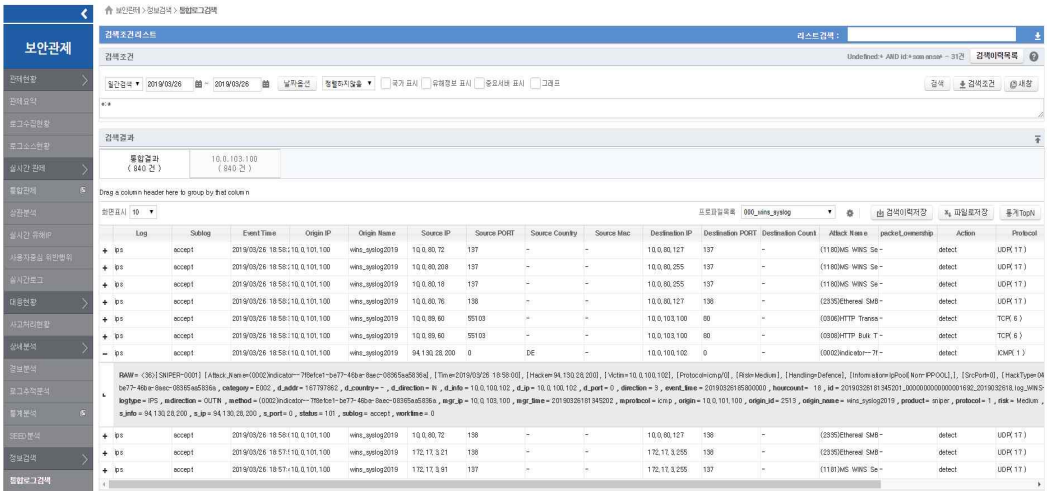
✓ UPX 패킹 프로그램 외에 자동화가 가능한 언패킹 프로그램을 조사해보고 악성코드 언패킹 모듈에 추가할 수 있도록 확장성 있는 코드 리팩토링을 진행할 예정임.

✓ 본 연구팀에서 개발한 모듈은 언패킹 프로그램의 에러 문구를 확인하여 예외 처리를 진행하지만, 이후에는 언패킹을 하기 전에 패킹 탐지를 수행하는 모듈을 추가할 예정임. 예를 들어, 파이썬 오픈소스 라이브러리 중 하나인 pefile, peutils 등의 모듈 이용하여 엔트로피 기반의 패킹 탐지 기술과 시그니처 기반의 패커 탐색 등을 통해 패킹 유무를 판별할 계획하고 있음.

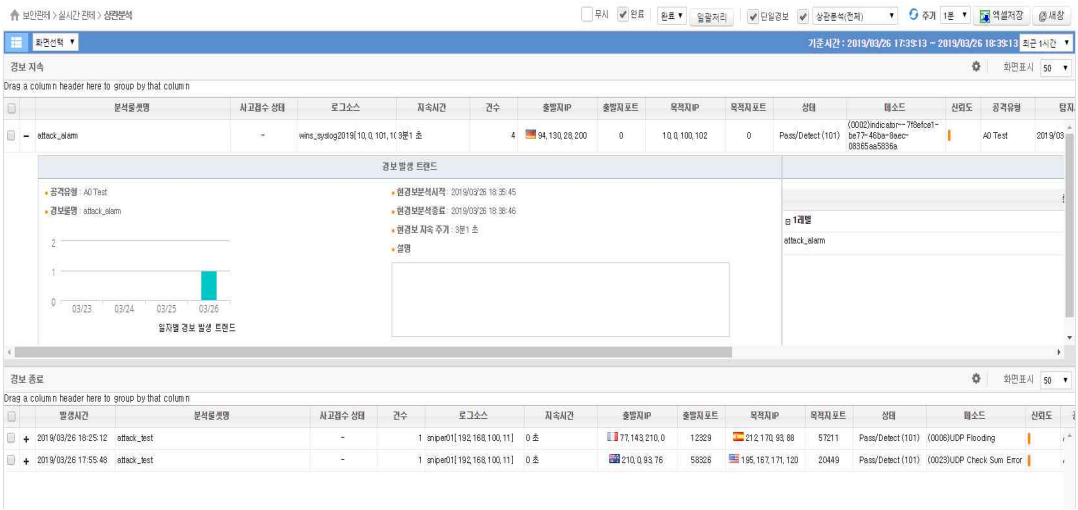
(2) WP-B : 실증기관 MSI (Securtiy Analytics 기반의 보안관제 솔루션) 구축

○ MSI 실증 환경 구축

✓ 국방부와 협의된 보안제품에 대한 이벤트 정보 수집 및 저장



✓ 위협정보 공유 정보를 기준으로 보안 이벤트 기준 비정상 행위 탐지



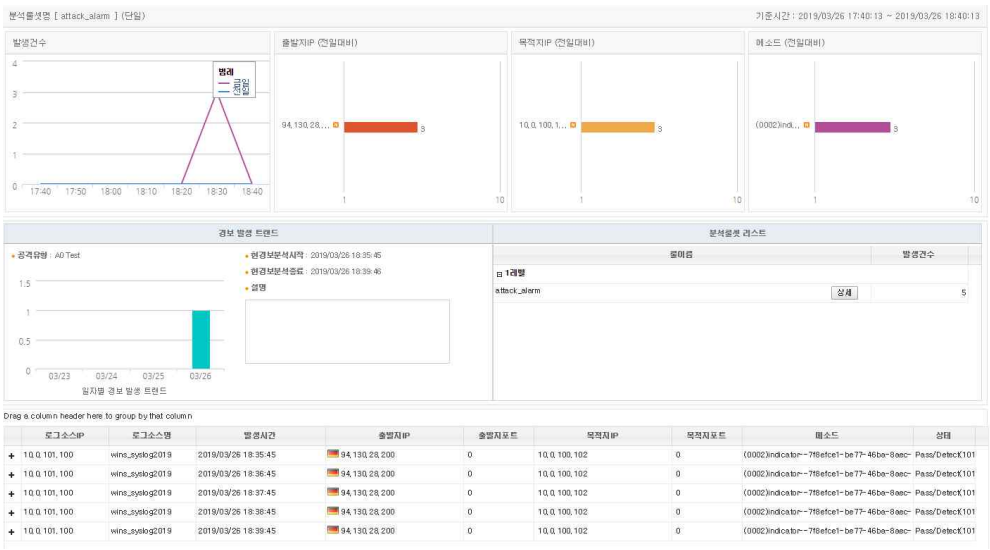
✓ 위협에 대한 실시간 모니터링 제공 및 대응 방안 제공



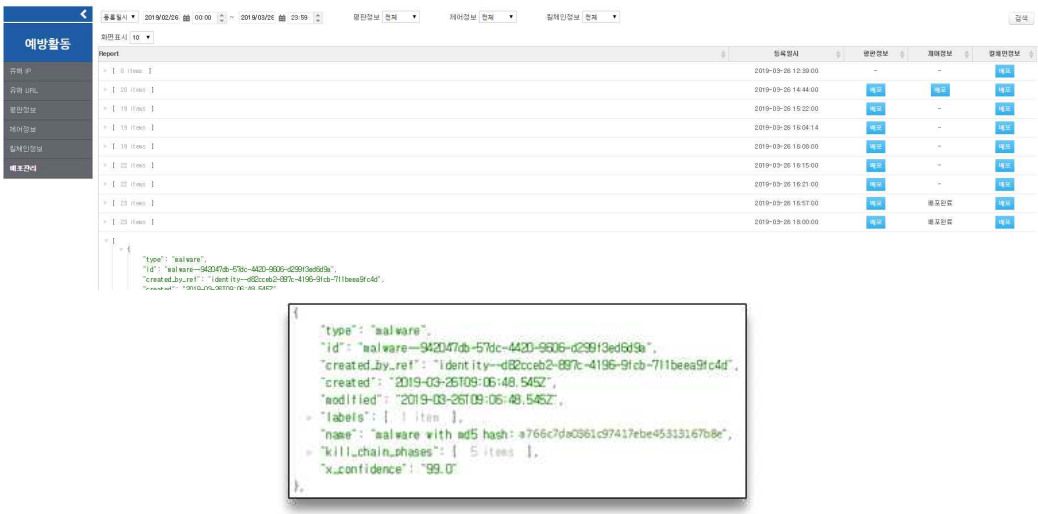
○ 국방부 요청사항 수정

✓ 특정 위협(indicator)를 기준으로 실시간 모니터링 기능

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



✓ 위협대응을 위한 보안정책 정보를 STIX/TAXII 기반으로 배포



✓ 위협정보 분석결과 CTI 연동 조회 화면 제공



(3) WP-C : EDR - 실증기관 보안솔루션 연동 체계 구축

(가) 실증사업

○ 국방부 실망 검증을 위한 EDR 플랫폼 구축

✓ MSI 시스템과의 정책 및 위협 정보 연동 개발

✓ 탐지된 악성코드 정보 전송 개발

○ 기능 고도화 및 커스터마이징

✓ 기존 유포된 랜섬웨어 약 10여종(Gandcrab, Clop, WannaCry, Cerber 등)을 분석하여 악성 행위 패턴 연구

✓ 악성 행위 패턴을 통한 랜섬웨어 탐지 기능 개발

(나) EDR 기능 고도화

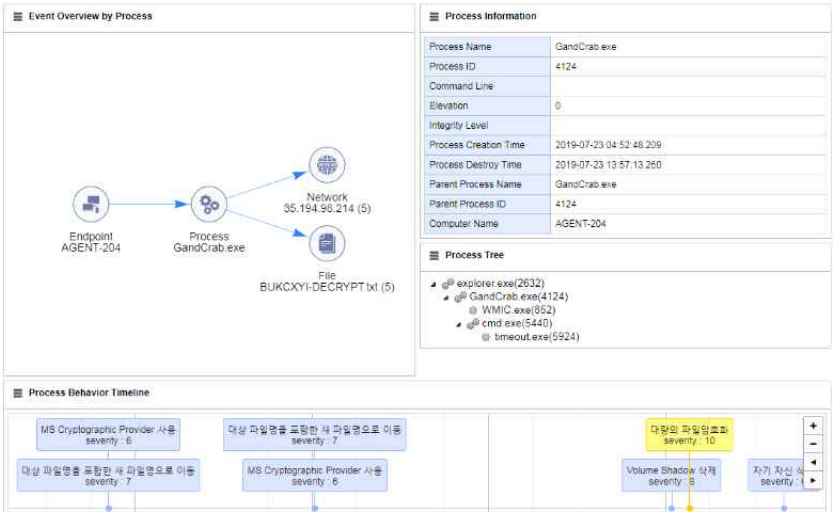
○ UI 고도화

✓ EDR 관리자 User Interface 개발



[그림 183] 관리자 User Interface : 대시보드

✓ EDR 관리자의 프로세스 모니터링



[그림 184] 관리자 User Interface : 프로세스 분석

○ 악성코드 카테고리별 악성 의심 행위 패턴 연구

✓ 악성 의심 행위 패턴을 이용한 악성코드 탐지 개발

GandCrab	RS001	Single	SS040	GetDriveType	
		Single	FU007	FindFirstFile	
		Loop	CR001	Crypt~	
			FU008	MoveFileWithProgress	Src included in Dst
		Single	SC017	SystemParametersInfo	change desktop
Cerber	RS002	Single	SS040	GetDriveType	
		Single	FU007	FindFirstFile	
		Loop	CR001	Crypt~	
			ZN004	MoveFileWithProgress	Src doesn't included in Dst
		Single	SC017	SystemParametersInfo	change desktop
Djvu	RS003	Single	SS040	GetDriveType	
		Single	FU007	FindFirstFile	
		Loop	CR001	Crypt~	
			FU008	MoveFileWithProgress	Src included in Dst
Clop	RS004	Single	SS040	GetDriveType	
		Single	FU007	FindFirstFile	
		Loop	ZN001	CreateFileW	Existing filename
			ZN005	DeleteFile	Existing filename
			CR001	Crypt~	

[그림 185] 랜섬웨어 타입별 악성 행위 패턴

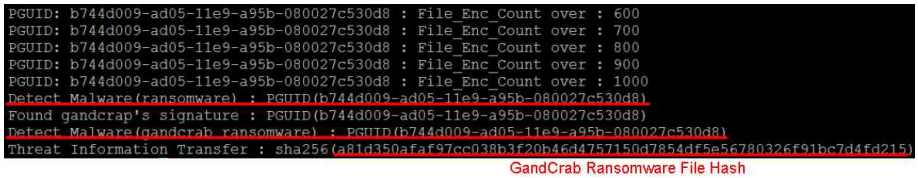
✓ Endpoint에서 악성 의심 행위 수집 룰셋 고도화



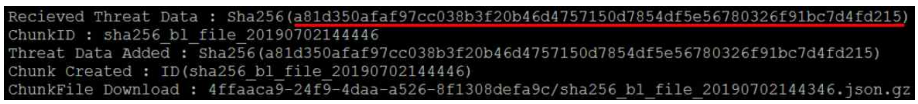
[그림 186] 악성행위 탐지 룰셋 예시 : DLL 인젝션

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 악성 의심 행위를 이용하여 랜섬웨어 탐지 및 대응



[그림 187] GandCrab 랜섬웨어 탐지 로그



[그림 188] GandCrab 랜섬웨어 대응 정보 배포 로그

✓ 악성 의심 행위를 탐지하기 위한 탐지 룰셋을 고도화 하여 추가 행위 수집

- 기 유포된 랜섬웨어 약 10여종(Gandcrab, Clop, WannaCry, Cerber 등)을 분석하여 악성 행위 패턴을 연구
- 악성 행위 패턴을 분석하여 랜섬웨어 탐지하는 기능 개발

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

라. 3차년도(2019년) 정량적 연구성과

(1) 목표대비 연구성과

구분			당초계획	실적	비고
특허 출원	국내		2	4	
	국외		1	1	
	계		3	5	
특허 등록	국내		6	5	
	국외		0	0	
	계		6	5	
국외 논문 게재	SCI		-	-	
	비SCI		-	-	
	계		-	-	
국내 논문 게재	SCI		-	1	
	비SCI		-	-	
	계		-	1	
국내 및 국제 학술회의 발표	SCI		-	-	
	비SCI		-	1	
	계		-	-	
국제 표준화	기고서 제출		-	-	
	기고서 채택		-	-	
	표준안 채택		-	1	
국내 표준화	기고서 제출		-	-	
	기고서 채택		-	-	
	표준안 채택		-	-	
기술 이전	계약 건수		2	3	
	계약액		40백만원	50백만원	
	징수액		-	-	
등록·기탁 대상 성과물	보고서 원문		-	-	
	연구시설·장비		-	-	
	기술요약정보		-	-	
	생명자원	생명정보	-	-	
		생물자원	-	-	
		신품종	-	-	
	소프트웨어		0	1	
	화학물		-	-	
인력 양성	학사		-	-	
	석사		-	-	
	박사		-	-	
기타	시제품		1	1	
	상용화		160백만원	216백만원	
	성과 홍보		1	1	
	기술 문서		4	5	
	일자리 창출	연구인력	0명	0명	
		생산인력	0명	0명	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 특허 출원 및 등록 목록

번호	지식재산권 등 명칭 (건별 각각 기재)	국명	출원			등록			특허등급 평가결과	기여율
			출원인	출원일	출원번호	등록인	등록일	등록번호		
1	침해사고 대응지시서에 기반한 보안장비 제어정책 자동 적용 시스템 및 그 방법	대한민국	(주)이글루시큐리티	2019.01.15	10-2019-0005120	(주)이글루시큐리티	2020.03.12	10-2090757	-	100
2	탐지 규칙 검증을 위한 패킷 생성 방법 및 장치	대한민국	(주)윈스	2018.07.24	10-2018-0086038	(주)윈스	2019.08.09	10-2011603	A3	100
3	악성코드 머신러닝 분류 모델 검증 방법과 그 장치	대한민국	(주)윈스	2018.09.06	10-2018-0106470	(주)윈스	2019.08.07	10-2010468	B2	100
4	Apparatus and Method for Verifying Malicious Code Machine Learning Classification Model	미국	(주)윈스	2019.08.27	16/553,054	-	-	-	-	100
5	악성코드 분석용 머신러닝을 위한 하이브리드 피처 벡터 생성 장치 및 방법	대한민국	국민대학교 산학협력단	2019.08.19	10-2019-0101301	-	-		-	100
6	라벨 정보가 포함된 특징 벡터 생성 장치 및 방법	대한민국	국민대학교 산학협력단	2019.10.14	10-2019-0126882	-	-		-	100
7	CNN 학습 기반의 멀웨어 분석 장치, 이를 수행하는 CNN 학습 기반의 멀웨어 분석 방법 및 이를 저장하는 기록매체	대한민국	국민대학교 산학협력단	2017.11.01	10-2017-0144951	국민대학교 산학협력단	2019.10.11	10-2033354	B3	100
8	실행 코드 상의 함수 시그니처 생성 장치 및 방법	대한민국	국민대학교 산학협력단	2018.08.03	10-2018-0090947	국민대학교 산학협력단	2020.01.08	10-2066022	B2	100
9	인공지능을 사용한 네트워크 트래픽 분석 장치 및 방법	대한민국	(주)윈스	2020.01.16	10-2020-0005890	-	-	-	-	100
10	딥 러닝을 이용한 시드기반 악성 트래픽 탐지 방법 및 장치	대한민국	고려대학교	2018.07.30	10-2018-0088477	고려대학교 세종산학협력단	2019.10.08	10-2032249		100

(3) 논문

번호	논문명	학술지명	주저자명	호	국명	발행기관	SCI 여부 (SCI/비SCI)	게재일	등록번호 (IF)
1	Automatic Payload Signature Update System for the Classification	KSII TRANSACTIONS ON INTERNET AND INFORMATION	Kyu-Seok Shim	Vol. 13, No. 3, pp. 1284-1297	Korea	Korean Society for Internet Informa	SCIE	2019.03	1976-7277 (0.711)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

	of Dynamically Changing Internet Applications	SYSTEMS				tion			

(4) 학술대회

번호	회의명칭	논문명	발표자	발표 일시	장소	국명
1	한국융합보안학회 2019년 추계학술대회	KOSIGN과제의 국방분야 실증 시험을 위한 프로세스 설계	강지원 (세종대학교)	2019.10.25	서울 중앙대학교	한국

(5)표준화

번호	수행 기관명	표준화 주제	표준화 기구	표준화 단계	관련 번호	제출(채택)일	국가
1	한국전자통신연구원	ITU-T X.1215 Use cases for structured threat information expression	ITU-T	표준안 채택	X.1215	2019.01.30	스위스

(6) 기술거래(이전 등)

(단위: 원)

번호	기술 이전 유형	기술 실시 계약명	기술 실시 대상 기관	기술 실시 발생일	기술료 (해당 연도 발생액)	누적 징수 현황
1	통상실시권	딥러닝 기반의 유사도 분류에 따른 트래픽 유형화 및 탐지 기술	(주)이글루시큐리티	2019.07.01	10,000,000 (기여율 : 100%)	-
2	통상실시권	악성코드 데이터 머신러닝을 위한 피처 벡터 기술	(주)윈스	2019.12.01	20,000,000 (기여율 : 100%)	-
3	통상실시권	악성코드 분석을 위한 머신러닝을 위한 하이브리드 피처벡터 생성	(주)지란지교시큐리티	2019.06.03	20,000,000 (기여율 : 50%)	-

(7) 사업화현황

번호	사업화 방식	사업화 형태	지역	사업화명	내용	업체명	매출액		매출 발생 연도	기술 수명
							국내	국외		
1	자가실시	기존 제품 개선	국내	Privacy-I EDR 시스템 도입 프로젝트 (소만사)	Privacy-I EDR 시스템 도입	(주) 모노커뮤니케이션즈	30,000,000 원	0	2019	-
2	자가실시	기존 제품 개선	국내	이메일보안 APT 대응솔루션 (지란지교시큐리티)	KOSIGN 연동기술 적용	에스케이인포섹 외	57,630,493 원	-	2019	-
3	자가실시	기존 제품 개선	국내	대구광역시 교육청 프로젝트 (이글루시큐리티)	EDR 이벤트 수집 및 제어정책 배포 구간에 STIX/TAXII 기술 적용	대구광역시 교육청	29,400,000 원	0	2019	-
4	자가실시	기존 제품 개선	국내	대전광역시 교육청 프로젝트 (이글루시큐리티)	EDR 이벤트 수집 및 제어정책 배포 구간에 STIX/TAXII 기술 적용	대전광역시 교육청	35,560,000 원	0	2019	-

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

5	자가실시	기존 제품 개선	국내	인천광역시 프로젝트 (이글루시큐리티)	EDR 이벤트 수집 및 제어정책 배포 구간에 STIX/TAXII 기술 적용	인천광역시	63,560,000 원	0	2019	-

(8) 저작권(소프트웨어, 서적 등)

번호	저작권명	창작일	저작자명	등록일	등록번호	저작권자명	기여율
1	KOSIGN-CTI V1.5 (코사인 악성코드 분석 시스템 V1.5)	2017.12.11	주식회사 윈스	2019.12.18	C2019-041347	주식회사 윈스	100%

(9) 기술문서

번호	기술문서 제목
1	KOSIGN_WEB_기능매뉴얼
2	KOSIGN_개발체계_軍실증보안대책(안)
3	KOSIGN기술_국방분야_실증_기능_시험서
4	위협분석_공유_플랫폼 요구사항_분석서(KOSIGN_CTI_서비스)
5	STIX2.0_TAXII2.0 연동 방안 설계

(10) 기타

○ 시제품

번호	기관명	시제품명
1	(주)소만사	Privacy -i EDR

○ 수상

✓ 금융보안원 주최 2019 디지털 금융혁신과 금융보안 공모전 - 논문분야 대상 (참여기관: 국민대학교)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다



[그림 189] 금융보안공모전 수상(참여기관: 국민대학교 산학협력단)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 성과홍보

✓ 정보보호핵심원천기술개발사업 성과관리위원회 발표(2019 정보보호 컨퍼런스 / 2019.11.20)

✓ 발표 내용: STIX/TAXII 기반 이기종 장비 연동 기술 및 과제 성과 소개



[그림 190] 2019년 성과관리위원회 발표사진

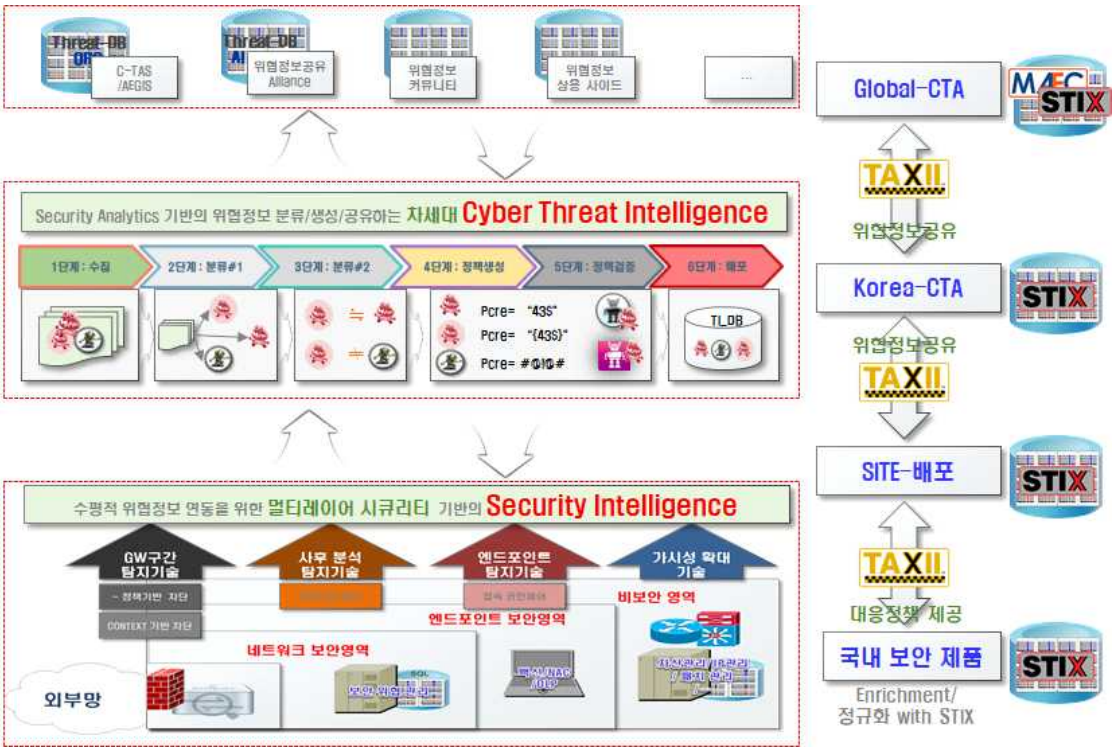
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

3. 목표 달성도 및 관련 분야 기여도

3-1. 최종 개발 목표

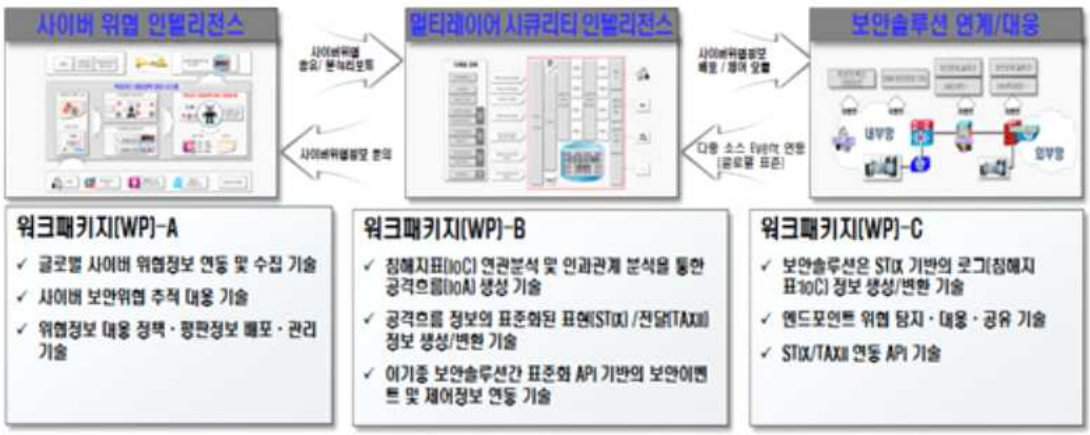
가. 연구개발 목표

○ 이기종 보안솔루션들의 효과적인 사이버위협 탐지 · 대응을 위한 Security Analytics 기반의 사이버위협정보를 분석 · 공유하는 KOSIGN (Korea Open Security Intelligence Global Network) 서비스 기술 개발



[그림 191] 최종연구개발 목표

○ 연구개발 범위



[그림 192] 워크패키지별 개발 범위

✓ WP-A : 사이버 위협 인텔리전스(CTI) 기술 개발

✓ WP-B : 멀티레이어 시큐리티 인텔리전스(MSI) 기술 개발

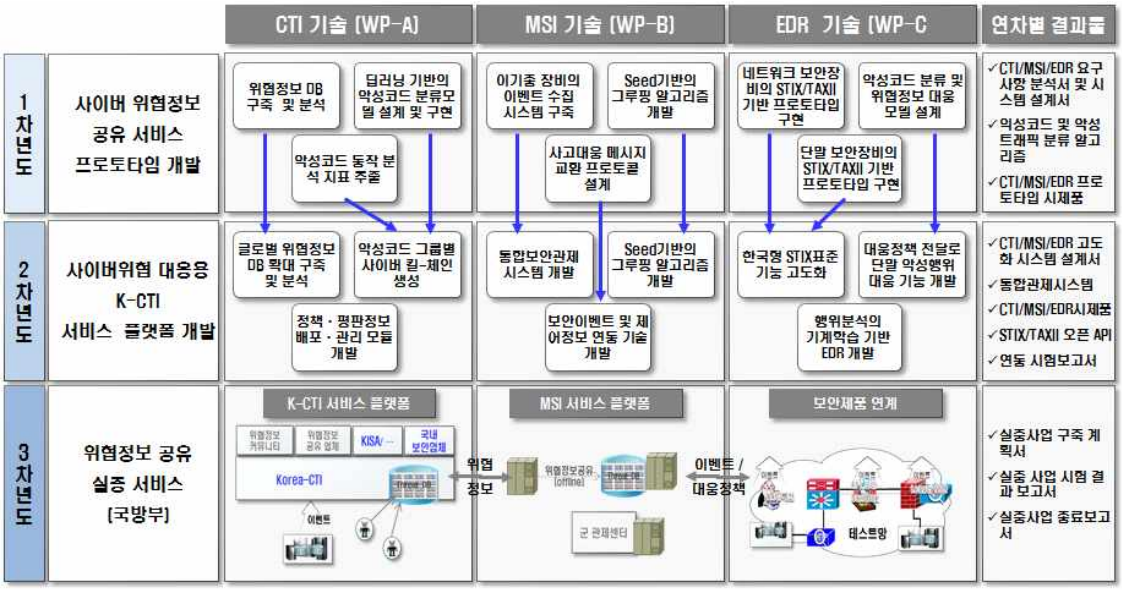
✓ WP-C : 보안솔루션 연계 대응(EDR) 기술 개발

✓ 표준화 : STIX/TAXII 국내외 표준 수행

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

나. 연차별 연구개발 목표

○ 연차별 연구개발 목표



[그림 193] 워크패키지별 연차별 개발 목표 및 결과물

✓ 연구개발은 1차/2차년에 걸쳐 개발

- 1차년도에는 사이버위협 정보공유 서비스 프로토타입 개발을 목표로 함
- 2차년도에는 K-CTI 서비스 플랫폼 개발을 목표로 함

✓ 3차년도에는 국방부 실증사업으로 진행

○ 1차년도 개발 목표

✓ 개발 목표 : 사이버위협정보 공유 서비스 프로토타입 개발

✓ 개발 주요 내역

1차년도 : 사이버 위협정보 공유 서비스 프로토타입 개발			
사이버 위협 인텔리전스(CTI) 플랫폼 기술	위협정보 수집하는 글로링 엔진 개발을 통한 위협정보 DB 구축	악성코드 정적 및 행위 분석	악성코드의 분류모델 설계
	상용 위협정보 공유를 통한 글로벌 위협정보 DB 구축	악성코드 동작 분석 지표 추출	클러스러링 기반 그룹핑 설계 및 구현
멀티레이어 시큐리리 인텔리전스(MSI) 플랫폼 기술	이기종 보안 장비/Agent의 실시간 이벤트 수집 시스템 구현	STIX 표준 기반 공격흐름 정보 생성/조회 API 구현	Seed정보를 이용한 트래픽 그룹핑 알고리즘 개발
	프로토타입 관리 시스템 개발	사고 대응을 위한 보안 정보 메시지 교환 프로토콜 설계	플로우 연관성을 이용한 그룹핑 알고리즘 개발
엔드포인트 악성행위 탐지/대응 기술 (EDR)	네트워크보안 이벤트 로그의 STIX 형식의 포맷 규격 설계	단말보안 이벤트 로그의 STIX 형식의 포맷 규격 설계	STIX 표준 기반 보안 위협 정보 생성/조회 API 구현
	한 개 이상의 네트워크 보안 제품을 STIX/TAXII 기반의 프로토타입으로 구현	한 개 이상의 단말보안 제품을 STIX/TAXII 기반의 프로토타입으로 구현	TAXII 표준 기반 위협정보 교환 플랫폼 인증 모듈 설계 및 구현

[그림 194] 1차년도 기술 개발내용 및 범위

- 글로벌 위협정보 수집/분석 및 딥러닝 기반 악성코드 분류모델 개발
- MSI 플랫폼 설계 및 프로토타입 구현
- 보안솔루션 위협정보 연동 규격 개발 및 프로토타입 API 구현
- 호스트의 비정상행위 정보 수집 및 EDR Agent 설계

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 2차년도 개발 목표

✓ 개발 목표 : 사이버 위협정보를 신속하게 공유하여 보안 솔루션(단말보안, 네트워크보안, 통합보안관제, 등)의 효율적인 사이버위협 대응할 수 있는 Korea-CTI 서비스 플랫폼(KOSIGN) 기술개발

✓ 개발 주요 내역

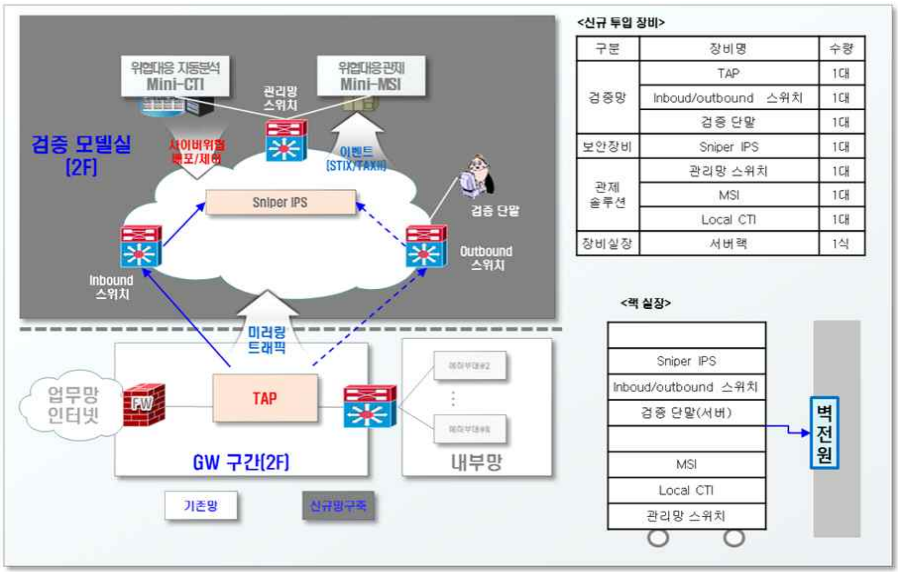


[그림 195] 2차년도 기술 개발내용 및 범위

- 글로벌 위협정보 수집/분석, 악성코드 분류 고도화 및 사이버 킬체인 모델 개발
- Security Analytics 기반의 비정상 행위 탐지하는 MSI 플랫폼 고도화 구현
- 보안솔루션 위협정보 연동/제어를 위한 API 구현
- EDR 에이전트의 대응 및 관리 서비스 개발

○ 3차년도 목표

✓ 수행 목표 : 개발 결과물 커스터마이징을 통해 국방부 요구사항이 반영된 최적의 위협정보 공유/분석/대응 체계 수립



[그림 196] 국방부 실증 사업 구축 범위(3차년도 사업)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

✓ 주요 수행 내역

- 외부의 CTI 플랫폼 구축 (시범사업용 및 참여기관 요청 대응)
- 국방부 실증사업 검증을 위한 MSI 플랫폼 구축 및 기능 요구사항 반영
- 실증망에 구축되는 보안장비의 연동기능 검증 (구축 보안장비 협의 필요)
- 악성코드에 대한 회피 기술 및 언패킹 해독기술 개발(2차년 연차평가 요청사항)

3-2. 목표 달성여부

가. 정량적 성과목표 달성여부

○ 연차별 정량적 목표 (계획/실적)

구분	특허				논문			표준화						기술이전	상용화 (백만원)	기술료 (백만원)	성과홍보	시제품	S/W등록	기술문서
	국제		국내		SCI(E)	비SCI		국제			국내									
	출원	등록	출원	등록		국제	국내	기고서제출	기고서채택	표준안채택	기고서제출	기고서채택	표준안채택							
1차년도 (2017년)	1/1	0	8/11	0	1/1	0	2/9	2/2	2/2	0	1/1	0/1	0	0	0/49	0	0/2	0	1/4	11/11
2차년도 (2018년)	2/2	0	8/9	3/4	2/3	1/4	2/12	2/5	2/5	0/0	1/2	1/2	1/3	2/2	0/50	40/40	1/2	6/6	7/7	12/13
3차년도 (2019년)	1/1	0	2/4	6/5	0/1	0	0/1	0	0	0/1	0	0	0	2/3	160/216	40/50	1/1	1/1	0/1	4/5
계획합계	**4**	**0**	**18**	**9**	**3**	**1**	**4**	**4**	**4**	**0**	**2**	**1**	**1**	**4**	**160**	**80**	**2**	**7**	**8**	**27**
실적합계	**4**	**0**	**24**	**9**	**5**	**4**	**22**	**7**	**7**	**1**	**3**	**3**	**3**	**5**	**315**	**90**	**5**	**7**	**12**	**29**

[표 11] 연차별 정량적 목표(계획/실적)

○ 결론 : 모든 성과목표 이상을 달성함

나. 기술적 목표달성 여부

○ 기술적인 측면의 계획대비 목표달성 여부

No	평가 항목 (주요성능 Spec)	단위	전체 항목 차지하는 비중 (%)	세계최고 수준 보유국/보유기업	연구개발 전 국내수준	1차년도 (2017년)		2차년도 (2018년)		3차년도 (2019년)		평가 방법
				성능수준	성능수준	목표	실적	목표	실적[1)]	목표	실적	
1	악성코드 동작분석 판단 지표	건	10%	207 (미국/MAEC)	200	200	205	250	1024	-	-	자체 평가 (논문)
2	악성코드 유사도 분석 성능	초	10%	0.1 (미국/Symantec)	0.089	0.1	0.1	0.02	0.001	-	-	자체 평가 (논문)
	악성코드 유사도 분석 정확도	%	10%		90%	-	-	95%	97.14%	-	-	
3	이기종 이벤트 수집성능	천EPS	15%	150,000 (미국 Splunk)	100	100	100	170	212	-	-	공인시험(2차년)
4	이벤트 분류 기준 악성트래픽 탐지율 (Recall)	%	5%	100% (미국/Symantec)	80	90%	86%	98%	99.3%	-	-	자체 평가 (논문)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

5	이벤트 분류 기준 악성트래픽 탐지정확도율 (Precision)	%	10%	100% (미국/Symantec)	97	90%	90%	98%	99.5%	-	-	자체 평가 (논문)
6	위협정보 생성을 위한 로그 조회 성능	소요 시간	10%	5초 (미국, Symantec)	-	4초 이내	4초 이내	2초 이내	1.76초	-	-	공인시험(2차년)
7	단말행위 정보의 기계학습 기반 비정상행위 탐지율	%	15%	90% (미국, EMC)	-	-	-	95%	96.3	-	-	공인시험(2차년)
8	K-CTI 연동 보안업체 수	개수	15%	- (미국/MS)	-	2	1	5	6	-	-	공인시험(2차년)
9	KOSIGN 종합연동시험	-	-	-	-	-	-	-	-	양호	양호[2)]	수요기관평가

[표 12] 정량적 목표 항목

1) 공인시험기관(KSEL)과 진행한 공인시험 결과값 임

2) 국방부의 사이버사령부 실증 시험 결과 (붙임 3 참조)

다. 기술발전 기여도

(1) 악성파일/코드 분석 분야

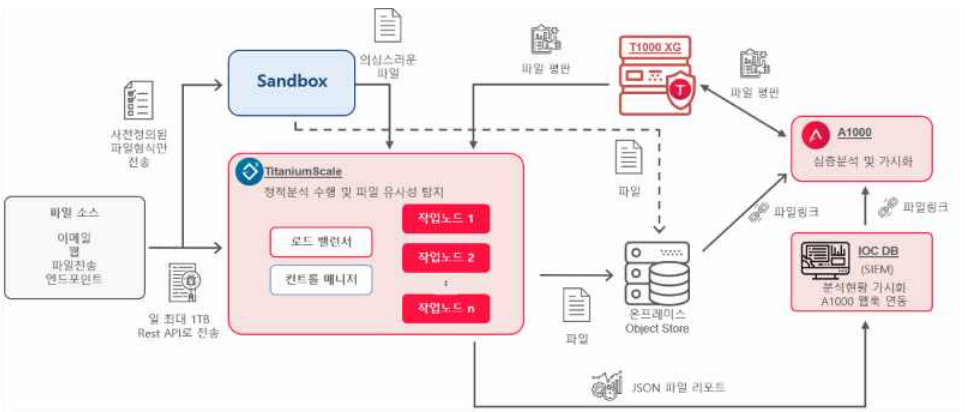
(가) 악성파일(코드) 분석 기술

○ 국외 기술개발 수준

✓ 글로벌보안 기업(Cisco, Symantec, Fortinet, PaloAlto, 등)은 자사의 센서에서 수집되는 악성파일을 클라우드센터를 통해 분석하고 분석결과 및 룰정책을 제공하고 있음

✓ 인터제르사가 출시한 '인터제르 애널라이즈(Intezer Analyze)'는 인터제르 고유의 소프트웨어 'DNA 매핑' 분석 기법인 '악성코드 유전자 분석(Genetic Malware Analysis)'를 기반으로 코드 유사성(Code Similarity), 코드 재사용(Code Reuse), 스트링 재사용(String Reuse) 등을 검사하여 파일의 유사성을 비교하여 악성코드를 판별

✓ 리버싱랩스는 위협지표를 추출한 후, 80억 개 이상의 신뢰할 수 있는 파일 평판데이터베이스인 활용하여 파일의 기능적 유사성을 판단해 악성코드를 식별하고, 유사 정도에 따라 파일을 단계별로 분류하는 서비스 제공



[그림 197] 리버싱랩스의 악성코드 분석 flow

○ 국내 악성코드 분석은 연구단계에서 상용화 단계로 진행되고 있음

✓ 한국인터넷진흥원(KISA)은 디플랫폼, 비트나인, 서울과학기술대, 강원대와 함께 연구개발한 '국가 차원 침해사고 대응을 위한 CTI 분석 및 정보 공유 기술 개발' 완료

- 침해사고 정보수집은 24개 데이터유형으로 나눠 19개 채널을 통해 수집하며, 보유한 데이터는 2018년 기준 약 1억1300만 건에 수준임
- 위협정보 간 관계를 분석하고 침해사고 등에 기반해 유사도 관계를 파악하고, 침해사고 그룹을 분석하고, CTI 보유정보 신뢰도와 위험도 분석 수행
- 악성코드 등 소스 간 어떤 관계가 있는지 분석하고 공격 행위를 파악해 사고를 예방

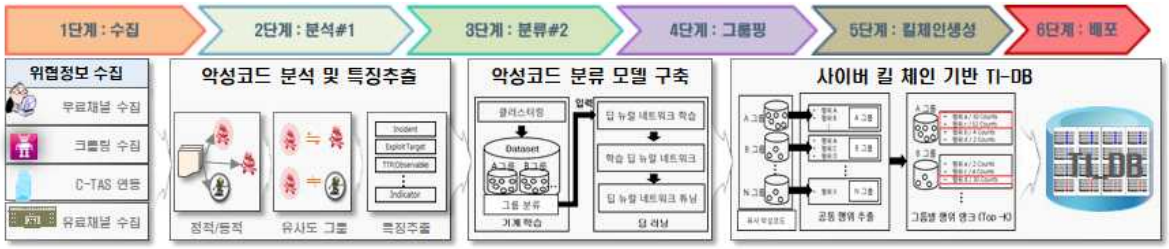
✓ 국내는 바이러스 업체(안랩, 하우리, 이스트소프트, 등)에서는 파일에 대한 정적/동적분석 및 행위기반 정보를 분석 수행

✓ 지란지교소프트가 글로벌 사이버 위협정보 제공기업 사이렌(CYREN)의 엔진을 기반으로 한 쓰렛필터(THREATFILTER)라는 제품을 선보임

(나) 개발결과물의 장단점

○ 악성파일 분석기술 비교

✓ 악성파일분석 하는 상용 서비스와 비교하여도 본 과제의 결과물의 분석방법은 유사함



[그림 198] 과제결과물의 악성파일분석 Flow

✓ 수집된 악성파일을 동적/정적분석을 수행하고, 정적분석의 특징으로 학습된 딥러닝 모델을 통해 악성여부를 판단

✓ 판단된 악성에 대한 행위정보(동적분석 결과)를 활용하여 그룹정보를 확인

✓ 행위정보와 해킹그룹 정보를 활용하여 행위를 예상하고 해당 차단정책룰 자동 생성

○ 개발 결과물의 기술적 우위

✓ 정적/동적분석을 통한 DNA 수준의 악성코드 유사성을 분석하고, 분석된 결과로 악성행위를 예측하는 상용 서비스임

✓ 개발 결과물은 유사성을 분석하고, 공통행위를 기반으로 행위랭크를 추출하여 향후 발생될 수 있는 주요행위까지 예상할 수 있는 기반의 악성분석 기술로써 기술적인 우수성을 가짐

✓ 연구용으로 개발하다보니 학습모델로 사용하는 악성파일 수량이 적어, 정확한 분석모델이 생성되지 않아 시간이 지남에 따라 악성탐지율은 떨어지는 경향이 존재할 수 있음

(다) 개발결과물 기여도

○ 딥러닝 기반의 분석분야를 개발한 국민대학교는 관련된 기술에 대해 기술이전을 진행하고 있어, 향후에는 유료로 분석된 정보를 활용하고 있는 국내보안업체들의 분석에 대한 자체 기술을 확보할 수 있는 기회를 제공할 수 있을 것으로 예상됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 한국보안산업협회가 주관이 되어 본과제의 결과물인 위협정보분석플랫폼(KOSIGN)을 구축하고, 구축된 국내 보안업체/운용관제 인원이 필요로 하는 신속한 악성파일 분석 및 대응 방안을 얻을 수 있을 것으로 예상됨.

(2) 위협정보 공유 분야

(가) 위협정보 공유기술 동향

○ 사이버위협의 선제적 대응 요구 증가

✓ 최근 지능형지속위협(APT: Advanced Persistent Threat), 랜섬웨어 등 알려지지 않은 형태로 고도화된 공격이 증가함에 따라 기존의 정보보안 제품으로는 선제적 대응이 어려운게 현실임. 이에 따라 위협요소에 대한 선제적 방어가 보안의 새로운 트렌드임

✓ 가트너는 사이버 위협 인텔리전스에 대해 증거를 기반하는 지식으로, 기업의 IT나 정보자산에 위협이 될 수 있는 부분에 실행 가능한 조언을 콘텍스트나 메커니즘, 지표 등으로 제시하는 정보로 정의하고 있음

✓ 위협 인텔리전스는 단순 위협 정보를 모아둔 데이터 집합체가 아닌 전술(Tactics), 기법(Techniques), 절차(Procedures) 등 공격 전반의 사항을 확실한 증거에 기반해 입체적으로 제공하는 사이버 방어 지식과 기술의 집약체라고 할 수 있음

✓ 결과적으로 공격자가 내부 침투 후, 악성코드를 심고, 악성 행위를 실행하는 전 과정을 재구성할 수 있는 능력을 갖추는 것이 지능형 공격을 막을 수 있는 유일한 방법인데 이것을 가능토록 해주는 기술이라 할 수 있음

○ 사이버위협 서비스의 향후 시장 전망

✓ 사이버 위협 인텔리전스 서비스는 IBM, 델(Dell), 시맨텍(Symantec), 파이어아이(Fireeye), 맥아피(McAfee) 등 글로벌 기업을 중심으로 서비스되고 있음

✓ 시장조사기관인 마켓앤마켓(MARKETSandMARKETS) 발표에 따르면 위협 인텔리전스 시장 규모는 2017년 33억3000만 달러에서 2022년 80억 4000만 달러로 연간 성장률이 18.4%로 증가할 것으로 전망

○ 위협정보 공유 서비스

✓ 사이버위협 인테리전스(CTI)를 접목해 언노운 위협 방어와 바이러스/멀웨어 유입 탐지·차단, 위협에 대한 대응속도 향상을 지향하고 있는 것이 세계적인 정보보안 추세

✓ 클라우드 형태의 악성코드 분석시스템을 제공하며, 또한 분석된 결과를 공유하는 서비스가 확산되고 있음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

서비스	특징
바이러스토탈	구글이 운영하는 바이러스토탈은 파일과 URL을 입력해 각종 악성코드를 쉽고 빠르게 탐지해주는 웹 기반 악성코드 탐지 서비스를 제공하고 있다. 약 70여개의 안티 바이러스 스캐너를 클라우드 서버 상에 구성해놓고 윈도우 계열 악성 파일이나 모바일 악성 앱 등 업로드 되는 다양한 파일에 알맞은 엔진으로 검사를 수행한다. 각종 자동 업로더 또는 API와 연동해 동작하는 서드파티 도구들을 함께 활용할 수 있는 것이 큰 이점이다.
멀웨어즈닷컴	멀웨어즈닷컴은 국내 세인트시큐리티에서 제공하는 서비스로 바이러스토탈과 유사한 동작 방식이다. 각종 채널에서 올라오는 파일을 클라우드 기반에서 실시간으로 수집하고 65여 개 엔진을 통해 악성 여부를 판정하고 분석한다. 해외 바이러스토탈 서비스와 한국인터넷진흥원의 사이버위협정보공유시스템(C-TAS)와 연동돼 운영하고 있다.
ANLYZ	2014년부터 운영된 'ANLYZ' 서비스는 다양한 파일 확장자에 대한 정적, 동적 분석을 지원하며 나라별로 업로드된 샘플과 파일, URL, PCAP 패킷 파일에 대한 분석 결과와 함께 악성 여부 결과를 제공하는 것이 특징.
조 샌드박스	스위스에서 운영되고 있는 조 샌드박스(JOE Sandbox)는 클라우드 기반 악성코드 자동 분석 서비스로 악성 카테고리 유형별로 상세하게 구분하고 기능별 위험도를 보여주는 것으로 유명한 편이다. 검사 정확도를 높이기 위해 샌드박스 내에서 동적으로 검사한 결과를 함께 보여주며 다양한 운영체제 파일에 대한 악성 여부를 판정해주는 것이 특징이다.
Jotti	'Jotti'는 2004년에 시작된 바이러스토탈과 가장 유사한 형태의 악성 여부 판정 서비스로 최대 동시 5개 파일을 업로드할 수 있고 250MB 이상의 파일까지 업로드 가능. 안드로이드 앱 검사를 진행할 경우 15개 엔진이 검사하며 실시간으로 기본 파일 크기와 종류, 해시 정보, 탐지 결과를 제공하는 것이 특징이다.
VirSCAN	중국에 기반을 둔 VirSCAN은 바이러스토탈이나 Jotti와 유사한 악성코드 판정 서비스로 약 32개 안티 바이러스 엔진을 사용하는 온라인 악성 검사 서비스임. 파일 업로드 시 10MB 파일 크기 제한을 가지며 휴리스틱 탐지 결과와 악성 확진 결과를 구분해 보여준다.
hybrid-analysis	hybrid-analysis는 독일의 IT 악성코드 분석 사이트로 정부, 대학, SOC와 IR 팀을 위해 자동화된 악성코드 분석 시스템인 'VXStream Sandbox'로 시작됐다. 독창적으로 악의적인 지표를 추출하기 위해 심층 메모리 분석을 구현하였으며 분석 결과는 악의적인 지표와 의심 지표로 나누어 제공하고 문자열 정보에 대한 검색 기능도 제공하고 있다.
비주얼쓰렛	중국에 기반을 두고 있는 비주얼쓰렛(Visucal Threat)은 안드로이드 앱 설치 파일이나 웹 사이트를 입력해 악성 여부나 유해 정보가 존재하는지 분석해주는 서비스. 파일 업로드 시 MD5 해시를 함께 올려야 등록되는 특징이 있으며 이메일을 통해 앱 정적 분석 결과와 파일 해시 정보와 리스크 등급을 함께 제공한다.
NVISO	벨기에에서 시작한 NVISO 앱 스캔 서비스는 안드로이드 앱을 대상으로 분석해주는 무료 악성코드 판정 서비스이다. 외부 엔진에 의한 검사 결과와 정적, 동적 분석 결과를 함께 제공하며 분석 과정에서 남은 ADB logcat 로그를 덤프해주는 기능 제공한다.

[그림 199] 클라우드 서버 기반 분석 서비스

○ 국내 위협정보 공유 서비스

✓ 국내 서비스 기업의 경우 해외 글로벌 기업 대비 시장의 후발 주자이기 때문에 해외 기업 간 CTI(Cyber Threat Intelligence) 동맹을 통해 공유 받은 위협 정보로 서비스 하거나 자체 위협 정보 공유 포탈을 이용하여 수집된 정보를 활용해 분석함

✓ 한국인터넷진흥원의 C-TAS(Cyber Threats Analysis System)은 위협정보 공유체계를 통해서 악성코드 샘플, 피싱(Phishing), 문자메시지 피싱(SMS Phishing, Smishing)등 공격의 침해지표(Indicators of Compromise, 이하 IoC)로 불리는 정보들을 공유함

- 한국인터넷진흥원(KISA)은 국내 주요 6개 보안업체(안랩, 빛스캔, 이스트소프트, 하우리, 잉카인터넷, NSHC)와 ' 사이버 위협 인텔리전스 네트워크 '를 운영 중임
- 국외 주요 6개 보안업체(파이어아이, 포티넷, 인텔시큐리티, 마이크로소프트, 팔로알토 네트워크, 시만텍) '글로벌 사이버 위협 인텔리전스 네트워크'를 운영 중임

✓ 국내 경우 2017년 하반기부터 SK인포섹, 이글루시큐리티, 넥스지, 이스트시큐리티, 안랩, 세인트시큐리티 등 보안 기업 또는 보안관제 기업을 중심으로 서비스 또는 준비 중임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(나) 개발결과물의 장단점

○ 공유기술 비교

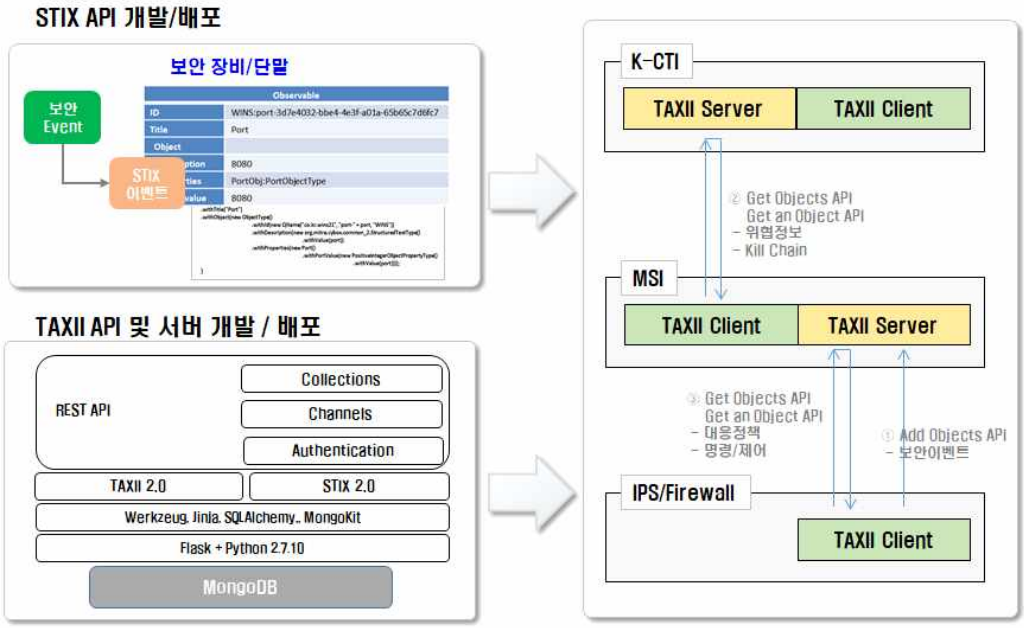
○ 위협정보공유 서비스 사업자의 공유기술

✓ 서비스사업자는 자사의 API를 활용하여서 위협정보를 공유하는 것이 일반적이 여서, 다수의 서비스사업자로부터 수집된 정보를 별도로 가공하여야 사용가능함

✓ 다양한 사이트로 부터 위협정보를 수집하고 신속한 대응정책을 제공하기 위해, 보안벤더 및 보안관제 운용사는 표준화된 STIX/TAXII의 API로 공유하고자 하는 요구사항 증가

✓ STIX/TAXII 2.0 출시가 2017년 10월에 출시되어, 이제 제품화되어 적용되고 있는 중임

○ 개발결과물의 기술적 우위



[그림 200] 개발결과물의 STIX/TAXII 2.0 기반의 공유 기술

✓ 표준 STIX/TAXII 2.0를 지원하는 공유기술 확보

- 동적/정적 분석된 위협정보를 표준화된 STIX2.0으로 저장(일부 항목은 사용자 정의를 통해 Snort/YARA 정책까지 저장할 수 있는 구조를 가짐)
- TAXII 2.0 표준을 준수하는 HTTP RESTful API를 지원하는 Java, Python, C++ TAXII 클라이언트 라이브러리로 개발 및 제공
- 표준화된 TAXII2.0 방식으로 위협정보를 공유함으로써 다양한 제품에 신속하게 적용할 수 있을 것으로 기대됨
- 표준 STIX/TAXII 2.0 API 및 개발 메뉴얼 공개. 보안제품에 신속하게 적용할 수 있음

✓ 국내 주요 보안벤더(네트워크벤더 : 윈스/시큐아이/지란지교, EDR벤더 : 소만사/한류AI센터, 백신벤더 : 세인트시큐리티)의 협의된 컬렉션별 ID로 검증 완료

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(다) 기술발전 기여도

- ✓ STIX/TAXII 국제 표준 기반의 보안 데이터 연동용 Library의 핵심기술 개발 및 인적 자원을 양성하여 국외 경쟁 기업들과의 차별 경쟁에 있어서 우위를 확보하기 위한 핵심(원천) IPR 확보에 성과를 거둠
- ✓ 개발된 STIX/TAXII 기술은 국내 보안 산업의 발전을 위해 한국정보보호산업협회(KISIA)에 소스까지 위탁 관리하도록 공개함으로써 국내 보안 사업계의 위협 대응체계 발전에 기여할 수 있을 것임
  - ▪ STIX/TAXII 기반의 위협정보 공유기술을 신속하게 제품에 탑재 가능
  - ▪ KISIA를 통한 개발된 제품에 대한 검증할 수 있는 서비스 지원 예정
- ✓ 공유기술을 활용하여 한국보안산업협회가 제공하는 KOSIGN 플랫폼에서 제공하는 악성파일을 분석/공유정보를 공유함
  - ▪ 공유기술을 탑재한 제품의 탐지기능 향상으로 제품의 경쟁력 향상
  - ▪ 신속한 위협정보공유 환경제공으로 보안위협의 최소화를 할 수 있을 것임

3-3. 목표 미달성 시 원인(사유) 및 차후대책(후속연구의 필요성 등)

- ○ 정량적 성과목표는 모든 분야에 대해 계획대비 그 이상을 달성하였음
- ○ 기술적인 측면의 성과목표는 모든 분야에 대해 계획대비 그 이상을 달성하였음

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4. 연구개발성과의 활용 계획 등

4-1. 향후 5년간 성과활용 · 확산 활용방안 및 계획(활동계획)

가. 성과활용 방안 및 계획

(1) 악성코드 분석/공유(WP-A : CTI) 기술 분야

(가) 성과활용 전략

- KOSIGN CTI기술 활용을 통해 “AI 보안 관제 솔루션” 기술 고도화하여 자사의 관제사업에 활용. 이를 토대로 기능 고도화된 KOSIGN CTI 제품화 및 사업화 할 계획임.
- 프로파일링과 상관 분석, 위협 평판 분석에 대한 추가 연구를 통하여 분석 서비스에 대한 기능을 고도화를 수행함으로써 “AI 관제 사업” 영역의 선두 기업의 기술 확보
- 향후 개발 방향
  - ✓ 각각의 단위모듈은 탐지의 정확도를 높이기 위해 지속적인 기능 고도화 필요
  - ✓ 각각의 분야는 타 장비/솔루션에 탑재되어 제품의 경쟁력을 향상시킬 수 있음

(나) 악성코드 분석기술 활용방안

- 본 과제를 통해 개발된 악성코드 탐지 및 분류 기술은 CTI 플랫폼에 단위 모듈로 구현되었으며, 기존의 시그니처 기반 보안기술의 한계(변종, 우회형 악성코드 미탐 문제)를 극복할 수 있을 것으로 기대됨.
- 해당 기술은 단위 모듈로서 다른 형태의 보안 장비에도 쉽게 설치되어 활용될 수 있으며, 정적 분석이나 동적 분석을 연계시킨 단독 기술로서 별개의 장비로 개발되어 활용될 수도 있기 때문에 다양한 상황에서 유용하게 활용될 수 있을 것으로 기대됨.
- 본 과제를 통해 개발된 악성코드의 유사도 측정과 검색 기술은 전통적으로 보안전문가들이 100% 수작업으로 분석해야 했던 악성코드들의 개수를 크게 줄여줄 수 있을 것으로 기대됨. 특히, 기존에 분석 완료한 악성코드 개수가 많아질수록 절감 효과가 커지기 때문에 장기간에 걸쳐 CTI 업무를 수행하는 환경에서 활용도가 높을 것으로 기대됨.
- 확보한 ML기반의 딥러닝 기술을 활용한 이벤트분석 및 대응자동화 기술 개발 및 제품에

(다) 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
KOSIGN CTI 기술에 대한 클라우드 TI 분석서비스 제품화	O	O			
경량 CTI 센서 제품화		O			
딥러닝 기반의 이벤트 분석 자동화 기술연구 및 제품화		O	O		
KOSIGN CTI 후속연구			O	O	O

[표 13] 연도별 CTI분야 성과활용 계획

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

(2) 관제솔루션(WP-B : MSI) 기술 분야

(가) 성과활용 전략

○ 사업화를 위한 향후 진행계획

✓ SECON, eGISEC 등의 국내외 정보보호 전시회에 KOSIGN 과제 성과가 포함된 통합보안관제 솔루션(ESM) 출품 및 홍보

✓ 본 과제 공동연구기관과의 기술 및 마케팅 협력을 통한 구축 사업 추진

✓ 솔루션 디바이스 전문업체와의 사업 협력 관계 구축 공동 사업화 및 마케팅 을 통한 국내외시장 진출 추진

○ 공공기관 보안관제 서비스 및 통합보안관리 솔루션 판매 1위의 서비스 네트워크를 활용하여 차세대 SIEM으로서의 MSI 솔루션 상용화 추진

○ 과제를 통해 개발하여 공개한 STIX/TAXII의 보안 분야 확산 촉진을 위해 보안성을 강화한 Secured STIX/TAXII 제품 개발 및 상용화 추진

(나) MSI 솔루션 상용화 추진 계획

○ 종료 1년차에는 당사의 보안관제 고객사들이 집중된 공공기관들을 주 타겟으로 차세대 SIEM으로서의 MSI 솔루션 판매에 진행하였음

○ 종료 2년차에는 민간, 금융 분야 고객들의 SIEM 수요에 맞춘 제품 개선을 통해 민수 영역까지 판로를 확대하는 마케팅 활동을 추진

○ 종료 3년차에는 국내 사업을 통해 확보된 기술력과 안정성에 기반하여 보안 기술력이 상대적으로 미흡한 일본 시장을 필두로 해외 사업까지 추진하고자 함 (당사는 2010년 7월부터 일본시장에 진출하여 일본 최대 sw 회사인 소프트뱅크와 보안 분야 사업협력 협약을 맺고 활발하게 일본 현지 사업을 진행 중)

(다) 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
차세대 SIEM으로서의 MSI 솔루션 상용화 추진계획	O	O	O		
STIX/TAXII Library 후속연구를 통한 Secured STIX/TAXII 제품 개발		O	O		
Secured STIX/TAXII 상용화 추진			O	O	O

[표 14] 연도별 MSI 분야의 성과활용 계획

(3) 단말보안 (WP-C : EDR) 기술 분야

(가) 소만사 성과활용(사업화) 방안

○ 성과활용 전략

✓ EDR 제품과 소만사 기존 제품과의 연동을 통한 차별화 기능 기획/설계 및 개발

✓ 지속적인 제품 홍보를 통한 매출 증대 (언론 홍보, 정보보안분야 컨퍼런스 소개)

✓ 보안담당자를 대상으로 세미나를 통한 EDR 제품 홍보

✓ EDR과의 위협정보연동을 위한 Threat Intelligence 기술 동향조사를 통한 최신기술 확보

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
외산 경쟁사 EDR 제품 분석	O	O			
차별화 기능 기획 및 개발	O	O	O		
정보보안 컨퍼런스를 통한 EDR 제품 홍보		O	O	O	O

[표 15] 연도별 EDR 분야 성과활용 계획

(나) 시큐아이

○ 성과활용 전략

✓ 개발 결과물은 국제적으로 호환되는 프로토콜 / 분류 체계 이므로 이를 활용하여 기업 내부의 장비 간 상호 호환이 필요한 부분에 적용

✓ STIX/TAXII 연동 모듈의 라이브러리 반영으로 후속모델(SECUI MF2, NGF, 등) 적용

✓ 지속적인 연동모듈 관리를 통한 후속모델에서도 동일 기능 제공

○ 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
MF2 후속모델인 NGF에 적용 및 Migration 진행	O	O	O		

[표 16] 연도별 시큐아이 성과활용 계획

(다) 지란지교

○ 성과활용 전략

✓ 공공, 제조, 금융, 유통 등 기업 메일을 사용하는 산업군 전반에 적용 가능한 제품으로 기존 자사 수신/발신 메일 보안 솔루션을 납품한 다양한 레퍼런스 대상 1차 Up-selling을 목표로 함

✓ 2차년도 SaaS 버전 개발 완료시 도입 규모가 작은 소기업에서도 상대적으로 저비용에 쉽게 도입이 가능해질 것임으로 타겟 시장도 더욱 확대 계획

○ 사업화 계획

✓ 통합 메일보안 어플라이언스 판매가 사업화의 주요 계획

✓ 1차 Sales 단계에서는 이메일 스팸차단 솔루션의 기존 국내 및 일본의 레퍼런스를 기반으로 추가 Value를 Add-on 하여 개발종료 해당 1차년도 매출을 확보

✓ 이어 SaaS 버전과 개발 종료 후 차세대 이메일 보안 플랫폼 구축으로의 로드맵 실현을 목표로 마켓과 매출을 확장 계획

✓ 국내 전지역의 이메일 통합 보안 영업과 현재 영향력 있는 비즈니스를 펼치고 있는 일본 현지 IT 유통사 및 17개 파트너사를 통한 직/간접 영업과 마케팅 활동을 펼쳐나갈 계획임.

✓ 더불어 SaaS 모델은 싱가폴 법인을 통해 인도네시아, 베트남 등 동남아 시장을 타겟으로 공격적인 영업을 진행할 예정임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
STIX/TAXII 연동기능 탑재한 통합 메일보안 어플라이언스	O	O (일본)	O (일본)		
SaaS 기반의 메일보안 제품화		O	O	O (동남아)	O (동남아)

[표 17] 연도별 지란지교시큐리티 성과활용 계획

(4) 표준화 분야

(가)성과활용 전략

○ 구조화된 위협정보 표현 규격(STIX)에 대한 유스케이스 권고안(X.1215)의 활용 전략

✓ 본 과제에서 개발된 보안 솔루션 위협정보 공유 API 보급 時 활용

✓ 국가기관, 보안수요자(관제센터), 보안산업체 중심의 사이버 위협정보 공유 및 연동 인프라 구축 時 활용

- 국가기관의 위협정보공유 시 효과적인 대응정책 수립을 위한 국제 표준(X.1215) 활용
- 사이버 위협정보 공유시스템 구축 시 보안산업제품 연동에 국제 표준(X.1215) 활용
- 연구기관 자체 사이버 위협정보 공유센터 구축/운영을 위한 국제 표준(X.1215) 활용

(나) 성과활용 계획

구분	종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
정보공유기술 상용화 추진계획	표준화된 STIX/TAXII를 적용한 제품 개발 지원	표준화된 STIX/TAXII를 적용한 제품 상용화 지원	-	-	-
정보공유기술 사업화 활동	-	표준화된 STIX/TAXII를 적용한 정보공유기술 사업화 모델 분석	표준화된 STIX/TAXII를 적용한 정보공유기술 사업화 지원	-	-
STIX/TAXII 후속 연구	-	국내 보안 솔루션의 정보공유 환경에 맞는 STIX 연구	상호 인증체계를 개선한 STIX/TAXII 구조 연구	상호 인증체계를 개선한 STIX/TAXII 기능 요구사항 분석	개선된 STIX/TAXII의 공개 API 분석

[표 18] 연도별 표준화 분야 성과활용 계획

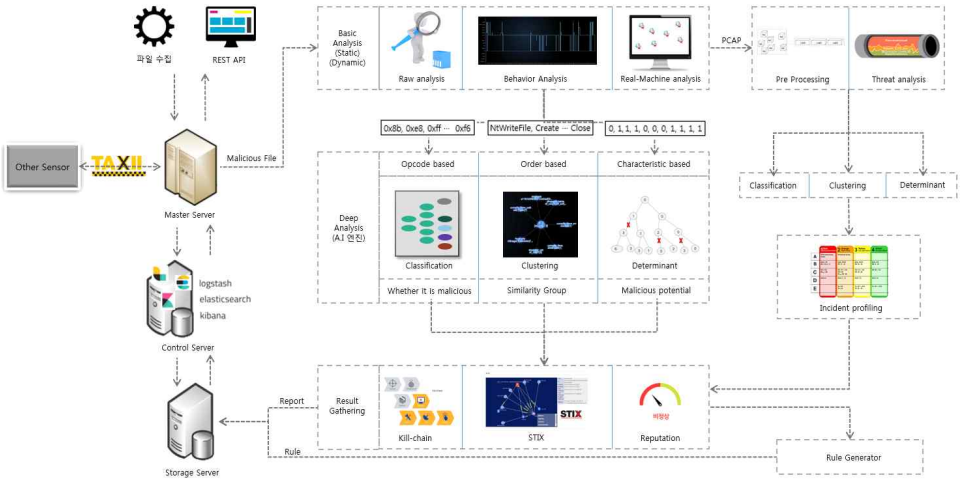
국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

4-2. 주요 성과활용 (기대)성과목표

가. 정성적 목표

(1) 악성코드 분석/공유(WP-A : CTI) 기술 분야

(가) 악성코드 분석/공유 기술 목표



[그림 201] 악성코드의 분석 및 공유기술 Flow

○ 악성코드분석은 크게 3개의 분야로 구분될 수 있음

✓ 악성코드의 정적/동적 분석을 통한 위협정보 기본분석

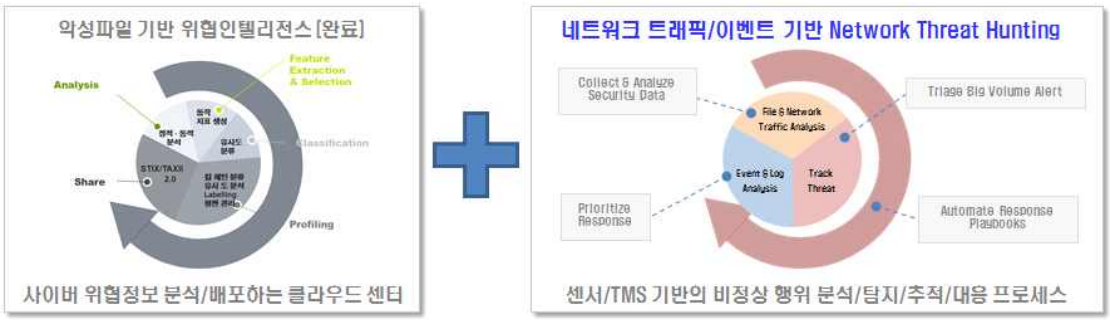
✓ 분석된 기본분석 정보를 활용한 심층분석(분류, 그룹핑, 잠재위협)

✓ 기본분석 및 심층분석을 통해 CTI 플랫폼을 통한 리포팅 및 정책 생성

(나) KOSIGN-CTI 기술 제품화

○ CTI(KOSIGN) 개발 결과물의 제품화 로드맵

✓ 상용화 개념도 (2021년 제품화를 목표로 개발중)



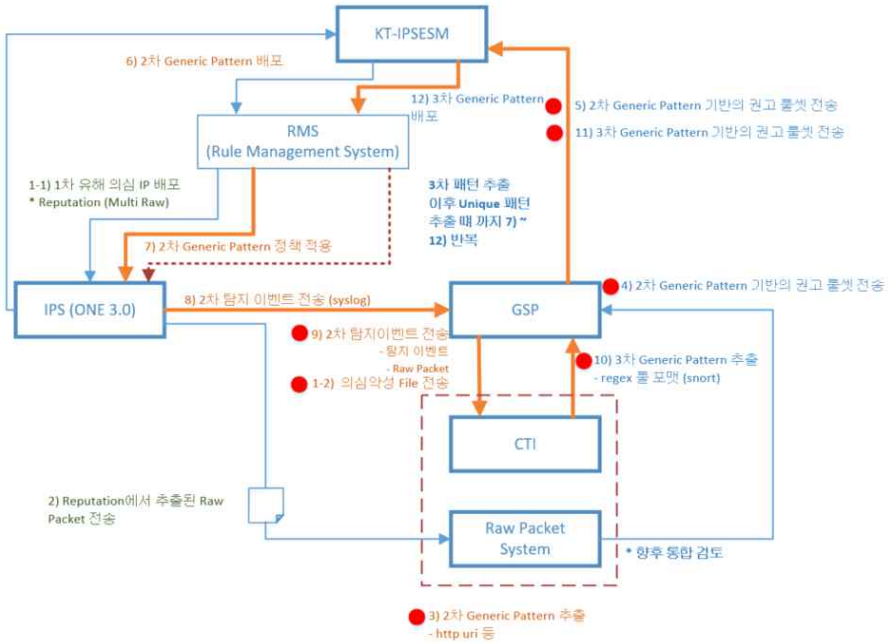
[그림 202] Sniper CTI 제품화

- 지능형 보안 플랫폼은 KOSIGN 기술을 활용한 악성파일의 행위분석으로 대응방안을 제공함
- 또한, 이벤트 기반의 Threat Hunting을 통한 비정상 행위를 판단하여, 해당 정책을 자동으로 배포하는 시스템을 개발하고자 함
- 연동은 STIX/TAXII 방식으로 연동함으로써 서비스의 확장성/유연성을 높임

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ KT 관제솔루션 연동의 단위기술 활용

✓ KT의 요구사항을 반영한 제품화

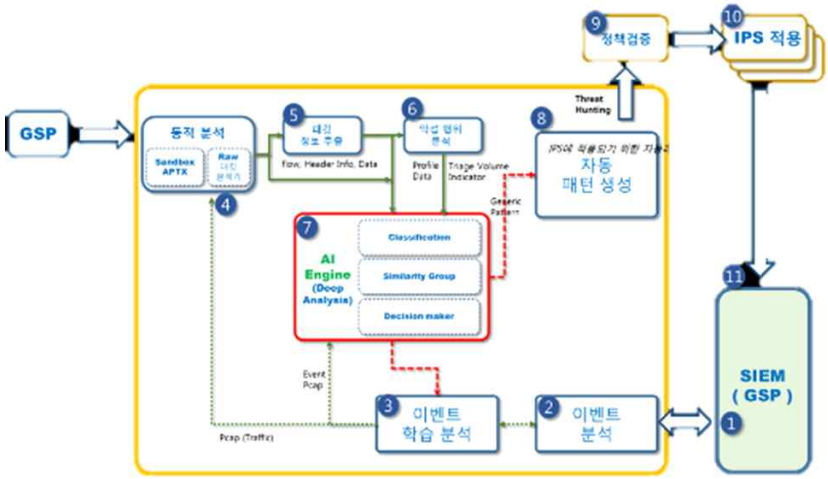


[그림 203] KT 관제솔루션(GSP)와 연계된 CTI 기술 활용

- KT의 관제솔루션(KT-IPS_ESM, GSP)와 연계를 통한 악성코드분석(TI) 기능 제공
- 기 구축된 Sniper-IPS 시스템과 연계를 통한 정책제공 및 검증완료를 통한 서비스의 안정성 확보

✓ CTI 기술 고도화

- 악성 코드 동적 분석 로그 기반의 TI 검출
- IPS 탐지 로그 기반의 해킹 IP 검출



[그림 204] CTI 결과물의 기능 고도화

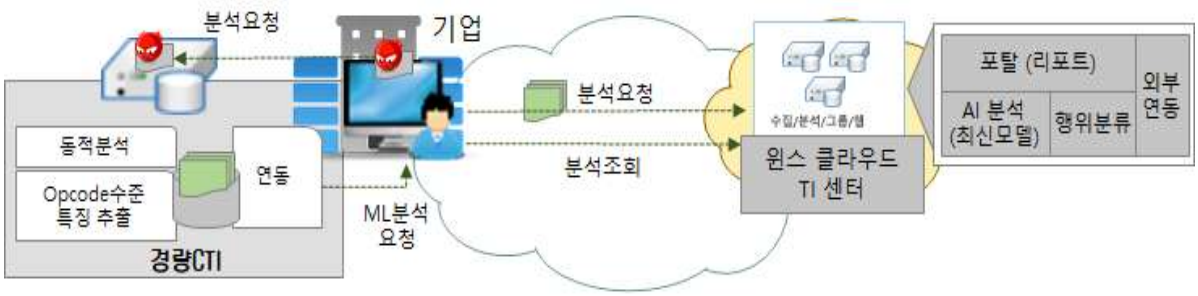
○ 추가 기능(언패킹 분석 기술) 고도화

✓ UPX 패킹 프로그램 외에 자동화가 가능한 언패킹 프로그램을 조사해보고 악성코드 언패킹 모듈에 추가할 수 있도록 확장성 있는 코드 리팩토링 진행 예정

✓ 언패킹을 하기 전에 패킹 탐지를 수행하는 모듈 추가 예정 (엔트로피 기반의 패킹 탐지 기술과 시그니처 기반의 패커 탐색 등을 통해 패킹 유무를 판별할 예정)

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ 경량 CTI 센서 제품화



[그림 205] 경량 CTI 제품화

✓ 보안관리자는 악성파일를 자체적인 분석하여 선제적 대응할 수 있는 환경 구축 원함

✓ 상용화를 위한 고려사항

- 기업/기관에서 수집된 악성파일을 외부(클라우드)에 유출할 수 없음
- 자체적으로 CTI 플랫폼을 구축하기 위해서는 시스템 구축비용 증가
- 또한, 최신 학습모델 유지를 위한 주기적인 업데이트

✓ 경량CTI 분석의 효과

- 파일자체가 외부로 유출되지 않음 (담당자는 전처리 정보만 클라우드 센터에 전달 고객과 NDA 협약 필요)
- 경량CTI 센서로 구축비용 감소
- 클라우드의 최신 학습모델 기반으로악성 탐지 정확도 향상

(2) 관제솔루션(WP-B : MSI) 기술 분야

○ STIX/TAXII 후속 연구

✓ 본 과제를 통해 개발된 STIX/TAXII Library는 선도적인 위치의 국제표준으로서 그 활용 가능성이 크지만, 보안 데이터를 취급하는 해당 기술의 특성 상 제품 자체의 보안성 강화가 필수적임.

✓ 대부분의 국제 표준들과 마찬가지로 STIX/TAXII 표준 또한 각국의 보안 관련 기관, 기업들의 초기 접근을 손쉽게 유도하기 위해 보안 관련 규약은 거의 전무한 상태임

✓ STIX/TAXII Library들이 다양한 보안 제품들에 광범위하게 탑재되기 위해서는 보안적인 대비책들이 완성된 형태의 안전한 모듈 개발이 필수적임

✓ 모듈간 상호인증체계 구성, 네트워크 전송구간 암호화, 데이터의 안전한 보관을 위한 데이터 암호화 등의 보안기능 구현과 함께 STIX/TAXII Library 자체의 취약점을 제거하는 Secure Coding 적용, 정적/동적 분석을 통한 보안 약점 해소 등의 보안성 강화를 통해 안전성이 획기적으로 강화된 제품을 종료 2년차, 3년차에 걸쳐서 개발하고자 함

○ Secured STIX/TAXII 상용화 추진

✓ STIX/TAXII 모듈의 국내 보안 제품 탑재를 활성화하기 위해 보안성이 강화된 Secured STIX/TAXII Library를 개발하여 상용화하고

✓ Secured STIX/TAXII 모듈에 대한 기술이전과 MSI 제품에 대한 사이트라이선스 방식으로 판매모델을 확대하여 국내 시장 마케팅의 기반을 다지고자 함

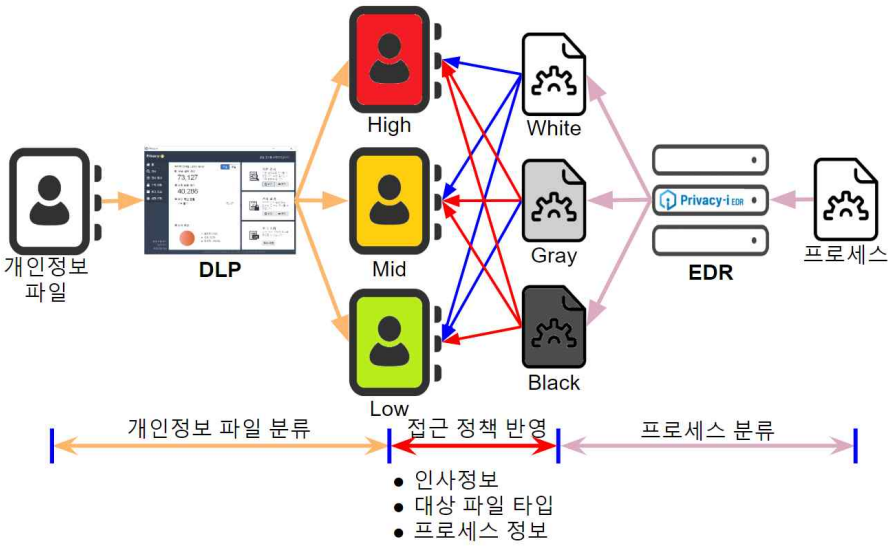
(3) 단말보안 (WP-C : EDR) 기술 분야

(가) 소만사

○ EDR 제품과 소만사 기존 제품과의 연동을 통한 차별화 기능 기획/설계 및 개발

✓ 소만사의 DLP 제품과 연동하여 기밀정보(개인정보) 보유 등급 인지

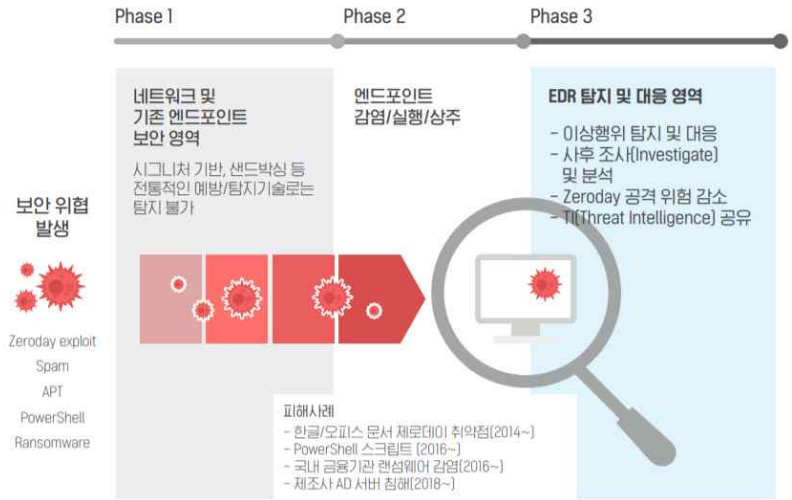
✓ 엔드포인트에서 실행되는 프로세스의 위험도에 따른 접근정책 적용한 탐지



[그림 206] DLP제품과 EDR제품의 연동 기능

○ 목표시스템

✓ 엔드포인트에서 발생하는 위협에 효과적으로 대응할 수 있는 제품 개발



[그림 207] EDR제품 개발 로드맵

✓ 향후 EDR 제품에 글로벌 경쟁사 대비 차별화 기능을 제공하여, 제품의 경쟁력을 확보하여 국내 뿐 아니라 글로벌 시장에서도 의미 있는 매출 달성 목표

(나) 시큐아이

○ STIX/TAXII 모듈 활용한 센서 제품의 연동기능 고도화

✓ 개발 결과물은 국제표준 프로토콜로써 기업내부의 장비 간 상호호환이 필요한 부분에 적용하고, 추가적으로 요구되는 연구 / 개발 / 유지보수 비용을 절감 가능

✓ 타 사 장비와의 동일한 연동규격 및 분류 체계를 가짐으로 상대적으로 적은 공수로도 제품 개발이 가능할 것으로 기대됨

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

○ TI 연동을 통한 관제기능 고도화

✓ 실제 보안 현장에서는 8%의 데이터만을 분석하며, 나머지 92%는 다크데이터로 남음

✓ 이러한 한계를 최소화 하기 위해 STIX/TAXII 기반의 위협정보 공유체계와 연동하여, 전문가 보안 역량을 결합하는 차세대 보안관제의 개발 방향으로 제품화 진행

(다) 지란지교시큐리티

○ 어플라이언스 제품 개발 목표

✓ 사이버 위협의 대부분이 컨텐츠를 유통할 수 있는 프로세스나 장치를 통해 침투하는 경향을 가지므로 컨텐츠를 유통하는 프로세스 행위 이벤트의 문맥(Context) 연관성을 학습 및 분석 수행

✓ 기업 데이터 자산과 직결되는 필수 영역인 메일, 문서 콘텐츠에 대한 학습 및 분석, 기업내 생산되는 컨텐츠를 중앙화하여 통합 컨텐츠 관리 수행하여, 내/외부 보안위협으로부터 방어/대응 수행

○ 글로벌 수준의 보안위협을 능동적으로 대처하기 위해 글로벌 보안위협 분석 자동화 인공지능(AI) 시스템 구축을 통한 클라우드 기반 분석센터를 운영함으로써 대한민국을 대표하는 글로벌 보안SW 기업으로 성장하는 것을 최종 목표로 함

(4) 표준화 분야

○ STIX/TAXII 국내외 표준 개발

✓ 국내 위협정보 공유 체계 및 사이버 위협 대응 방안에 대한 국제표준화 추진 (現 TAXII 국제표준 부재)

✓ 국내 보안 솔루션의 위협정보 공유 時 상호 인증체계를 고려한 TAXII 연동을 위한 데이터 교환 포맷의 국제표준 준수

나. 정량적 목표

구분		종료+1 (2020년)	종료+2 (2021년)	종료+3 (2022년)	종료+4 (2023년)	종료+5 (2024년)
CTI 분야	판매수량	CTI 플랫폼 1식	CTI 플랫폼 2식	CTI 플랫폼 6식 경량 CTI 10식	CTI 플랫폼 10식 경량 CTI 50식	CTI 플랫폼 10식 경량 CTI 100식
	매 출 액	100백만원	200백만원	500백만원	1,500백만원	2,500백만원
	고용	2명	4명	10명	30명	50명
MSI 분야	판매수량	MSI 2대	MSI 4대	MSI10대 모듈 5대	MSI15대 모듈 5대	MSI15대 모듈 5대
	매 출 액	100백만원	200백만원	500백만원	700백만원	700백만원
	고용	2명	4명	10명	14명	14명
EDR 분야	판매수량	10대	20대	50대	70대	100대
	매 출 액	300백만원	600백만원	1,500백만원	2,100백만원	3,000백만원
	고용	6명	12명	30명	42명	60명

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

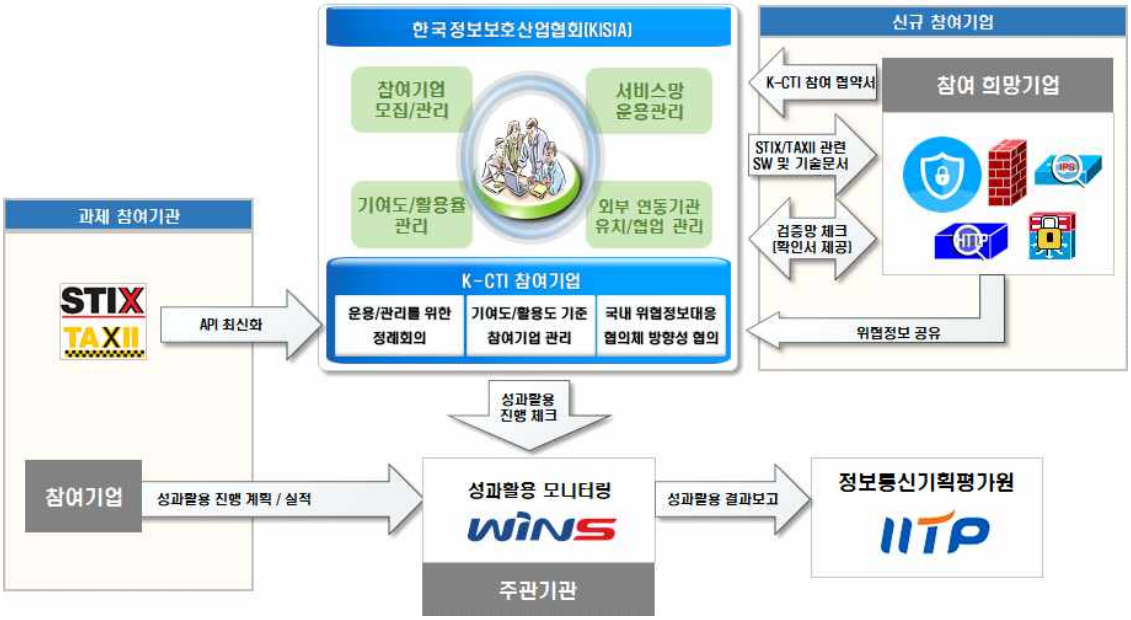
보안 장비 분야	판매수량	10대	20대	50대	70대	100대
	매 출 액	100백만원	200백만원	500백만원	700백만원	1.000백만원
	고용	2명	4명	10명	14명	20명
합계	**매 출 액**	600백만원	1,200백만원	3,000백만원	5,000백만원	7,200만원
	고용	12명	24명	60명	100명	144명

[표 19] 연도별 성과활용 (기대)성과목표(요약표)

4-3. 성과활용・관리 추진체계

가. 개발 기술별 성과관리

○ 성과활용 관리방안 개념도



[그림 208] 성과활용 관리방안

✓ 주관기관은 참여 기업별 반기별 성과활용 내역을 모니터링 하고, 위협정보공유협의체에 참가하여 성과활용 진행사항을 체크함

- 위협정보공유 플랫폼은 KISIA(한국정보보호산업협회)에 구축하고, KISIA가 운용관리 주체가 됨
- 참여기업은 KISIA의 위협정보공유협의체에 참여하고, 주기적인 운용・관리방안 협의

✓ 체크된 성과활용 결과를 정보통신기획평가원(IITP)에 주기적 보고

○ 위협정보공유 협의체 활성화 방안

✓ KISIA에 위탁・공개한 STIX/TAXII API 및 관련 기술개발 자료는 지속적 업데이트 수행

✓ KISIA 내부망에 STIX/TAXII 검증할 수 있는 플랫폼 구축 (참여기업은 기술지원)

✓ 신규 참여하는 제조사는 KISIA를 통해 위협정보공유 서비스에 대한 검증 수행 ()

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

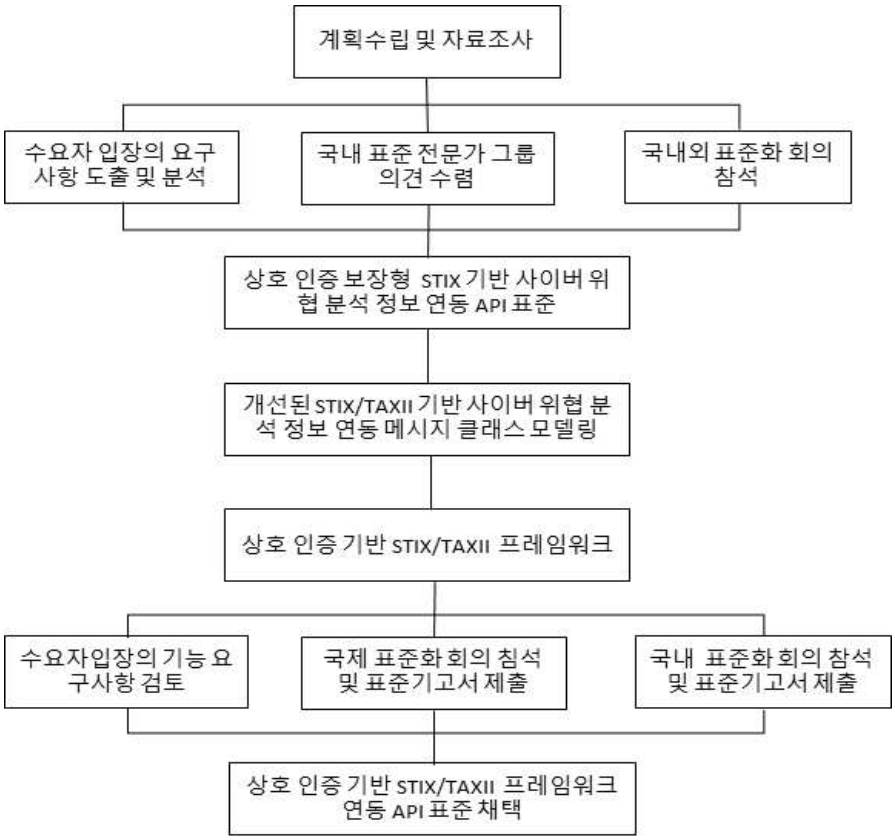
나. 표준화 성과관리

○ 성과관리 추진체계

✓ 참여기업의 지속적인 요구사항 모니터링 및 의견 수렴

✓ 국내 전문가 그룹 의견 수렴 및 국내외 표준화 회의 참석

✓ 국내외 표준기고서 제출을 통한 표준채택



[그림 209] 표준화 성과관리

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

붙임 1. 사업화대상기술별 기술명세서

1. 과제정보

과 제 명	국문	Security Analytics 기반의 이기종 보안솔루션 위협 분석 및 대응 기술 개발				
	영문	Developing threat analysis and response technology based on Security Analytics for Heterogeneous security solution				
기술분류	대분류	차세대보안	중분류	시스템 및 암호보안	소분류	위협분석 및 관제
주관기관	(주)윈스		연구책임자	조학수		
연락처(책임자)	사무실 : 031-622-8605		이메일(책임자)	marius71@wins21.co.kr		

※ 첨부물로 업로드시 필요, 사업계획서에 포함 시 중복으로 불필요

□ 미제출 사유 확인 ※ 미제출 대상인 경우, 해당 □에 √하여 주시기 바랍니다.

미제출 사유 체크리스트						
법령상 비밀/비공개 기술인 경우	R&D사업이나 제출대상이 아닌 경우		R&D 성격이 아닌 경우(비R&D) (연구책임자가 제출 여부 등을 판단) (R&D사업은 반드시 제출 대상으로 체크 불가)			
□ 보안과제	☑ **주관기관이 기업인 경우**	□ 현재 또는 **개발목표가 기초연구**로서 기술성숙도(TRL) 2단계 이하인 경우	□ 정책연구	□ 표준화 연구 (R&D 미포함)	□ 기반구축 (R&D 미포함)	□ 인력양성 (R&D 미포함)
기타 (사유 기재)	(사유)					

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

붙임 2. 자체 보안관리 진단표

구분	체크항목	결과 체크 (√표)	비고 (미실시 사유)
보안관리 체계	o 기관 내 보안관리규정을 제정/적용하고 있다	O(√), X( )	
	o 보안관리 조직이 있으며, 자체 보안점검실시 등 잘 운영되고 있다	O(√), X( )	
	o 보안교육을 정기적(1회이상/연)으로 실시하고 있다	O(√), X( )	
	o 보안사고에 대한 방지대책 및 비상시 대응계획이 준비되어 있다	O(√), X( )	
참여연구원 관리	o 참여연구원에 대하여 보안서약서를 받았다	O(√), X( )	
	o 참여연구원에게 보안관리의 중요성 등을 인식시키고 있다	O(√), X( )	
연구개발 내용/결과 관리	o 주요 연구자료 및 성과물의 무단유출 방지대책을 수립하고 있다	O(√), X( )	
	o 보안성 검토 방법 및 절차를 이행하고 있다	O(√), X( )	
	o 기술이전 관련 내부규정 및 절차를 준수하고 있다	O(√), X( )	
연구시설 관리	o 연구시설 보안관련 내부규정 또는 지침을 이행하고 있다	O(√), X( )	
	o 주요 시설에는 보안장비가 설치되어 있다	O(√), X( )	
	o 보호구역이 지정되어 있다	O(√), X( )	
정보통신망 관리	o 정보통신망 보안관련 내부규정 또는 지침이 구비되어 있다	O(√), X( )	
	o 보안관리 책임자의 승인 항목이 구분되어 있다	O(√), X( )	
	o 주요 데이터에 대해 백업을 실시하고 있다	O(√), X( )	
	o 개인용 정보통신장비(노트북, USB메모리)에 대하여 인가/관리중이다	O(√), X( )	
	o 전산망 보호를 위한 HW 및 SW 등을 도입하여 적용하고 있다	O(√), X( )	
	o 직책, 임무별 열람 권한을 차등화하여 부여하고 있다	O(√), X( )	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

붙임 3. 국방부의 사이버사령부 실증 시험 결과

4284-01-02-19-09

실증시험 결과 종합의견

○ 과제명 : 한국형 사이버위협정보 공유기술(KOSIGN) 연구

○ 실증기간 : '19. 7. 8.(월) ~ 8. 30.(금)

○ 실증장소 : (구)사이버지휘통제센터 3층(실증시험실)

○ 실증위원단 : 상황관리대장 등 6명

구 분	소 속	계 급	성 명	서 명
위원장	작전센터	중령	윤 영 수	윤영수
위 원	작전센터	7급	김 미 선	김미선
위 원	작전센터	8급	김 병 완	김병완
위 원	체계개발단	소령(진)	김 회 록	김회록
위 원	체계개발단	상사	이 은 경	이은경
간 사	기획과	5급	박 창 욱	박창욱

○ 실증결과

실증 항목		실증기관 검토의견	실증 결과
1. 개발체계 설치 및 초기자료 구축		ㅇ의견 없음	충 족 : 7 미 달 : 0 소결함 : 0
2. 품질요소(기능) 만족도		ㅇ(소결함) 3-1-4, 위협대응정책에 배포정보 요약하여 제공 ㅇ(추가의견) 2-1-2, CTI 행위지표에 분석정보 팝업 표시 ㅇ(추가의견) 3-1-2, 대시보드에 기간설정 기능 추가	충 족 : 15 미 달 : 0 소결함 : 1
3. 통합 연동 운용 가능성		ㅇ의견 없음	충 족 : 5 미 달 : 0 소결함 : 0
4.적합성 검토의견	상호운용성	ㅇ군내 침해지표 및 정책적용 정보를 효과적으로 보여주지 못하여 추가적인 확인 작업이 필요 ㅇ군 특성을 고려하여 침해지표 및 정책적용을 위한 자동화 및 사용자 인터페이스 개선이 필요	
	적용가능성	ㅇ각종 보호체계가 연동표준화를 구현하도록 시기 검토 필요 ㅇKOSIGN 도입시 사전 ISP를 통해 장비성능/요구기능(작전체계 연동여부 등) 세부 판단 필요	
종합의견		ㅇKOSIGN은 정보보호체계의 영역별 설치·운용으로 인한 비효율적 자원/인력 부담 가중을 줄이기 위한 솔루션으로 반드시 필요함 ㅇ군내에서 운용중인 기존 정보보호체계와 KOSIGN 설치시기의 조정이 필요 ㅇ정/오탐 판단 및 정책배포를 위한 별도의 전문 운영인력 운용, 정보보호 시장의 연동 표준화 기술 성숙도, ISP를 통한 사업 안전성, 사령부 및 각 군 방호센터 등 체계 운영을 위한 인력 확보 방안이 선행되어야 함	

국가연구개발 보고서원문 성과물 전담기관인 한국과학기술정보연구원에서 가공·서비스 하는 연구보고서는 동의 없이 상업적 및 기타 영리목적으로 사용할 수 없습니다

주 의

1. 이 보고서는 과학기술정보통신부에서 시행한 정보통신·방송 연구개발사업의 보고서입니다.

2. 이 보고서 내용을 발표하는 때에는 반드시 과학기술정보통신부에서 시행한 사업의 연구개발 결과임을 밝혀야 합니다.

3. 국가과학기술 기밀유지에 필요한 내용은 대외적으로 발표 또는 공개하여서는 안됩니다.